MODULE 00 · EXAM STRATEGY - ALL DOMAINS

# AWS Certified Solutions Architect – Professional

SAP-C03. What the exam tests, what changed from C02, and how this course is built.

EXAM SAP-C03 QUESTIONS 75 in 180 min PASS 720 of 1000

admin@sthithapragna.com

# Who this exam is for

- **Two or more years** designing and implementing solutions on AWS is AWS's recommendation.
- **Designs span many applications** in a complex, multi-account organisation.
- **New in C03:** serverless and **AI-integrated architectures** are named in the target candidate.
- **It tests judgement, not recall.** Most questions have two defensible answers.

> ON THE EXAM
>
> The deciding detail is usually one clause in a long scenario. This course trains you to find it.

# The format, precisely

- **75 questions in 180 minutes.** 65 are scored; 10 are unscored and not identified.
- **Scaled from 100 to 1,000, with 720 to pass.** Scoring is compensatory.
- **Multiple response needs every correct option.** No partial credit.
- **Unanswered scores as incorrect**, and guessing carries no penalty.

> ON THE EXAM
>
> 720 is not 72%. Scaled scoring means the cut score cannot be converted to a number of questions.

# The five domains

| DOMAIN | WEIGHT | WHAT IT IS REALLY ABOUT |
|---|---|---|
| 1 Architecture built for the cloud | 25% | Events, containers, networks, data, and AI |
| 2 Security, compliance, governance | 25% | Identity, perimeters, keys, guardrails |
| 3 Cost-optimized architecture | 15% | Commitments, right-sizing, AI and transfer cost |
| 4 Resilience, migration, continuity | 15% | Disaster recovery, chaos testing, migration |
| 5 Operational excellence, automation | 20% | IaC, pipelines, observability, self-healing |

ON THE EXAM

Domains 1 and 2 carry half the exam. AI appears in all five, not as a domain of its own.

# What the exam does not expect

- **Training or fine-tuning models**, and data science workflows.
- **Security incident forensics** and detailed threat investigation.
- **In-depth operating system knowledge.**
- **Application code development** and debugging.

> ON THE EXAM
>
> The line for AI is drawn at architecture: inference, RAG, agents, guardrails and observability are in.

# If you studied for C02

- **Reorganised by concern**: architecture, security, cost, resilience, operations.
- **Four C02 out-of-scope calls reversed**: VPC Lattice, FIS, Resilience Hub, ARC.
- **Many services left the in-scope list**, including Migration Hub, Snowball, Macie and Detective.
- Modules 50 and 51 cover every change and every closed or renamed service.

> ON THE EXAM
>
> C02's last exam day was 16 November 2026. Some correct C02 answers are now distractors.

# How this course was built

- **The C03 exam guide was read in full**, and modules map to its numbered skills.
- **Every fact was checked against current AWS documentation** in November 2026.
- **A question bank was used as a topic map only.** No question from it appears here.
- **Every scenario and practice question is original.**

> ON THE EXAM
>
> Where AWS changed something after the guide's sources were written, the module says so and gives the date.

# How to read the slides

- **The coloured marker on a bullet is a signal**: key fact, nuance, or trap.
- **The boxed line at the foot** is the exam-facing point, often a tiebreaker.
- **The bar down the left edge** shows which domain you are in.
- Narration carries the reasoning; the slide carries the structure.

> ON THE EXAM
>
> Nothing important is on a slide and missing from the narration, so the course works as audio too.

# Worked scenarios, and the pause

- **Every teaching module ends with six worked scenarios** at exam difficulty.
- **When the narration says pause, pause**, and commit to an answer.
- **Every option is explained**, including why the wrong ones fail.
- Watching without answering first feels productive and teaches very little.

> ON THE EXAM
>
> 312 worked scenarios and 150 practice questions. They are the part that moves your score.

# The course at a glance

| SECTION | MODULES | ABOUT |
|---|---|---|
| Domain 1: architecture | 01 to 13 | 2h 46m |
| Domain 2: security | 14 to 24 | 2h 00m |
| Domain 3: cost | 25 to 31 | 1h 09m |
| Domain 4: resilience and migration | 32 to 39 | 1h 16m |
| Domain 5: operations | 40 to 48 | 1h 20m |
| Cross-cutting: pairs, changes, technique | 49 to 52 | 0h 39m |
| Practice: five domain papers and a mock | PE1 to PE6 | 2h 30m |

ON THE EXAM

About 9 hours 10 minutes of teaching, and 11 hours 40 minutes with the practice exams.

# Finding your way around

| IF YOU WANT | GO TO |
| --- | --- |
| Generative AI, RAG and agents | Modules 06, 07, 24, 27, 47 |
| Networking, hybrid and DNS | Modules 08 to 11 |
| Identity, keys and guardrails | Modules 14 to 20 |
| Disaster recovery and chaos testing | Modules 37 to 39 |
| Pipelines, deployments and observability | Modules 40 to 48 |
| Final-week revision | Modules 49 to 52, then the mock |

ON THE EXAM

Chapter marks on the video give each module's start time.

# A study route

- **Watch modules 01 to 52 in order.** Later modules build on earlier ones.
- **Sit each domain paper** after finishing its domain, and rewatch behind your misses.
- **Sit the full mock in one session**, close to exam day.
- **Count correct guesses as misses.** Otherwise the score flatters you.

> ON THE EXAM
>
> Every practice paper ends with a table mapping each question to the module that teaches it.

# Two notes on language

- **The prose is British:** organisation, optimise, licence, centre.
- **AWS names keep their US spelling**: Cost-Optimized, AWS Organizations.
- That mix is deliberate, so names match what you see in the console.
- **Depth is set for passing the exam**, not for implementation.

> ON THE EXAM
>
> Every module ends with a recap slide. Those recaps make good revision notes.

Module 01 opens Domain 1 with **event-driven architecture** and the delivery guarantees the exam keeps testing.

MODULE 01 · DOMAIN 1 - ARCHITECTURE BUILT FOR THE CLOUD

# Event-Driven Architecture and Delivery Guarantees

At-least-once is the default everywhere. Ordering, deduplication and routing are choices you make.

DOMAIN 1 of 5 EXAM WEIGHT 25% MODULE 1 of 52

admin@sthithapragna.com

Every AWS messaging service can deliver a message **more than once**. Exactly once is something your consumer does.

# What each service actually promises

| SERVICE | DELIVERY | ORDERING |
|---|---|---|
| SQS standard | At least once | Best effort only |
| SQS FIFO | Deduplicated for 5 minutes | Strict, per message group ID |
| SNS standard | At least once, retries then drops | None |
| SNS FIFO | Deduplicated for 5 minutes | Strict; queues as subscribers |
| EventBridge | At least once, 24 h / 185 retries | None |
| Kinesis Data Streams | At least once | Strict, per shard, by partition key |

ON THE EXAM

Ordering on AWS is always scoped: per message group or per partition key. Nothing gives you global order cheaply.

# Where do you remove duplicates?

AT THE BROKER

## FIFO deduplication

- Deduplication ID or content hash
- Five-minute window only
- Catches producer retries
- Does not stop redelivery after a consumer fails

IN THE CONSUMER

## Idempotent processing

- Key taken from the business event
- Conditional write before the side effect
- Survives retries, replays and redrives
- Works on any broker

THE TIEBREAKER

Broker deduplication stops duplicate sends. Only an idempotent consumer stops duplicate effects.

# Building an idempotent consumer

- **Key from the event,** not the message: order ID, payment ID, event ID.
- **Conditional write first.** DynamoDB put with attribute_not_exists on the key.
- **Expire keys with TTL** once replays can no longer arrive.
- **Powertools for AWS Lambda** ships an idempotency utility built on this pattern.
- **Not the SQS message ID.** A producer retry creates a new one.

> ON THE EXAM
>
> The idempotency key must identify the business action. A broker-generated ID changes on every resend.

# Ordered processing: FIFO queue or Kinesis?

CHOOSE SQS FIFO WHEN

## Ordered work queue

- One consumer group does the work
- Order per entity via message group ID
- Messages are deleted once processed
- Per-message retry and dead-letter queue

CHOOSE KINESIS WHEN

## Ordered, replayable log

- Several consumers read independently
- Order per entity via partition key
- Data must be replayed from a point in time
- Very high, sustained throughput

THE TIEBREAKER

Several independent readers, or a need to reprocess history, means a stream. One worker pool means a queue.

# Ordering costs throughput

- **One message group is one lane.** Messages in it are processed strictly in sequence.
- FIFO default: **300 TPS per partition**, per API action, 3,000 with batches of 10.
- **High throughput mode** reaches 70,000 TPS in the largest Regions.
- **A constant group ID** serialises the whole queue, whatever the mode.
- **Ask what must be ordered:** per shipment, per account. Never everything.

> ON THE EXAM
>
> Use the entity ID as the message group ID. Order where the business needs it, parallel everywhere else.

# Where failed messages go

| SOURCE | FAILURE HANDLING |
| --- | --- |
| SQS | Redrive policy: maxReceiveCount, then a dead-letter queue |
| SNS subscription | Subscription-level dead-letter queue |
| EventBridge target | Retry policy per target, then an SQS dead-letter queue |
| Lambda async invoke | On-failure destination: SQS, SNS, EventBridge or Lambda |
| Kinesis to Lambda | Bisect batch, max retries, on-failure destination |

ON THE EXAM

Without a dead-letter queue or destination, EventBridge and SNS eventually drop the event. Silence is the default.

# Cross-account and cross-Region event routing

01
### Produce
Workload account puts events on its own bus.

02
### Forward
A rule sends matching events to a central bus.

03
### Govern
Central bus policy allows the organisation only.

04
### Route
Central rules deliver to targets in other accounts.

05
### Replicate
Rules forward to a bus in another Region.

ON THE EXAM

Skill 1.1.5 is about event buses and forwarding. The central bus is where policy, archive and replay live.

# Deliver to a target, or to their bus?

DIRECT CROSS-ACCOUNT TARGET

## Since January 2025

- SQS, Lambda, SNS, Kinesis Data Streams, API Gateway
- Target owner adds a resource policy
- No EventBridge resources in the receiving account
- Same Region only

FORWARD TO THEIR EVENT BUS

## Bus to bus

- Receiving team owns its own rules
- One delivery fans out to many targets
- Required for any cross-Region hop
- Rule needs an IAM role to put events

THE TIEBREAKER

Crossing a Region means a bus. Same Region, and the receiver wants nothing to manage, means a direct target.

# Securing and operating the central bus

- **aws:PrincipalOrgID** in the bus policy admits the whole organisation in one statement.
- Forwarded events keep their original **account** and **source** fields.
- **Watch for loops** when a forwarded event matches a rule that forwards it back.
- **Archive and replay** on the central bus recovers events after a consumer bug.
- **Global endpoints** fail ingestion over to a secondary Region.

> ON THE EXAM
>
> One condition key, aws:PrincipalOrgID, replaces a bus policy that lists every account by number.

# Forwarding rule or global endpoint?

CROSS-REGION RULE

## Copy events onward

- Runs inside the source Region
- Producers keep publishing to one Region
- Useless if that Region's EventBridge is impaired
- Good for aggregation and analytics

GLOBAL ENDPOINT

## Fail ingestion over

- Route 53 health check decides the active Region
- Same-named custom bus in both Regions
- Replication needed for automatic failback
- RTO and RPO of 360 seconds, 420 at most

THE TIEBREAKER

If the requirement is that producers keep publishing when a Region fails, the rule is the wrong layer.

# Reading the scenario

| WHEN THE QUESTION SAYS | IT IS TESTING |
|---|---|
| Charged twice, processed twice | Idempotent consumer, not a new broker |
| In order for each customer | Message group ID or partition key |
| Several teams, reprocess history | A stream, not a queue |
| Events silently missing | A dead-letter queue that was never configured |
| Receiving team manages nothing | Direct cross-account target |
| Keep publishing if a Region fails | EventBridge global endpoint |

ON THE EXAM

Each phrase removes options before you read them. Find it in the scenario first.

> Meridian Freight's payments service is a Lambda function triggered by an SQS standard queue. Each message charges a customer's card through a third-party API. Function duration is under two seconds; the visibility timeout is five minutes.
>
> A few customers each week are charged twice for the same booking.

## What should the solutions architect do?

A Increase the visibility timeout to 15 minutes

B Replace the queue with an SQS FIFO queue using content-based deduplication

C Record the booking ID in DynamoDB with a conditional write before charging, and skip the charge if the write fails

D Replace SQS with an SNS topic that invokes the function directly

◆ PAUSE AND DECIDE

## What should the solutions architect do?

A. Longer visibility timeout

*The function already finishes far inside five minutes. The timeout is not what causes the duplicates.*

B. FIFO with deduplication

*Removes duplicate sends within five minutes. A crash after charging but before delete still redelivers.*

C. Idempotency key in DynamoDB

Makes the side effect safe to repeat, whatever caused the redelivery.

D. SNS invoking Lambda

*Still at least once, and loses the queue's buffering and retry control.*

THE SIGNAL

Duration well inside the visibility timeout rules out A. Duplicated side effects point at the consumer, not the broker.

> Meridian Freight processes shipment status events through an SQS FIFO queue. About 40,000 shipments are active at once, and each shipment's events must be applied in the order they occurred.
>
> Every message uses the message group ID status-updates. The backlog grows every afternoon, while the consuming Lambda function shows low concurrency.

**What change resolves the backlog while preserving the required ordering?**

A. Use the shipment ID as the message group ID

B. Enable high throughput mode on the existing queue

C. Raise the Lambda function's reserved concurrency

D. Move to an SQS standard queue and sort events by timestamp in the consumer

◆ PAUSE AND DECIDE

# What change resolves the backlog while preserving the required ordering?

**A** Shipment ID as group ID

Order is kept per shipment, and 40,000 groups can be processed in parallel.

**B** High throughput mode

*Scales by spreading groups. With a single group there is nothing to spread.*

**C** More reserved concurrency

*One message group delivers to one consumer at a time. Extra concurrency sits idle.*

**D** Standard queue and sorting

*A consumer cannot sort events that have not arrived yet. Ordering is lost.*

THE SIGNAL

Low concurrency with a growing FIFO backlog means too few message groups. The requirement was per shipment, not global.

> 2,000 Meridian Freight trucks each send 10 telemetry readings per second. Three teams consume the readings independently: routing, maintenance and data science. Readings from each truck must be processed in order.
>
> After retraining a model, data science needs to reprocess the previous seven days of readings.

## Which design meets these requirements?

A. An EventBridge custom bus with an archive, replaying events when needed

B. An SNS standard topic fanning out to three SQS standard queues

C. One SQS FIFO queue per team, with the producer writing to all three

D. Kinesis Data Streams, partitioned by truck ID, with retention extended to seven days

◆ PAUSE AND DECIDE

## Which design meets these requirements?

A EventBridge with archive

*Replay exists, but EventBridge guarantees no ordering at all.*

B SNS standard fan-out

*Gives each team its own copy, but neither standard SNS nor standard SQS keeps order.*

C Three FIFO queues

*Couples the producer to every team, and nothing keeps readings after they are deleted.*

D Kinesis by truck ID, seven days

Ordered per truck, independent consumers, and replay from a point in time.

THE SIGNAL

Independent consumers plus reprocessing history is the signature of a stream. A queue forgets a message once it is deleted.

> Meridian Freight's platform account publishes customer-deleted events to a custom EventBridge bus in eu-west-1. The data protection team owns an SQS queue in a separate account in the same Region and must receive only these events.
>
> The data protection team does not want to create or manage any EventBridge resources.

**Which solution meets the requirements with the LEAST operational overhead?**

A. A Lambda function in the platform account that assumes a role and calls SendMessage

B. A rule in the platform account targeting the queue directly, with a queue policy allowing the rule

C. A rule targeting the data protection account's default bus, plus a rule there targeting the queue

D. An SNS topic in the platform account with the queue subscribed to it

◆ PAUSE AND DECIDE

## Which solution meets the requirements with the LEAST operational overhead?

A Lambda with SendMessage

*Works, but it is custom code doing what a rule target now does natively.*

B Direct cross-account target

One rule, one queue policy. Nothing EventBridge-related in the receiving account.

C Bus to bus

*Puts a rule in the data protection account, which the team explicitly does not want.*

D SNS in between

*Adds a second service and its own policy for no benefit over a direct target.*

THE SIGNAL

Same Region, and the receiver wants nothing to manage. Since January 2025 that is a direct cross-account target.

> Meridian Freight runs a warm standby of its booking platform in eu-central-1. Booking events published to a custom bus in eu-west-1 must also be processed by a Lambda function in eu-central-1, so the standby's database stays current.
>
> The primary Region is healthy; this is about keeping the standby in step.

## How should events reach the function in eu-central-1?

A. A rule in eu-west-1 targeting an event bus in eu-central-1, with a rule there invoking the function

B. A rule in eu-west-1 targeting the Lambda function in eu-central-1 directly

C. A rule in eu-west-1 targeting an SQS queue in eu-central-1 that triggers the function

D. An EventBridge global endpoint with event replication enabled

◆ PAUSE AND DECIDE

# How should events reach the function in eu-central-1?

**A** Bus to bus across Regions

The supported cross-Region pattern: the target of a cross-Region rule is an event bus.

**B** Lambda in another Region

*Cross-Region rule targets must be event buses, not functions.*

**C** SQS in another Region

*Same problem. Direct targets work across accounts, not across Regions.*

**D** Global endpoint

*Solves a different problem: failing ingestion over when a Region is impaired.*

THE SIGNAL

Cross-account direct targets do not extend across Regions. Any Region hop goes through an event bus.

Meridian Freight's order services publish to a custom EventBridge bus in us-east-1. A rule already forwards every event to a bus of the same name in us-west-2.

During a regional EventBridge impairment, producers received errors and orders were lost. The business wants publishing to continue automatically in a future impairment, and to return to us-east-1 automatically afterwards.

## What should the solutions architect implement?

A Add a dead-letter queue to the existing forwarding rule

B Have every producer publish each event to both Regions

C Put a Route 53 failover record in front of the EventBridge API endpoints

D An EventBridge global endpoint with a Route 53 health check and event replication enabled

◆ PAUSE AND DECIDE

## What should the solutions architect implement?

A DLQ on the forwarding rule

*The events never reached the bus. A rule's dead-letter queue cannot catch a failed PutEvents.*

B Publish to both Regions

*Duplicates every event and pushes failover logic into every producer.*

C Route 53 in front of the API

*You cannot place your own DNS record in front of AWS service endpoints.*

D Global endpoint with replication

Fails ingestion over, and replication is what allows automatic failback.

THE SIGNAL

The forwarding rule existed and still lost orders. Failures at ingestion need a layer in front of the Region.

# What to carry out of this module

- **At least once everywhere.** Duplicate effects are fixed in the consumer, with a business key.
- **Ordering is always scoped:** message group ID or partition key, never global.
- **Stream for many readers and replay,** queue for one worker pool.
- **Direct cross-account targets** since January 2025. Cross-Region always needs a bus.
- **Global endpoints** protect ingestion. Forwarding rules cannot.

> ON THE EXAM
>
> Stale fact to watch: SQS messages now go up to 1 MiB, not the 256 KB older material teaches.

MODULE 02 · DOMAIN 1 - ARCHITECTURE BUILT FOR THE CLOUD

# Stateless Design and Durable Workflows

Where the state lives decides how you scale, how you recover, and what you pay for while you wait.

DOMAIN 1 of 5 EXAM WEIGHT 25% MODULE 2 of 52

admin@sthithapragna.com

A server you can replace at any moment must **remember nothing**. The state has to live somewhere else.

# Where each kind of state belongs

| STATE | PUT IT IN | WHY |
|---|---|---|
| User sessions | ElastiCache or DynamoDB | Shared, expires with TTL |
| Uploaded files | Amazon S3 | Not the instance disk |
| Workflow progress | Step Functions or durable functions | Survives failures and waits |
| WebSocket connection IDs | DynamoDB | Any backend can push |
| Config and secrets | Parameter Store, Secrets Manager | Never baked into images |

ON THE EXAM

Compute holds nothing it cannot rebuild from a shared store.

# Sticky sessions or externalised state?

STICKY SESSIONS

## State on the instance

- Load balancer pins a user to one target
- No code change needed
- Session lost when that target goes
- Uneven load as users accumulate

EXTERNALISED STATE

## State in a shared store

- Any target can serve any request
- Scale in and deploy without loss
- Small code change to read and write sessions
- Even load across the fleet

THE TIEBREAKER

Stickiness hides statefulness. It does not remove it, so scale-in and Spot still lose sessions.

# Session store: ElastiCache or DynamoDB?

CHOOSE ELASTICACHE WHEN

## Lowest latency, one Region

- Sub-millisecond reads at very high rates
- Valkey or Redis OSS, with key TTL
- Serverless option removes node sizing
- Global Datastore: secondaries are read-only

CHOOSE DYNAMODB WHEN

## Durable and multi-Region

- Single-digit millisecond, fully managed
- TTL deletes expired sessions
- Global tables accept writes in every Region
- No cluster to size or patch

THE TIEBREAKER

Writes from more than one Region rule out Global Datastore. That is a DynamoDB global tables question.

A workflow that waits for days should **not hold compute**, and should not lose its place when something fails.

# Three ways to run a multi-step workflow

| OPTION | DURATION | SEMANTICS | BILLED BY |
|---|---|---|---|
| Step Functions Standard | Up to 1 year | Exactly once | State transitions |
| Express, asynchronous | Up to 5 minutes | At least once | Executions, duration, memory |
| Express, synchronous | Up to 5 minutes | At most once | Executions, duration, memory |
| Lambda durable functions | Up to 1 year | Checkpoint and replay | Invocations; waits not charged |

ON THE EXAM

The semantics column decides more questions than the duration column. Non-idempotent steps need exactly once.

# Step Functions: Standard or Express?

CHOOSE STANDARD WHEN

## Long, auditable, non-idempotent

- Runs longer than five minutes
- Steps must not repeat, such as payments
- Waits for a callback or a .sync job
- Needs 90 days of execution history

CHOOSE EXPRESS WHEN

## Short, high-volume, idempotent

- Finishes inside five minutes
- Thousands of executions per second
- Steps are safe to repeat
- Cost per execution matters most

THE TIEBREAKER

Callbacks and .sync jobs exist only in Standard. Waiting on anything external rules Express out.

# Step Functions or Lambda durable functions?

CHOOSE STEP FUNCTIONS WHEN

## Orchestrate services

- Direct integrations with many AWS services
- Visual workflow and execution history
- Distributed Map for large parallel batches
- Logic defined in Amazon States Language

CHOOSE DURABLE FUNCTIONS WHEN

## Workflow as application code

- Steps and waits written in the function's code
- Python, Node.js, Java, Go or .NET SDK
- Waits pause execution and compute charges
- Team stays inside Lambda

THE TIEBREAKER

Both are durable for up to a year. The deciding detail is where the team wants the workflow logic to live.

# Durable functions: the rules that bite

- **Replay from the start.** Lambda reruns your code and substitutes stored results for completed steps.
- **Code must be deterministic.** No random values or clock reads outside a step.
- **Side effects go inside steps,** so a completed step never runs again.
- **Execution timeout** defaults to 24 hours, up to 1 year. History kept 1 to 90 days.
- **Cross-account invoke** of another function is not supported.

> ON THE EXAM
>
> Checkpoint and replay means anything outside a step runs again on every resume. Keep it pure.

# Waiting for people and partner systems

- **Task token callback:** Standard workflow pauses until SendTaskSuccess or SendTaskFailure.
- **Durable function waits** pause on a timer or an external callback.
- **Heartbeat and timeout** on the waiting state catch callers that never reply.
- **Polling loops in Lambda** pay for idle time and stop at 15 minutes.
- **Skill 2.5.3** reuses this pattern for human approval of AI actions.

> ON THE EXAM
>
> A wait measured in hours or days is a callback, never a loop. Idle compute is the wrong answer.

# Real-time push with API Gateway WebSocket APIs

01
## Connect
$connect route stores the connection ID in DynamoDB.

02
## Subscribe
A message route records what the client follows.

03
## Event
A backend change is published to EventBridge or SNS.

04
## Push
Lambda posts to each connection via @connections.

05
## Disconnect
$disconnect route deletes the stale ID.

ON THE EXAM

API Gateway holds the socket. Your backend only needs the connection ID and the @connections endpoint.

# WebSocket limits that shape the design

- **Connection duration: 2 hours.** Not adjustable. Clients must reconnect.
- **Idle timeout: 10 minutes.** Not adjustable. Send a heartbeat.
- **Message payload: 128 KB,** sent in frames of 32 KB or less.
- **500 new connections per second** per account per Region. This one is adjustable.
- **Push, do not poll.** Pushing a change beats thousands of clients asking every second.

> ON THE EXAM
>
> A quota increase is never the answer to a 2-hour or 10-minute disconnect. Those limits are fixed.

# Reading the scenario

| WHEN THE QUESTION SAYS | IT IS TESTING |
|---|---|
| Logged out during scale-in or deploy | Session state on the instance |
| Users write in either Region | DynamoDB global tables, not Global Datastore |
| Waits days for a person or partner | Standard callback or a durable wait |
| Thousands per second, idempotent steps | Express workflows on cost |
| Team wants the workflow in its own code | Lambda durable functions |
| Disconnects at 2 hours or 10 minutes | Fixed WebSocket limits; fix the client |

ON THE EXAM

Each phrase is a constraint, and each constraint removes at least two options.

> Meridian Freight's booking site runs on EC2 instances in an Auto Scaling group behind an Application Load Balancer with sticky sessions. Shopping carts are held in instance memory.
>
> After scale-in events and deployments, customers report empty carts and being logged out. The company wants to keep scaling aggressively.

## Which change prevents the lost sessions?

A Increase the target group's deregistration delay to 30 minutes

B Switch to a Network Load Balancer with source IP affinity

C Store sessions in Amazon ElastiCache and disable stickiness

D Use larger instances so scaling happens less often

◆ PAUSE AND DECIDE

## Which change prevents the lost sessions?

A Longer deregistration delay

*Lets in-flight requests finish. The instance still terminates and its memory goes with it.*

B NLB with source IP affinity

*Another form of stickiness. Same loss when the target goes, and worse behind shared NAT.*

C Sessions in ElastiCache

Any instance can serve any user, so termination loses nothing.

D Larger instances

*Fewer losses, not none, and it contradicts the wish to scale aggressively.*

THE SIGNAL

Loss on scale-in and deploy means state on the instance. Every answer that keeps it there only delays the loss.

> Meridian Freight runs its customer portal active-active in eu-west-1 and us-east-1. Route 53 latency routing can send a user to either Region on any request, and users update their session data as they work.
>
> Session changes must be visible in the other Region within about a second, and sessions must survive a node failure.

**Which session store meets these requirements?**

A. A separate ElastiCache cluster in each Region

B. A DynamoDB global table with TTL on the session item

C. An ElastiCache Global Datastore spanning both Regions

D. An S3 bucket in each Region with Cross-Region Replication

◆ PAUSE AND DECIDE

## Which session store meets these requirements?

A Separate clusters per Region

*Nothing replicates. A user routed to the other Region starts a new session.*

B DynamoDB global table

Writes accepted in both Regions, replicated typically within a second, durable.

C ElastiCache Global Datastore

*Secondary clusters only accept reads. Session writes in the second Region fail.*

D S3 with replication

*Replication is asynchronous and can take minutes. Not a session store.*

THE SIGNAL

Users update sessions in either Region. A read-only secondary cannot accept those writes.

> Meridian Freight is automating damage claims. The workflow validates the claim, waits for an independent surveyor's report, then pays the customer through a payments API that is not idempotent.
>
> Surveyor reports can take up to three weeks. Auditors need the history of each claim's execution.

**Which approach should the solutions architect use?**

A. An asynchronous Express workflow with a Wait state

B. A Lambda function that polls for the report every hour

C. A synchronous Express workflow invoked from API Gateway

D. A Standard workflow using a task token callback for the surveyor's report

◆ PAUSE AND DECIDE

## Which approach should the solutions architect use?

A Async Express with Wait

*Five-minute limit, and at-least-once semantics could repeat the payment.*

B Polling Lambda

*Pays for repeated invocations, and holds workflow state nowhere durable.*

C Sync Express

*Five-minute limit, and no execution history for auditors.*

D Standard with callback

Waits weeks without charge, runs the payment exactly once, keeps history.

THE SIGNAL

Three weeks rules out Express. A non-idempotent payment and an audit history both point at Standard.

> Meridian Freight ingests about 3,000 scanner events per second. Each event passes through four short transformation steps, about 200 milliseconds in total, and ends with a DynamoDB PutItem keyed on the scan ID.
>
> The current Standard workflow costs far more than expected.

## Which change is MOST cost-effective?

A Change to an asynchronous Express workflow

B Keep Standard and remove the Retry blocks to reduce transitions

C Batch events and process them with a Distributed Map in Standard

D Convert each step to a separate Standard workflow

◆ PAUSE AND DECIDE

## Which change is MOST cost-effective?

**A** Asynchronous Express

Billed by execution and duration, and the PutItem on a fixed key is safe to repeat.

**B** Remove retries

*Retries only add transitions when they fire. The four steps are still billed every time.*

**C** Distributed Map in Standard

*Built for large batch jobs, and it adds buffering latency to a stream.*

**D** One workflow per step

*Multiplies executions and transitions. Strictly more expensive.*

THE SIGNAL

High volume, short duration, idempotent steps. Every one of those words describes Express.

A Meridian Freight team owns a customer onboarding process written in Python and deployed as Lambda functions. It must pause for up to seven days while a customer uploads verification documents, then continue.

The team wants the whole workflow in its existing codebase and test suite, does not want to learn Amazon States Language, and must not pay for compute while waiting.

**Which solution meets these requirements with the LEAST change?**

A. Rewrite the process as a Step Functions Standard workflow with a callback

B. Re-enqueue a message on an SQS delay queue until the documents arrive

C. A Lambda durable function, with steps for each stage and a wait for the upload callback

D. An EventBridge Scheduler schedule that invokes the function daily to check progress

◆ PAUSE AND DECIDE

## Which solution meets these requirements with the LEAST change?

**A** Step Functions rewrite

*Technically sound, but it moves the logic into States Language, which the team ruled out.*

**B** SQS delay loop

*Delay tops out at 15 minutes, so it becomes hundreds of re-enqueues and hand-built state.*

**C** Lambda durable function

Workflow stays in Python, checkpoints each step, and waits without compute charges.

**D** Daily scheduled check

*Workflow state must be stored and reloaded by hand, and progress lags by up to a day.*

THE SIGNAL

The constraint is not technical. The team wants the workflow in its own code, which is what durable functions add.

> Meridian Freight's live tracking page receives shipment positions through an API Gateway WebSocket API. Dispatchers keep the page open all day.
>
> Dispatchers report that the page stops updating roughly every two hours, and that quiet shipments stop updating after about ten minutes without a position change.

## What should the solutions architect do?

A Request a quota increase for WebSocket connection duration and idle timeout

B Have the client send periodic heartbeat messages and reconnect automatically when closed

C Increase the timeout of the Lambda function behind the $default route

D Replace the WebSocket API with a REST API that the page polls every second

◆ PAUSE AND DECIDE

## What should the solutions architect do?

A Quota increase

*Neither limit is adjustable. The request cannot be granted.*

B Heartbeat and auto-reconnect

Keeps quiet connections alive and recovers cleanly from the 2-hour close.

C Longer Lambda timeout

*The function is not holding the connection. API Gateway is.*

D REST polling every second

*Thousands of mostly empty requests, more cost and load for a worse experience.*

THE SIGNAL

Two hours and ten minutes are the fixed WebSocket limits. Round-number failures are usually quotas.

# What to carry out of this module

- **Lost sessions on scale-in** mean state on the instance. Move it out, do not protect the instance.
- **Writes in two Regions:** DynamoDB global tables. Global Datastore secondaries are read-only.
- **Standard** for long, exactly-once, callback. **Express** for short, high-volume, idempotent.
- **Durable functions** since December 2025: durable workflows written as Lambda code.
- **WebSocket 2-hour and 10-minute limits** are fixed. Heartbeat and reconnect.

> ON THE EXAM
>
> Older courses have no durable functions. When code-first workflows appear, that option is now a real answer.

MODULE 03 · DOMAIN 1 - ARCHITECTURE BUILT FOR THE CLOUD

# Containers and Orchestration at Scale

Pick the platform, pick what scales, and treat the image registry as part of your security boundary.

DOMAIN 1 of 5 EXAM WEIGHT 25% MODULE 3 of 52

admin@sthithapragna.com

Choosing a container platform is choosing **how much of the machine** you still own.

# Who manages what

| OPTION | AWS MANAGES | YOU STILL MANAGE |
|---|---|---|
| ECS on Fargate | Hosts, patching, capacity | Task size and scaling policy |
| ECS Managed Instances | EC2 provisioning, patching, scaling | Instance requirements, if any |
| ECS on EC2 | Control plane only | AMIs, patching, capacity providers |
| EKS Auto Mode | Nodes, load balancers, storage, networking | Workloads, VPC, disruption budgets |
| EKS managed node groups | Node provisioning and updates on request | Instance choice, upgrades, add-ons |
| EKS on Fargate | Hosts per pod | Pod sizing; no DaemonSets or GPUs |

ON THE EXAM

Two newer rows, ECS Managed Instances and EKS Auto Mode, sit between Fargate and self-managed hosts.

# ECS or EKS?

CHOOSE ECS WHEN

## AWS-native, least overhead

- No existing Kubernetes investment
- Simplest operational model
- Deep integration with AWS services
- Team does not want to run Kubernetes

CHOOSE EKS WHEN

## Kubernetes is the requirement

- Existing Helm charts, operators, manifests
- Portability across clouds or on premises
- Kubernetes ecosystem tooling
- Same API on EKS Anywhere and in the cloud

THE TIEBREAKER

Kubernetes in the scenario means EKS. Without it, ECS is usually the lower-overhead answer.

# Fargate or ECS Managed Instances?

CHOOSE FARGATE WHEN

## No hosts at all

- Per-task vCPU and memory billing
- Each task isolated on its own host
- No GPU support
- Instance type is not your concern

CHOOSE MANAGED INSTANCES WHEN

## Specific EC2, still managed

- GPU, network-optimised or burstable types
- AWS patches roughly every 14 days
- EC2 price plus a management fee
- Spot and Capacity Reservations supported

THE TIEBREAKER

Needs a GPU or a particular instance family, and nobody wants to patch hosts: Managed Instances.

# EKS Auto Mode in one slide

- **Karpenter-based scaling** launches nodes for unschedulable pods and removes idle ones.
- **Load balancers, storage and pod networking** provisioned for you.
- **21-day maximum node lifetime** keeps nodes patched by replacement.
- **Disruption budgets still yours.** A blocking PDB can stall node updates.
- **Custom NodePools** for instance choice. Do not edit the defaults.

> ON THE EXAM
>
> Auto Mode is managed Karpenter plus managed add-ons. Kubernetes stays; node operations go.

# Scaling happens at two layers

| MECHANISM | SCALES | DRIVEN BY |
|---|---|---|
| Horizontal Pod Autoscaler | Pods | CPU, memory or custom metrics |
| Cluster Autoscaler | Node groups | Pending pods; one ASG per group |
| Karpenter / Auto Mode | Nodes, any suitable type | Pending pods; consolidates idle nodes |
| ECS service auto scaling | Tasks | Application Auto Scaling policies |
| ECS capacity providers | EC2 instances | Managed scaling from task demand |
| Lambda | Execution environments | Requests, within concurrency limits |

ON THE EXAM

Pods or tasks scaling without capacity scaling gives you Pending work. Both layers need a mechanism.

# Cluster Autoscaler or Karpenter?

CLUSTER AUTOSCALER

## Scales node groups

- Adjusts Auto Scaling group sizes
- Usually one instance type per group
- Many groups for many shapes
- Does not repack running pods

KARPENTER

## Launches right-sized nodes

- Calls EC2 directly for each need
- Chooses across many instance types
- Consolidates under-used nodes
- Diversifies Spot across families

THE TIEBREAKER

Slow scale-out, poor bin-packing or a sprawl of node groups points to Karpenter, or Auto Mode to have it managed.

# ECS service auto scaling

- **Application Auto Scaling** adjusts the service's desired task count.
- **Target tracking** on CPU, memory or ALBRequestCountPerTarget.
- **Step, scheduled and predictive** policies for known patterns.
- **CPU is the wrong signal** for I/O-bound services that wait on downstream calls.
- **Capacity providers** make EC2 capacity follow the tasks.

> ON THE EXAM
>
> Scale on the metric that tracks the bottleneck. For request-driven services that is requests per target.

# Lambda concurrency

- **Account limit** is shared by every function in the Region, unless reserved.
- **Scaling rate:** 1,000 execution environments per function every 10 seconds.
- **Reserved concurrency** guarantees capacity to a function and caps it. No charge.
- **Provisioned concurrency** keeps environments initialised. Billed while configured.
- **SnapStart** cuts cold starts for Java, Python and .NET without provisioning.

> ON THE EXAM
>
> Reserved concurrency is about who gets capacity. Provisioned concurrency is about cold-start latency.

Your registry is part of your **attack surface**. What you scanned at push time can become vulnerable next week.

# Amazon ECR controls that appear in questions

| CONTROL | WHAT IT DOES |
|---|---|
| Basic scanning | OS package CVEs, on push or manual. AWS-native engine |
| Enhanced scanning | Amazon Inspector, OS and language packages, continuous |
| Tag immutability | Tags cannot be overwritten; exclusions since July 2025 |
| Lifecycle policies | Expire or archive by age, count or last pull |
| Archive storage class | Since November 2025; restore within about 20 minutes |
| Replication | Copy images across Regions and accounts automatically |

ON THE EXAM

Continuous rescanning of deployed images requires enhanced scanning. Basic scanning never rescans on its own.

# Basic or enhanced scanning?

BASIC SCANNING

## Point-in-time OS checks

- Operating system packages only
- Scan on push or on request
- No extra service needed
- Results for that moment only

ENHANCED SCANNING

## Continuous, via Inspector

- OS and programming language packages
- Rescans as new CVEs are published
- Findings flow to Security Hub
- Billed through Amazon Inspector

THE TIEBREAKER

Language libraries such as Python or Java packages, or rescanning when new CVEs appear: enhanced.

# Reading the scenario

| WHEN THE QUESTION SAYS | IT IS TESTING |
|---|---|
| Existing Helm charts or operators | EKS, not an ECS rewrite |
| GPU containers, no host patching | ECS Managed Instances |
| Pods stay Pending after scale-out | Node-layer scaling is missing or slow |
| CPU low but latency rising | Wrong target-tracking metric |
| One function starves another | Reserved concurrency |
| New CVEs in running images | Enhanced, continuous scanning |

ON THE EXAM

Platform, scaling layer, scaling metric, concurrency, registry. Name which one the question is about first.

> Meridian Freight is moving 40 microservices from a self-managed Kubernetes cluster in its data centre to AWS. Teams deploy with Helm charts and rely on two Kubernetes operators.
>
> The platform team is three people and wants to stop patching, scaling and replacing worker nodes.

**Which solution meets these requirements with the LEAST operational overhead?**

A Rewrite the services as ECS task definitions on Fargate

B Amazon EKS with self-managed node groups and Cluster Autoscaler

C Amazon EKS Auto Mode

D Kubernetes installed on EC2 instances with a custom AMI pipeline

◆ PAUSE AND DECIDE

## Which solution meets these requirements with the LEAST operational overhead?

A ECS rewrite

*Fargate removes hosts, but rewriting 40 services and replacing two operators is large new work.*

B EKS, self-managed nodes

*Keeps Kubernetes, but the team is still patching and scaling nodes.*

C EKS Auto Mode

Keeps Helm and operators; AWS runs node scaling, patching and add-ons.

D Self-installed Kubernetes

*Adds control plane operations on top of everything they already do.*

THE SIGNAL

Kubernetes tooling keeps it on EKS. Wanting to stop node operations moves it to Auto Mode.

> Meridian Freight's route optimisation service runs containerised inference on ECS and needs NVIDIA GPU instances. It currently runs on ECS with EC2 Auto Scaling groups and a hand-built AMI patching process.
>
> The company wants to stop managing AMIs and host patching while keeping GPU instances.

**What should the solutions architect recommend?**

A ECS Managed Instances with a capacity provider specifying GPU instance types

B Move the service to ECS on Fargate with GPU-enabled task sizes

C Keep ECS on EC2 and automate AMI builds with a scheduled pipeline

D Package the model as a Lambda container image

◆ PAUSE AND DECIDE

## What should the solutions architect recommend?

**A** ECS Managed Instances

AWS provisions and patches the GPU instances you specify.

**B** Fargate with GPUs

*Fargate does not offer GPUs, so this option does not exist.*

**C** Automated AMI pipeline

*Still the company's patching process, just automated. The requirement was to stop owning it.*

**D** Lambda container image

*Lambda has no GPU support.*

THE SIGNAL

GPU rules out Fargate and Lambda. Stop patching rules out EC2 you manage. One option is left.

Meridian Freight's EKS cluster uses Cluster Autoscaler with six managed node groups, each a single instance type. Batch pods wait several minutes in Pending, many nodes run half empty, and Spot interruptions hit whole node groups at once.

The team wants faster scale-out, better packing and more resilient Spot usage, and will keep managing the cluster itself.

## What should the solutions architect do?

A Add more node groups to cover additional instance sizes

B Raise the Horizontal Pod Autoscaler's minimum replicas

C Run low-priority placeholder pods to keep spare nodes warm

D Replace Cluster Autoscaler with Karpenter, using a NodePool that allows many instance families and Spot

◆ PAUSE AND DECIDE

## What should the solutions architect do?

A More node groups

*More shapes to manage, and still no consolidation of half-empty nodes.*

B Higher HPA minimum

*Adds pods, not nodes. Makes Pending worse.*

C Placeholder pods

*Buys headroom by paying for idle nodes. Packing gets worse, not better.*

D Karpenter with diverse NodePool

Launches fitting nodes directly, consolidates, spreads Spot across families.

THE SIGNAL

Three symptoms of single-type node groups: slow fit, poor packing, correlated Spot loss. Karpenter fixes all three.

> Meridian Freight's quoting service runs on ECS behind an Application Load Balancer, with target tracking on average CPU at 60 percent. Each request mostly waits on a partner pricing API.
>
> At peak, response times triple while service CPU stays near 25 percent, and the task count never increases.

**Which change makes the service scale with demand?**

A. Lower the CPU target to 20 percent

B. Target tracking on ALBRequestCountPerTarget

C. A scheduled action that doubles tasks at peak hours

D. Double the CPU and memory of each task

◆ PAUSE AND DECIDE

## Which change makes the service scale with demand?

A **Lower CPU target**

*Still the wrong signal. Scales on idle CPU noise and over-provisions off-peak.*

B **Requests per target**

Tracks the real load on a service that is waiting, not computing.

C **Scheduled scaling**

*Helps the known peak only, and guesses at the size.*

D **Bigger tasks**

*More CPU for a service that is not using its CPU.*

THE SIGNAL

Low CPU with rising latency means the service is waiting. Scale on requests, not on processor time.

In one AWS account, a nightly Lambda batch job scales to thousands of concurrent executions. During that window, Meridian Freight's customer-facing checkout function is throttled.

Checkout needs up to 300 concurrent executions. The company wants to fix this as cost-effectively as possible.

## Which solution is MOST cost-effective?

A Configure 300 provisioned concurrency on the checkout function

B Request a higher account concurrency limit

C Schedule the batch job for a time with no checkout traffic

D Set reserved concurrency of 300 on checkout and a reserved cap on the batch function

◆ PAUSE AND DECIDE

## Which solution is MOST cost-effective?

A **Provisioned concurrency**

*Also protects checkout, but bills for 300 warm environments around the clock.*

B **Higher account limit**

*The batch job can grow into any new headroom. Nothing isolates checkout.*

C **Reschedule the batch**

*An online checkout has no reliably quiet hour, and nothing enforces it.*

D **Reserved concurrency**

Guarantees checkout's capacity and caps the batch, at no charge.

THE SIGNAL

Starvation between functions is a reservation problem. Provisioned concurrency also works, and costs money.

> Meridian Freight's security team requires that container images already running in production are re-evaluated whenever new vulnerabilities are published, including vulnerabilities in Python libraries.
>
> Release tags must never be overwritten, but developers need a nightly tag they can move every day.

## Which Amazon ECR configuration meets these requirements?

A. Enhanced scanning with continuous scan, and tag immutability with an exclusion for the nightly tag

B. Basic scanning with scan on push, and mutable tags

C. Enhanced scanning on push only, and tag immutability on every tag

D. Basic scanning triggered daily by EventBridge Scheduler, and tag immutability on every tag

◆ PAUSE AND DECIDE

## Which Amazon ECR configuration meets these requirements?

**A** Enhanced continuous, with exclusion

Rescans as CVEs appear, covers language packages, locks releases, frees nightly.

**B** Basic on push, mutable

*No Python coverage, no rescanning, and release tags can be overwritten.*

**C** Enhanced on push, all immutable

*No rescanning after push, and the nightly tag can no longer move.*

**D** Basic daily, all immutable

*Basic never sees Python libraries, and nightly cannot move.*

THE SIGNAL

Language libraries plus re-evaluation means enhanced continuous. A movable tag among fixed ones means an exclusion.

# What to carry out of this module

- **Kubernetes tooling means EKS.** Least node work on EKS means Auto Mode.
- **GPU without host patching:** ECS Managed Instances. Fargate has no GPUs.
- **Scale both layers.** Pods or tasks, and the capacity under them.
- **Reserved concurrency** for fairness, free. Provisioned for cold starts, paid.
- **Enhanced continuous scanning** for language packages and new CVEs.

> ON THE EXAM
>
> App Runner and AWS Batch are no longer on the in-scope list. Do not choose them on this exam.

MODULE 04 · DOMAIN 1 - ARCHITECTURE BUILT FOR THE CLOUD

# Service Mesh and Ingress Design

How traffic gets in, and how services find and trust each other once it is inside.

DOMAIN 1 of 5 EXAM WEIGHT 25% MODULE 4 of 52

admin@sthithapragna.com

North-south traffic needs a front door. East-west traffic between services needs discovery, retries and trust.


admin@sthithapragna.com

# The services and the direction they serve

| SERVICE | DIRECTION | BEST AT |
|---|---|---|
| Application Load Balancer | North-south | HTTP routing, auth, WAF |
| Network Load Balancer | North-south | TCP and UDP, static IPs, PrivateLink |
| Amazon API Gateway | North-south | API keys, quotas, transforms |
| AWS Load Balancer Controller | North-south | ALB and NLB for Kubernetes |
| ECS Service Connect | East-west | ECS service discovery and retries |
| Amazon VPC Lattice | East-west | Any compute, across VPCs and accounts |

ON THE EXAM

AWS App Mesh is not on this list. It was discontinued on 30 September 2026.

# Application or Network Load Balancer?

CHOOSE ALB WHEN

## Layer 7 decisions

- Route on path, host or header
- Authenticate users with OIDC or Cognito
- AWS WAF on the listener
- Lambda functions as targets

CHOOSE NLB WHEN

## Layer 4 performance

- TCP, UDP or TLS passthrough
- Static IP or Elastic IP per AZ
- Client source IP preserved
- Front end for a PrivateLink service

THE TIEBREAKER

Fixed IPs for a partner allow-list, non-HTTP protocols, or PrivateLink all mean NLB.

# API Gateway: REST API or HTTP API?

CHOOSE REST API WHEN

## Full API management

- API keys and usage plans per client
- AWS WAF and resource policies
- Caching and request validation
- Private or edge-optimised endpoints

CHOOSE HTTP API WHEN

## Lower cost and latency

- Native JWT authorisers
- Private integration through Cloud Map
- Automatic deployments
- Features the API does not need are absent

THE TIEBREAKER

Per-client quotas, WAF, caching or a private endpoint rule out HTTP APIs. Otherwise HTTP is cheaper.

# Kubernetes ingress on EKS

- **AWS Load Balancer Controller** watches the cluster and provisions load balancers.
- **Ingress resource** becomes an ALB; **Service of type LoadBalancer** becomes an NLB.
- **IP target mode** sends traffic straight to pod IPs. Required for Fargate pods.
- **IngressGroup** lets several Ingress resources share one ALB.
- **EKS Auto Mode** runs this capability for you.

> ON THE EXAM
>
> One ALB per Ingress is the default and gets expensive. IngressGroup shares one across teams.

A service mesh gives every call between services **discovery, retries, encryption and metrics** without changing the code.

# ECS Service Connect or VPC Lattice?

CHOOSE SERVICE CONNECT WHEN

## ECS services together

- All callers and callees run on ECS
- Proxy added to each task automatically
- Retries, outlier detection, free metrics
- Namespace can be shared with RAM

CHOOSE VPC LATTICE WHEN

## Any compute, any VPC

- Mixes EC2, ECS, EKS, Lambda and IPs
- Crosses VPCs and accounts, no peering
- IAM auth policies on each request
- No sidecars to run or upgrade

THE TIEBREAKER

Mixed compute, crossing VPCs, or per-request IAM authorisation means Lattice. ECS-only means Service Connect.

# VPC Lattice building blocks

| COMPONENT | WHAT IT IS |
|---|---|
| Service network | Logical boundary that VPCs and services join |
| Service | A named endpoint with listeners and routing rules |
| Target group | EC2, IP, Lambda, ALB, ECS or Kubernetes targets |
| Auth policy | IAM policy on the network, the service, or both |
| Resource configuration | TCP access to resources such as an RDS database |
| RAM share | How other accounts join the network or use a service |

ON THE EXAM

Services join a service network; VPCs associate with it. Neither side needs a route to the other.

# VPC Lattice or Transit Gateway?

TRANSIT GATEWAY

## Connect networks

- Routes whole CIDR ranges
- Needs non-overlapping addresses
- Any port, any protocol
- Security groups and NACLs do the filtering

VPC LATTICE

## Connect services

- Exposes only named services
- Overlapping CIDRs are fine
- HTTP, HTTPS and gRPC; TCP via resources
- IAM decides who may call what

THE TIEBREAKER

Network reachability is Transit Gateway. Service-to-service access with identity is Lattice.

# Lattice beyond HTTP: resource configurations

- **Resource configuration** exposes a TCP resource to other VPCs and accounts.
- **By RDS ARN,** by IP address, by domain name, or by CIDR range.
- **Resource gateway:** network interfaces in the provider VPC that receive the traffic.
- **Shared with RAM;** reached via a service network or a resource endpoint.
- **TCP only,** and block transitive sharing so a consumer cannot re-share it.

> ON THE EXAM
>
> A database in another account, no load balancer in front, overlapping CIDRs: a Lattice resource configuration.

# Reading the scenario

| WHEN THE QUESTION SAYS | IT IS TESTING |
|---|---|
| Partners allow-list our IP addresses | NLB with Elastic IPs |
| Different quota for each API client | REST API usage plans |
| App Mesh in the answer | A discontinued service |
| ECS only, discovery and retries | ECS Service Connect |
| Across accounts, overlapping CIDRs | VPC Lattice |
| Database in another account, privately | Lattice resource configuration |

ON THE EXAM

Front door or between services? Decide that first and half the options disappear.

> Meridian Freight exposes a shipment-status service to logistics partners over a proprietary TCP protocol. Several partners' firewalls only permit outbound traffic to IP addresses they have explicitly allow-listed.
>
> The service must see each partner's real source IP address for auditing.

**Which front end should the solutions architect use?**

A An Application Load Balancer with AWS WAF

B Amazon CloudFront in front of an Application Load Balancer

C An API Gateway Regional REST API

D A Network Load Balancer with an Elastic IP address in each Availability Zone

◆ PAUSE AND DECIDE

## Which front end should the solutions architect use?

A ALB with WAF

*HTTP only, and its IP addresses change, so partners cannot allow-list them.*

B CloudFront and ALB

*Still HTTP only, and edge addresses are many and changing.*

C API Gateway REST API

*HTTP-based, with no fixed IP addresses.*

D NLB with Elastic IPs

Carries raw TCP, fixed addresses, and preserves the client source IP.

THE SIGNAL

A proprietary TCP protocol removes every HTTP option. Allow-listed IPs confirm the NLB.

> Meridian Freight is publishing a rate-quote API to 200 partner companies. Each partner has a contracted monthly request quota and a per-second throttle, and the security team requires AWS WAF in front of the API.
>
> The backend is a set of Lambda functions.

## Which solution meets these requirements?

A. An HTTP API with a JWT authoriser for each partner

B. A REST API with an API key and usage plan per partner, and AWS WAF associated with the stage

C. An Application Load Balancer with Lambda targets and AWS WAF

D. An HTTP API behind Amazon CloudFront, with AWS WAF on the distribution

◆ PAUSE AND DECIDE

## Which solution meets these requirements?

A HTTP API with JWT

*Authenticates partners, but HTTP APIs have no usage plans, so no per-partner quotas.*

B REST API, usage plans, WAF

Usage plans hold each partner's quota and throttle; WAF attaches to the stage.

C ALB with WAF

*No concept of per-client quotas at all.*

D HTTP API behind CloudFront

*Solves WAF by adding CloudFront, but quotas are still missing.*

THE SIGNAL

A quota and throttle per client is a usage plan, and usage plans exist only on REST APIs.

> Meridian Freight ran its EKS microservices on AWS App Mesh until the service was discontinued. The services run in three AWS accounts, and several also call Lambda functions.
>
> The security team wants every service-to-service call authorised against IAM, and the platform team wants no sidecar proxies to maintain.

## What should replace App Mesh?

A. A VPC Lattice service network shared through AWS RAM, with auth policies on each service

B. ECS Service Connect with a shared AWS Cloud Map namespace

C. A self-managed Istio installation on each cluster

D. A Transit Gateway connecting the three VPCs, with security groups between services

◆ PAUSE AND DECIDE

# What should replace App Mesh?

**A** VPC Lattice with auth policies

EKS and Lambda targets, across accounts, IAM on every call, no sidecars.

**B** ECS Service Connect

*For ECS services only. These run on EKS.*

**C** Self-managed Istio

*Works, but it is all sidecars and all yours to run and upgrade.*

**D** Transit Gateway

*Network reachability only. Security groups cannot authorise against IAM.*

THE SIGNAL

EKS plus Lambda, three accounts, IAM per call, no sidecars. Each detail independently points to Lattice.

> Meridian Freight runs 25 ECS services in one account and Region. Each service currently has its own internal Application Load Balancer so that other services can reach it.
>
> The company wants service discovery, automatic retries and per-service traffic metrics, and to remove the internal load balancers, with the LEAST operational overhead and cost.

**What should the solutions architect implement?**

A. AWS Cloud Map DNS-based service discovery with no proxy

B. Keep the internal load balancers and add AWS X-Ray tracing

C. ECS Service Connect in a single namespace

D. A VPC Lattice service network with each ECS service registered

◆ PAUSE AND DECIDE

## What should the solutions architect implement?

A. Cloud Map DNS only

*Discovery, but no retries and no traffic metrics. Clients see stale DNS on scale-in.*

B. Keep ALBs, add X-Ray

*Keeps 25 load balancers, which the company wants to remove.*

C. ECS Service Connect

Discovery, retries and free CloudWatch metrics for ECS, with no load balancers.

D. VPC Lattice

*Works, but adds per-service and per-request charges for reach it does not need.*

THE SIGNAL

One account, one Region, ECS only. Nothing here needs Lattice's reach, so the cheaper ECS-native option wins.

Meridian Freight acquired a regional carrier. Both companies' VPCs use 10.0.0.0/16, and re-addressing either is not possible this year.

Meridian's billing service, on Lambda, must call the carrier's inventory API, on EKS. Only the billing role may call it, and nothing else in either network may be reachable.

**Which solution meets these requirements?**

A VPC peering between the two VPCs

B A Transit Gateway with both VPCs attached

C A PrivateLink endpoint service in front of a Network Load Balancer

D A VPC Lattice service network, with an auth policy allowing only the billing role

◆ PAUSE AND DECIDE

## Which solution meets these requirements?

A VPC peering

*Peering cannot connect VPCs with overlapping CIDR ranges.*

B Transit Gateway

*Overlapping ranges cannot be routed, and it would expose whole networks.*

C PrivateLink with an NLB

*Handles the overlap, but cannot authorise each call against a specific IAM role.*

D VPC Lattice with auth policy

Overlap is irrelevant, only the one service is exposed, and IAM decides who calls.

THE SIGNAL

Overlapping CIDRs remove routing answers. Authorising one IAM role per call removes PrivateLink.

> Analytics jobs on EKS in Meridian Freight's analytics account must query an Amazon RDS for PostgreSQL database in the data account. The VPCs have overlapping CIDRs and VPC peering is not permitted.
>
> The database has no load balancer in front of it, and its IP address changes on failover.

**Which solution provides private access with the LEAST operational overhead?**

A. A Network Load Balancer targeting the database's IP, exposed with PrivateLink, plus a Lambda function to update the target on failover

B. A VPC Lattice resource configuration for the database ARN, with a resource gateway, shared through AWS RAM

C. A Transit Gateway between the two accounts

D. Make the database publicly accessible and restrict it with a security group

◆ PAUSE AND DECIDE

## Which solution provides private access with the LEAST operational overhead?

A NLB, PrivateLink and a Lambda

*Works, and was the standard answer. The failover script is the overhead the question warns about.*

B Lattice resource configuration

Identifies the database by ARN, so failover is handled. Shared privately across accounts.

C Transit Gateway

*Overlapping CIDRs cannot be routed.*

D Public database

*Fails the requirement for private access.*

THE SIGNAL

The changing IP on failover is planted to make the NLB answer expensive. An ARN-based configuration removes it.

# What to carry out of this module

- **NLB** for fixed IPs, non-HTTP and PrivateLink. **ALB** for routing, auth and WAF.
- **REST API** for usage plans, WAF, caching and private endpoints. Otherwise HTTP API.
- **App Mesh is discontinued** as of 30 September 2026.
- **Service Connect** for ECS together. **Lattice** for any compute across VPCs and accounts.
- **Lattice resource configurations** reach databases and other TCP resources.

> ON THE EXAM
>
> Scope reversal: C02 courses call VPC Lattice out of scope. On C03 it is named in skill 1.1.7.

MODULE 05 · DOMAIN 1 - ARCHITECTURE BUILT FOR THE CLOUD

# Edge Architecture and Multi-Tenant Isolation

Code that runs before the request travels, and the boundaries that keep one customer out of another's data.

DOMAIN 1 of 5 EXAM WEIGHT 25% MODULE 5 of 52

admin@sthithapragna.com

Code at the edge is for decisions that must happen **before the request travels** to your origin.

# CloudFront Functions or Lambda@Edge

| | CLOUDFRONT FUNCTIONS | LAMBDA@EDGE |
|---|---|---|
| Events | Viewer request and response | Viewer and origin, both directions |
| Duration | Sub-millisecond | Seconds |
| Code size | 10 KB, JavaScript | Up to 50 MB, Node.js or Python |
| Network and body | No network, no body | Network calls and request body |
| Scale | Millions of requests per second | 10,000 per second per Region |
| State | CloudFront KeyValueStore | Any AWS service via the SDK |

ON THE EXAM

If the function needs the network, a library, the request body or an origin event, it is Lambda@Edge.

# Which runtime for which job?

CLOUDFRONT FUNCTIONS

## Lightweight request shaping

- Redirects and URL rewrites
- Add or change headers
- Normalise the cache key
- Validate a JWT signature

LAMBDA@EDGE

## Real processing

- Call an external service or database
- Resize images on a cache miss
- Inspect or change the request body
- Use third-party libraries

THE TIEBREAKER

Default to CloudFront Functions. Move to Lambda@Edge only when a named capability forces it.

# Edge patterns worth naming

- **Cache key normalisation** raises the hit ratio, which lowers latency and origin load.
- **KeyValueStore** holds redirects, feature flags or A/B weights without redeploying.
- **Origin selection** per request, from a function, for routing tenants or versions.
- **Reject bad requests at the edge** so invalid tokens never reach the origin.
- **Lambda@Edge is deployed from us-east-1** and replicated outwards.

> ON THE EXAM
>
> The cheapest request is the one your origin never sees. Edge logic is often a cost answer as well as a latency one.

In a shared system, the tenant ID is a **security boundary**. Everything that touches data must carry it and enforce it.

# Silo, bridge and pool

| MODEL | SHAPE | ISOLATION | COST PER TENANT |
|---|---|---|---|
| Silo | Dedicated stack or account per tenant | Strongest | Highest |
| Bridge | Shared compute, dedicated data stores | Strong for data | Medium |
| Pool | Everything shared, tenant ID in every row | Enforced by policy | Lowest |

ON THE EXAM

Most real platforms are tiered: silo for the few customers who pay for it, pool for everyone else.

# Carrying tenant context through every layer

| LAYER | MECHANISM |
| --- | --- |
| Identity | Cognito: tenant attribute in tokens, or a pool per tenant |
| API | API Gateway usage plans per tenant tier |
| Compute | Lambda tenant isolation mode, since November 2025 |
| Data | DynamoDB LeadingKeys, PostgreSQL row-level security |
| Encryption | KMS key per tenant, or encryption context |
| Queues | SQS fair queues, since July 2025 |

ON THE EXAM

Tenant context starts in a signed token. Every later layer trusts the token, never a header the client wrote.

# Cognito: shared pool or pool per tenant?

SHARED POOL, TENANT ATTRIBUTE

## Surface-level tenancy

- One sign-in for every tenant
- custom:tenantID, read-only to clients
- Same MFA and branding for all
- App enforces the claim everywhere

POOL PER TENANT

## Strong identity isolation

- MFA policy set per tenant
- Own branding and identity providers
- No shared user directory
- More pools to provision and manage

THE TIEBREAKER

Settings that live at pool level, such as MFA, cannot vary by attribute. Different MFA rules mean different pools.

# Enforcing isolation on pooled data

- **DynamoDB:** dynamodb:LeadingKeys condition restricts items to the caller's tenant partition.
- **Session tags** put the tenant ID in the role session; the policy reads aws:PrincipalTag.
- **Aurora PostgreSQL:** IAM cannot scope rows. Use row-level security policies.
- **S3:** a prefix per tenant, with policy variables restricting each to its own.
- **Application filters alone** are the weakest control: one missed WHERE clause leaks.

> ON THE EXAM
>
> Isolation enforced by IAM or the database survives an application bug. A filter in code does not.

# Tenant-specific encryption

KMS KEY PER TENANT

## Strong, per-tenant control

- Separate key policy for each tenant
- Disable the key to cut off one tenant
- Per-tenant audit in CloudTrail
- More keys, more cost, more quota

SHARED KEY, ENCRYPTION CONTEXT

## Pooled, still auditable

- tenant_id passed as encryption context
- Policy condition on kms:EncryptionContext
- Context appears in CloudTrail
- One key for many tenants

THE TIEBREAKER

A tenant who must be able to revoke access, or who supplies their own key, needs a key of their own.

# Noisy neighbours and shared compute

- **SQS fair queues:** set a message group ID on a standard queue; no consumer changes.
- **Usage plans** throttle each tenant tier at the API.
- **Reserved concurrency** per tier stops one tier starving another.
- **Lambda tenant isolation mode:** pass a tenant ID on invoke; environments never cross tenants.
- **A FIFO queue is not a fairness tool.** It orders, and it limits throughput.

> ON THE EXAM
>
> Fair queues keep standard-queue throughput while stopping one tenant's backlog delaying the rest.

# CloudFront SaaS Manager

- **Multi-tenant distribution:** a template of shared origins, behaviours and security.
- **Distribution tenants** inherit it, each with its own domain and certificate.
- **Per-tenant overrides:** WAF web ACL, geographic restrictions, parameters such as origin path.
- **Connection groups** provide the routing endpoint that tenants' CNAMEs point to.
- **Not supported:** continuous deployment, OAI, dedicated IP SSL.

> ON THE EXAM
>
> Thousands of customer domains on one platform: one multi-tenant distribution, not thousands of distributions.

# Reading the scenario

| WHEN THE QUESTION SAYS | IT IS TESTING |
|---|---|
| Headers, redirects, millions per second | CloudFront Functions |
| Resize, call a service, read the body | Lambda@Edge |
| A few customers need guaranteed separation | Tiered silo and pool |
| Enforced by IAM, not application code | LeadingKeys with session tags |
| One tenant's jobs delay everyone | SQS fair queues |
| Different MFA rules per tenant | Cognito user pool per tenant |

ON THE EXAM

Multi-tenant questions reward the answer that enforces isolation below the application.

> Meridian Freight's customer site on CloudFront serves several million requests per second at peak. The company must add security headers to every response and redirect legacy /track URLs to /shipments.
>
> The solution should add as little latency and cost as possible.

**What should the solutions architect implement?**

A. Lambda@Edge functions on the origin request and origin response events

B. CloudFront Functions on the viewer request and viewer response events

C. Listener rules on the origin's Application Load Balancer

D. A Lambda function behind API Gateway that rewrites each request

◆ PAUSE AND DECIDE

## What should the solutions architect implement?

A Lambda@Edge on origin events

*Origin events only run on cache misses, so cached responses miss the headers. Costlier too.*

B CloudFront Functions on viewer events

Sub-millisecond, scales to millions per second, runs on every request and response.

C ALB listener rules

*Only sees cache misses, and redirects would travel all the way to the Region.*

D API Gateway and Lambda

*Adds a regional hop and per-request cost to every request.*

THE SIGNAL

Simple header and redirect logic at very high volume is the textbook CloudFront Functions case.

> Meridian Freight's mobile app requests proof-of-delivery photos in several sizes. Originals are stored once in Amazon S3. Resized versions should be created on first request and cached at the edge.
>
> The resizing uses a third-party image library and must fetch the original from S3.

## How should the resizing be implemented?

A. A CloudFront Function on the viewer request event

B. S3 Object Lambda access points

C. A nightly job that pre-generates every size for every photo

D. A Lambda@Edge function on the origin response event

◆ PAUSE AND DECIDE

## How should the resizing be implemented?

A CloudFront Function

*No libraries, no network access, 10 KB of code. It cannot resize an image.*

B S3 Object Lambda

*Closed to new customers, and not an edge cache pattern.*

C Nightly pre-generation

*Creates sizes nobody requests, and new photos wait until the next night.*

D Lambda@Edge on origin response

Runs only on a cache miss, can use the library and fetch from S3; the result is cached.

THE SIGNAL

A library and a network fetch rule out CloudFront Functions. Cache-miss-only work belongs on an origin event.

> Meridian Freight sells its tracking platform as SaaS. Three bank customers have contracts requiring that their data and compute never share infrastructure with other customers.
>
> About 400 smaller customers are price-sensitive, and the company must keep their cost to serve low.

## Which tenancy model should the solutions architect recommend?

A. Pool every tenant, with row-level security in a shared database

B. A dedicated AWS account and stack for every tenant

C. Silo stacks in dedicated accounts for the three banks, and a pooled tier for everyone else

D. Pool every tenant, with a separate KMS key for each

◆ PAUSE AND DECIDE

# Which tenancy model should the solutions architect recommend?

A **Pool everyone with RLS**

*Good isolation, but the banks' compute and database are still shared. Breaks the contract.*

B **Silo everyone**

*Meets the banks' terms, but 400 dedicated stacks wreck the cost to serve.*

C **Tiered silo and pool**

Physical separation where contracts demand it, shared economics everywhere else.

D **Pool with a key per tenant**

*Separates keys, not infrastructure. The banks still share compute.*

THE SIGNAL

Two populations with different requirements, in one scenario, is the signature of a tiered model.

> Meridian Freight's pooled tier stores all tenants' shipments in one DynamoDB table with tenantId as the partition key. Lambda functions currently filter by tenant in application code.
>
> After a near miss in code review, the security team wants tenant isolation enforced outside the application code, without a policy or table per tenant.

## What should the solutions architect implement?

A. Assume a role with a TenantID session tag, using a policy with dynamodb:LeadingKeys set to that tag

B. A separate DynamoDB table for each tenant

C. Mandatory code review for every query that touches the table

D. A separate customer managed KMS key for each tenant

◆ PAUSE AND DECIDE

## What should the solutions architect implement?

**A** Session tag and LeadingKeys

IAM rejects any request outside the tenant's partition, with one shared policy.

**B** Table per tenant

*Strong, but moves the pool tier to a bridge model, which the team ruled out.*

**C** More code review

*Still relies on application code. The near miss shows this is not enough.*

**D** Key per tenant

*Encrypts data at rest; does not stop a valid session reading another tenant's items.*

THE SIGNAL

Enforced outside the code, with no per-tenant policy: IAM conditions driven by a tag on the session.

> Meridian Freight's pooled tier uses one SQS standard queue for report-generation jobs from all tenants. When one large tenant submits a bulk import, other tenants' jobs wait for hours.
>
> The company wants fair processing across tenants without changing the consumer code or creating a queue per tenant.

## What should the solutions architect do?

A. Convert to a FIFO queue using the tenant ID as the message group ID

B. Create a separate queue for each tenant and poll them in rotation

C. Double the consumer fleet during bulk imports

D. Send each message with the tenant ID as its message group ID on the existing standard queue

◆ PAUSE AND DECIDE

## What should the solutions architect do?

**A** FIFO with tenant groups

*Adds strict ordering and throughput limits nobody asked for, and is a new queue.*

**B** Queue per tenant

*Explicitly ruled out, and needs new consumer polling logic.*

**C** More consumers

*Shortens the wait but does not make it fair; cost rises with every import.*

**D** Fair queue via message group ID

SQS serves quieter tenants first. Same queue, consumers unchanged.

THE SIGNAL

A message group ID on a standard queue turns on fairness. On a FIFO queue it turns on ordering.

> Meridian Freight's enterprise customers each require sign-in through their own SAML identity provider, and two of them require different MFA rules from everyone else.
>
> Smaller customers sign in with a username and password, and the company wants their onboarding kept simple.

## Which Amazon Cognito design meets these requirements?

A One user pool for all customers, with a custom:tenantID attribute

B A user pool per enterprise customer, and one shared pool with a tenant attribute for smaller customers

C One identity pool per customer

D One user pool with a group per customer

◆ PAUSE AND DECIDE

## Which Amazon Cognito design meets these requirements?

A One pool, tenant attribute

*MFA is set for the whole pool, so two customers cannot have different rules.*

B Pools per enterprise, shared for small

Pool-level settings vary where needed; small customers stay simple.

C Identity pool per customer

*Identity pools issue AWS credentials. They do not authenticate users or set MFA.*

D Groups per customer

*Groups carry roles and claims, but MFA is still pool-wide.*

THE SIGNAL

MFA rules that differ between tenants cannot live in one user pool. That single detail decides it.

# What to carry out of this module

- **CloudFront Functions by default.** Lambda@Edge for network, libraries, body or origin events.
- **Silo, bridge, pool,** and usually a tier of each. Read for two customer populations.
- **Enforce below the code:** LeadingKeys, row-level security, per-tenant keys.
- **New since 2025:** SQS fair queues, Lambda tenant isolation mode, CloudFront SaaS Manager.
- **Pool-level settings such as MFA** force a Cognito pool per tenant.

> ON THE EXAM
>
> Skill 1.1.13 is new to this exam. Older courses do not teach tenant isolation at all.

MODULE 06 · DOMAIN 1 - ARCHITECTURE BUILT FOR THE CLOUD

# AI Integration: Bedrock and Agents

Calling models across a multi-account estate, and giving agents tools without giving away the keys.

DOMAIN 1 of 5 EXAM WEIGHT 25% MODULE 6 of 52

admin@sthithapragna.com

Integrating generative AI is an **architecture** problem: access, safeguards, capacity, residency and cost.

# The Bedrock pieces an architect works with

| PIECE | WHAT IT IS FOR |
|---|---|
| Converse API | One request format across models, including tool use |
| Inference profiles | Cross-Region routing, and per-application cost tracking |
| Service tiers | Priority, Standard or Flex, per request |
| Guardrails | Content filters and safeguards on inputs and outputs |
| Knowledge Bases | Managed retrieval for RAG, covered in module 7 |
| Agents and AgentCore | Models that call tools to complete tasks |

ON THE EXAM

Only Bedrock and SageMaker AI appear in the guide's AI category. Amazon Q, Kendra and Comprehend do not.

# Ways to pay for inference

| OPTION | CHOOSE IT FOR |
|---|---|
| On-demand, Standard tier | Everyday interactive traffic |
| Priority tier | Latency-critical, user-facing; premium price |
| Flex tier | Non-interactive work that can wait; discounted |
| Batch inference | Large offline jobs submitted as files |
| Provisioned Throughput | Guaranteed capacity for one model |
| Cross-Region inference | More throughput by spreading across Regions |

ON THE EXAM

Service tiers arrived in November 2025. Flex is the cost answer for agent steps and evaluations that can wait.

# Geographic or global cross-Region inference?

GEOGRAPHIC PROFILE

## Stays in a geography

- Routes within US, EU or APAC
- Standard pricing
- Suits data residency rules
- SCPs must allow each listed Region

GLOBAL PROFILE

## Any commercial Region

- Highest available throughput
- About 10 percent cheaper
- No geographic boundary
- SCPs must allow RequestedRegion unspecified

THE TIEBREAKER

A residency requirement means geographic. No residency constraint and a cost goal means global.

# A multi-account pattern for generative AI

01
### Define
Responsible AI team builds a guardrail in the management account.

02
### Enforce
A Bedrock policy in Organizations applies it to OUs.

03
### Restrict
SCPs limit approved models and Regions.

04
### Invoke
Workload accounts call Bedrock through VPC endpoints.

05
### Observe
Invocation logs flow to the central log archive.

ON THE EXAM

Bedrock policies, since April 2026, enforce a guardrail on every invocation across an OU with no per-account setup.

# Central gateway or governed direct access?

CENTRAL GATEWAY ACCOUNT

## One front door

- Workloads call an internal API
- Central quotas, caching and model routing
- One place to rotate and govern access
- A shared bottleneck to scale

DIRECT, GOVERNED ACCESS

## Each account calls Bedrock

- Bedrock policies enforce guardrails
- SCPs limit models and Regions
- Cost by IAM principal tag or app profile
- No extra service in the request path

THE TIEBREAKER

Custom routing, caching or central quotas justify a gateway. Consistent safeguards alone no longer do.

# Controls that belong in every account

- **Bedrock policy** pins a guardrail version from the management account. One per Region.
- **SCP deny** on bedrock:InvokeModel for model ARNs that are not approved.
- **Interface VPC endpoints** for Bedrock runtime, with endpoint policies.
- **Model invocation logging** to CloudWatch Logs or S3. Off until enabled.
- **Prompts and outputs** are not used to train the models or shared with providers.

> ON THE EXAM
>
> A Bedrock policy is Regional. Enforcing in three Regions means a guardrail and policy for each.

An agent is a model in a loop: it chooses a tool, calls it, reads the result, and decides again.

# Amazon Bedrock AgentCore components

| COMPONENT | WHAT IT PROVIDES |
|---|---|
| Runtime | Isolated session per user; microVM sessions up to 8 hours |
| Gateway | Turns APIs, Lambda and OpenAPI specs into MCP tools |
| Memory | Short-term within a session, long-term across sessions |
| Identity | Inbound sign-in, outbound token vault for OAuth and API keys |
| Policy | Checks every tool call; deny by default, written in Cedar |
| Observability | OpenTelemetry traces, tokens and latency in CloudWatch |

ON THE EXAM

AgentCore is framework- and model-agnostic. Code Interpreter, Browser and Evaluations complete the set.

# Bedrock Agents or AgentCore?

BEDROCK AGENTS

## Configure, do not code

- Instructions, action groups, knowledge bases
- Bedrock-hosted models
- Least code to a working agent
- Still supported for existing users

AGENTCORE

## Bring your own agent

- Any framework: Strands, LangGraph, CrewAI
- Any model, inside or outside Bedrock
- MCP tools, VPC access, long sessions
- Agent-to-agent communication

THE TIEBREAKER

An existing framework, a non-Bedrock model, MCP or long sessions means AgentCore.

# Giving agents tools safely

- **Least privilege per tool.** The agent's role should reach only what its tools need.
- **Credentials from Identity's token vault,** never in prompts, code or environment variables.
- **Policy intercepts each tool call,** so a confused model cannot exceed its limits.
- **Prompt injection** in retrieved content can steer an agent. Validate before acting.
- **High-impact actions** wait for human approval. Module 24 covers the pattern.

> ON THE EXAM
>
> Treat the model as untrusted. Enforce limits in the tool layer, where a prompt cannot argue its way past them.

# Reading the scenario

| WHEN THE QUESTION SAYS | IT IS TESTING |
|---|---|
| Swap models without code changes | Converse API |
| Throttled, but data must stay in the EU | Geographic cross-Region profile |
| Guardrail in every account, automatically | Bedrock policy in Organizations |
| Bedrock cost per team, no code changes | Tags on each team's IAM role |
| Existing LangGraph agent, hours-long sessions | AgentCore Runtime |
| Act on a user's behalf in a SaaS app | AgentCore Identity token vault |

ON THE EXAM

Most AI questions are governance and capacity questions wearing an AI costume.

> Meridian Freight's support assistant currently calls one model through InvokeModel with a model-specific request body. The team wants to compare models from three providers and switch between them freely.
>
> Changing the model should not require changes to application code.

## What should the solutions architect recommend?

A. Write an adapter for each provider's request format behind InvokeModel

B. Purchase Provisioned Throughput for each candidate model

C. Use the Converse API and read the model ID from configuration

D. Host each model on its own SageMaker AI endpoint

◆ PAUSE AND DECIDE

# What should the solutions architect recommend?

A Adapters per provider

*Works, but it is code the Converse API already removes.*

B Provisioned Throughput

*Buys capacity. Does nothing for request format, and is costly for experiments.*

C Converse API, model ID in config

One message format across providers. Switching is a configuration change.

D SageMaker AI endpoints

*Adds hosting to manage and still varies per model.*

THE SIGNAL

Model portability is what the Converse API exists for. The request body is the thing that changes per model.

> Meridian Freight's customer assistant runs in eu-west-1 and is throttled during the European morning peak. Contracts require that customer prompts are processed only in EU Regions.
>
> The company wants to remove the throttling as cost-effectively as possible.

## What should the solutions architect do?

A Switch to the global cross-Region inference profile

B Switch to the EU geographic cross-Region inference profile

C Purchase Provisioned Throughput in eu-west-1 sized for the peak

D Send overflow requests to us-east-1 during the peak

◆ PAUSE AND DECIDE

## What should the solutions architect do?

A Global profile

*Cheapest and most capacity, but can process prompts outside the EU.*

B EU geographic profile

Spreads load across EU Regions at standard pricing. Residency kept.

C Provisioned Throughput

*Solves throttling, but you pay for peak capacity all day.*

D Overflow to us-east-1

*Breaks the EU processing requirement outright.*

THE SIGNAL

Residency removes the global profile. Cost removes Provisioned Throughput. Geographic profiles sit between them.

> Meridian Freight has 60 AWS accounts, and teams in many of them are building generative AI features on Bedrock. The responsible AI team has defined a guardrail with content filters and denied topics.
>
> Every model invocation in every account must pass through that guardrail, even if a team forgets to configure it, with the LEAST operational overhead.

**What should the solutions architect implement?**

A. An AWS Config rule that flags applications calling Bedrock without a guardrail

B. A central gateway account that all Bedrock requests must pass through

C. An SCP that denies InvokeModel unless a guardrail identifier is supplied

D. A Bedrock policy in AWS Organizations, referencing the guardrail version, attached to the root

◆ PAUSE AND DECIDE

## What should the solutions architect implement?

**A** Config rule

*Detects after the fact. Unprotected invocations still happen.*

**B** Central gateway

*Can enforce it, but every request now depends on a service you build and run.*

**C** SCP requiring a guardrail ID

*Forces teams to pass one, but each must still configure it, and it breaks callers who forget.*

**D** Bedrock policy at the root

Applies the guardrail to every invocation automatically, with no per-account setup.

THE SIGNAL

Even if a team forgets, with least overhead. Since April 2026 that is exactly what a Bedrock policy does.

> Twelve Meridian Freight product teams share one AI platform account. Each team's application calls Bedrock using its own IAM role.
>
> Finance wants monthly Bedrock cost by team in Cost Explorer. The platform team wants the LEAST effort, no change to the account structure, and no change to the teams' application code.

**What should the solutions architect implement?**

A. Tag each team's IAM role with a team tag and activate it as a cost allocation tag

B. A separate AWS account for each team

C. Parse invocation logs and multiply tokens by published prices

D. An application inference profile per team, tagged with a cost allocation tag

◆ PAUSE AND DECIDE

## What should the solutions architect implement?

**A** Tagged IAM roles

Since April 2026, Bedrock cost is allocated by the calling principal's tags. No code changes.

**B** Account per team

*Would work, but the scenario rules out changing the account structure.*

**C** Parse logs

*Builds a billing system by hand, and drifts from actual charges.*

**D** Tagged application profiles

*Also splits cost, but every team must change the model ID its code invokes.*

THE SIGNAL

Separate IAM roles per team, and no code changes. Since April 2026, principal tags carry Bedrock cost allocation.

> Meridian Freight has built a claims-handling agent with LangGraph. Some claims take up to four hours of back-and-forth, and the agent must call internal APIs that are only reachable inside a VPC.
>
> The team wants each user's session isolated and does not want to rewrite the agent.

## Where should the agent run?

A Rebuild it as a Bedrock Agent with action groups

B AgentCore Runtime, with AgentCore Gateway exposing the internal APIs as tools

C An AWS Lambda function invoked for each claim

D A self-managed ECS service with custom per-user session isolation

◆ PAUSE AND DECIDE

# Where should the agent run?

A **Bedrock Agent**

*Means rebuilding the agent in Bedrock Agents' configuration model. Ruled out.*

B **AgentCore Runtime and Gateway**

Runs the existing LangGraph code, isolates each session, reaches the VPC.

C **Lambda**

*A 15-minute limit cannot hold a four-hour session.*

D **Self-managed ECS**

*Possible, but you build session isolation yourself. More to run.*

THE SIGNAL

Existing framework rules out Bedrock Agents. Four hours rules out Lambda. Isolation built in rules out DIY.

A Meridian Freight scheduling agent, running on AgentCore Runtime, books delivery slots in each customer's third-party calendar service. Customers grant access through that service's OAuth consent screen.

Security requires that tokens never appear in prompts, code or configuration files.

## How should the agent obtain each customer's calendar credentials?

A Store each customer's refresh token in a Secrets Manager secret read by the agent code

B Include the access token in the system prompt for each session

C Give the agent an IAM role with permission to the calendar service

D Use AgentCore Identity, storing the OAuth tokens in its token vault for each user

◆ PAUSE AND DECIDE

## How should the agent obtain each customer's calendar credentials?

A **Secrets Manager per customer**

*Workable, but the agent code handles tokens and the OAuth flow itself.*

B **Token in the prompt**

*Breaks the requirement directly, and exposes the token to the model.*

C **IAM role**

*A third-party service does not accept AWS IAM credentials.*

D **AgentCore Identity token vault**

Runs the OAuth consent flow and holds each user's tokens outside the agent.

THE SIGNAL

Delegated, per-user access to a third-party service is an outbound OAuth problem. AgentCore Identity is built for it.

# What to carry out of this module

- **Converse API** for model portability. **Inference profiles** for routing and cost tags.
- **Geographic profile** when residency matters; **global** when it does not.
- **Bedrock policies** enforce a guardrail across an OU. Regional and version-pinned.
- **AgentCore** for existing frameworks, long sessions, MCP tools, delegated credentials.
- **Treat the model as untrusted.** Enforce limits in the tool layer.

> ON THE EXAM
>
> Every date in this module is 2025 or later. Older courses cannot have taught it.

MODULE 07 · DOMAIN 1 - ARCHITECTURE BUILT FOR THE CLOUD

# AI Architecture: RAG and Inference

Grounding answers in your own documents, and hosting models that Bedrock does not serve.

DOMAIN 1 of 5 EXAM WEIGHT 25% MODULE 7 of 52

admin@sthithapragna.com

RAG does not change the model. It changes **what the model can see** at the moment it answers.

# RAG or a customised model?

CHOOSE RAG WHEN

## The problem is knowledge

- Facts the model was never trained on
- Content that changes often
- Answers must cite their sources
- Access depends on who is asking

CONSIDER CUSTOMISATION WHEN

## The problem is behaviour

- A specific tone or output format
- A narrow task done consistently
- Labelled examples are available
- Model training is out of exam scope

THE TIEBREAKER

Changing facts and citations mean RAG. Customising a model is the wrong tool for knowledge that changes weekly.

# The RAG pipeline

01
### Connect
S3, SharePoint, Confluence and others, synced.

02
### Parse
Default parser, a foundation model, or Data Automation.

03
### Chunk
Split documents into retrievable passages.

04
### Embed
An embeddings model turns each chunk into a vector.

05
### Store
A vector index holds vectors and metadata.

06
### Retrieve
Find, filter, rerank, then generate with citations.

ON THE EXAM

Skill 1.2.4 says ingestion and retrieval strategies. Most questions are about chunking, storage or filtering.

# Managed or custom knowledge base?

MANAGED KNOWLEDGE BASE

## AWS runs the pipeline

- GA since June 2026
- Ingestion, vectors, storage and retrieval managed
- Six connectors, including SharePoint and S3
- Agentic retrieval for multi-step questions

CUSTOM KNOWLEDGE BASE

## You choose each piece

- Pick the vector store
- Choose parsing and chunking strategy
- GraphRAG with Neptune Analytics
- Reuse an existing vector database

THE TIEBREAKER

Least operational overhead, no vector-store requirement: Managed. A named vector store or chunking need: custom.

# Vector stores for a custom knowledge base

| STORE | CHOOSE IT WHEN |
|---|---|
| OpenSearch Serverless | Default; hybrid search; needed for SharePoint, Confluence, Salesforce sources |
| Aurora PostgreSQL | Vectors beside relational data you already run |
| Neptune Analytics | GraphRAG: answers depend on relationships |
| Amazon S3 Vectors | Very large, cost-sensitive, sub-second is fast enough |
| Third-party stores | An existing Pinecone, MongoDB Atlas or Redis estate |

ON THE EXAM

S3 Vectors, GA December 2025, claims up to 90 percent lower cost. The trade is latency, not durability.

# S3 Vectors or OpenSearch Serverless?

CHOOSE S3 VECTORS WHEN

## Scale and cost first

- Billions of vectors
- Queries are occasional
- Under a second is acceptable
- Lowest cost to store and query

CHOOSE OPENSEARCH WHEN

## Latency and features first

- High query rates
- Consistent low latency
- Hybrid keyword and vector search
- Rich filtering and aggregations

THE TIEBREAKER

Large and rarely queried means S3 Vectors. Busy, interactive and hybrid means OpenSearch.

# Chunking strategies

| STRATEGY | WHAT IT DOES | USE IT WHEN |
|---|---|---|
| Default | About 300 tokens, keeps sentences | No special structure |
| Fixed-size | Set token count and overlap | Uniform documents |
| Hierarchical | Small child chunks inside larger parents | Precise match, wide context |
| Semantic | Splits where meaning changes | Topics shift within documents |
| None | Each document is one chunk | Already split, such as FAQs |
| Custom Lambda | Your logic after chunking | Special formats or metadata |

ON THE EXAM

The chunking strategy cannot be changed after the data source is connected. Choose before the first sync.

# Levers for retrieval quality

- **Metadata filtering** narrows search by tenant, department, date or document type.
- **Hybrid search** adds keyword matching for part numbers, codes and names.
- **Reranking models** reorder results so the best passages reach the model.
- **Agentic retrieval** splits multi-part questions into sub-queries.
- **Structured data:** GenerateQuery turns questions into SQL for Amazon Redshift.

> ON THE EXAM
>
> Exact identifiers that semantic search misses, such as order numbers, are a hybrid search signal.

# Retrieve or RetrieveAndGenerate?

RETRIEVE

## You orchestrate

- Returns the relevant chunks only
- You build the prompt
- Any model, any framework
- Fits agents that decide what to do

RETRIEVEANDGENERATE

## Bedrock orchestrates

- Retrieval and generation in one call
- Citations to source chunks
- Least code
- Guardrails can be applied

THE TIEBREAKER

Least code with citations: RetrieveAndGenerate. Custom prompting or an agent framework: Retrieve.

# Securing a RAG system

- **Retrieval returns whatever was ingested.** It does not know who is asking.
- **Apply the filter server-side** from the caller's verified identity, never from user input.
- **Separate knowledge bases** when isolation must be physical, as in a silo tier.
- **Customer managed KMS keys** for the vector store and multimodal storage.
- **Guardrails** on generation, including grounding checks against retrieved text.

> ON THE EXAM
>
> A prompt telling the model to ignore other tenants' documents is not access control.

# SageMaker AI inference options

| OPTION | LIMITS | CHOOSE IT WHEN |
|---|---|---|
| Real-time endpoint | 25 MB, 60 s; 8 min streaming | Steady, low-latency traffic |
| Serverless inference | 4 MB, 60 s; pay per use | Intermittent, unpredictable traffic |
| Asynchronous inference | 1 GB, up to 1 hour; scales to zero | Large inputs, long processing, queued |
| Batch transform | Datasets of GBs; runs for days | Offline scoring, no endpoint needed |

ON THE EXAM

Payload size and processing time decide this table. A 300 MB input or a 20-minute job means asynchronous.

# Bedrock or a SageMaker AI endpoint?

CHOOSE BEDROCK WHEN

## A foundation model by API

- Model is offered on Bedrock
- No infrastructure to manage
- Pay per token or by tier
- Guardrails, knowledge bases, agents built in

CHOOSE SAGEMAKER AI WHEN

## Your model, your hosting

- A model you trained or an open-weight model
- Custom container or framework
- Choose instance and GPU types
- Classic ML: forecasting, classification

THE TIEBREAKER

A model the company built itself, or one Bedrock does not offer, needs a SageMaker AI endpoint.

# Reading the scenario

| WHEN THE QUESTION SAYS | IT IS TESTING |
|---|---|
| Content changes weekly; cite sources | RAG, not a customised model |
| RAG with least operational overhead | Managed Knowledge Base |
| Billions of vectors, rarely queried, cheapest | Amazon S3 Vectors |
| Accurate match, but answers lack context | Hierarchical chunking |
| User saw another tenant's document | Server-side metadata filter |
| Own model, huge inputs, long jobs | SageMaker asynchronous inference |

ON THE EXAM

RAG questions are rarely about the model. They are about data: how it is cut, stored, filtered and secured.

> Meridian Freight wants an assistant that answers customer questions about its shipping policies. Policies change most weeks, and legal requires every answer to cite the policy section it came from.
>
> The company has no machine learning team.

## What should the solutions architect recommend?

A. Fine-tune a foundation model on the policy documents every week

B. A Bedrock knowledge base over the policies, queried with RetrieveAndGenerate

C. Include every policy document in the system prompt of each request

D. Run continued pre-training on the policies each quarter

◆ PAUSE AND DECIDE

## What should the solutions architect recommend?

A Weekly fine-tuning

*A training run per policy change, needs ML skills, and cannot cite sources.*

B Knowledge base with RetrieveAndGenerate

Policies re-sync as they change, and answers cite the chunks used.

C Everything in the prompt

*Pays for every policy on every request, and hits context limits as policies grow.*

D Quarterly pre-training

*Knowledge would be months out of date, and still no citations.*

THE SIGNAL

Weekly change plus mandatory citations. Both point at retrieval, and neither can be met by training.

> Meridian Freight's operations team wants a RAG assistant over procedures held in SharePoint and in an S3 bucket. The team has no experience running vector databases.
>
> It has no requirement for a particular vector store or chunking approach, and wants the LEAST operational overhead.

**Which solution should the solutions architect recommend?**

A. A custom knowledge base with a quick-created OpenSearch Serverless collection

B. A self-managed vector database on EC2, populated by a Lambda pipeline

C. An Amazon Bedrock Managed Knowledge Base with SharePoint and S3 connectors

D. An Amazon Kendra index connected to SharePoint

◆ PAUSE AND DECIDE

## Which solution should the solutions architect recommend?

A Custom KB, OpenSearch Serverless

*Works, and was the answer before June 2026. The team still owns a vector store.*

B Self-managed vector database

*The most to build and run, for a team with no experience.*

C Managed Knowledge Base

AWS runs ingestion, vectors, storage and retrieval; both sources have native connectors.

D Amazon Kendra

*Not on this exam's in-scope service list.*

THE SIGNAL

No vector store requirement and least overhead. Since June 2026 that describes a Managed Knowledge Base.

> Meridian Freight is building semantic search over 15 years of archived shipping documents: about 800 million embeddings. Auditors run a few hundred searches a day, and a response within a second is acceptable.
>
> The company uses a custom knowledge base and wants the lowest storage and query cost.

**Which vector store should the solutions architect choose?**

A Amazon OpenSearch Serverless

B Amazon Aurora PostgreSQL with pgvector

C Amazon Neptune Analytics

D Amazon S3 Vectors

◆ PAUSE AND DECIDE

## Which vector store should the solutions architect choose?

A **OpenSearch Serverless**

*Fast and capable, but costly to keep running for a few hundred queries a day.*

B **Aurora with pgvector**

*A provisioned database for an archive that is mostly idle.*

C **Neptune Analytics**

*For relationship-heavy GraphRAG. Nothing here needs a graph.*

D **Amazon S3 Vectors**

Built for very large, rarely queried indexes at the lowest cost.

THE SIGNAL

Huge, rarely queried, sub-second acceptable, cheapest. Every clause describes S3 Vectors.

> Meridian Freight's knowledge base over long equipment manuals uses small fixed-size chunks. Retrieval finds the right passage, but answers often omit warnings and steps from the surrounding section.
>
> The team wants precise matching with more context in each answer.

## What should the solutions architect change?

A Re-ingest with hierarchical chunking, searching child chunks and returning their parents

B Switch to no chunking, so each manual is one chunk

C Increase the number of results returned from 5 to 50

D Add a guardrail with a contextual grounding check

◆ PAUSE AND DECIDE

## What should the solutions architect change?

**A** Hierarchical chunking

Small children keep the match precise; the parent supplies the section.

**B** No chunking

*A whole manual per chunk destroys match precision and floods the context.*

**C** Fifty results

*Adds many unrelated passages rather than the neighbouring ones.*

**D** Grounding check

*Flags unsupported answers. It cannot add context that was never retrieved.*

THE SIGNAL

Retrieval is accurate but context is missing. That exact pair of symptoms is what hierarchical chunking solves.

> Meridian Freight's SaaS platform uses one knowledge base for all customers' uploaded documents. Each chunk was ingested with a tenant_id metadata attribute, but retrieval does not use it.
>
> A user from one customer received a passage from another customer's contract.

## What should the solutions architect do?

A Add an instruction to the prompt to use only the user's own company's documents

B Apply a tenant_id metadata filter, taken from the verified token, on every retrieval request

C Add a guardrail denied topic for other customers' names

D Add a reranking model to improve relevance

◆ PAUSE AND DECIDE

## What should the solutions architect do?

A. Prompt instruction

*The passage has already been retrieved. A prompt is not access control.*

B. Server-side metadata filter

Other tenants' chunks are never retrieved, so they cannot leak.

C. Guardrail denied topic

*Matches topics, not ownership; leaks anything not on the list.*

D. Reranking

*Improves ordering. Another tenant's passage can still be the best match.*

THE SIGNAL

The metadata already exists. The fix is to filter on it, from identity the user cannot alter.

> Meridian Freight's data science team has trained a damage-assessment model. Each input is a bundle of photographs of about 300 MB, and each assessment takes around 20 minutes.
>
> Claims arrive unpredictably, sometimes none for days. The company wants to pay as little as possible while idle.

## How should the model be hosted?

A. A SageMaker AI real-time endpoint

B. SageMaker AI serverless inference

C. SageMaker AI asynchronous inference, scaled to zero when idle

D. An on-demand Amazon Bedrock model

◆ PAUSE AND DECIDE

# How should the model be hosted?

A **Real-time endpoint**

*25 MB and 60-second limits, and instances run while idle.*

B **Serverless inference**

*4 MB and 60 seconds. Both far below this workload.*

C **Asynchronous, scale to zero**

1 GB inputs, up to an hour each, and no instances while idle.

D **Bedrock on-demand**

*Bedrock serves its catalogue of models. This is the company's own model.*

THE SIGNAL

300 MB and 20 minutes exceed every option except asynchronous. Idle days make scale to zero the clincher.

# What to carry out of this module

- **Knowledge problem, RAG.** Behaviour problem, customisation, which is out of exam scope.
- **Managed Knowledge Base** since June 2026 for least overhead; custom for specific stores.
- **S3 Vectors** for huge, cheap, rarely queried; **OpenSearch** for busy and hybrid.
- **Hierarchical chunking** when matches are right but context is thin.
- **Filter retrieval by verified identity.** Prompts are not access control.

> ON THE EXAM
>
> For SageMaker AI, check payload and duration against each option's limits before anything else.

MODULE 08 · DOMAIN 1 - ARCHITECTURE BUILT FOR THE CLOUD

# Hybrid Connectivity and Data Synchronisation

Links that survive failure, data that stays in step, and legacy systems that keep talking.

DOMAIN 1 of 5 EXAM WEIGHT 25% MODULE 8 of 52

admin@sthithapragna.com

Hybrid connectivity is designed for the day a link fails, not the day it works.

# Direct Connect or Site-to-Site VPN?

DIRECT CONNECT

## Private, predictable

- 1, 10, 100 or 400 Gbps dedicated ports
- Consistent latency, no internet path
- Weeks to provision
- Not encrypted by default

SITE-TO-SITE VPN

## Fast, encrypted

- 1.25 Gbps per tunnel; 5 Gbps with large tunnels
- Latency follows the internet
- Up in minutes
- IPsec encrypted by default

THE TIEBREAKER

Needed this week means VPN. Sustained throughput and predictability mean Direct Connect. Most answers use both.

# The three virtual interface types

| VIF | CONNECTS TO | USE IT FOR |
|---|---|---|
| Private | A virtual private gateway or DX gateway | Reaching VPCs on private addresses |
| Public | AWS public endpoints | S3, DynamoDB and public services over the circuit |
| Transit | A Direct Connect gateway only | Reaching a Transit Gateway and everything behind it |

ON THE EXAM

Direct Connect and Transit Gateway in the same question means a transit VIF through a DX gateway.

# Direct Connect resiliency models

| MODEL | SHAPE | FOR |
|---|---|---|
| Maximum | Separate connections on separate devices at two or more locations | Critical production |
| High | One connection at each of two locations | Most production |
| Development and Test | Two connections, separate devices, one location | Non-critical work |
| Classic | Created without the toolkit; no resiliency | Existing single links |

ON THE EXAM

Surviving the loss of a whole location needs at least High. Surviving that plus a device failure needs Maximum.

# VPN numbers that decide answers

- **Two tunnels per connection,** in different AWS endpoints, for redundancy.
- **A virtual private gateway caps near 1.25 Gbps** in aggregate, however many connections.
- **Large bandwidth tunnels: 5 Gbps,** since November 2025. Transit Gateway or Cloud WAN only.
- **ECMP** spreads traffic across tunnels for more bandwidth. Needs BGP and a Transit Gateway.
- **Direct Connect is preferred over VPN** for the same prefix, so failover is automatic.

> ON THE EXAM
>
> Any VPN throughput above about 1.25 Gbps needs a Transit Gateway. The virtual private gateway is the bottleneck.

# Encrypting traffic over Direct Connect

MACSEC

## Encrypt the circuit

- Supported dedicated ports only
- Line rate, no throughput penalty
- Your router to the AWS router
- Not on hosted connections

PRIVATE IP VPN

## Encrypt the journey

- IPsec over a transit VIF
- Limited by tunnel bandwidth
- End to end, whatever is in between
- Needs a Transit Gateway

THE TIEBREAKER

Line-rate encryption on your own dedicated port means MACsec. End-to-end or hosted means private IP VPN.

# A resilient hybrid path

01
### On premises
Two routers, two Direct Connect locations.

02
### Transit VIFs
One per connection, into a DX gateway.

03
### Transit Gateway
Hub for VPCs in many accounts.

04
### VPN backup
Large tunnels to the same Transit Gateway.

05
### BGP decides
DX preferred; VPN takes over on failure.

ON THE EXAM

Two DX locations for capacity, a VPN for the worst case, one Transit Gateway so routing stays simple.

# Keeping data in step across the boundary is a different problem from moving it once.

# Hybrid data services

| SERVICE | WHAT IT DOES |
|---|---|
| AWS DataSync | Scheduled, incremental copy with validation; agentless from other clouds |
| S3 File Gateway | NFS or SMB share on premises, files stored as S3 objects, local cache |
| Volume Gateway | iSCSI block volumes, backed up as EBS snapshots |
| Tape Gateway | Virtual tape library for existing backup software |
| AWS Transfer Family | Managed SFTP, FTPS, FTP and AS2 endpoints on S3 or EFS |
| FSx File Gateway | Closed to new customers since October 2024 |

ON THE EXAM

DataSync moves data on a schedule. Gateways give on-premises applications a local protocol that lands in AWS.

# DataSync or S3 File Gateway?

CHOOSE DATASYNC WHEN

## Copy on a schedule

- Existing file system stays as it is
- Data needed in AWS hourly or daily
- Integrity validation and throttling
- Also AWS to AWS and cloud to AWS

CHOOSE S3 FILE GATEWAY WHEN

## Applications write to S3

- Applications keep an NFS or SMB share
- Each file becomes an S3 object
- Local cache for fast recent reads
- Continuous, not batch

THE TIEBREAKER

Applications must keep writing to a share, and files must land in S3 continuously: File Gateway.

# Integrating legacy systems

- **Amazon MQ** runs ActiveMQ or RabbitMQ: JMS, AMQP, STOMP and MQTT apps move unchanged.
- **API Gateway REST mapping templates** reshape requests and responses, such as XML to JSON.
- **Lambda as an adapter** between a legacy interface and a modern one.
- **EventBridge Pipes** filter, enrich and transform between a source and a target.
- **Transfer Family AS2** for business-to-business file exchange.

> ON THE EXAM
>
> Skill 1.3.3 says data transformations. The legacy side does not change; the integration layer translates.

# Amazon MQ or SQS and SNS?

CHOOSE AMAZON MQ WHEN

## Existing broker protocols

- JMS, AMQP, STOMP, MQTT or OpenWire
- Messaging code cannot change
- Lift and shift of ActiveMQ or RabbitMQ
- Broker instances you size

CHOOSE SQS AND SNS WHEN

## Cloud-native messaging

- New or rewritten applications
- AWS SDK and HTTPS APIs
- Virtually unlimited scale
- Nothing to size or patch

THE TIEBREAKER

Cannot change the messaging code means Amazon MQ. New code or a rewrite means SQS and SNS.

# Reading the scenario

| WHEN THE QUESTION SAYS | IT IS TESTING |
|---|---|
| Connectivity needed this week | Site-to-Site VPN now, Direct Connect later |
| Survive losing a location and a device | Maximum resiliency |
| VPN backup must carry several Gbps | Transit Gateway with large tunnels |
| Line-rate encryption over 100 Gbps DX | MACsec |
| Apps keep writing to a share; files in S3 | S3 File Gateway |
| JMS application, code cannot change | Amazon MQ |

ON THE EXAM

Every connectivity question has a failure in it. Find it before reading the options.

> Meridian Freight is opening a new distribution centre that must connect to its VPCs, through an existing Transit Gateway, within a week. In steady state it will send about 3 Gbps of predictable traffic.
>
> Ordering a Direct Connect connection at the nearest location takes about six weeks.

**What should the solutions architect recommend?**

A. Order Direct Connect and connect the site when it is ready

B. A Site-to-Site VPN to the Transit Gateway now, then Direct Connect, keeping the VPN as backup

C. A Site-to-Site VPN to a virtual private gateway in each VPC

D. AWS Client VPN for the distribution centre's users

◆ PAUSE AND DECIDE

## What should the solutions architect recommend?

A. Wait for Direct Connect

*Misses the one-week deadline by five weeks.*

B. VPN now, DX later, VPN as backup

Meets the deadline, then the steady state, and keeps a failover path.

C. VPN per VPC

*Ignores the existing Transit Gateway, and each VGW caps near 1.25 Gbps.*

D. Client VPN

*Connects individual users, not a site's network.*

THE SIGNAL

A deadline shorter than the DX lead time means VPN first. Predictable sustained traffic means DX after.

> Meridian Freight's order platform depends on Direct Connect and is classed as business-critical. The company must keep full Direct Connect bandwidth even if an entire Direct Connect location fails, and a device fails at the same time elsewhere.
>
> A VPN backup is not acceptable for this traffic.

## Which Direct Connect design meets these requirements?

A Two connections on separate devices at one location

B One connection at each of two locations

C Separate connections on separate devices at two or more locations

D One Direct Connect connection with a Site-to-Site VPN backup

◆ PAUSE AND DECIDE

# Which Direct Connect design meets these requirements?

A Two devices, one location

*Development and Test model. Losing the location loses everything.*

B One per location

*High model. Survives a location, but not a device failure at the survivor.*

C Separate devices, two-plus locations

Maximum model. Survives the location and a device, at full bandwidth.

D DX with VPN backup

*The scenario rules out VPN as the backup.*

THE SIGNAL

Location failure plus device failure, with no drop in bandwidth, is the definition of Maximum resiliency.

> Meridian Freight's Direct Connect carries about 4 Gbps. Its backup is a Site-to-Site VPN on a virtual private gateway. During a recent circuit failure the VPN carried only a fraction of the traffic.
>
> The backup must carry the full 4 Gbps in a future failure.

**What should the solutions architect do?**

A. Move the VPN to a Transit Gateway and use large bandwidth tunnels

B. Add three more VPN connections to the virtual private gateway

C. Enable acceleration on the existing VPN connection

D. Replace the customer gateway with a faster appliance

◆ PAUSE AND DECIDE

## What should the solutions architect do?

**A** Transit Gateway, large tunnels

Removes the VGW ceiling; one 5 Gbps tunnel covers 4 Gbps.

**B** More VPN connections on the VGW

*The VGW's aggregate cap near 1.25 Gbps applies however many you add.*

**C** Accelerated VPN

*Improves the internet path, not the gateway's ceiling. Also not supported with large tunnels.*

**D** Faster customer gateway

*The bottleneck is on the AWS side.*

THE SIGNAL

The virtual private gateway is the ceiling. More tunnels into it change nothing.

> Meridian Freight replicates its trading data over a dedicated 100 Gbps Direct Connect connection. A new regulation requires all traffic over the circuit to be encrypted.
>
> The link runs near capacity at month end, and the encryption must not reduce throughput.

**Which solution meets these requirements?**

A. A private IP VPN over a transit VIF

B. TLS in every application that uses the link

C. A Site-to-Site VPN over a public VIF

D. MACsec on the dedicated connection

◆ PAUSE AND DECIDE

## Which solution meets these requirements?

A Private IP VPN

*Encrypts, but tunnel bandwidth falls far short of 100 Gbps.*

B TLS everywhere

*Depends on every application, so it cannot guarantee all traffic is covered.*

C VPN over a public VIF

*Same tunnel bandwidth limit, with a more complex path.*

D MACsec

Encrypts the circuit at line rate on a supported dedicated port.

THE SIGNAL

All traffic, at 100 Gbps, with no throughput loss, on a dedicated port. Only MACsec fits all four.

> Meridian Freight's depot scanners save delivery images to an on-premises NFS share. The images must appear in Amazon S3 for analytics within minutes, and depot applications frequently reopen recent images.
>
> The depot applications cannot be changed.

**Which solution should the solutions architect recommend?**

A. An AWS DataSync task that runs every hour

B. AWS Transfer Family with an SFTP endpoint

C. Volume Gateway in cached mode

D. S3 File Gateway presenting an NFS share to the applications

◆ PAUSE AND DECIDE

## Which solution should the solutions architect recommend?

A Hourly DataSync

*Up to an hour late, which misses within minutes.*

B Transfer Family SFTP

*The applications would have to change to upload by SFTP.*

C Volume Gateway

*Presents block storage over iSCSI, not an NFS share, and stores snapshots, not objects.*

D S3 File Gateway

Same NFS protocol, files land as S3 objects, cache serves recent reads.

THE SIGNAL

Unchanged NFS applications, files in S3 within minutes, fast local rereads. That is File Gateway's description.

> Meridian Freight is moving a legacy order-processing system to AWS. Its components exchange messages through an Apache ActiveMQ broker using JMS, with queues and topics.
>
> The messaging code cannot be modified, and the company wants the LEAST operational overhead.

**What should the solutions architect use for messaging?**

A. Amazon SQS through the SQS Java Messaging Library

B. A self-managed ActiveMQ cluster on EC2

C. Amazon MQ for ActiveMQ

D. Amazon EventBridge with a custom event bus

◆ PAUSE AND DECIDE

## What should the solutions architect use for messaging?

A SQS with the JMS library

*Requires changing client configuration and code, and offers queues only, not topics.*

B Self-managed ActiveMQ

*Compatible, but the company patches, scales and fails over the broker itself.*

C Amazon MQ for ActiveMQ

The same broker, managed. Clients connect over JMS exactly as before.

D EventBridge

*Uses AWS APIs, not JMS. The code would have to be rewritten.*

THE SIGNAL

Code cannot change rules out every AWS-API service. Least overhead rules out running the broker yourself.

# What to carry out of this module

- **VPN for speed, Direct Connect for steady state,** VPN kept as backup.
- **Count the failures:** location means High; location plus device means Maximum.
- **VPN above 1.25 Gbps needs a Transit Gateway.** Large tunnels reach 5 Gbps.
- **MACsec** for line-rate circuit encryption; **private IP VPN** for end to end.
- **File Gateway** for unchanged file apps; **Amazon MQ** for unchanged JMS or AMQP apps.

> ON THE EXAM
>
> Stale facts: VPN tunnels are no longer capped at 1.25 Gbps, and FSx File Gateway is closed to new customers.

MODULE 09 · DOMAIN 1 - ARCHITECTURE BUILT FOR THE CLOUD

# Hybrid DNS and Hybrid Compute

Names that resolve in both directions, and compute that runs where AWS Regions cannot.

DOMAIN 1 of 5 EXAM WEIGHT 25% MODULE 9 of 52

admin@sthithapragna.com

Hybrid DNS has **two directions**. Name the one in the question before choosing an endpoint.

# Inbound or outbound endpoint?

INBOUND ENDPOINT

## On premises asks AWS

- IP addresses in your VPC to query
- Resolves private hosted zone names
- Data centre DNS forwards to it
- Arrives over Direct Connect or VPN

OUTBOUND ENDPOINT

## AWS asks on premises

- Lets the VPC Resolver forward out
- Used with a forwarding rule
- The rule names the domain
- Leaves over Direct Connect or VPN

THE TIEBREAKER

Who needs the answer decides the endpoint. On premises asking means inbound; AWS asking means outbound.

# Rules, zones and sharing at scale

- **Forwarding rules** are shareable with RAM, but must be associated with each VPC.
- **Route 53 Profiles** bundle zones, rules and DNS Firewall, applied across VPCs and accounts.
- **Private hosted zones** answer only for associated VPCs. Associations can cross accounts.
- **Split-horizon:** public and private zones for the same name answer differently by source.
- **DNS hostnames and resolution** must be enabled on the VPC, or private zones are ignored.

> ON THE EXAM
>
> Sharing is not associating. Profiles exist because associating rules with hundreds of VPCs does not scale.

# A rename, and a new resolver

- **Route 53 Resolver is now Route 53 VPC Resolver.** Same service, new name.
- It was renamed when **Route 53 Global Resolver** was introduced.
- **Global Resolver,** GA March 2026: internet-reachable, anycast, for branch and remote clients.
- It resolves **private hosted zone names** and filters malicious domains for those clients.
- **Inbound and outbound endpoints** still belong to the VPC Resolver.

> ON THE EXAM
>
> Questions may say VPC Resolver or Resolver. They are the same service. Global Resolver is a different one.

# Inbound endpoint or Global Resolver?

VPC RESOLVER INBOUND ENDPOINT

## A data centre on the network

- Network interfaces in your VPC
- Reached over Direct Connect or VPN
- Data centre DNS forwards to it
- Few large sites

ROUTE 53 GLOBAL RESOLVER

## Many sites, one service

- Anycast, nearest Region answers
- Internet-reachable for authorised clients
- Central filtering of malicious domains
- Replaces per-site DNS appliances

THE TIEBREAKER

Hundreds of branches, central DNS filtering, no appliance per site: Global Resolver.

Hybrid compute is for workloads that must stay **near something**: equipment, users, data or a regulator.

# Hybrid compute options

| OPTION | WHAT IT IS | CHOOSE IT WHEN |
|---|---|---|
| Outposts racks | AWS hardware in your facility | Must run on premises, AWS APIs |
| Outposts servers | 1U or 2U AWS servers | Branch, retail and edge sites |
| Local Zones | AWS infrastructure in a metro area | Single-digit ms to city users |
| EKS Hybrid Nodes | Your servers join an EKS cluster | Reliable link; AWS runs control plane |
| EKS Anywhere | Whole Kubernetes cluster on your hardware | Disconnected or intermittent sites |
| ECS Anywhere | Your servers run ECS tasks | ECS on existing hardware |

ON THE EXAM

EKS Hybrid Nodes is the newest row. It needs a reliable connection; EKS Anywhere does not.

# EKS Hybrid Nodes or EKS Anywhere?

EKS HYBRID NODES

## Control plane in AWS

- Your servers are nodes of an EKS cluster
- AWS runs and scales the control plane
- Needs a reliable link to AWS
- Billed per vCPU hour while attached

EKS ANYWHERE

## Everything on site

- Control plane and nodes run locally
- Keeps working when disconnected
- You operate the whole cluster
- Suits air-gapped or intermittent sites

THE TIEBREAKER

Disconnected, disrupted or intermittent links mean EKS Anywhere. AWS says so in the Hybrid Nodes docs.

# Outposts or Local Zones?

CHOOSE OUTPOSTS WHEN

## It must be on your premises

- Beside equipment or local systems
- Data must stay in your facility
- You provide space, power and cooling
- Service link of at least 500 Mbps

CHOOSE LOCAL ZONES WHEN

## It must be near users

- Single-digit ms to a metro area
- AWS runs the facility
- Nothing to install or host
- Pay as in a Region

THE TIEBREAKER

On premises is a requirement for Outposts. Low latency to a city alone is a Local Zone.

# One operating model across both estates

- **Systems Manager hybrid activations** manage on-premises servers like EC2.
- **ECS Anywhere** uses the SSM agent to register external instances.
- **IAM Roles Anywhere** gives on-premises workloads temporary AWS credentials.
- **CloudWatch and Managed Prometheus** give one view of both estates.
- **Long-lived access keys on premises** are the anti-pattern these replace.

> ON THE EXAM
>
> Hybrid compute is easy to start and hard to run. The answer that unifies operations usually wins.

# Reading the scenario

| WHEN THE QUESTION SAYS | IT IS TESTING |
|---|---|
| On premises must resolve AWS private names | Inbound endpoint |
| AWS must resolve on-premises names | Outbound endpoint and forwarding rule |
| Same DNS settings across many VPCs | Route 53 Profiles |
| Hundreds of branches, central DNS filtering | Route 53 Global Resolver |
| Site loses its link for days | EKS Anywhere, not Hybrid Nodes |
| Low latency to one city, nothing on premises | Local Zones |

ON THE EXAM

DNS questions turn on direction and scale. Compute questions turn on connectivity and location.

> Meridian Freight's data centre applications must call internal APIs whose names exist only in a Route 53 private hosted zone. The data centre is connected to AWS by Direct Connect and runs its own DNS servers.
>
> AWS workloads do not need to resolve any on-premises names.

## What should the solutions architect configure?

A. A Resolver outbound endpoint with a forwarding rule for the on-premises domain

B. A Resolver inbound endpoint, with the data centre DNS forwarding the zone's domain to it

C. Convert the private hosted zone to a public hosted zone

D. A DNS server on EC2 that copies the zone's records

◆ PAUSE AND DECIDE

## What should the solutions architect configure?

A Outbound endpoint

*Serves the other direction: AWS asking on premises. Not needed here.*

B Inbound endpoint with conditional forwarding

Gives on-premises DNS a target inside the VPC that answers from the zone.

C Make the zone public

*Publishes internal names to the internet.*

D DNS on EC2

*Rebuilds the inbound endpoint by hand and drifts from the zone.*

THE SIGNAL

The data centre is asking. Asking into AWS means inbound, with a conditional forwarder on premises.

> Meridian Freight has 80 VPCs across 30 accounts. Each needs the same three forwarding rules, two private hosted zones and a DNS Firewall rule group. New VPCs are created every week.
>
> Today a script shares and associates each item with each VPC, and frequently misses some.

**What should the solutions architect implement?**

A. Share the rules with AWS RAM, and keep the script for associations

B. A central DNS server on EC2 that every VPC uses through DHCP options

C. A Route 53 Profile containing the zones, rules and firewall group, shared and associated with the VPCs

D. Route 53 Global Resolver for all VPCs

◆ PAUSE AND DECIDE

## What should the solutions architect implement?

A RAM plus the script

*Sharing was never the problem. The per-VPC associations are, and they stay scripted.*

B DNS server on EC2

*A self-managed single point of failure, and it bypasses DNS Firewall.*

C Route 53 Profile

One bundle of zones, rules and firewall, applied as a unit to each VPC.

D Global Resolver

*For branch and remote clients outside AWS, not for VPCs.*

THE SIGNAL

The same DNS configuration across many VPCs and accounts is exactly what Route 53 Profiles bundle.

> Meridian Freight's 300 depots each run a small DNS appliance so that handheld scanners can resolve internal API names held in a Route 53 private hosted zone. Security wants malicious domains blocked at every depot.
>
> The company wants to retire the depot appliances and manage DNS centrally.

**Which solution should the solutions architect recommend?**

A. Route 53 Global Resolver with access to the private hosted zone and domain filtering

B. A VPC Resolver inbound endpoint, with a VPN from every depot

C. Make the private hosted zone public and keep filtering on the appliances

D. A VPC Resolver outbound endpoint with forwarding rules to each depot

◆ PAUSE AND DECIDE

## Which solution should the solutions architect recommend?

**A** Global Resolver

One anycast service for every depot, resolving private names and filtering threats.

**B** Inbound endpoint, 300 VPNs

*Works, but swaps 300 appliances for 300 VPN tunnels, and adds no filtering.*

**C** Public zone

*Exposes internal names, and keeps the appliances it was meant to retire.*

**D** Outbound endpoint

*Wrong direction: lets AWS query the depots, not the reverse.*

THE SIGNAL

Hundreds of sites, central filtering, no appliance per site. Since March 2026 that is Global Resolver.

> Meridian Freight runs container workloads at remote port terminals. The terminals' satellite links drop for hours, sometimes days, and workloads must keep running and be managed locally during an outage.
>
> The company wants to standardise on Kubernetes tooling used with Amazon EKS.

**Which option should the solutions architect choose for the terminals?**

A Amazon EKS Hybrid Nodes

B Amazon ECS Anywhere

C An Amazon EKS cluster in the nearest AWS Local Zone

D Amazon EKS Anywhere on hardware at each terminal

◆ PAUSE AND DECIDE

## Which option should the solutions architect choose for the terminals?

A **EKS Hybrid Nodes**

*Control plane is in AWS, so management stops when the link drops. AWS says it does not fit these sites.*

B **ECS Anywhere**

*Not Kubernetes, and also relies on AWS for its control plane.*

C **Local Zone**

*Still reached over the satellite link, so an outage cuts the terminal off.*

D **EKS Anywhere**

Whole cluster on site; keeps running and is managed locally when disconnected.

THE SIGNAL

Links that drop for days rule out every option whose control plane lives in AWS.

> Meridian Freight runs a self-managed Kubernetes cluster in its data centre, on GPU servers bought last year that must stay in service. The data centre has redundant Direct Connect links to AWS.
>
> The platform team wants to stop operating the Kubernetes control plane and use EKS tooling, with the LEAST operational overhead.

**What should the solutions architect recommend?**

A. Replace the cluster with Amazon EKS Anywhere on the same servers

B. Move every workload to Amazon EKS in the Region and retire the GPU servers

C. Amazon EKS Hybrid Nodes, joining the GPU servers to an EKS cluster

D. AWS Outposts racks to replace the GPU servers

◆ PAUSE AND DECIDE

## What should the solutions architect recommend?

A EKS Anywhere

*The control plane still runs on site, so the team keeps operating it.*

B Move everything to the Region

*Retires servers the scenario says must stay in service.*

C EKS Hybrid Nodes

AWS runs the control plane; the existing GPU servers become nodes.

D Outposts

*Replaces hardware that must be kept, at significant new cost.*

THE SIGNAL

A reliable link, hardware that must stay, and no control plane to run. That is the Hybrid Nodes case.

> Meridian Freight is launching a live dispatch app for drivers in one large city, several hundred kilometres from the nearest AWS Region. The app needs single-digit millisecond latency to drivers' devices.
>
> Meridian has no data centre in that city, and no data needs to stay on premises.

## Where should the latency-sensitive tier run?

A An AWS Local Zone in that city

B An AWS Outposts rack in a rented colocation facility in the city

C The nearest Region, behind Amazon CloudFront

D The nearest Region, behind AWS Global Accelerator

◆ PAUSE AND DECIDE

# Where should the latency-sensitive tier run?

**A** Local Zone

AWS compute in the city itself, with nothing to host or maintain.

**B** Outposts in a colocation facility

*Achieves the latency, but adds hardware, space and a service link for no requirement.*

**C** Region with CloudFront

*Caches content, but dispatch is dynamic; each request still travels to the Region.*

**D** Region with Global Accelerator

*Improves the path, but cannot remove hundreds of kilometres of distance.*

THE SIGNAL

Low latency to a city with nothing that must be on premises is a Local Zone. Outposts needs a reason to be on site.

# What to carry out of this module

- **Inbound: on premises asks AWS. Outbound: AWS asks on premises.**
- **Route 53 Profiles** for DNS at scale. **Global Resolver** for many remote sites.
- **Route 53 Resolver is now called VPC Resolver.** Same service.
- **Reliable link:** EKS Hybrid Nodes. **Intermittent link:** EKS Anywhere.
- **Must be on premises:** Outposts. **Must be near a city:** Local Zones.

> ON THE EXAM
>
> Two changes since 2025: the VPC Resolver rename, and Global Resolver going GA in March 2026.

MODULE 10 · DOMAIN 1 - ARCHITECTURE BUILT FOR THE CLOUD

# Multi-VPC, IPAM and IPv6 Adoption

Connecting many VPCs, planning the address space they share, and moving to IPv6 without breaking anything.

DOMAIN 1 of 5 EXAM WEIGHT 25% MODULE 10 of 52

admin@sthithapragna.com

Address space is **shared**. Plan it centrally once, or pay for overlapping CIDRs for years.

# Ways to connect VPCs

| OPTION | SHAPE | LIMIT THAT DECIDES |
|---|---|---|
| VPC peering | Wire between two VPCs | Not transitive; no per-GB processing charge |
| Transit Gateway | Regional hub with route tables | Per-attachment and per-GB charges |
| AWS Cloud WAN | Global network from one policy | Built for many Regions and segments |
| PrivateLink | Doorway to one service | Indifferent to overlapping CIDRs |
| VPC Lattice | Service network, module 4 | Indifferent to overlapping CIDRs |

ON THE EXAM

Overlapping CIDRs remove every routing option. Only PrivateLink and Lattice are indifferent to addresses.

# VPC peering: limits that decide questions

- **Not transitive.** A peers with B and B with C; A still cannot reach C.
- **No edge-to-edge routing:** no use of a peer's internet gateway, NAT, VPN or endpoints.
- **50 active peerings per VPC** by default, 125 at most. Cross-Region and cross-account work.
- **No per-GB processing charge.** Only normal data transfer.
- **Security group references** work across peering in the same Region.

> ON THE EXAM
>
> Peering is cheaper per byte. Transit Gateway is cheaper per relationship.

# Transit Gateway, including what changed

- **Route tables are the segmentation tool.** One gateway can hold many.
- **5,000 attachments,** 50 Gbps burst per VPC attachment, MTU 8500, 1500 over VPN.
- **Security group referencing** across attached VPCs, since late 2024.
- **Network function attachments** connect AWS Network Firewall directly, since June 2025.
- **Encryption support** enforces encryption in transit for all traffic, since November 2025.

> ON THE EXAM
>
> Appliance mode on the inspection attachment keeps both directions of a flow in the same AZ.

# Association or propagation?

ASSOCIATION

## Which table I read

- Exactly one table per attachment
- Decides where my traffic can go
- Controls what this VPC reaches
- Change it to move a VPC between segments

PROPAGATION

## Which tables learn about me

- Can propagate into many tables
- Decides who can reach me
- Controls who sees this VPC
- Or add static routes instead

THE TIEBREAKER

Segments are built from propagation: spokes learn shared services; shared services learn every spoke.

# Transit Gateway or Cloud WAN?

TRANSIT GATEWAY

## Regional hubs

- One gateway per Region
- Route tables configured per gateway
- Inter-Region links by peering
- Best for one or a few Regions

AWS CLOUD WAN

## One global network

- Core network spans many Regions
- Segments defined once in a policy
- Attachments placed into segments by tags
- Connects on-premises sites as well

THE TIEBREAKER

Many Regions with the same segments everywhere, managed from one policy, means Cloud WAN.

Overlapping CIDRs are an organisational failure. IPAM turns address planning into an allocation service.

# How VPC IPAM works

- **Pools in a hierarchy:** top-level range, then Regional pools, then pools per environment.
- **Allocation rules** enforce netmask sizes and required tags on each pool.
- **Organizations integration** discovers VPCs across every member account.
- **Pools shared with RAM,** so teams allocate from the plan when creating VPCs.
- **Advanced tier** is needed for pools outside the home Region and allocations to other accounts.

> ON THE EXAM
>
> IPAM prevents overlap at allocation time and reports it afterwards. A spreadsheet does neither.

IPv6 removes address exhaustion and overlap. **Dual-stack** is the bridge; IPv6-only is where it leads.

# IPv6 building blocks

| PIECE | WHAT IT DOES |
|---|---|
| Dual-stack subnet | IPv4 and IPv6 together; each subnet gets a /64 |
| IPv6-only subnet | No IPv4 addresses at all; nothing to exhaust |
| Egress-only internet gateway | IPv6 out to the internet; blocks inbound connections |
| DNS64 and NAT64 | IPv6-only workloads reach IPv4 services via a NAT gateway |
| Dual-stack load balancers | ALB and NLB serve IPv4 and IPv6 clients |
| Public IPv4 charge | Every public IPv4 address billed hourly since February 2024 |

ON THE EXAM

DNS64 and NAT64 are the bridge for IPv6-only workloads: route 64:ff9b::/96 to a NAT gateway.

# A dual-stack migration path

01
### Add IPv6
Assign an IPv6 block to each VPC, from IPAM.

02
### Dual-stack
Give existing subnets and load balancers IPv6.

03
### Egress
Egress-only gateway for private IPv6 traffic.

04
### IPv6-only
New workloads in IPv6-only subnets, with DNS64 and NAT64.

05
### Retire IPv4
Release public IPv4 addresses as clients move.

ON THE EXAM

Dual-stack first, so nothing breaks. IPv6-only for new workloads, where address pressure is worst.

# NAT gateway or egress-only internet gateway?

NAT GATEWAY

## IPv4 out, and NAT64

- Private IPv4 traffic to the internet
- Translates IPv6 to IPv4 for NAT64
- Hourly charge plus per GB processed
- Needs a public IPv4 address

EGRESS-ONLY GATEWAY

## IPv6 out only

- Private IPv6 traffic to the internet
- Stateful: inbound connections blocked
- No hourly or processing charge
- No translation of any kind

THE TIEBREAKER

Private IPv6 traffic to IPv6 destinations should use the egress-only gateway. It costs nothing to process.

# Reading the scenario

| WHEN THE QUESTION SAYS | IT IS TESTING |
|---|---|
| Dev must not reach Prod; both reach shared | TGW route table propagation |
| Two VPCs, huge volume, nothing else | VPC peering on cost |
| Same segments across many Regions | AWS Cloud WAN |
| Teams keep creating overlapping CIDRs | VPC IPAM with allocation rules |
| IPv6-only workload calls an IPv4 API | DNS64 and NAT64 |
| NAT gateway bill, dual-stack subnets | Egress-only gateway for IPv6 |

ON THE EXAM

Connectivity questions turn on shape and cost. Addressing questions turn on who chooses the range.

Meridian Freight has 40 development VPCs and 25 production VPCs attached to one Transit Gateway, plus a shared services VPC. Today every VPC can reach every other.

Development must not reach production, and both must reach shared services, without adding gateways.

## What should the solutions architect do?

A Create a separate Transit Gateway for each environment

B Use separate route tables for development and production, with only shared services propagated into each

C Block development CIDRs in production security groups

D Add network ACLs to every production subnet

◆ PAUSE AND DECIDE

## What should the solutions architect do?

A. A gateway per environment

*Isolates, but adds gateways, which the scenario rules out.*

**B. Route tables per segment**

No route exists between the segments, so isolation holds at the routing layer.

C. Security group rules

*Hundreds of rules to maintain, and a missed one reopens the path.*

D. Network ACLs

*Same problem per subnet, with stateless rules that are easy to get wrong.*

THE SIGNAL

**Segmentation on one Transit Gateway is built from route tables and propagation.**

> Two Meridian Freight VPCs in the same Region, analytics and the data lake, exchange about 400 TB per month. Nothing else needs to connect to either VPC, and their CIDRs do not overlap.
>
> The company wants the lowest-cost connection.

**Which connection should the solutions architect use?**

A. VPC peering

B. A Transit Gateway with both VPCs attached

C. AWS Cloud WAN

D. A PrivateLink endpoint service in front of the data lake

◆ PAUSE AND DECIDE

## Which connection should the solutions architect use?

**A** VPC peering

No hourly fee and no per-GB processing; transit limits do not matter here.

**B** Transit Gateway

*Charges per GB processed on all 400 TB, every month.*

**C** Cloud WAN

*A global network for two VPCs in one Region, with processing charges too.*

**D** PrivateLink

*Charges per GB processed, and exposes one service, not the network.*

THE SIGNAL

One pair, huge volume, nothing else. Peering's limits do not apply, and its pricing wins.

> Meridian Freight operates in nine AWS Regions and needs production, development and shared-services segments, isolated the same way everywhere. New VPCs should join the right segment automatically from their tags.
>
> Today, nine Transit Gateways with peering and hand-maintained route tables have drifted apart.

## What should the solutions architect recommend?

A. Add an automation pipeline that reconciles the nine Transit Gateway route tables

B. Replace Transit Gateway with a full mesh of VPC peering

C. AWS Cloud WAN with segments defined in the core network policy and tag-based attachment rules

D. A VPC Lattice service network in each Region

◆ PAUSE AND DECIDE

## What should the solutions architect recommend?

A **Reconciliation pipeline**

*Builds by hand what Cloud WAN's central policy already provides.*

B **Peering mesh**

*Hundreds of connections, no transit, no segments. Far worse.*

C **Cloud WAN with policy and tags**

Segments exist once in policy across all Regions; tags place new VPCs.

D **Lattice per Region**

*Connects services, not networks, and does not span Regions as a segment.*

THE SIGNAL

Many Regions, identical segments, drift, and tag-based joining. Each is a Cloud WAN design goal.

> Meridian Freight's 200 accounts keep producing VPCs with overlapping CIDRs because teams choose their own ranges. Several overlaps have blocked Transit Gateway attachments.
>
> The network team wants ranges allocated centrally per Region and environment, with size limits, and overlaps reported, with the LEAST effort.

**What should the solutions architect implement?**

A. A shared spreadsheet of ranges, with an AWS Config rule that checks VPC CIDRs

B. An SCP that denies CreateVpc unless the CIDR is in an approved list

C. A Lambda function that deletes any new VPC whose CIDR overlaps

D. VPC IPAM with Organizations integration, Regional and environment pools, allocation rules, shared with RAM

◆ PAUSE AND DECIDE

## What should the solutions architect implement?

A **Spreadsheet and Config**

*Detects after the fact; the plan itself still lives outside AWS.*

B **SCP with an approved list**

*Static list that must be edited for every new range; no allocation, no reporting.*

C **Deleting Lambda**

*Destructive, custom, and still lets teams choose ranges.*

D **IPAM pools and rules**

Teams allocate from the plan; rules enforce size; overlaps are reported.

THE SIGNAL

The cause is teams choosing ranges. Only an allocation service removes the cause.

> Meridian Freight's new EKS cluster runs in IPv6-only subnets to avoid exhausting private IPv4 space. Some pods must call a partner's pricing API, which is reachable only over IPv4 on the internet.
>
> The pods must not have IPv4 addresses.

**What should the solutions architect configure?**

A. An egress-only internet gateway with a ::/0 route

B. Enable DNS64 on the subnets and route 64:ff9b::/96 to a NAT gateway

C. Assign public IPv4 addresses to the pods' network interfaces

D. A PrivateLink endpoint to the partner's API

◆ PAUSE AND DECIDE

## What should the solutions architect configure?

A Egress-only gateway

*Carries IPv6 only. It cannot reach an IPv4-only destination.*

B DNS64 and NAT64

Synthesises IPv6 answers; the NAT gateway translates to the IPv4 API.

C Public IPv4 on pods

*Breaks the stated constraint, and adds hourly IPv4 charges.*

D PrivateLink

*Requires the partner to offer an endpoint service. This API is on the internet.*

THE SIGNAL

IPv6-only source, IPv4-only destination. That translation is exactly what DNS64 and NAT64 provide.

> Meridian Freight's private subnets are dual-stack. All outbound internet traffic goes through NAT gateways, which process about 300 TB per month. Most destinations, including the company's main SaaS providers, support IPv6.
>
> The company wants to cut the NAT gateway processing charges with minimal change.

## What should the solutions architect do?

A Add an egress-only internet gateway and route ::/0 to it from the private subnets

B Add a NAT gateway in every Availability Zone

C Move the workloads into public subnets

D Replace NAT gateways with NAT instances

◆ PAUSE AND DECIDE

## What should the solutions architect do?

**A** Egress-only gateway for IPv6

IPv6-capable traffic bypasses NAT entirely, with no processing charge.

**B** More NAT gateways

*Can cut cross-AZ charges, but processing per GB is unchanged.*

**C** Public subnets

*Exposes workloads, needs public IPv4 addresses, and is a large change.*

**D** NAT instances

*Trades a charge for an operational burden and a bottleneck.*

THE SIGNAL

Dual-stack subnets plus IPv6-capable destinations: the egress-only gateway is free to process.

# What to carry out of this module

- **Peering per byte, Transit Gateway per relationship,** Cloud WAN across many Regions.
- **Segmentation is propagation.** Spokes learn shared services, never each other.
- **IPAM** fixes overlap at the cause: who chooses the range.
- **Dual-stack first,** IPv6-only for new workloads, DNS64 and NAT64 for IPv4 dependencies.
- **Egress-only gateway** moves IPv6 traffic off the NAT gateway meter.

> ON THE EXAM
>
> Public IPv4 addresses have been charged hourly since February 2024. That cost now drives IPv6 decisions.

MODULE 11 · DOMAIN 1 - ARCHITECTURE BUILT FOR THE CLOUD

# Network Security and Global Traffic Routing

Inspect and filter at the right layer, then route users across Regions to the endpoint that should answer.

DOMAIN 1 of 5 EXAM WEIGHT 25% MODULE 11 of 52

admin@sthithapragna.com

Inspect at the right layer: packets, flows or requests. Each control sees only its own layer.

# The controls and the layer each sees

| CONTROL | LAYER | BEST AT |
|---|---|---|
| Security group | Instance, stateful | Allow rules, referencing other groups |
| Network ACL | Subnet, stateless | Explicit deny of address ranges |
| AWS Network Firewall | VPC traffic, stateful | IPS rules, domain filtering, managed |
| Gateway Load Balancer | Transparent appliances | Third-party firewalls at scale |
| AWS WAF | HTTP requests | Injection, bots, rate limits |
| AWS Shield | Network and application | DDoS; Advanced adds response team |

ON THE EXAM

Security groups cannot deny. A specific address range to block is a network ACL or firewall rule.

# Security group or network ACL?

SECURITY GROUP

## Stateful, allow only

- Attached to an interface
- Return traffic allowed automatically
- Can reference other security groups
- No deny rules

NETWORK ACL

## Stateless, ordered

- Applies to a whole subnet
- Return traffic needs its own rule
- Allow and deny, lowest number first
- Ephemeral ports must be opened

THE TIEBREAKER

Block a specific address range now: network ACL deny. Allow by role or tier: security group reference.

# Network Firewall or Gateway Load Balancer?

AWS NETWORK FIREWALL

## Managed, AWS-native

- Stateful and stateless rule groups
- Suricata-compatible IPS rules
- Domain allow and deny lists
- Attach directly to Transit Gateway

GATEWAY LOAD BALANCER

## Your vendor's appliances

- Third-party firewalls you already license
- Transparent, using GENEVE encapsulation
- Scales and health-checks appliances
- GWLB endpoints steer traffic to it

THE TIEBREAKER

A named third-party firewall or existing licences means GWLB. Least operational overhead means Network Firewall.

# Centralised inspection through a Transit Gateway

01

## Spoke VPCs

Workloads route 0.0.0.0/0 to the Transit Gateway.

02

## Inspection

Network Firewall, attached directly or in an inspection VPC.

03

## Appliance mode

Keeps both directions of a flow in one AZ.

04

## Egress VPC

Shared NAT gateways to the internet.

05

## Return

Same path back, same firewall endpoint.

ON THE EXAM

One inspection point for many VPCs. Appliance mode stops return traffic landing on a different endpoint.

# Centralised or distributed inspection?

CENTRALISED

## One inspection point

- One rule set, one team
- Shared NAT and firewall cost
- Transit Gateway processing on every flow
- A shared dependency for all VPCs

DISTRIBUTED

## Firewall in each VPC

- No hairpin through a hub
- Failure stays local
- Rules managed centrally with policies
- More endpoints to pay for

THE TIEBREAKER

Central control and shared egress favour centralised. Isolation of failure and no hub hop favour distributed.

# Two VPC-wide guardrails, both new

- **VPC Block Public Access** (Nov 2024): block internet traffic, both ways or ingress only.
- It **supersedes route tables and security groups**; exclusions for chosen VPCs or subnets.
- **VPC Encryption Controls** (Nov 2025): monitor, then enforce, encryption in transit.
- Enforce mode blocks unencrypted resources; only **8 resource types** can be excluded.
- **Network Firewall and GWLB are not supported** in a VPC in enforce mode.

> ON THE EXAM
>
> Both can be deployed across an organisation with declarative policies. Both postdate older study material.

# AWS WAF and Shield

- **WAF** attaches to CloudFront, ALB, API Gateway REST APIs, AppSync and Cognito.
- **Managed rule groups** for common exploits, SQL injection and known bad inputs.
- **Rate-based rules** and **Bot Control** limit abusive clients.
- **Shield Standard** is automatic and free for network-layer DDoS.
- **Shield Advanced**: response team, cost protection, health-based detection.

> ON THE EXAM
>
> Request-level attacks are WAF. Volumetric attacks are Shield. Cost protection for a DDoS bill is Shield Advanced.

# VPC Flow Logs: what they can and cannot tell you

- **Accepted and rejected flows** by interface, subnet or VPC.
- **Custom fields** such as traffic-path, flow-direction and reject-reason.
- **encryption-status** field, with Encryption Controls, shows whether a flow was encrypted.
- **No packet contents.** Flow logs never show payloads or URLs.
- **Traffic Mirroring** copies packets when full inspection is needed.

> ON THE EXAM
>
> Flow logs answer who talked to whom and whether it was allowed. They never answer what was said.

Routing users across Regions is a choice between speed, location rules and failover.

# Route 53 routing policies

| POLICY | DECIDES BY | USE IT FOR |
|---|---|---|
| Latency | Lowest measured latency | Fastest Region for each user |
| Geolocation | Where the user is | Data residency, language, licensing |
| Geoproximity | Distance, with a bias | Shifting load between Regions |
| Failover | Health of the primary | Active-passive recovery |
| Weighted | Proportions you set | Gradual migration, canaries |
| IP-based | The client's network range | Routing known ISPs or offices |

ON THE EXAM

Compliance means geolocation. Speed means latency. Geolocation needs a default record for unmatched users.

# Global Accelerator or CloudFront?

GLOBAL ACCELERATOR

## Network-level

- Two static anycast IP addresses
- TCP and UDP, any protocol
- Regional failover in seconds, no DNS caching
- No caching of content

CLOUDFRONT

## HTTP-level

- Caches content at the edge
- HTTP and HTTPS only
- Edge functions and WAF
- Addresses change; use DNS names

THE TIEBREAKER

Static IPs, UDP or failover that ignores DNS caching means Global Accelerator. Cacheable web content means CloudFront.

# Reading the scenario

| WHEN THE QUESTION SAYS | IT IS TESTING |
|---|---|
| Block this address range now | Network ACL deny rule |
| Existing third-party firewall licences | Gateway Load Balancer |
| No VPC may ever accept internet traffic | VPC Block Public Access |
| Prove traffic in the VPC is encrypted | VPC Encryption Controls, monitor first |
| Static IPs, UDP, fast Regional failover | Global Accelerator |
| Users must be served in their own country | Route 53 geolocation |

ON THE EXAM

Name the layer, then the control. Name the routing goal, then the policy.

> Meridian Freight's security team sees repeated connection attempts against a TCP service in a private subnet, all from one /24 range belonging to a known bad actor. The service is not HTTP.
>
> The range must be blocked for the whole subnet immediately.

**What should the solutions architect do?**

A Add a deny rule for the range to the instances' security group

B Add a low-numbered deny rule for the range to the subnet's network ACL

C Add the range to an AWS WAF IP set block rule

D Subscribe to AWS Shield Advanced

◆ PAUSE AND DECIDE

## What should the solutions architect do?

A Security group deny

*Security groups have no deny rules. This option cannot be configured.*

B Network ACL deny

Evaluated first by number, applies to the whole subnet, takes effect at once.

C WAF IP set

*WAF only sees HTTP requests on supported front ends. This is a raw TCP service.*

D Shield Advanced

*For DDoS. Connection attempts from one range need a simple block.*

THE SIGNAL

A specific range to deny, at subnet scope, on a non-HTTP service. Only the network ACL fits.

> Meridian Freight has 50 VPCs attached to one Transit Gateway. Security requires that all outbound internet traffic is inspected and only allowed to an approved list of domains, under one rule set.
>
> The team wants the LEAST operational overhead and no third-party appliances.

**Which design should the solutions architect recommend?**

A. A NAT gateway in every VPC, with security groups restricting destinations

B. Squid proxy instances in a central VPC

C. AWS Network Firewall attached to the Transit Gateway, with a domain allow list, and a central egress VPC

D. Route 53 Resolver DNS Firewall in every VPC

◆ PAUSE AND DECIDE

## Which design should the solutions architect recommend?

**A** NAT per VPC with security groups

*Security groups match addresses, not domains, and there are 50 rule sets.*

**B** Squid proxies

*Works, but it is a fleet you patch, scale and keep available yourself.*

**C** Network Firewall on the Transit Gateway

One managed rule set inspecting every VPC's egress, filtering by domain.

**D** DNS Firewall

*Filters DNS lookups only. Traffic to a hard-coded IP address bypasses it.*

THE SIGNAL

Domain filtering on the traffic itself, one rule set, managed. That combination is Network Firewall in a central path.

> Meridian Freight's security policy mandates a specific third-party next-generation firewall, for which the company holds enterprise licences and trained staff. Traffic between VPCs must pass through it.
>
> The firewall fleet must scale and survive the loss of an appliance without changing application routing.

**How should the solutions architect insert the firewalls?**

A. A Gateway Load Balancer in front of the appliance fleet, with Gateway Load Balancer endpoints in the traffic path

B. Replace the vendor firewall with AWS Network Firewall

C. A Network Load Balancer in front of the appliances

D. One large appliance instance with source and destination checks disabled

◆ PAUSE AND DECIDE

## How should the solutions architect insert the firewalls?

**A** Gateway Load Balancer

Transparent, scales the fleet, health checks appliances, keeps routing unchanged.

**B** Network Firewall instead

*Breaks the policy mandating the vendor, and wastes the licences.*

**C** Network Load Balancer

*Terminates at its own address, so the appliances do not see transparent traffic.*

**D** One large instance

*A single point of failure, with no scaling.*

THE SIGNAL

A mandated vendor plus transparent, scalable insertion is the definition of Gateway Load Balancer.

> Meridian Freight's audit found internet-reachable instances in workload accounts, created by teams who attached internet gateways and opened security groups. Only one designated DMZ subnet in each account may receive internet traffic.
>
> The control must hold regardless of how teams configure routes or security groups, across all workload accounts.

**What should the solutions architect implement?**

A. An SCP that denies attaching internet gateways in workload accounts

B. An AWS Config rule that removes internet routes when found

C. Network ACLs on every subnet that deny inbound internet traffic

D. VPC Block Public Access in ingress-only mode, with an exclusion for the DMZ subnet, deployed by declarative policy

◆ PAUSE AND DECIDE

## What should the solutions architect implement?

A SCP denying internet gateways

*Also blocks the DMZ and any outbound design, and cannot carve out one subnet.*

B Config remediation

*Acts after exposure, and teams can change it back.*

C Network ACLs everywhere

*Teams who can edit routes and groups can edit ACLs too.*

D Block Public Access with an exclusion

Supersedes routes and security groups; the DMZ is a deliberate exception.

THE SIGNAL

Regardless of routes or security groups is Block Public Access's defining property.

A regulator requires Meridian Freight to prove that all traffic between workloads inside its payments VPC is encrypted in transit, and to prevent unencrypted resources being added later.

The VPC is two years old and runs a mix of instance generations.

**What should the solutions architect do first?**

A Turn on VPC Encryption Controls in enforce mode on the VPC

B Turn on VPC Encryption Controls in monitor mode, add encryption-status to new flow logs, and find blocking resources

C Require every application team to configure TLS

D Enable MACsec on the Direct Connect connection

◆ PAUSE AND DECIDE

## What should the solutions architect do first?

A. Enforce mode now

*Not allowed on an existing VPC. Monitor mode must come first.*

B. Monitor mode, flow logs, find blockers

Produces evidence, lists old instances to upgrade, then enables enforce.

C. TLS everywhere

*No proof across the VPC, and nothing prevents a new unencrypted resource.*

D. MACsec

*Encrypts a Direct Connect circuit, not traffic inside the VPC.*

THE SIGNAL

An existing VPC goes to monitor mode first. Enforce mode follows once old resources are upgraded or excluded.

> Meridian Freight's truck telematics units send data over UDP to an ingestion service running in two Regions. The units' firmware holds fixed IP addresses that can only be changed by a site visit.
>
> If one Region fails, devices must reach the other within seconds.

## What should the solutions architect use?

A Route 53 failover routing with health checks

B Amazon CloudFront with an origin group

C AWS Global Accelerator with an endpoint group in each Region

D A Network Load Balancer with Elastic IPs in each Region, both in the firmware

◆ PAUSE AND DECIDE

## What should the solutions architect use?

**A** Route 53 failover

*Devices use fixed IPs, not DNS, and DNS caching would slow failover anyway.*

**B** CloudFront

*HTTP only. UDP telemetry cannot pass through it.*

**C** Global Accelerator

Two static anycast IPs for any protocol; shifts to the healthy Region in seconds.

**D** NLB IPs in firmware

*Puts failover logic in every device, and any change needs a site visit.*

THE SIGNAL

Fixed IPs, UDP and fast Regional failover. Every one of those is a Global Accelerator property.

# What to carry out of this module

- **Security groups allow; network ACLs can deny.** Pick the layer that sees the threat.
- **Network Firewall** for managed inspection; **GWLB** for a mandated vendor.
- **Block Public Access** overrides routes and groups. **Encryption Controls**: monitor, then enforce.
- **Flow logs never contain payloads.** Traffic Mirroring for contents.
- **Global Accelerator** for static IPs, UDP and fast failover; **geolocation** for jurisdiction.

> ON THE EXAM
>
> Network Firewall and GWLB cannot run in a VPC with Encryption Controls in enforce mode.

MODULE 12 · DOMAIN 1 - ARCHITECTURE BUILT FOR THE CLOUD

# Storage, Database and Caching Selection

Pick the store from the access pattern, scale it for availability, and cache what is read too often.

DOMAIN 1 of 5 EXAM WEIGHT 25% MODULE 12 of 52

admin@sthithapragna.com

Choose the store from how the data is accessed, not from what the data looks like.

# General-purpose and analytical databases

| SERVICE | ACCESS PATTERN IT FITS |
| --- | --- |
| Amazon RDS | Relational, an engine you already run, moderate scale |
| Amazon Aurora | Relational, high availability, many replicas, global reads |
| Amazon DynamoDB | Known keys, any scale, single-digit millisecond |
| Amazon DocumentDB | JSON documents, MongoDB-compatible APIs |
| Amazon Neptune | Relationships: fraud rings, networks, recommendations |
| Amazon Redshift | Analytics across large historical datasets |

ON THE EXAM

Ad hoc joins mean relational. Known access patterns at massive scale mean DynamoDB.

# Purpose-built stores in scope

| SERVICE | CHOOSE IT WHEN | WATCH FOR |
|---|---|---|
| Amazon Keyspaces | Apache Cassandra workloads | CQL-compatible, serverless |
| Amazon Timestream | Time-series metrics and telemetry | LiveAnalytics closed to new customers |
| Amazon MemoryDB | In-memory speed as the primary, durable store | Not just a cache |
| Amazon ElastiCache | Caching in front of another store | Valkey, Redis OSS or Memcached |

ON THE EXAM

Timestream for LiveAnalytics closed to new customers in June 2025. New work goes to Timestream for InfluxDB.

# RDS or Aurora?

CHOOSE RDS WHEN

## Familiar and economical

- Oracle, SQL Server, Db2 or specific versions
- Moderate read scaling
- Lowest cost for steady, small workloads
- Least change from on premises

CHOOSE AURORA WHEN

## Availability and scale

- MySQL or PostgreSQL compatible
- Up to 15 replicas on shared storage
- Fast failover, storage grows itself
- Global Database and serverless

THE TIEBREAKER

Many readers, fast failover or cross-Region reads point to Aurora. A commercial engine points to RDS.

# Scaling databases for availability

| MECHANISM | WHAT IT GIVES YOU |
|---|---|
| RDS Multi-AZ instance | Synchronous standby for failover; not readable |
| RDS Multi-AZ DB cluster | Two readable standbys, faster failover |
| Read replicas | Asynchronous copies for reads, also cross-Region |
| Aurora Replicas | Up to 15 readers on shared storage, failover targets |
| Aurora Global Database | Cross-Region replicas, managed Regional failover |
| DynamoDB global tables | Active-active in many Regions |

ON THE EXAM

Multi-AZ is for availability, replicas are for reads. A classic Multi-AZ standby serves no traffic.

# Global tables: eventual or strong consistency?

MULTI-REGION EVENTUAL (MREC)

## The default

- Replicas in any number of Regions
- Replication typically under a second
- Last writer wins on conflicts
- RPO of a few seconds

MULTI-REGION STRONG (MRSC)

## RPO of zero

- Exactly three Regions, or two plus a witness
- Reads always return the latest write
- Higher write latency
- No TTL, LSIs or transactions

THE TIEBREAKER

RPO of zero and read-your-latest-write in any Region means MRSC. The mode cannot be changed later.

Storage is chosen by **access protocol** first. Performance and cost come second.

# Storage by access pattern

| SERVICE | PROTOCOL | CHOOSE IT WHEN |
|---|---|---|
| Amazon S3 | Objects, HTTP | Durable, unlimited, most data |
| S3 Express One Zone | Objects, one AZ | Single-digit ms, very high request rates |
| EBS gp3 | Block, one instance | Most volumes; up to 80,000 IOPS |
| EBS io2 Block Express | Block, Multi-Attach | Sub-ms, beyond 80,000 IOPS |
| Amazon EFS | NFS, Linux | Shared files across instances and AZs |
| Amazon FSx | SMB, Lustre, ONTAP, OpenZFS | Windows, HPC or multiprotocol |

ON THE EXAM

Since September 2025 gp3 reaches 80,000 IOPS. The old rule, above 16,000 needs io2, is wrong.

# EBS gp3 or io2 Block Express?

CHOOSE GP3 WHEN

## Cost-effective performance

- Up to 80,000 IOPS and 2,000 MiB/s
- IOPS and throughput set independently
- Millisecond latency is acceptable
- Most databases and applications

CHOOSE IO2 BLOCK EXPRESS WHEN

## The highest tier

- Up to 256,000 IOPS
- Sub-millisecond latency
- Multi-Attach to several instances
- 99.999 percent durability

THE TIEBREAKER

IOPS alone no longer forces io2 below 80,000. Latency, Multi-Attach or extreme IOPS still do.

# Caching strategies

| CACHE | SITS IN FRONT OF | CHOOSE IT WHEN |
|---|---|---|
| DynamoDB Accelerator | DynamoDB only | Microsecond reads, no app logic change |
| ElastiCache | Any database or API | Flexible caching, sessions, leaderboards |
| CloudFront | Web origins | Content close to users |
| API Gateway cache | REST API stages | Repeated identical API responses |

ON THE EXAM

Lazy loading caches what is read. Write-through keeps the cache fresh. TTL bounds staleness in both.

# DAX or ElastiCache?

CHOOSE DAX WHEN

## DynamoDB, transparently

- The database is DynamoDB
- Microsecond read latency
- Swap the client, keep the calls
- Item and query results cached

CHOOSE ELASTICACHE WHEN

## Anything, with control

- Relational or other sources
- Cache computed results or sessions
- Valkey is the lower-cost engine
- Application controls what is cached

THE TIEBREAKER

DynamoDB with minimal code change means DAX. Any other source, or computed results, means ElastiCache.

# Reading the scenario

| WHEN THE QUESTION SAYS | IT IS TESTING |
|---|---|
| Many readers, failover in seconds, MySQL | Aurora with Aurora Replicas |
| RPO zero, latest write from any Region | DynamoDB global tables, MRSC |
| New time-series workload | Timestream for InfluxDB |
| 40,000 IOPS, cost-sensitive | gp3, not io2 |
| Microsecond reads on DynamoDB | DAX |
| Windows SMB and Linux NFS, same data | FSx for NetApp ONTAP |

ON THE EXAM

Three of these six answers changed since 2025. Check every number against today's limits.

> Meridian Freight's tracking database is MySQL on Amazon RDS. Read traffic will grow tenfold, needing around ten read replicas, and failover must complete within about 30 seconds.
>
> The team also wants storage to grow without intervention.

**Which solution should the solutions architect recommend?**

A RDS for MySQL Multi-AZ with ten read replicas

B Amazon Aurora MySQL with Aurora Replicas

C Migrate the data to Amazon DynamoDB

D An RDS Multi-AZ DB cluster with two readable standbys

◆ PAUSE AND DECIDE

## Which solution should the solutions architect recommend?

A RDS with ten read replicas

*Replicas lag asynchronously, each with its own storage to manage, and are not automatic failover targets.*

B Aurora MySQL with Aurora Replicas

Readers on shared storage, fast failover, storage that grows itself.

C DynamoDB

*A rewrite of a relational application for a read-scaling problem.*

D Multi-AZ DB cluster

*Two readable standbys cannot serve tenfold read growth.*

THE SIGNAL

Many readers, fast failover and self-growing storage on MySQL. Each is an Aurora architecture property.

> Meridian Freight is building a multi-Region payments ledger. Losing any acknowledged write in a Regional failure is unacceptable, and a read in any Region must return the latest balance.
>
> The team accepts higher write latency, and the table has no TTL or transactions.

## Which design meets these requirements?

A DynamoDB global tables with multi-Region eventual consistency

B Aurora Global Database with write forwarding

C DynamoDB global tables with multi-Region strong consistency across three Regions

D A single-Region DynamoDB table with point-in-time recovery

◆ PAUSE AND DECIDE

## Which design meets these requirements?

A Eventual consistency

*RPO of a few seconds, and reads can be stale in another Region.*

B Aurora Global Database

*Asynchronous replication to secondaries, so RPO is not zero.*

C Strong consistency, three Regions

RPO of zero, and every Region reads the latest write.

D Single Region with PITR

*Restores from backup; nothing serves other Regions.*

THE SIGNAL

Zero data loss plus latest-read everywhere is MRSC. The scenario even removes its two restrictions.

> Meridian Freight is starting a new project to store engine telemetry from 20,000 trucks as time-series data, queried by time range for dashboards and alerts.
>
> Meridian has never used Amazon Timestream, and wants a managed time-series database.

**Which service should the solutions architect choose?**

A Amazon Timestream for InfluxDB

B Amazon Timestream for LiveAnalytics

C Amazon DynamoDB with a time-based sort key

D Amazon Redshift

◆ PAUSE AND DECIDE

## Which service should the solutions architect choose?

**A** Timestream for InfluxDB

A managed time-series database AWS recommends for new customers.

**B** Timestream for LiveAnalytics

*Closed to new customers since 20 June 2025.*

**C** DynamoDB with time sort key

*Possible, but you build time-series querying and retention yourself.*

**D** Redshift

*Analytics warehouse, not a store for live dashboards and alerts.*

THE SIGNAL

Never used Timestream is the planted detail. New customers cannot start on LiveAnalytics.

A Meridian Freight database server needs a 4 TiB volume with a sustained 40,000 IOPS. Millisecond latency is acceptable, and the volume is attached to one instance.

The company wants the lowest-cost volume that meets the requirement.

**Which EBS volume type should the solutions architect choose?**

A. io2 Block Express with 40,000 provisioned IOPS

B. Throughput Optimized HDD (st1)

C. Several gp2 volumes striped with RAID 0

D. gp3 with 40,000 provisioned IOPS

◆ PAUSE AND DECIDE

## Which EBS volume type should the solutions architect choose?

A io2 Block Express

*Meets it, at a higher price, for latency and features nobody asked for.*

B st1

*Hard disk for sequential throughput, nowhere near 40,000 IOPS.*

C Striped gp2

*The old workaround, with more volumes to manage and IOPS tied to size.*

D gp3, 40,000 IOPS

Within gp3's 80,000 IOPS ceiling since 2025, at lower cost.

THE SIGNAL

40,000 IOPS used to force io2. Since September 2025 it fits comfortably in gp3.

> Meridian Freight's rate catalogue lives in DynamoDB. During peak hours the same items are read thousands of times per second, and the application needs microsecond read latency.
>
> The development team wants to avoid writing caching logic.

## What should the solutions architect add?

A. An ElastiCache for Valkey cluster with lazy loading in the application

B. A DynamoDB Accelerator (DAX) cluster, with the application using the DAX client

C. More provisioned read capacity on the table

D. DynamoDB global tables in a second Region

◆ PAUSE AND DECIDE

## What should the solutions architect add?

A ElastiCache with lazy loading

*Works, but lazy loading is exactly the caching logic the team wants to avoid.*

B DAX

API-compatible cache for DynamoDB; microsecond reads with a client swap.

C More read capacity

*More throughput, still millisecond latency.*

D Global tables

*For multi-Region availability, not microsecond reads.*

THE SIGNAL

DynamoDB, microseconds, no caching code. All three point at DAX.

> Meridian Freight's billing application runs on Windows and needs SMB file shares joined to Active Directory. A Linux analytics cluster must read the same files over NFS.
>
> The storage must be fully managed and highly available.

**Which storage should the solutions architect choose?**

A Amazon FSx for Windows File Server

B Amazon EFS

C Amazon FSx for NetApp ONTAP

D S3 File Gateway

◆ PAUSE AND DECIDE

## Which storage should the solutions architect choose?

A. FSx for Windows File Server

*SMB with Active Directory, but not NFS for the Linux cluster.*

B. EFS

*NFS for Linux, with no SMB for Windows.*

C. FSx for NetApp ONTAP

Serves the same data over SMB and NFS, joined to Active Directory.

D. S3 File Gateway

*A hybrid gateway appliance, not managed shared storage in AWS.*

THE SIGNAL

Two protocols on the same data is the defining requirement. Multiprotocol access is ONTAP's strength.

# What to carry out of this module

- **Access pattern first.** Joins mean relational; known keys at scale mean DynamoDB.
- **Multi-AZ for failover, replicas for reads.** Aurora for many readers and fast failover.
- **MRSC** for RPO zero across Regions: three Regions, no TTL, LSIs or transactions.
- **gp3 up to 80,000 IOPS.** io2 for sub-millisecond, Multi-Attach or more.
- **Timestream for LiveAnalytics** is closed to new customers. Use InfluxDB.

> ON THE EXAM
>
> DAX for DynamoDB without code; ElastiCache for anything else. ONTAP when SMB and NFS share data.

MODULE 13 · DOMAIN 1 - ARCHITECTURE BUILT FOR THE CLOUD

# Data Lakes, Lakehouse and Analytics Pipelines

Open tables on S3, governed centrally, queried by the right engine, and shared without giving the data away.

DOMAIN 1 of 5 EXAM WEIGHT 25% MODULE 13 of 52

admin@sthithapragna.com

A lakehouse keeps data in open files on S3, and adds table behaviour on top: transactions, schema and governance.

# The lakehouse, layer by layer

01
### Ingest
Kinesis, MSK, AppFlow, DMS land data in S3.

02
### Store
Iceberg tables in S3, or S3 Tables.

03
### Catalogue
Glue Data Catalog holds schemas and locations.

04
### Govern
Lake Formation grants table, column and row access.

05
### Query
Athena, Redshift and EMR read the same tables.

06
### Share
Cross-account grants, or Clean Rooms.

ON THE EXAM

One copy of the data, many engines. The catalogue and the permissions are what make that safe.

# Iceberg tables or plain Parquet files?

PLAIN PARQUET FOLDERS

## Files with a naming scheme

- Append-friendly, rewrite to change
- Deleting one customer rewrites partitions
- Concurrent writers can collide
- Schema changes are fragile

APACHE ICEBERG TABLES

## Files with table semantics

- ACID transactions on S3
- Row-level UPDATE, DELETE and MERGE
- Schema and partition evolution
- Time travel to earlier snapshots

THE TIEBREAKER

Row-level deletes, upserts or concurrent writers on the lake mean Iceberg.

# S3 Tables or self-managed Iceberg?

SELF-MANAGED ICEBERG

## General purpose bucket

- You schedule compaction and cleanup
- Or enable Glue Data Catalog compaction
- Full control of layout
- Bucket and prefix permissions

AMAZON S3 TABLES

## Table buckets

- Iceberg tables as a bucket type
- Automatic compaction and snapshot cleanup
- Table-level permissions
- Up to 3x faster queries, AWS claims

THE TIEBREAKER

Iceberg without running maintenance jobs: S3 Tables. Existing tables and full control: self-managed.

# Lake Formation permissions

- **Grants on databases, tables and columns,** plus data filters for rows.
- **LF-tags** grant by classification, so new tables inherit access from their tags.
- **Cross-account sharing uses AWS RAM,** by named resource or by LF-tag.
- **Resource links** let Athena and Redshift Spectrum query shared tables.
- Same organisation: available at once. Another organisation: an invitation to accept.

> ON THE EXAM
>
> Hundreds of tables and many consumers: tag-based access control. Named grants do not scale.

# Lake Formation sharing or AWS Clean Rooms?

LAKE FORMATION SHARING

## Give access to data

- Consumer can read the shared rows
- Column and row filters limit what
- Inside or across organisations
- Trust the consumer with the data

AWS CLEAN ROOMS

## Share results, not rows

- Data stays in each member's account
- Analysis rules: aggregation, list, custom
- Differential privacy for aggregates
- Neither side sees the other's raw records

THE TIEBREAKER

If a partner must never see your raw records, sharing access is wrong. Clean Rooms shares only permitted results.

# Choosing the engine

| ENGINE | CHOOSE IT WHEN |
| --- | --- |
| Amazon Athena | Serverless SQL on S3, ad hoc, pay per data scanned |
| Amazon Redshift | Warehouse: high concurrency, complex joins, dashboards |
| Redshift Spectrum | Redshift queries that reach into S3 tables |
| Amazon EMR | Spark and other frameworks; EC2, EKS or Serverless |
| AWS Glue ETL | Serverless Spark jobs, crawlers, the Data Catalog |
| Amazon OpenSearch Service | Search and log analytics |

ON THE EXAM

Engines share the catalogue and the tables. Choose by workload shape, not by where the data lives.

# Athena or Redshift?

CHOOSE ATHENA WHEN

## Occasional, serverless

- Ad hoc and infrequent queries
- Pay per terabyte scanned
- No cluster or capacity
- Data already in S3 tables

CHOOSE REDSHIFT WHEN

## Sustained, concurrent

- Hundreds of users all day
- Complex joins, sub-second dashboards
- Serverless or provisioned capacity
- Spectrum still reads the lake

THE TIEBREAKER

All-day dashboards for hundreds of users outgrow Athena. Occasional exploration does not need Redshift.

# Streaming and SaaS ingestion

| SERVICE | CHOOSE IT WHEN |
| --- | --- |
| Kinesis Data Streams | AWS-native streams, ordered by partition key |
| Amazon MSK | Kafka APIs, existing Kafka clients and connectors |
| MSK Express brokers | Up to 3x throughput per broker, no storage to size |
| Amazon AppFlow | Scheduled or event flows from SaaS apps such as Salesforce |
| AWS DMS | Change data capture from databases into the lake |

ON THE EXAM

Existing Kafka clients mean MSK. SaaS sources without writing integration code mean AppFlow.

# Kinesis Data Streams or Amazon MSK?

KINESIS DATA STREAMS

## AWS-native

- AWS SDK producers and consumers
- On-demand or provisioned shards
- Tight Lambda integration
- Least to learn on AWS

AMAZON MSK

## Kafka-compatible

- Existing Kafka clients unchanged
- Kafka Connect and ecosystem tools
- Standard, Express or Serverless
- Portability beyond AWS

THE TIEBREAKER

Kafka already in use means MSK. Starting fresh on AWS with the least to run means Kinesis.

# A serverless processing pipeline

01
### Stream
Kinesis Data Streams receives events.

02
### Transform
Lambda processes batches from each shard.

03
### Land
Results written to Iceberg tables in S3.

04
### Catalogue
Tables registered in the Glue Data Catalog.

05
### Query
Athena queries on demand; nothing runs when idle.

ON THE EXAM

Skill 1.1.3: no servers, scaling per shard, pay per use. Heavy transforms move to Glue ETL jobs.

# Reading the scenario

| WHEN THE QUESTION SAYS | IT IS TESTING |
|---|---|
| Delete one customer's rows across the lake | Iceberg tables |
| Iceberg without maintenance jobs | Amazon S3 Tables |
| Hundreds of tables, share by classification | Lake Formation LF-tags |
| Partner must not see our raw records | AWS Clean Rooms |
| Hundreds of analysts, dashboards all day | Redshift, not Athena |
| Existing Kafka clients and connectors | Amazon MSK |

ON THE EXAM

Analytics questions turn on change, scale of governance, trust and concurrency.

> Meridian Freight's 200 TB data lake is Parquet in S3, partitioned by date. Privacy requests require deleting individual customers' records, which today means rewriting whole partitions overnight.
>
> Several ingestion jobs write to the same datasets concurrently.

## What should the solutions architect recommend?

A. Keep Parquet and rewrite affected partitions with a nightly Glue job

B. Convert the datasets to Apache Iceberg tables and run row-level DELETE statements

C. Filter deleted customers at read time with S3 Object Lambda

D. Load the lake into Amazon Redshift and delete there

◆ PAUSE AND DECIDE

## What should the solutions architect recommend?

A Nightly partition rewrites

*The expensive process the scenario describes, and still unsafe with concurrent writers.*

B Iceberg with row-level DELETE

Deletes touch only affected files, with transactions for concurrent writers.

C S3 Object Lambda

*Hides data rather than deleting it, and is closed to new customers.*

D Move to Redshift

*Abandons the open lake every other engine reads.*

THE SIGNAL

Row-level deletes plus concurrent writers on S3. Both are what a table format exists to provide.

> Meridian Freight's analytics team wants to adopt Apache Iceberg for new datasets. A trial in a general purpose bucket worked, but query performance fell as small files accumulated.
>
> The team does not want to build or schedule maintenance jobs.

**What should the solutions architect recommend?**

A. Schedule EMR jobs to compact files and expire snapshots

B. Switch back to plain Parquet files

C. Store the tables in an Amazon S3 table bucket

D. Move the datasets to Amazon DynamoDB

◆ PAUSE AND DECIDE

## What should the solutions architect recommend?

A Scheduled EMR maintenance

*Fixes the files, but it is exactly the job the team will not build.*

B Back to Parquet

*Gives up the reasons for adopting Iceberg.*

C S3 table bucket

Iceberg with compaction and snapshot cleanup run automatically by AWS.

D DynamoDB

*A key-value database, not an analytics table store.*

THE SIGNAL

Small-file decay plus no appetite for maintenance jobs is the S3 Tables brief.

> Meridian Freight's central data account holds 600 tables. Forty consumer accounts in the organisation need access according to each table's sensitivity: public, internal or restricted.
>
> New tables are added weekly and must be shared correctly without anyone editing grants.

## What should the solutions architect implement?

A S3 bucket policies granting each account access to table prefixes

B Lake Formation named-resource grants for every table to every account

C Copy each permitted table into each consumer account

D Lake Formation LF-tags on tables, with tag expressions granted to consumer accounts

◆ PAUSE AND DECIDE

## What should the solutions architect implement?

**A** Bucket policies

*Object-level access, no column or row control, and policy size limits at this scale.*

**B** Named grants

*Thousands of grants, and every new table needs new ones.*

**C** Copies per account

*Forty copies to keep in step and govern.*

**D** LF-tags

Tag the table once; access follows from its classification.

THE SIGNAL

Access by classification, and new tables shared without editing grants: tag-based access control.

> Meridian Freight and a retail partner want to know how many customers they share and the shipment volume to those customers by region. Each company has its customer data in its own AWS account.
>
> Neither company may see the other's customer records, and results must never identify an individual.

**Which solution meets these requirements?**

A. An AWS Clean Rooms collaboration with aggregation analysis rules and a minimum aggregation threshold

B. A Lake Formation cross-account share of each company's customer table

C. Exchange hashed email addresses through a shared S3 bucket

D. Redshift data sharing between the two companies' warehouses

◆ PAUSE AND DECIDE

## Which solution meets these requirements?

**A** Clean Rooms with aggregation rules

Joint counts by region come out; raw records never leave either account.

**B** Lake Formation share

*Gives the partner readable access to the records it must not see.*

**C** Hashed emails in S3

*Hashes of common data can be reversed by matching, so records leak.*

**D** Redshift data sharing

*Shares readable tables, which is the same problem as option B.*

THE SIGNAL

Joint answers without exposing either side's records is the purpose of Clean Rooms.

> About 300 Meridian Freight analysts use dashboards over shipment data all working day, with complex joins across eight large tables. The dashboards run on Athena against the lake.
>
> Query charges have tripled and users complain of slow dashboards.

**What should the solutions architect recommend?**

A. Create more Athena workgroups to spread the load

B. Serve the dashboards from Amazon Redshift, using Spectrum for older history in the lake

C. Run Presto on a long-running Amazon EMR cluster

D. Index the tables in Amazon OpenSearch Service

◆ PAUSE AND DECIDE

## What should the solutions architect recommend?

A More Athena workgroups

*Organises and limits spend; each query still scans and costs the same.*

B Redshift with Spectrum

Built for concurrent, join-heavy dashboards; history stays in the lake.

C Presto on EMR

*A cluster you tune and operate, to rebuild what a warehouse provides.*

D OpenSearch

*Search and log analytics, not relational joins across tables.*

THE SIGNAL

Sustained concurrency and complex joins are a warehouse workload. Spectrum means the lake is not abandoned.

> Meridian Freight runs a self-managed Apache Kafka cluster on premises, with dozens of producers, consumers and Kafka Connect connectors. Throughput is growing fast and broker storage management takes constant effort.
>
> The applications do not use Kafka Streams, and must not be rewritten.

**Where should the company move its streaming platform?**

A Amazon Kinesis Data Streams in on-demand mode

B Amazon MSK with Standard brokers and provisioned storage

C Amazon MSK with Express brokers

D Self-managed Kafka on EC2 with EBS volumes

◆ PAUSE AND DECIDE

## Where should the company move its streaming platform?

A Kinesis Data Streams

*Every Kafka client and connector would have to be rewritten.*

B MSK Standard brokers

*Kafka-compatible, but storage still has to be provisioned and watched.*

C MSK Express brokers

Kafka APIs unchanged, higher throughput per broker, no storage to manage.

D Kafka on EC2

*Moves the same storage burden into AWS.*

THE SIGNAL

Existing Kafka keeps MSK. Growing throughput and storage pain point to Express brokers.

# What to carry out of this module

- **Iceberg** for row-level change and concurrent writers; **S3 Tables** to skip maintenance.
- **Lake Formation LF-tags** for governance at scale; RAM for cross-account.
- **Clean Rooms** when partners must not see each other's raw records.
- **Athena** for occasional queries; **Redshift** for concurrent dashboards.
- **MSK** for existing Kafka; **Kinesis** for AWS-native; **AppFlow** for SaaS.

> ON THE EXAM
>
> This whole module is new to the professional exam. Older SAP courses do not teach it.

MODULE 14 · DOMAIN 2 - SECURITY, COMPLIANCE, AND GOVERNANCE

# Identity Federation at Scale

One identity, proven once by the provider you already trust, accepted across every account.

DOMAIN 2 of 5 EXAM WEIGHT 25% MODULE 14 of 52

admin@sthithapragna.com

Federation means AWS **never holds the password**. It trusts a provider that proves who you are.

# The standards and what each carries

| STANDARD | CARRIES | TYPICAL USE |
|---|---|---|
| SAML 2.0 | A signed assertion of who the user is | Workforce sign-in from Okta, Entra ID, ADFS |
| OpenID Connect | A signed identity token (JWT) | Workloads such as CI pipelines; app sign-in |
| SCIM | User and group records | Provisioning and deprovisioning automatically |
| OAuth 2.0 | Delegated access tokens | Apps acting for users; module 15 |

ON THE EXAM

SAML and OIDC prove identity. SCIM keeps the user list in step. They solve different problems.

# IAM Identity Center or SAML federation per account?

IAM SAML PROVIDER PER ACCOUNT

## One trust per account

- A SAML provider and roles in every account
- Users pick an account and role at the IdP
- Changes repeated across every account
- Workable for a handful of accounts

IAM IDENTITY CENTER

## One trust for the organisation

- One connection to the identity provider
- Permission sets become roles in each account
- Assign groups to accounts centrally
- Access portal, CLI and AWS applications

THE TIEBREAKER

Many accounts means Identity Center. Per-account SAML providers do not scale with an organisation.

# Identity Center facts the exam checks

- **Organization instance** in the management account; administration can be delegated.
- **Account instances** serve AWS applications in one account, not multi-account access.
- **Permission sets** become IAM roles. Assign them to **groups**, not individuals.
- **Multi-Region replication** since February 2026, with a multi-Region KMS key.
- Administration stays in the **primary Region**; access continues if it is disrupted.

> ON THE EXAM
>
> Older material says an instance lives in one Region only. Since 2026 it can replicate to others.

# Where the identities come from

| IDENTITY SOURCE | CHOOSE IT WHEN | WATCH FOR |
|---|---|---|
| Identity Center directory | No corporate directory, small organisation | Another user store to run |
| Active Directory | Corporate AD already holds the workforce | Managed Microsoft AD or AD Connector |
| External identity provider | Okta, Entra ID or Ping is the source of truth | Use SCIM, or provisioning is manual |

ON THE EXAM

Identity Center has exactly one identity source. Choose the one that is already authoritative.

# Managed Microsoft AD or AD Connector?

AWS MANAGED MICROSOFT AD

## A real directory in AWS

- Windows Server AD run by AWS
- Trusts with on-premises forests
- Shareable with other accounts
- Needed by FSx and RDS for SQL Server

AD CONNECTOR

## A proxy to your AD

- Stores no directory data in AWS
- Your password and lockout policies apply
- Cannot be shared across accounts
- Fails if the link to AD fails

THE TIEBREAKER

No directory data may live in AWS means AD Connector. Sharing or trusts mean Managed Microsoft AD.

# SCIM: why provisioning matters

- **Automatic create, update and delete** of users and groups from the identity provider.
- **Leavers lose access** as soon as they are disabled at the provider.
- **Group membership** changes flow through, so assignments stay correct.
- **Without SCIM,** users must be created by hand before they can be assigned.
- SAML still handles sign-in. SCIM handles who exists.

> ON THE EXAM
>
> Leavers keeping access, or users missing until someone creates them, are SCIM problems.

# OpenID Connect for workloads

- **IAM OIDC identity provider** trusts tokens from an issuer such as GitHub Actions.
- **AssumeRoleWithWebIdentity** exchanges the token for short-lived credentials.
- **Condition on the sub claim** to restrict which repository and branch may assume the role.
- **A trust policy without a sub condition** lets any repository on that issuer in.
- **IAM Roles Anywhere** covers workloads with X.509 certificates instead, module 17.

> ON THE EXAM
>
> Long-lived access keys in a pipeline are the anti-pattern. OIDC federation removes them.

# Identity that travels into the data

- **Trusted identity propagation** carries the user's identity into data services.
- Targets include **Redshift, Athena, EMR, Lake Formation and S3 Access Grants**.
- **CloudTrail records the person,** not only the application's role.
- **Attributes for access control** pass IdP attributes as session tags for ABAC.
- Without propagation, every analyst looks identical in the audit trail.

> ON THE EXAM
>
> If the audit trail shows the application role instead of the person, the answer is trusted identity propagation.

# Reading the scenario

| WHEN THE QUESTION SAYS | IT IS TESTING |
|---|---|
| Workforce access to many accounts | Identity Center with permission sets |
| Leavers keep access for days | SCIM provisioning |
| No directory data may be stored in AWS | AD Connector |
| Pipeline uses stored access keys | OIDC federation with a sub condition |
| Keep access if the home Region fails | Identity Center multi-Region replication |
| Audit shows the app role, not the person | Trusted identity propagation |

ON THE EXAM

Identity questions turn on who the identity is, where it comes from, and how long it lives.

> Meridian Freight has 120 AWS accounts and uses Okta as its workforce identity provider. Engineers need console and CLI access to different accounts according to their team and role.
>
> The security team wants one place to manage access and the LEAST operational overhead.

**What should the solutions architect implement?**

A. An IAM SAML provider and roles in every account, deployed with StackSets

B. IAM Identity Center with Okta as the identity source, SCIM, and permission sets assigned to groups

C. IAM users in each account, synchronised from Okta by a script

D. An Amazon Cognito user pool federated with Okta

◆ PAUSE AND DECIDE

## What should the solutions architect implement?

A. SAML provider per account

*Works, but 120 trusts and role sets to maintain, and no central assignment view.*

B. Identity Center with Okta and SCIM

One trust, groups from Okta, permission sets assigned centrally.

C. Synchronised IAM users

*Recreates long-lived credentials in 120 accounts.*

D. Cognito user pool

*For customers of an application, not workforce access to AWS accounts.*

THE SIGNAL

Workforce, many accounts, existing IdP, one place to manage. That is Identity Center's whole purpose.

> Meridian Freight connected IAM Identity Center to Microsoft Entra ID for SAML sign-in. Administrators create Identity Center users by hand when someone joins.
>
> An audit found that people who left the company could still reach AWS accounts days after being disabled in Entra ID.

## What should the solutions architect do?

A Reduce the permission set session duration to one hour

B Require MFA at every sign-in

C Enable SCIM automatic provisioning from Entra ID to Identity Center

D Run a weekly script that deletes Identity Center users not found in Entra ID

◆ PAUSE AND DECIDE

## What should the solutions architect do?

A Shorter sessions

*Limits each session, but the stale user records remain.*

B MFA everywhere

*Good practice, unrelated to removing departed users.*

C SCIM provisioning

Disabling a user in Entra ID removes them from Identity Center automatically.

D Weekly cleanup script

*Still leaves access for up to a week, and is custom code to maintain.*

THE SIGNAL

Manual user creation is the planted detail. Lingering leavers are a provisioning problem.

> Meridian Freight wants employees to sign in to IAM Identity Center with their existing on-premises Active Directory credentials. Company policy forbids storing any directory data, including password hashes, in the cloud.
>
> The data centre is connected to AWS over redundant Direct Connect links.

**Which directory option should the solutions architect use?**

A. AD Connector pointing at the on-premises domain controllers

B. AWS Managed Microsoft AD with a trust to the on-premises forest

C. Simple AD synchronised from on premises

D. Domain controllers on EC2 replicating from on premises

◆ PAUSE AND DECIDE

## Which directory option should the solutions architect use?

**A** AD Connector

Proxies authentication to on premises and stores no directory data in AWS.

**B** Managed Microsoft AD with trust

*A full directory in AWS, which the policy forbids.*

**C** Simple AD

*Holds its own directory, cannot trust or sync, and is closed to new customers.*

**D** Domain controllers on EC2

*Replicates the whole directory, hashes included, into AWS.*

THE SIGNAL

No directory data in the cloud rules out every option except the proxy.

> Meridian Freight's GitHub Actions workflows deploy to AWS using an IAM user's access keys stored as repository secrets. Rotating them is error-prone and one key was recently exposed in a log.
>
> Only the main branch of the infrastructure repository may deploy to production.

**What should the solutions architect implement?**

A Rotate the access keys monthly from Secrets Manager

B An IAM user per workflow with a permissions boundary

C IAM Roles Anywhere with a certificate on each runner

D An IAM OIDC provider for GitHub, and a role trusting only that repository's main branch through the sub claim

◆ PAUSE AND DECIDE

## What should the solutions architect implement?

A **Monthly rotation**
*Keeps long-lived keys; an exposed key is still valid for weeks.*

B **Users with boundaries**
*Limits damage, but multiplies the long-lived keys.*

C **Roles Anywhere**
*For workloads holding certificates from your PKI; hosted runners do not.*

D **OIDC with a sub condition**
No stored keys; each run gets short-lived credentials, only from main.

THE SIGNAL

The pipeline already has an identity token. Trust it, and restrict the sub claim to the repository and branch.

> Meridian Freight's IAM Identity Center organization instance runs in eu-west-1, with Okta as the identity source. A regulator requires that engineers can still reach their AWS accounts if eu-west-1 is disrupted.
>
> The company wants to keep a single place to administer access.

**What should the solutions architect do?**

A. Create a second organization instance of Identity Center in another Region

B. Enable Identity Center replication to an additional Region, using a multi-Region customer managed KMS key

C. Create break-glass IAM users with access keys in every account

D. Delete Identity Center and recreate it in a different Region

◆ PAUSE AND DECIDE

## What should the solutions architect do?

A Second organization instance

*Only one organization instance is allowed per organisation.*

B Multi-Region replication

Entitlements replicate; access continues; administration stays in eu-west-1.

C Break-glass IAM users everywhere

*Emergency access for a few, not workforce access, and many long-lived keys.*

D Recreate elsewhere

*Moves the single point of failure; does not remove it.*

THE SIGNAL

Since February 2026 Identity Center replicates to additional Regions. Older material says this is impossible.

> Meridian Freight's analysts use a BI tool, signed in through IAM Identity Center, to query Athena tables governed by Lake Formation. The tool queries with its own IAM role.
>
> Auditors cannot tell which analyst ran a query, and Lake Formation cannot apply per-team permissions.

**What should the solutions architect implement?**

A. A separate IAM role for each analyst, chosen by the BI tool

B. CloudTrail data events for the Athena workgroup

C. Trusted identity propagation from Identity Center through the BI tool to Athena and Lake Formation

D. A session tag on the BI tool's role naming the current user

◆ PAUSE AND DECIDE

## What should the solutions architect implement?

A **Role per analyst**

*Thousands of roles to manage, and grants duplicated per person.*

B **CloudTrail data events**

*Records more calls, but still by the tool's role.*

C **Trusted identity propagation**

The analyst's identity reaches Athena and Lake Formation, and CloudTrail.

D **Session tag with user name**

*Self-asserted by the tool, and Lake Formation does not grant on it.*

THE SIGNAL

The person is lost at the application boundary. Propagation carries them through it.

# What to carry out of this module

- **SAML and OIDC prove identity; SCIM provisions it.** Lingering leavers mean missing SCIM.
- **Many accounts mean Identity Center,** with permission sets assigned to groups.
- **AD Connector** stores nothing in AWS; **Managed Microsoft AD** shares and trusts.
- **OIDC for pipelines,** with a sub condition. No stored access keys.
- **Multi-Region Identity Center** since 2026; **propagation** for person-level audit.

> ON THE EXAM
>
> Stale fact: an Identity Center instance is no longer limited to one Region.

MODULE 15 · DOMAIN 2 - SECURITY, COMPLIANCE, AND GOVERNANCE

# Application Authentication and Authorisation

Sign users and services in with tokens, decide what they may do in one policy engine, and give pods their own identity.

DOMAIN 2 of 5 EXAM WEIGHT 25% MODULE 15 of 52

admin@sthithapragna.com

Authentication answers **who you are**.
Authorisation answers **what you may do**.
Put each where it belongs.

# Cognito user pool or identity pool?

USER POOL

## Who are you?

- Sign-up, sign-in, MFA, account recovery
- Social, SAML and OIDC federation
- Issues ID and access tokens
- Groups become claims in tokens

IDENTITY POOL

## What may you touch in AWS?

- Exchanges a token for AWS credentials
- Maps users to IAM roles
- Policy variables scope each user
- Optional unauthenticated guest role

THE TIEBREAKER

If users call AWS services directly, such as S3 from a mobile app, add an identity pool.

# OAuth 2.0 flows worth knowing

| FLOW | WHO USES IT | NOTE |
|---|---|---|
| Authorization code with PKCE | Web and mobile apps signing in users | The default for user sign-in |
| Client credentials | Service to service, no user | Cognito charges per token issued |
| Refresh token | Apps renewing access quietly | Revocable; keeps sessions short |
| Scopes | Any token | Limit what the token allows |

ON THE EXAM

No human in the loop means client credentials. A person signing in means authorization code with PKCE.

# Cognito user pool feature plans

| PLAN | ADDS |
| --- | --- |
| Lite | Core sign-up and sign-in, social and enterprise federation |
| Essentials | Default: managed login, passwordless, access token customisation |
| Plus | Threat protection: adaptive authentication, compromised credentials |

ON THE EXAM

Risk-based MFA and compromised-password detection are Plus features. Passkeys and managed login are Essentials.

# Authorising requests at API Gateway

| AUTHORIZER | VALIDATES | CHOOSE IT WHEN |
|---|---|---|
| Cognito authorizer | User pool tokens and scopes | REST API, users in Cognito |
| JWT authorizer | Any OIDC or OAuth issuer | HTTP API, standard tokens |
| IAM authorization | SigV4-signed AWS principals | Callers are AWS roles |
| Lambda authorizer | Anything your code checks | Custom logic or Verified Permissions |

ON THE EXAM

Fine-grained rules beyond group membership are usually a Lambda authorizer calling Verified Permissions.

# Rules in code, or in Verified Permissions?

AUTHORISATION IN CODE

## Scattered logic

- Rules repeated in every service
- Changes need a deployment each time
- Hard for auditors to review
- Drifts between services

AMAZON VERIFIED PERMISSIONS

## One policy engine

- Cedar policies in a policy store
- Services ask IsAuthorized at runtime
- Role and attribute based rules
- Policies reviewable and versioned centrally

THE TIEBREAKER

The same permission rules duplicated across services, or auditors needing to read them, means Verified Permissions.

# Verified Permissions in practice

- **Policy store** holds Cedar policies and a schema of principals, actions and resources.
- **Identity source:** a Cognito user pool or OIDC provider, so tokens become principals.
- **API-linked policy stores** generate a Lambda authorizer for API Gateway.
- **Rules on attributes:** region, role, amount, tenant, combined with groups.
- **Authorizer decisions are cached** for 120 seconds by default; revocation lags.

ON THE EXAM

Verified Permissions decides application actions. IAM still decides access to AWS resources.

Each pod should have its own AWS permissions, not borrow the node's.

# EKS Pod Identity or IRSA?

EKS POD IDENTITY

## AWS's recommended default

- No OIDC provider per cluster
- Roles trust one service principal
- Same role reused across clusters
- Session tags for ABAC

IAM ROLES FOR SERVICE ACCOUNTS

## Still needed in places

- OIDC provider for each cluster
- Trust policy names each cluster
- Required on Fargate and Windows
- Also EKS Anywhere, self-managed Kubernetes

THE TIEBREAKER

Pod Identity whenever supported. Fargate pods, Windows nodes and EKS Anywhere still need IRSA.

# Reading the scenario

| WHEN THE QUESTION SAYS | IT IS TESTING |
|---|---|
| Mobile users upload straight to S3 | User pool plus identity pool |
| Partner backends, no human user | Client credentials grant with scopes |
| Risk-based MFA, compromised passwords | Cognito Plus plan |
| Same permission rules in many services | Verified Permissions with Cedar |
| Cluster upgrades break role trust | EKS Pod Identity |
| Pods on Fargate need AWS access | IRSA, not Pod Identity |

ON THE EXAM

Authentication questions turn on who the caller is. Authorisation questions turn on where the rules live.

> Meridian Freight's driver app lets drivers sign in and upload proof-of-delivery photos straight to Amazon S3 using the AWS SDK, to avoid routing large files through the backend.
>
> Each driver must only be able to write to their own prefix in the bucket.

## What should the solutions architect implement?

A. A Cognito user pool for sign-in, and an identity pool whose role policy uses the identity ID as a prefix variable

B. A Cognito user pool with an API Gateway Cognito authorizer

C. An IAM user for each driver with an access key in the app

D. An identity pool with unauthenticated access only

◆ PAUSE AND DECIDE

## What should the solutions architect implement?

**A** User pool plus identity pool

Temporary AWS credentials per driver, confined to their own prefix by a policy variable.

**B** API Gateway authorizer

*Protects an API, but uploads would route through the backend, which the design avoids.*

**C** IAM user per driver

*Long-lived keys inside an app on thousands of phones.*

**D** Unauthenticated only

*No sign-in, so drivers cannot be told apart or confined.*

THE SIGNAL

Users calling an AWS service directly is the identity pool's purpose. The policy variable does the confinement.

> Three logistics partners' backend systems will call Meridian Freight's rate API automatically. No people are involved in these calls.
>
> Each partner must receive tokens limited to the rate endpoints, and tokens must expire within an hour.

**What should the solutions architect implement?**

A. API keys in an API Gateway usage plan for each partner

B. An IAM user with access keys for each partner

C. Managed login pages where partners sign in each day

D. A Cognito app client per partner using the client credentials grant, with custom scopes for the rate endpoints

◆ PAUSE AND DECIDE

## What should the solutions architect implement?

A **API keys**

*Identify callers for quotas, but never expire and are not an authorisation mechanism.*

B **IAM users**

*Long-lived keys, and partners become principals in your account.*

C **Managed login**

*For people. These are machines.*

D **Client credentials with scopes**

Short-lived tokens per partner, limited by scope to the rate endpoints.

THE SIGNAL

Machine to machine, expiring tokens, limited scope: the client credentials grant.

> Meridian Freight's customer portal uses a Cognito user pool on the Essentials plan. It is facing credential-stuffing attacks using passwords leaked from other sites.
>
> The company wants extra verification only when a sign-in looks risky, and to block known compromised passwords.

## What should the solutions architect do?

A. Add an AWS WAF rate-based rule to the sign-in endpoint

B. Turn on passwordless sign-in with passkeys

C. Move the user pool to the Plus plan and enable threat protection with adaptive authentication

D. A pre-authentication Lambda trigger that counts failed attempts

◆ PAUSE AND DECIDE

## What should the solutions architect do?

A **WAF rate limit**

*Slows bulk attempts, but cannot judge risk per sign-in or spot leaked passwords.*

B **Passkeys**

*Strong where adopted, but existing password users remain exposed.*

C **Plus plan threat protection**

Risk-based extra verification and compromised-credential checks, built in.

D **Pre-auth trigger**

*Custom counting code, with no risk scoring or leaked-password data.*

THE SIGNAL

Adaptive authentication and compromised-credential detection are Plus plan features, not Essentials.

> Rules deciding which Meridian Freight dispatchers may approve which shipments depend on the dispatcher's region, role and the shipment's value. The rules are coded separately in six microservices and have drifted apart.
>
> Auditors want to review the rules in one place, and changes should not require redeploying services.

## What should the solutions architect recommend?

A. A shared authorisation library imported by each service

B. Amazon Verified Permissions, with the rules as Cedar policies and services calling it for decisions

C. IAM policies attached to each dispatcher's role

D. Cognito groups for each combination of region and role

◆ PAUSE AND DECIDE

## What should the solutions architect recommend?

A Shared library

*Reduces drift, but every rule change means redeploying six services.*

B Verified Permissions

One reviewable policy store; services ask at runtime; no redeploy for rule changes.

C IAM policies

*IAM governs AWS API calls, not application objects such as a shipment's value.*

D Cognito groups

*Cannot express a rule on the shipment's value, and multiplies groups.*

THE SIGNAL

Application rules on attributes, reviewed centrally, changed without redeploys. That is a policy engine.

> Meridian Freight runs 30 EKS clusters on Linux EC2 nodes and replaces clusters during upgrades. Each replacement requires editing the trust policy of every IAM role used by IRSA.
>
> The platform team wants pod-level permissions without per-cluster trust changes.

**What should the solutions architect recommend?**

A. EKS Pod Identity, with roles trusting the EKS pods service principal and associations per service account

B. Keep IRSA and script the trust policy updates

C. Grant all required permissions to the node instance role

D. Store access keys in Kubernetes secrets

◆ PAUSE AND DECIDE

## What should the solutions architect recommend?

**A** EKS Pod Identity

Trust names a service principal, not a cluster, so new clusters need no edits.

**B** Scripted IRSA updates

*Automates the problem instead of removing it.*

**C** Node instance role

*Every pod on the node gets every permission. Not pod-level.*

**D** Keys in secrets

*Long-lived credentials inside the cluster.*

THE SIGNAL

IRSA trust names each cluster's OIDC provider. Pod Identity's trust names none, which is the fix.

> A Meridian Freight team runs a new EKS workload entirely on AWS Fargate. Its pods need to read from one DynamoDB table and write to one SQS queue.
>
> Each pod must have only those permissions, without long-lived credentials.

## How should the pods obtain AWS credentials?

A. EKS Pod Identity associations for the service account

B. The Fargate pod execution role, with DynamoDB and SQS permissions added

C. IAM roles for service accounts, using the cluster's OIDC provider

D. Access keys mounted from a Kubernetes secret

◆ PAUSE AND DECIDE

# How should the pods obtain AWS credentials?

A **EKS Pod Identity**

*Not supported for pods running on Fargate.*

B **Pod execution role**

*Used by Fargate to pull images and write logs, not by the application.*

C **IRSA**

Supported on Fargate, scoped per service account, temporary credentials.

D **Keys in a secret**

*Long-lived credentials, which the scenario rules out.*

THE SIGNAL

Fargate is the deciding word. Pod Identity is the default elsewhere, but not there.

# What to carry out of this module

- **User pool proves who; identity pool grants AWS access** when users call AWS directly.
- **Client credentials** for machines; **authorization code with PKCE** for people.
- **Plus plan** for adaptive authentication and compromised-password detection.
- **Verified Permissions** for application rules, written in Cedar, reviewed centrally.
- **Pod Identity by default; IRSA** on Fargate, Windows and EKS Anywhere.

> ON THE EXAM
>
> IAM governs AWS APIs. Verified Permissions governs your application's own actions.

MODULE 16 · DOMAIN 2 - SECURITY, COMPLIANCE, AND GOVERNANCE

# Least Privilege and Cross-Account Access

Grant only what is used, prove it with Access Analyzer, and cross account boundaries without opening doors you did not mean to.

DOMAIN 2 of 5 EXAM WEIGHT 25% MODULE 16 of 52

admin@sthithapragna.com

Least privilege is a **loop**, not a document. Grant, observe, refine, and guard the next change.

# Who has to say yes?

| REQUEST | POLICIES THAT MUST ALLOW |
| --- | --- |
| Same account | Identity policy or resource policy |
| Cross-account, resource policy | Both: caller's identity policy and the resource policy |
| Cross-account, assume role | Caller may AssumeRole, and the role trusts the caller |
| Any request | No explicit deny, and SCPs, RCPs and boundaries allow |

ON THE EXAM

Within one account, either side can grant. Across accounts, both sides must grant.

# Assume a role, or use a resource policy?

ASSUME A ROLE

## Become a principal there

- Works for every service
- Gives up the caller's own permissions
- Trust policy controls who may enter
- Session is logged in the target account

RESOURCE-BASED POLICY

## Reach in as yourself

- S3, KMS, SQS, SNS, Lambda and others
- Keeps the caller's own permissions
- Needed to copy between two accounts
- Resource owner names allowed principals

THE TIEBREAKER

Moving data between your resource and theirs in one call needs a resource policy, because a role swaps permissions.

# Organisation-aware conditions

- **aws:PrincipalOrgID** in a resource policy: any principal in my organisation.
- **aws:PrincipalOrgPaths**: only principals under a given OU.
- **aws:ResourceOrgID** in an identity policy: only resources in my organisation.
- **aws:SourceOrgID**: for AWS service principals acting for my organisation.
- New accounts are covered automatically; no account ID lists to maintain.

> ON THE EXAM
>
> Listing account IDs in a policy is the distractor. An organisation condition is the scalable answer.

# Which confused deputy defence?

THIRD PARTY ASSUMES YOUR ROLE

## sts:ExternalId

- Vendor's account is the principal
- Unique ID per customer, set by vendor
- Condition in the role's trust policy
- Stops one customer naming another's role

AWS SERVICE ACTS ON YOUR BEHALF

## aws:SourceArn and SourceAccount

- Service principal such as sns.amazonaws.com
- Condition in the resource policy
- Pins the exact bucket, topic or rule
- Stops another account's resource using it

THE TIEBREAKER

ExternalId is for a vendor assuming a role. SourceArn and SourceAccount are for AWS service principals.

# IAM Access Analyzer, three analysers

| ANALYSER | ANSWERS | COST |
| --- | --- | --- |
| External access | What is shared outside my zone of trust? | Free |
| Internal access | Which of my principals can reach this resource? | Per monitored resource |
| Unused access | Which roles, keys and permissions go unused? | Per role or user |

ON THE EXAM

Set the zone of trust to the organisation, so sharing between member accounts is not reported as external.

# Closing the least-privilege loop

| TOOL | WHEN IT ACTS | WHAT IT DOES |
|---|---|---|
| Policy generation | After activity | Drafts a policy from CloudTrail usage |
| Unused access findings | Continuously | Recommends permissions to remove |
| Policy validation | While authoring | Flags errors and security warnings |
| Custom policy checks | In the pipeline | Blocks new access, public access, named actions |

ON THE EXAM

Stop a bad policy before deployment with custom policy checks. Find drift afterwards with analyser findings.

# Delegating administration safely

PERMISSIONS BOUNDARY

## A ceiling on a principal

- Attached to a role or user
- Effective access is the intersection
- Grants nothing by itself
- Lets developers create roles safely

SCPS AND RCPS

## A ceiling on accounts

- Attached to the organisation, OU or account
- Apply to every principal or resource
- Grant nothing by itself
- Management account is not affected

THE TIEBREAKER

Let teams create their own roles, but require a boundary on every role they create.

# Reading the scenario

| WHEN THE QUESTION SAYS | IT IS TESTING |
|---|---|
| Vendor assumes a role in many customers' accounts | sts:ExternalId |
| Service principal writes to your topic or bucket | aws:SourceArn, aws:SourceAccount |
| Share with every account, including future ones | aws:PrincipalOrgID |
| Developers create roles without escalation | Required permissions boundary |
| Permissions granted but never used | Unused access analyser |
| Block risky policies before deployment | Custom policy checks |

ON THE EXAM

Detective findings explain what is wrong now. Preventive checks stop the next change.

> A monitoring vendor needs read access to Meridian Freight's AWS accounts. The vendor's platform assumes a role in each customer's account from its own AWS account.
>
> Meridian's security team is worried that another vendor customer could configure the platform to read Meridian's data.

**What should the solutions architect add to the role?**

A An aws:SourceArn condition naming the vendor's platform

B An aws:PrincipalOrgID condition for Meridian's organisation

C IAM user access keys issued to the vendor instead of a role

D An sts:ExternalId condition in the trust policy, using the unique ID the vendor assigned to Meridian

◆ PAUSE AND DECIDE

## What should the solutions architect add to the role?

A aws:SourceArn

*For AWS service principals, not a vendor's own account assuming a role.*

B aws:PrincipalOrgID

*The vendor is outside Meridian's organisation, so this would lock it out.*

C IAM user keys

*Long-lived secrets, and no protection against the confused deputy.*

D sts:ExternalId

The platform only assumes the role when acting for the customer holding that ID.

THE SIGNAL

A third party assuming roles across many customers is the textbook case for an external ID.

> Meridian Freight wants application teams to create IAM roles for their own Lambda functions without waiting for the central security team.
>
> Teams must not be able to create a role with more permissions than an approved set, or remove that limit later.

**What should the solutions architect implement?**

A. Allow iam:CreateRole only when the iam:PermissionsBoundary condition names an approved boundary, and deny changing or deleting boundaries

B. An SCP that denies iam:CreateRole in all application accounts

C. AdministratorAccess for team leads, with CloudTrail alerts on IAM changes

D. A weekly review of new roles by the security team

◆ PAUSE AND DECIDE

## What should the solutions architect implement?

**A** Required boundary

Self-service role creation, capped by the boundary, which teams cannot remove.

**B** SCP deny

*Removes self-service entirely, failing the first requirement.*

**C** Admin plus alerts

*Detects escalation after it happens rather than preventing it.*

**D** Weekly review

*A week of exposure, and still a manual gate.*

THE SIGNAL

Delegate role creation, require the boundary, protect the boundary.

> Meridian Freight has 180 accounts in AWS Organizations. An audit found many roles with broad permissions copied from templates years ago.
>
> The security team wants an ongoing, organisation-wide view of unused roles and unused permissions, with suggested policy changes.

## What should the solutions architect recommend?

A. Generate a policy from CloudTrail for each role, one role at a time

B. Download the IAM credential report from each account monthly

C. An AWS Config rule that flags roles with AdministratorAccess

D. An unused access analyser with the organisation as its zone of trust, using its recommendations to remove permissions

◆ PAUSE AND DECIDE

## What should the solutions architect recommend?

A Per-role policy generation

*Useful for one role; not an ongoing view across 180 accounts.*

B Credential report

*Covers users and keys only, per account, with no permission detail.*

C Config rule

*Finds one named policy, not permissions that go unused.*

D Organisation unused access analyser

Continuous findings for every role, with removal recommendations.

THE SIGNAL

Ongoing, organisation-wide, unused, with recommendations. Every word points to the unused access analyser.

> A central S3 bucket holds Meridian Freight's shared reference data. Every account in the organisation must be able to read it, including accounts created in future.
>
> The platform team does not want to edit the bucket policy whenever an account is added.

## What should the bucket policy use?

A Allow s3:GetObject to any principal, with an aws:PrincipalOrgID condition matching the organisation ID

B A list of every member account ID as principals

C Share the bucket with the organisation through AWS RAM

D Make the bucket public and restrict it with an S3 gateway endpoint

◆ PAUSE AND DECIDE

# What should the bucket policy use?

**A** aws:PrincipalOrgID

Every current and future account in the organisation, no edits.

**B** List of account IDs

*Works today; needs an edit for every new account.*

**C** AWS RAM

*RAM does not share S3 buckets; access is by bucket policy.*

**D** Public bucket

*Public access, which Block Public Access should prevent anyway.*

THE SIGNAL

Future accounts, no edits. That is an organisation condition, not a list.

> Meridian Freight deploys IAM and resource policies through a CI/CD pipeline. A recent change made a bucket public, and another granted s3:DeleteBucket to an application role.
>
> The team wants the pipeline to fail such changes before they are deployed.

**What should the solutions architect add to the pipeline?**

A. An external access analyser that alerts on new public findings

B. An SCP denying s3:DeleteBucket across the organisation

C. IAM Access Analyzer custom policy checks, using CheckNoPublicAccess and CheckAccessNotGranted for the listed actions

D. A template linter that checks policy syntax

◆ PAUSE AND DECIDE

## What should the solutions architect add to the pipeline?

A External access analyser

*Detective: reports after the bucket is already public.*

B SCP deny

*Blocks one action everywhere, not public access, and not a pipeline gate.*

C Custom policy checks

Fails the build on public access or on the named actions.

D Syntax linter

*Valid syntax can still grant dangerous access.*

THE SIGNAL

Before deployment means preventive. Analyser findings arrive after deployment.

> An S3 bucket in Meridian Freight's account sends event notifications to an SNS topic. The topic policy currently allows the s3.amazonaws.com service principal to publish.
>
> The security team wants only that one bucket, in Meridian's own account, to be able to publish through S3.

**What should the solutions architect add to the topic policy?**

A aws:SourceArn matching the bucket ARN and aws:SourceAccount matching Meridian's account

B An sts:ExternalId condition

C An aws:PrincipalOrgID condition for Meridian's organisation

D Replace the service principal with Meridian's account root

◆ PAUSE AND DECIDE

## What should the solutions architect add to the topic policy?

**A** SourceArn and SourceAccount

Pins the service's actions to Meridian's own bucket.

**B** ExternalId

*For third parties assuming a role, not service principals.*

**C** PrincipalOrgID

*A service principal is not in your organisation, so this blocks the bucket.*

**D** Account root

*The publisher is the S3 service, which would then be denied.*

THE SIGNAL

Service principal acting for a resource: pin the source. Vendor assuming a role: external ID.

# What to carry out of this module

- **Across accounts both sides must allow.** Within one account either side can.
- **ExternalId** for vendors assuming roles; **SourceArn** for service principals.
- **Organisation conditions** replace account ID lists and cover future accounts.
- **Unused access findings** refine; **custom policy checks** prevent.
- **Delegate with a required boundary**, and deny removing it.

> ON THE EXAM
>
> Least privilege is grant, observe, refine, and guard the next change.

MODULE 17 · DOMAIN 2 - SECURITY, COMPLIANCE, AND GOVERNANCE

# Data Perimeters and Workload Identity

Only trusted identities, on trusted resources, from expected networks. Then give workloads outside AWS a way in without keys.

DOMAIN 2 of 5 EXAM WEIGHT 25% MODULE 17 of 52

admin@sthithapragna.com

A data perimeter allows access only when **trusted identities** reach **trusted resources** from **expected networks**.

# Which control enforces which perimeter?

| CONTROL | ATTACHED TO | ENFORCES |
|---|---|---|
| SCP | Your principals | Only trusted resources, expected networks |
| RCP | Your resources | Only trusted identities, expected networks |
| VPC endpoint policy | Network path | Only trusted identities and resources |

ON THE EXAM

An SCP cannot restrict outsiders, because it only governs your own principals. That is the RCP's job.

# The condition keys behind the perimeter

| KEY | QUESTION IT ANSWERS |
| --- | --- |
| `aws:PrincipalOrgID` | Is the caller one of ours? |
| `aws:ResourceOrgID` | Is the target resource one of ours? |
| `aws:SourceIp, aws:SourceVpc` | Did it come from our network? |
| `aws:PrincipalIsAWSService` | Is AWS calling for itself? Exempt it |
| `aws:ViaAWSService` | Is a service calling on my behalf? Exempt it |

ON THE EXAM

Network conditions without the service exemptions break services that call other services for you.

# Resource control policies

- **Set in Organizations**, like SCPs, but evaluated on access to your resources.
- **Apply to any caller**, including principals outside your organisation.
- **Supported services include** S3, STS, KMS, SQS and Secrets Manager.
- **Cover future resources** without editing each bucket or key policy.
- **Grant nothing**, and do not apply to the management account.

> ON THE EXAM
>
> Stop outsiders reaching any bucket, including ones a team creates tomorrow: an RCP.

# Validating the perimeter holds

- **External access analyser** reports anything shared beyond the zone of trust.
- **Archive rules** mark expected sharing, such as with a known partner.
- **Custom policy checks** stop new external access before deployment.
- **Findings flow to Security Hub** for central triage.

> ON THE EXAM
>
> Perimeter policies prevent. External access findings prove the prevention is working.

# Reaching private apps: VPN or Verified Access?

CLIENT VPN

## Join the network

- User lands inside the VPC
- Reach governed by routes and groups
- Checked once, at connection
- Broad access once connected

AWS VERIFIED ACCESS

## Reach one application

- No network access granted
- Policy per application, in Cedar
- Identity and device posture
- Evaluated on every request

THE TIEBREAKER

Per-application access with device posture and no VPN means Verified Access.

# Verified Access building blocks

| PIECE | WHAT IT DOES |
| --- | --- |
| Trust providers | Identity: IAM Identity Center or OIDC. Device: e.g. CrowdStrike, Jamf |
| Groups and policies | Cedar rules on identity and device claims |
| HTTP endpoints | Web apps behind a load balancer or network interface |
| TCP endpoints | RDS, NLB, network interface or CIDR, for SSH, RDP, databases |
| Connectivity Client | Required on the device for TCP endpoints |

ON THE EXAM

Since February 2025 Verified Access covers TCP as well as web, so SSH and database access are in scope.

A server outside AWS should prove who it is with **something it already has**, not an access key someone pasted in.

# IAM Roles Anywhere

- **Trust anchor:** your certificate authority, AWS Private CA or your own.
- **Profile:** which roles may be assumed, with optional session policies.
- **Credential helper** signs with the private key and returns temporary credentials.
- **Role trust** can match certificate attributes, such as subject or issuer.
- **Revocation** by imported certificate revocation lists.

> ON THE EXAM
>
> The workload already has an X.509 certificate from your PKI: Roles Anywhere.

# Certificate or token?

IAM ROLES ANYWHERE

## Workload holds a certificate

- On-premises servers with corporate PKI
- Devices with X.509 certificates
- Trust anchor is your CA
- Credential helper on the host

OIDC WEB IDENTITY FEDERATION

## Workload holds a token

- Jobs in another cloud with OIDC tokens
- CI systems such as GitHub Actions
- IAM OIDC identity provider
- AssumeRoleWithWebIdentity

THE TIEBREAKER

Match the mechanism to what the workload already has: a certificate, or an OIDC token.

# Reading the scenario

| WHEN THE QUESTION SAYS | IT IS TESTING |
|---|---|
| Credentials used from outside our network | SCP with SourceIp or SourceVpc, service exemptions |
| No outsider may reach any of our buckets | RCP with aws:PrincipalOrgID |
| Traffic through the endpoint, our things only | VPC endpoint policy |
| Contractors, one app, device posture, no VPN | Verified Access |
| On-premises servers with certificates | IAM Roles Anywhere |
| Workload in another cloud with OIDC tokens | Web identity federation |

ON THE EXAM

Name the perimeter first: identity, resource or network. The control follows.

> A Meridian Freight developer's access keys leaked and were used from the internet. Meridian's workloads only call AWS from its own VPCs and its corporate IP range.
>
> The security team wants such credentials to be useless outside those networks, across all accounts, without breaking AWS services that call other services for Meridian.

## What should the solutions architect implement?

A Amazon GuardDuty with automated revocation of affected keys

B An RCP denying access when aws:PrincipalOrgID is not Meridian's organisation

C A bucket policy on each bucket allowing only Meridian's IP range

D An SCP denying requests not from Meridian's VPCs or IP range, exempting aws:PrincipalIsAWSService and aws:ViaAWSService

◆ PAUSE AND DECIDE

## What should the solutions architect implement?

A GuardDuty revocation

*Reacts after misuse is detected; credentials still work until then.*

B RCP on organisation

*The leaked keys belong to Meridian's own principal, so they pass this test.*

C Bucket policies

*Covers S3 only, one bucket at a time, and breaks service calls.*

D SCP network perimeter

Every API, every account, with exemptions for service-to-service calls.

THE SIGNAL

Your own credentials, used from the wrong place: the identity perimeter's network condition, in an SCP.

Meridian Freight has 900 S3 buckets across 60 accounts, and teams create new ones every week. A review found two bucket policies that granted read access to an unknown external account.

Security wants a guarantee that no identity outside the organisation can access any bucket, whatever future bucket policies say.

## What should the solutions architect implement?

A. An SCP denying s3:PutBucketPolicy for all principals

B. An RCP for S3 that denies access unless aws:PrincipalOrgID matches Meridian's organisation, with an exemption for AWS service principals

C. An external access analyser with alerts on new findings

D. An AWS Config rule that removes non-compliant bucket policies

◆ PAUSE AND DECIDE

## What should the solutions architect implement?

A **Deny PutBucketPolicy**

*Stops all bucket policies, including legitimate ones, and does not fix existing ones.*

B **RCP on S3**

Overrides any bucket policy, existing or future, for outside identities.

C **External access analyser**

*Detects, but does not guarantee anything.*

D **Config remediation**

*Leaves a window between the change and the fix.*

THE SIGNAL

Outsiders, every resource, whatever the resource policy says. That is a resource perimeter, and an RCP.

> Meridian Freight's on-premises billing servers call Amazon S3 and Amazon SQS using IAM user access keys stored in configuration files. Each server already has an X.509 certificate issued by Meridian's corporate certificate authority.
>
> The company wants to remove long-lived keys without changing application code.

## What should the solutions architect recommend?

A. IAM Roles Anywhere, with the corporate CA as a trust anchor and the credential helper on each server

B. Rotate the access keys every 30 days with Secrets Manager

C. A Cognito identity pool that issues credentials to the servers

D. AWS Verified Access in front of S3 and SQS

◆ PAUSE AND DECIDE

## What should the solutions architect recommend?

**A** IAM Roles Anywhere

Certificates already exist; the helper supplies temporary credentials to the SDK.

**B** Rotated keys

*Still long-lived keys, and reading the secret needs credentials too.*

**C** Cognito identity pool

*Designed for application users, not servers.*

**D** Verified Access

*For people reaching private applications, not workloads calling AWS APIs.*

THE SIGNAL

Servers outside AWS with certificates from your own CA. That sentence describes Roles Anywhere.

> External auditors need access to Meridian Freight's internal compliance web app and to a reporting database on Amazon RDS, both in private subnets.
>
> Access must be per application, require a healthy managed laptop, and avoid giving the auditors any network access to the VPC.

## What should the solutions architect implement?

A. AWS Client VPN with authorisation rules for the two subnets

B. A public Application Load Balancer with Cognito authentication

C. AWS Verified Access with an identity trust provider and a device trust provider, an HTTP endpoint for the app and an RDS endpoint for the database

D. A bastion host in a public subnet with SSH tunnelling

◆ PAUSE AND DECIDE

## What should the solutions architect implement?

A **Client VPN**

*Gives network access to whole subnets, which the scenario rules out.*

B **Public ALB with Cognito**

*Web only, publicly exposed, and no device posture check.*

C **Verified Access**

Per-app policies with device posture, covering web and RDS endpoints.

D **Bastion host**

*Network access through a hardened host, and no device checks.*

THE SIGNAL

No network access, per application, device posture, and a database. Verified Access with a TCP endpoint.

> A Meridian Freight analytics job runs in another cloud provider and must write results to an S3 bucket in AWS. The job's platform issues it an OIDC identity token automatically.
>
> The company runs no certificate authority and wants no long-lived AWS keys.

**What should the solutions architect recommend?**

A IAM Roles Anywhere with a new AWS Private CA

B An IAM user with keys stored in the other cloud's secret store

C AWS Verified Access in front of the bucket

D An IAM OIDC identity provider for that platform's issuer, and a role assumed with AssumeRoleWithWebIdentity

◆ PAUSE AND DECIDE

## What should the solutions architect recommend?

A Roles Anywhere with Private CA

*Works, but adds a CA and certificate handling the job does not need.*

B IAM user keys

*Long-lived keys, which the scenario rules out.*

C Verified Access

*For people reaching applications, not jobs calling S3.*

D OIDC web identity federation

Uses the token the job already has; no CA, no keys.

THE SIGNAL

The workload already holds an OIDC token. Federate it; do not build a PKI to issue certificates.

Meridian Freight's data processing VPC reaches Amazon S3 through a gateway endpoint and has no internet access.

Security wants traffic through the endpoint to reach only buckets owned by the organisation, and only by identities from the organisation, so that stolen external credentials cannot be used to copy data out.

**What should the solutions architect configure?**

A. A VPC endpoint policy allowing S3 actions only when aws:PrincipalOrgID and aws:ResourceOrgID match the organisation

B. A network ACL allowing only the S3 prefix list

C. S3 Block Public Access on every account

D. A security group allowing outbound HTTPS only

◆ PAUSE AND DECIDE

## What should the solutions architect configure?

**A** VPC endpoint policy

Filters every request on the path by both identity and resource.

**B** Network ACL

*IP ranges cover all of S3, so any bucket is still reachable.*

**C** Block Public Access

*Protects Meridian's buckets, not traffic to an attacker's bucket.*

**D** Security group

*Port-level, with no view of buckets or identities.*

THE SIGNAL

Only network-layer control that understands identities and buckets: the endpoint policy.

# What to carry out of this module

- **Trusted identities, trusted resources, expected networks**, all three.
- **SCP** for your principals, **RCP** for your resources, **endpoint policy** for the path.
- **Exempt service calls** in network conditions, or the perimeter breaks things.
- **Verified Access** for per-app access with device posture, web or TCP.
- **Certificate means Roles Anywhere; OIDC token means web identity.**

> ON THE EXAM
>
> Name the perimeter that failed, then pick the policy type attached to that side.

MODULE 18 · DOMAIN 2 - SECURITY, COMPLIANCE, AND GOVERNANCE

# Encryption and Key Management

Customer managed keys and rotation, where key material lives, certificates for TLS 1.3, and when a dedicated HSM is required.

DOMAIN 2 of 5 EXAM WEIGHT 25% MODULE 18 of 52

admin@sthithapragna.com

Encryption is easy to switch on. The architecture is in **who controls the key**, where it lives, and how it changes.

# Three kinds of KMS key

| KEY TYPE | YOU CONTROL | ROTATION |
|---|---|---|
| AWS owned | Nothing; not visible in your account | Set by AWS |
| AWS managed | Can see and audit use only | Yearly, cannot change |
| Customer managed | Key policy, grants, enable, disable, delete | Optional, 90 to 2560 days |

ON THE EXAM

A requirement to control access, audit use, share cross-account or choose rotation means a customer managed key.

# Automatic rotation

- **Period:** any value from 90 to 2560 days; default 365.
- **On-demand rotation** as well, for an immediate new version.
- **Same key ID and ARN.** Old versions kept, so old data still decrypts.
- **Supported:** symmetric keys with KMS-generated material, multi-Region included.
- **Not automatic:** asymmetric, HMAC, imported material, custom key stores.

> ON THE EXAM
>
> Rotation changes the key material, not the key. Nothing re-encrypts and no application changes.

# Where does the key material live?

| OPTION | MATERIAL IS IN | CHOOSE IT WHEN |
|---|---|---|
| Standard KMS | KMS HSMs, multi-tenant | Default; FIPS 140-3 Level 3 validated |
| Imported key material | KMS, generated by you | You must create or escrow the material |
| CloudHSM key store | Your dedicated CloudHSM cluster | Single-tenant HSM, with KMS integration |
| External key store | Your HSM outside AWS | Material must never be in AWS |

ON THE EXAM

Every option keeps the KMS API, so S3, EBS and RDS encryption keep working unchanged.

# CloudHSM directly, or through KMS?

KMS CUSTOM KEY STORE

## Dedicated HSM, AWS integration

- Keys in your CloudHSM cluster
- S3, EBS, RDS use them via KMS
- KMS policies, grants, CloudTrail
- Symmetric encryption keys only

CLOUDHSM DIRECTLY

## Your application calls the HSM

- PKCS#11, JCE, OpenSSL interfaces
- Any algorithm the HSM supports
- TLS offload, Oracle TDE, code signing
- No native AWS service integration

THE TIEBREAKER

Dedicated HSM plus native AWS service encryption: custom key store. Your own crypto operations: CloudHSM directly.

# Multi-Region keys

- **Primary and replicas** share key ID and key material across Regions.
- **Encrypt in one Region, decrypt in another** with no cross-Region call.
- **Each replica has its own key policy**; rotation is synchronised.
- **Use for** client-side encryption with global tables, DR, cross-Region signing.
- **Not needed** when the service re-encrypts on replication, such as S3 CRR.

> ON THE EXAM
>
> Ciphertext moving between Regions, with decryption needed during a Regional outage: multi-Region keys.

# Certificates for encryption in transit

| NEED | SERVICE |
| --- | --- |
| Public TLS on ALB, CloudFront, API Gateway | ACM public certificate, free, auto-renewed |
| Public certificate installed on your own server | ACM exportable public certificate |
| Internal names, client identity, mutual TLS | AWS Private CA |
| Very short-lived internal certificates | Private CA short-lived certificate mode |

ON THE EXAM

ACM public certificates now default to 198 days, so renewal must be automatic, not a calendar reminder.

# TLS 1.3 and mutual TLS

- **Security policies** on ALB, NLB and CloudFront select TLS 1.3 and allowed ciphers.
- **TLS 1.3 only** policies exist where older clients can be refused.
- **ALB mutual TLS:** verify mode checks client certificates against a trust store.
- **Passthrough mode** forwards the client certificate for the target to check.
- **End to end:** re-encrypt from load balancer to target where rules require.

ON THE EXAM

Load balancer validates client certificates from your private CA: ALB mutual TLS in verify mode.

# Reading the scenario

| WHEN THE QUESTION SAYS | IT IS TESTING |
|---|---|
| Rotate every 180 days, no app change | Customer managed key, custom rotation period |
| Single-tenant HSM, keep S3 and EBS encryption | KMS custom key store on CloudHSM |
| Key material must stay outside AWS | External key store |
| Decrypt in another Region during an outage | Multi-Region keys |
| Public certificate on an EC2 appliance | ACM exportable certificate |
| Clients prove identity with certificates | Private CA plus ALB mutual TLS |

ON THE EXAM

FIPS 140-3 Level 3 alone does not require CloudHSM. Standard KMS is validated too. Single tenancy does.

> Meridian Freight encrypts customs documents in S3 with SSE-KMS using an AWS managed key. A new regulation requires the encryption key material to rotate every 180 days.
>
> The change must not require re-encrypting existing objects or changing the application.

## What should the solutions architect do?

A. Switch to a customer managed key with automatic rotation set to 180 days

B. Keep the AWS managed key and set its rotation period to 180 days

C. Create a new key every 180 days and re-encrypt all objects with S3 Batch Operations

D. Import key material into a customer managed key and enable automatic rotation

◆ PAUSE AND DECIDE

## What should the solutions architect do?

**A** Customer managed, 180 days

Custom periods are supported; old versions still decrypt existing objects.

**B** AWS managed, 180 days

*AWS managed keys rotate yearly; the period cannot be changed.*

**C** New key and re-encrypt

*Meets the rule, but re-encrypts everything, which is ruled out.*

**D** Imported material

*Automatic rotation is not available for imported key material.*

THE SIGNAL

A custom rotation period needs a customer managed key with KMS-generated material.

A banking regulator requires Meridian Freight's payments subsidiary to hold its encryption keys in single-tenant hardware security modules that only the company administers.

The subsidiary wants to keep using SSE-KMS for Amazon S3 and KMS encryption for Amazon EBS and Amazon RDS.

## What should the solutions architect recommend?

A. Standard customer managed KMS keys, which use FIPS-validated HSMs

B. CloudHSM used directly, with client-side encryption in each application

C. An external key store pointing at an on-premises HSM

D. A KMS custom key store backed by a CloudHSM cluster the company administers

◆ PAUSE AND DECIDE

## What should the solutions architect recommend?

A Standard KMS

*Validated, but multi-tenant and administered by AWS.*

B CloudHSM directly

*Single-tenant, but loses SSE-KMS and native service encryption.*

C External key store

*Adds an on-premises dependency the requirement never asked for.*

D CloudHSM key store

Dedicated HSMs the company controls, behind the KMS API services use.

THE SIGNAL

Single-tenant HSM and native service encryption together means a CloudHSM-backed custom key store.

> A European customer requires that Meridian Freight's encryption keys for its data never exist inside AWS, and that Meridian can make the data unreadable to AWS at any time by withdrawing access to the keys.
>
> Data must stay in S3 with SSE-KMS.

## Which design meets the requirement?

A. A customer managed key with imported key material, deleted when access must end

B. A KMS external key store connected to Meridian's own HSM outside AWS

C. A KMS custom key store backed by CloudHSM

D. A customer managed key with a key policy that denies AWS service principals

◆ PAUSE AND DECIDE

## Which design meets the requirement?

A Imported material

*You can delete it, but a copy lives in KMS while in use.*

B External key store

Material stays in Meridian's HSM; disconnecting stops all decryption.

C CloudHSM key store

*Dedicated, but the HSMs are inside AWS.*

D Restrictive key policy

*S3 needs KMS to decrypt; denying it breaks SSE-KMS.*

THE SIGNAL

Never inside AWS means an external key store. Every other option keeps material in AWS hardware.

> Meridian Freight's partner integration API sits behind an Application Load Balancer. Each partner system must authenticate with a client certificate before any request reaches the application.
>
> Certificates should be issued by Meridian and be short-lived, so a leaked certificate expires within days.

**What should the solutions architect implement?**

A ACM public certificates issued to each partner

B Self-signed certificates checked in the application code

C AWS Private CA in short-lived certificate mode, with ALB mutual TLS in verify mode using a trust store

D A Network Load Balancer with TLS passthrough and no validation

◆ PAUSE AND DECIDE

## What should the solutions architect implement?

A ACM public certificates

*Server certificates for your domains, not client identities Meridian issues.*

B Self-signed, checked in code

*Requests reach the application before being rejected.*

C Private CA plus ALB mTLS

Meridian-issued, short-lived, and validated at the load balancer.

D NLB passthrough

*No validation at all.*

THE SIGNAL

Clients authenticate with certificates you issue, checked at the edge: Private CA and mutual TLS.

> Meridian Freight runs a third-party API gateway appliance on EC2 that terminates TLS for a public domain. It needs a publicly trusted certificate and its private key installed on the instance.
>
> The team wants AWS to manage issuance and renewal rather than buying certificates manually.

**What should the solutions architect use?**

A. A standard ACM public certificate associated with the instance

B. A certificate from AWS Private CA

C. A self-signed certificate rotated by a Lambda function

D. An ACM exportable public certificate, redeployed to the appliance when ACM renews it

◆ PAUSE AND DECIDE

## What should the solutions architect use?

A Standard ACM certificate

*Its private key cannot be exported, and it cannot attach to an instance.*

B Private CA

*Not trusted by public browsers or clients.*

C Self-signed

*Not publicly trusted.*

D ACM exportable certificate

Public trust, private key available, renewed by ACM.

THE SIGNAL

Public trust, key on your own server, AWS-managed renewal: exportable public certificate.

> Meridian Freight encrypts sensitive fields client-side with KMS before writing to a DynamoDB global table in two Regions.
>
> During a full outage of the first Region, the application in the second Region must decrypt those fields without calling the first Region.

**What should the solutions architect use?**

A. A multi-Region customer managed key, with a replica in the second Region

B. Separate keys per Region, with each item encrypted under both

C. The DynamoDB table's default encryption with an AWS owned key

D. One single-Region key, called cross-Region from the second Region

◆ PAUSE AND DECIDE

## What should the solutions architect use?

**A** Multi-Region key

The replica decrypts locally, because it shares key material.

**B** Encrypt under both keys

*Works, but doubles the encryption and the complexity.*

**C** Table default encryption

*Protects at rest, not the client-side field encryption required.*

**D** Cross-Region call

*Fails exactly when the first Region is down.*

THE SIGNAL

Ciphertext replicated as-is, decrypted elsewhere when the source Region is gone: multi-Region keys.

# What to carry out of this module

- **Customer managed keys** for control, cross-account use and custom rotation.
- **Rotation** 90 to 2560 days, same key ID, KMS-generated symmetric keys only.
- **Single tenant:** CloudHSM key store. **Outside AWS:** external key store.
- **ACM** public and exportable; **Private CA** for internal and client identity.
- **Multi-Region keys** when ciphertext crosses Regions and must decrypt there.

> ON THE EXAM
>
> Ask who controls the key, where the material lives, and how it rotates.

MODULE 19 · DOMAIN 2 - SECURITY, COMPLIANCE, AND GOVERNANCE

# Post-Quantum Cryptography

What a quantum computer would break, what it would not, and how ML-KEM and ML-DSA fit into AWS today.

DOMAIN 2 of 5 EXAM WEIGHT 25% MODULE 19 of 52

admin@sthithapragna.com

Quantum computers threaten **public-key** cryptography. The urgent risk is traffic recorded **today** and decrypted later.

# What is at risk

| CRYPTOGRAPHY | QUANTUM IMPACT | ACTION |
|---|---|---|
| RSA, ECDH key exchange | Broken | Move to ML-KEM, hybrid first |
| RSA, ECDSA signatures | Broken | Move to ML-DSA for long-lived trust |
| AES-256 at rest | Weakened, still strong | No change needed |
| SHA-256 and larger hashes | Weakened, still strong | No change needed |

ON THE EXAM

Data at rest under AES-256 is not the problem. Re-encrypting it buys nothing.

# ML-KEM or ML-DSA?

ML-KEM, FIPS 203

## Agree a secret key

- Key encapsulation mechanism
- Replaces RSA and ECDH key exchange
- Protects confidentiality
- Used in hybrid TLS handshakes

ML-DSA, FIPS 204

## Prove who signed it

- Digital signature algorithm
- Replaces RSA and ECDSA signatures
- Protects authenticity and integrity
- Code signing, certificates, roots of trust

THE TIEBREAKER

Keeping data secret means ML-KEM. Proving origin or integrity means ML-DSA.

# Why hybrid key exchange?

- **Hybrid** combines a classical exchange such as ECDH with ML-KEM.
- **Secure if either holds:** classical against today, ML-KEM against tomorrow.
- **Industry norm now;** AWS expects pure post-quantum exchange later.
- **Negotiated in TLS 1.3:** clients that do not offer it fall back to classical.

> ON THE EXAM
>
> Hybrid is not a compromise. It is how AWS and the industry deploy ML-KEM today.

# Hybrid post-quantum TLS on AWS

| WHERE | STATUS |
| --- | --- |
| KMS, ACM, Secrets Manager, STS, IAM, S3 | On server-side; update your clients |
| CloudFront, viewer to edge | On by default for all security policies |
| ALB and NLB listeners | Opt in: choose a PQ TLS security policy |
| Aurora, RDS, Transfer Family SFTP | Opt in: upgrade engine or change policy |
| Classic Load Balancer | Not planned; migrate away |

ON THE EXAM

AWS endpoints are ready. Your load balancers and your clients are your responsibility.

# Post-quantum keys in KMS

| KEY SPEC | KEY USAGE | OPERATIONS |
|---|---|---|
| ML_DSA_44, 65, 87 | SIGN_VERIFY | Sign, Verify, GetPublicKey |
| ML_KEM_512, 768, 1024 | ENCAPSULATE_DECAPSULATE | Encapsulate, Decapsulate |

ON THE EXAM

Post-quantum TLS protects calls to KMS. PQ keys in KMS are a separate feature for your own use.

# Signatures and roots of trust

- **Long-lived trust first:** firmware, code signing, device roots of trust.
- **AWS Private CA** issues ML-DSA certificates and CAs.
- **KMS ML-DSA keys** sign artefacts, with keys never leaving the HSM.
- **Session authentication** is less urgent: it cannot be forged retroactively.

> ON THE EXAM
>
> Devices in the field for a decade need a post-quantum root of trust before they ship.

# A post-quantum migration plan

01
### Inventory
Find where public-key crypto is used

02
### Prioritise
Long-lived secrets and long-lived trust first

03
### Transit
Hybrid ML-KEM on listeners and clients

04
### Signing
ML-DSA for code, firmware and roots

05
### Agility
Make algorithms configurable, not coded in

ON THE EXAM

Crypto agility, swapping an algorithm by configuration, is the lasting goal.

# Reading the scenario

| WHEN THE QUESTION SAYS | IT IS TESTING |
|---|---|
| Recorded traffic, decrypted in future | Hybrid ML-KEM TLS |
| Firmware or code trusted for many years | ML-DSA signatures |
| Re-encrypt stored data for quantum | Not needed; AES-256 holds |
| Agree a shared secret with a partner | ML-KEM key in KMS |
| ALB clients still use classical exchange | Listener PQ security policy |
| Endpoint supports PQ, logs show classical | Update the client |

ON THE EXAM

Confidentiality: ML-KEM. Authenticity: ML-DSA. At rest: leave it.

> Meridian Freight's customs API carries trade data that must stay confidential for 20 years. It is served through an Application Load Balancer with a TLS 1.3 security policy.
>
> Security is concerned that traffic captured today could be decrypted by a future quantum computer.

## What should the solutions architect do first?

A Re-encrypt the backing S3 data with a new customer managed key

B Change the ALB listener to a security policy that supports hybrid post-quantum key exchange, and update clients

C Replace the RSA 2048 certificate with an RSA 4096 certificate

D Wait until pure post-quantum key exchange is standardised

◆ PAUSE AND DECIDE

## What should the solutions architect do first?

A Re-encrypt at rest

*AES-256 at rest is not what a quantum computer breaks.*

B PQ listener policy

Hybrid ML-KEM protects today's sessions against future decryption.

C Larger RSA key

*Quantum attacks break RSA regardless of size.*

D Wait

*Every day of waiting adds recorded traffic to the harvest.*

THE SIGNAL

Harvest now, decrypt later is fixed in the handshake, and ALB requires you to opt in.

> Meridian Freight is designing firmware for trailer telematics units that will stay in service for 15 years. Each unit must verify firmware updates before installing them.
>
> The signing key must be protected in a validated HSM and the scheme must remain trustworthy if large quantum computers appear.

**Which approach should the solutions architect choose?**

A ECDSA P-384 signing keys in KMS

B An ML-KEM key in KMS used to sign the firmware

C An ML-DSA signing key in KMS, with the public key provisioned into each unit before it ships

D RSA 4096 signing keys in CloudHSM

◆ PAUSE AND DECIDE

## Which approach should the solutions architect choose?

A ECDSA P-384

*Elliptic-curve signatures are broken by a quantum computer.*

B ML-KEM

*A key encapsulation mechanism. It cannot sign anything.*

C ML-DSA in KMS

Post-quantum signatures, key held in KMS HSMs, root provisioned at manufacture.

D RSA 4096

*Dedicated hardware does not make RSA quantum-safe.*

THE SIGNAL

Signing plus long life plus quantum risk: ML-DSA, provisioned before the device ships.

> Meridian Freight's board asks for a post-quantum plan. A consultant proposes re-encrypting 4 PB of S3 and EBS data, currently encrypted with SSE-KMS under symmetric customer managed keys, as the first project.
>
> Most of the company's sensitive data also crosses the internet between partners and AWS.

## What should the solutions architect advise?

A. Leave data at rest as it is, since KMS symmetric encryption remains quantum resistant, and prioritise post-quantum key exchange in transit

B. Re-encrypt all data under new symmetric keys

C. Move all data to a CloudHSM custom key store

D. Re-encrypt all data with ML-KEM keys in KMS

◆ PAUSE AND DECIDE

## What should the solutions architect advise?

**A** Prioritise transit

Matches the risk: symmetric at rest holds; recorded traffic does not.

**B** New symmetric keys

*Replaces strong keys with equally strong keys.*

**C** CloudHSM key store

*Changes who holds the key, not its quantum resistance.*

**D** ML-KEM for bulk data

*ML-KEM agrees keys; it does not encrypt data at rest.*

THE SIGNAL

Start where quantum computers break things: public-key exchange in transit, not AES at rest.

> Meridian Freight and a customs authority must establish a shared secret so the authority can encrypt declarations that only Meridian can decrypt.
>
> Meridian's private key must never leave a FIPS-validated HSM, and the exchange must be quantum resistant.

**What should the solutions architect use?**

A. A KMS ECC key with KEY_AGREEMENT usage and DeriveSharedSecret

B. A KMS ML-DSA key shared with the authority

C. An RSA key pair stored in Secrets Manager

D. A KMS ML-KEM key: the authority encapsulates with Meridian's public key, and Meridian calls Decapsulate

◆ PAUSE AND DECIDE

## What should the solutions architect use?

**A** ECDH key agreement

*Keeps the key in an HSM, but elliptic-curve exchange is not quantum resistant.*

**B** ML-DSA

*Signs; cannot establish a shared secret.*

**C** RSA in Secrets Manager

*Not quantum resistant, and the key leaves an HSM.*

**D** ML-KEM in KMS

Post-quantum key establishment; the private key stays in KMS.

THE SIGNAL

Shared secret, quantum resistant, private key in an HSM: an ML-KEM key in KMS.

> Meridian Freight wants every external entry point to offer hybrid post-quantum key exchange. Its estate includes a CloudFront distribution, a Network Load Balancer with TLS listeners, and applications calling the KMS and S3 APIs with current SDKs.
>
> The team wants to know which component needs a configuration change.

## Which component requires the team to act?

A The CloudFront distribution's viewer connections

B The AWS KMS service endpoint

C The Network Load Balancer's TLS listeners

D The Amazon S3 service endpoint

◆ PAUSE AND DECIDE

## Which component requires the team to act?

A CloudFront viewers

*On by default for all security policies.*

B KMS endpoint

*Supported server-side; current SDKs can use it.*

C NLB listeners

Opt in: select a PQ security policy on each listener.

D S3 endpoint

*Supported server-side for all bucket types.*

THE SIGNAL

AWS endpoints and CloudFront viewers: done for you. Your load balancer listeners: your job.

A Meridian Freight audit of CloudTrail records for AWS Secrets Manager shows that calls from an on-premises Java application still use classical key exchange.

Secrets Manager endpoints already support hybrid post-quantum TLS.

**What should the solutions architect do?**

A Enable post-quantum TLS in the Secrets Manager resource policy

B Upgrade the application's SDK and TLS client to versions that offer hybrid ML-KEM

C Ask AWS Support to enable post-quantum TLS for the account

D Route the calls through an AWS Site-to-Site VPN

◆ PAUSE AND DECIDE

## What should the solutions architect do?

A Resource policy

*No such setting; the server already supports it.*

B Upgrade the client

The client must offer ML-KEM for the handshake to use it.

C Support case

*Nothing to enable; it is already on server-side.*

D Site-to-Site VPN

*IPsec tunnels use their own classical key exchange.*

THE SIGNAL

The server supports it but logs show classical: the client is not offering it.

# What to carry out of this module

- **Quantum breaks public-key crypto;** AES-256 at rest stays strong.
- **Harvest now, decrypt later** makes transit key exchange the first fix.
- **ML-KEM** agrees secrets; **ML-DSA** signs. Never swap them.
- **AWS endpoints and CloudFront:** on. **ALB, NLB, databases:** opt in.
- **Inventory, prioritise by lifetime, and build for crypto agility.**

> ON THE EXAM
>
> Confidentiality: ML-KEM. Authenticity: ML-DSA. At rest: leave it.

MODULE 20 · DOMAIN 2 - SECURITY, COMPLIANCE, AND GOVERNANCE

# Organisations, Guardrails, SCPs and RCPs

Shape the organisation into OUs, vend accounts with a baseline, and choose the right policy type for each guardrail.

DOMAIN 2 of 5 EXAM WEIGHT 25% MODULE 20 of 52

admin@sthithapragna.com

Accounts are the strongest boundary AWS has. **OUs** group them by policy, and **guardrails** follow the OU.

# A typical OU structure

| OU | HOLDS | GUARDRAIL EMPHASIS |
|---|---|---|
| Security | Log archive, security tooling | Locked down; few humans |
| Infrastructure | Networking, shared services | Network changes controlled |
| Workloads | Prod and non-prod sub-OUs | Prod stricter than non-prod |
| Sandbox | Experiments, no production data | Budgets, no connectivity |
| Suspended | Accounts being closed | Deny almost everything |

ON THE EXAM

Group by the policies an account needs, not by the organisation chart.

# Organizations policy types

| POLICY | CONSTRAINS | EXAMPLE |
|---|---|---|
| SCP | Your principals' maximum permissions | No leaving the organisation |
| RCP | Maximum access to your resources | Require TLS for every caller |
| Declarative | Service configuration, durably | Block public AMI sharing |
| Backup, tag | Backup plans, tag standards | Daily backup of tagged resources |
| AI opt-out, Bedrock | AI service data use and settings | Opt out of content use |

ON THE EXAM

Permissions are SCPs and RCPs. A service's settings are a declarative policy.

# SCP or RCP?

SERVICE CONTROL POLICY

## What our principals may do

- Applies to IAM users and roles in member accounts
- Follows our principals anywhere
- Cannot restrict outside principals
- Region limits, protect security tooling

RESOURCE CONTROL POLICY

## What may be done to our resources

- Applies to resources in member accounts
- Constrains any caller, including outsiders
- Supported services only, such as S3, KMS, STS
- Enforce TLS, keep outsiders out

THE TIEBREAKER

Neither grants anything. Neither affects the management account or service-linked roles.

# How SCPs evaluate

- **An allow is needed at every level:** root, each OU, and the account.
- **A deny at any level** wins, and children cannot undo it.
- **Full IAM language** since September 2025: conditions, NotResource, resource ARNs.
- **Exceptions by condition**, such as aws:PrincipalArn for a break-glass role.
- **Management account is never restricted**, so run no workloads there.

> ON THE EXAM
>
> If removing FullAWSAccess at an OU blocks everything below it, that is the allow-at-every-level rule.

# Control Tower control behaviours

| BEHAVIOUR | IMPLEMENTED WITH | ACTS |
|---|---|---|
| Preventive | SCPs, RCPs, declarative policies | Blocks the action |
| Detective | AWS Config rules | Reports after the fact |
| Proactive | CloudFormation hooks | Fails the stack before creation |

ON THE EXAM

Before provisioning, with a clear reason to the deployer: proactive. After: detective.

# Landing zones and Account Factory

- **Landing zone 4.0** (Nov 2025): Config, CloudTrail, roles and Backup integrations optional.
- **No mandatory OUs**; a controls-only setup is possible.
- **Account Factory** vends accounts into an OU with its baseline and controls.
- **Account Factory for Terraform** when account requests live in a Terraform pipeline.
- **Customizations for Control Tower** adds your own StackSets and SCPs per OU.

> ON THE EXAM
>
> Accounts created automatically, in the right OU, with guardrails and baseline: Account Factory.

# Reading the scenario

| WHEN THE QUESTION SAYS | IT IS TESTING |
|---|---|
| New accounts with a baseline, from a pipeline | Account Factory, or AFT with Terraform |
| Our staff must never do X, except break-glass | SCP deny with a principal exception |
| Every caller, including partners, must Y | RCP |
| Service setting stays enforced as APIs change | Declarative policy |
| Fail the deployment before creation | Proactive control |
| SCP does not stop the management account | Move workloads out |

ON THE EXAM

Ask whose action is constrained: our principals, anyone on our resources, or the service itself.

> Meridian Freight creates about 20 new AWS accounts a month. Platform engineers manage all infrastructure in Terraform and want account requests reviewed as pull requests.
>
> Each new account must land in the correct OU with the logging baseline, guardrails and standard customisations applied automatically.

## What should the solutions architect recommend?

A. AWS Control Tower with Account Factory for Terraform, placing accounts in OUs with their controls

B. A Lambda function that calls the Organizations CreateAccount API

C. CloudFormation StackSets deployed to each account after manual creation

D. One shared account per team, with IAM roles for each project

◆ PAUSE AND DECIDE

## What should the solutions architect recommend?

**A** Control Tower with AFT

Terraform-driven requests; accounts land governed, with baseline and customisations.

**B** CreateAccount Lambda

*Creates accounts, but the baseline and controls are yours to build.*

**C** StackSets after manual creation

*Manual step, and nothing places accounts or applies controls.*

**D** Shared accounts

*Abandons the account boundary the design depends on.*

THE SIGNAL

Account vending plus Terraform pull requests: Account Factory for Terraform.

> Meridian Freight wants to guarantee that no account in its Sandbox OU can share AMIs or EBS snapshots publicly, and that new EC2 instances require IMDSv2.
>
> The controls must keep working if EC2 adds new APIs that could change these settings, and account administrators must not be able to override them.

## What should the solutions architect use?

A. An SCP denying the current sharing and metadata API actions

B. AWS Config rules with automatic remediation

C. IAM permissions boundaries on all roles in the Sandbox accounts

D. A declarative policy for EC2 attached to the Sandbox OU

◆ PAUSE AND DECIDE

## What should the solutions architect use?

A SCP on current actions

*Covers today's APIs; a new API could bypass it.*

B Config remediation

*Detects and reverses, leaving a window of exposure.*

C Permissions boundaries

*Per role, and administrators can create roles without them.*

D Declarative policy

Sets the service configuration itself, regardless of which API is called.

THE SIGNAL

A setting that must stay set even as APIs change: a declarative policy.

> Meridian Freight's security team requires that no one in any member account, including account administrators, can stop CloudTrail, leave the organisation, or use Regions outside the EU.
>
> A single break-glass role must be exempt from the Region restriction.

**What should the solutions architect implement?**

A IAM policies in each account denying those actions

B An RCP denying those actions on every resource

C SCPs attached to the root denying those actions, with the Region deny excepting the break-glass role by aws:PrincipalArn

D Permissions boundaries on every administrator role

◆ PAUSE AND DECIDE

## What should the solutions architect implement?

A IAM policies per account

*Account administrators can simply remove them.*

B RCP

*Constrains access to resources; leaving the organisation and Region use are principal actions.*

C SCPs with an exception

Binds every member principal; the condition exempts one role.

D Permissions boundaries

*Administrators can create new roles without boundaries.*

THE SIGNAL

Our own principals, including admins, with a named exception: an SCP with aws:PrincipalArn.

> Meridian Freight shares S3 buckets and SQS queues in its member accounts with several logistics partners' AWS accounts.
>
> Security must ensure that every request to these resources uses TLS, whether it comes from Meridian's principals or from partners, without editing each bucket and queue policy.

**What should the solutions architect implement?**

A. An SCP denying requests where aws:SecureTransport is false

B. An RCP denying requests to S3 and SQS where aws:SecureTransport is false

C. An AWS Config rule that flags buckets without a TLS policy

D. A VPC endpoint policy requiring TLS

◆ PAUSE AND DECIDE

## What should the solutions architect implement?

A SCP

*Binds Meridian's principals only; partner requests are unaffected.*

B RCP

Applies to every caller of Meridian's resources, partners included.

C Config rule

*Detective, and still requires editing each policy to fix.*

D Endpoint policy

*Only covers traffic through Meridian's own endpoint.*

THE SIGNAL

A rule for every caller of our resources, applied centrally: an RCP.

> Meridian Freight attached an SCP to the organisation root denying all Regions outside the EU. An audit found EC2 instances running in a US Region in the management account.
>
> The SCP is attached correctly and works in member accounts.

**What should the solutions architect recommend?**

A. Move the workloads into member accounts, and keep the management account for organisation administration only

B. Attach the SCP directly to the management account

C. Add an RCP with the same Region restriction

D. Recreate the SCP as a declarative policy

◆ PAUSE AND DECIDE

## What should the solutions architect recommend?

**A** Move workloads out

Organisation guardrails cannot reach the management account; workloads belong elsewhere.

**B** Attach to management account

*SCPs never restrict the management account, however attached.*

**C** Add an RCP

*RCPs do not affect the management account either.*

**D** Declarative policy

*Does not express a Region restriction, and does not fix the root cause.*

THE SIGNAL

Guardrails exempt the management account by design. Keep it empty of workloads.

> Meridian Freight's teams deploy with CloudFormation. Security wants non-compliant resource properties, such as unencrypted databases or public load balancers in production, to be rejected before they are created.
>
> Developers must see which control failed, in the deployment itself.

**Which Control Tower controls should the solutions architect enable?**

A Detective controls backed by AWS Config rules

B Security Hub CSPM standards with findings sent to developers

C Preventive controls implemented as SCPs

D Proactive controls, implemented as CloudFormation hooks

◆ PAUSE AND DECIDE

## Which Control Tower controls should the solutions architect enable?

A **Detective**

*Reports after the resource exists.*

B **Security Hub CSPM**

*Also after the fact, and outside the deployment.*

C **Preventive SCPs**

*Block actions, but see few resource properties and return a generic denial.*

D **Proactive**

Checks properties before creation and fails the stack naming the control.

THE SIGNAL

Before creation, on resource properties, explained in the deployment: proactive controls.

# What to carry out of this module

- **OUs by required policy**; guardrails follow the OU to new accounts.
- **SCP** for our principals, **RCP** for every caller, **declarative** for settings.
- **Allow at every level, deny anywhere wins**; full IAM language in SCPs.
- **Preventive, proactive, detective** controls differ by timing.
- **Management account is exempt**: no workloads there.

> ON THE EXAM
>
> Ask whose action is constrained, and when the control must act.

MODULE 21 · DOMAIN 2 - SECURITY, COMPLIANCE, AND GOVERNANCE

# Centralised Logging and Security Aggregation

Collect every account's trail, configuration, logs, findings and model invocations in one place, and share resources across accounts safely.

DOMAIN 2 of 5 EXAM WEIGHT 25% MODULE 21 of 52

admin@sthithapragna.com

Evidence must outlive the account that produced it. Send it somewhere the producer cannot reach.

# Which stream holds which evidence?

| SERVICE | RECORDS | CENTRALISE WITH |
|---|---|---|
| CloudTrail | Who called which API, when, from where | Organisation trail to log archive |
| AWS Config | Resource configuration over time | Organisation aggregator |
| CloudWatch Logs | Application and service logs | Centralisation rules |
| GuardDuty | Threat findings from activity | Delegated administrator |
| Bedrock invocation logs | Prompts, responses, tokens | S3 and CloudWatch Logs per Region |

ON THE EXAM

API activity is CloudTrail. What a resource looked like is Config. Prompts and responses are invocation logs.

# CloudTrail across the organisation

- **Organisation trail** covers every member account; members cannot stop or change it.
- **Deliver to the log archive account**, with S3 Object Lock and a KMS key.
- **Data events** such as S3 object and Lambda calls are extra, and selected.
- **CloudTrail Lake closed to new customers** on 31 May 2026; AWS points to CloudWatch.
- **Trails, Insights and aggregated events** are unaffected.

> ON THE EXAM
>
> If an answer starts a new CloudTrail Lake event data store, it is stale for a new customer.

# Copy the logs, or view them?

LOG CENTRALISATION RULES

## Copy into one account

- Rules set in management or delegated admin
- Accounts, OUs or whole organisation
- Copied at ingestion, optional backup Region
- New log data only, not history

CROSS-ACCOUNT OBSERVABILITY

## View in place

- Monitoring account links to sources
- Logs, metrics and traces stay put
- Unified dashboards and queries
- Source admins still control retention

THE TIEBREAKER

Retention and tamper resistance need a copy. A single pane of glass only needs viewing.

# Amazon Security Lake

- **Normalises to OCSF**, an open schema, stored as Parquet in your S3.
- **AWS sources:** CloudTrail, VPC Flow Logs, Route 53 resolver, EKS audit, WAF, findings.
- **Custom sources** from on premises, other clouds and third parties.
- **Subscribers:** data access to the objects, or query access through Lake Formation.
- **Rollup Regions** consolidate data, which helps with residency.

> ON THE EXAM
>
> Many log formats, one open schema, many consumers including a SIEM: Security Lake.

# Security Hub, CSPM and GuardDuty

| SERVICE | ANSWERS |
| --- | --- |
| GuardDuty | Is something malicious happening? |
| Inspector | Which workloads have known vulnerabilities? |
| Security Hub CSPM | Are resources configured to standards? |
| Security Hub | Which risks matter most, and how could they chain? |

ON THE EXAM

Security Hub, generally available since December 2025, correlates the other three into prioritised exposures.

# Logging AI model invocations

- **Model invocation logging** captures full requests, responses and token counts.
- **Off by default**, and configured per account and per Region.
- **Destinations:** S3, CloudWatch Logs, or both, in the same account and Region.
- **Large or binary data** over 100 KB, such as images, goes to S3 only.
- **CloudTrail** records the call and caller, not the prompt or response.

> ON THE EXAM
>
> Auditing what a model was asked and answered means invocation logging, enabled in every account and Region.

# Sharing resources across accounts

| SHARE | WITH | THROUGH |
|---|---|---|
| Transit gateway, subnets, prefix lists | Workload accounts | AWS RAM |
| Route 53 resolver rules | All VPC accounts | AWS RAM |
| IPAM pools, License Manager configs | OUs or the organisation | AWS RAM |
| S3 buckets, KMS keys, SQS queues | Other principals | Resource-based policies |

ON THE EXAM

Share with an OU or the organisation, so new accounts are included automatically.

# Reading the scenario

| WHEN THE QUESTION SAYS | IT IS TESTING |
|---|---|
| Member admins must not stop API logging | Organisation trail |
| Copy logs from every account, plus backup | CloudWatch centralisation rules |
| Normalise many log sources for a SIEM | Security Lake |
| Prioritise chained risks across services | Security Hub |
| Audit prompts and responses | Model invocation logging |
| Workload accounts use the network team's TGW | AWS RAM share |

ON THE EXAM

Name the evidence first: API calls, configuration, logs, findings or prompts. The service follows.

> Meridian Freight's auditors require a record of every API call in all 140 member accounts, stored for seven years in the log archive account.
>
> Account administrators must not be able to stop or alter the logging, and records must be protected from deletion.

## What should the solutions architect implement?

A. A trail in each account, deployed by StackSets, delivering to its own bucket

B. A new CloudTrail Lake organisation event data store with seven-year retention

C. An organisation trail delivering to an S3 bucket in the log archive account with Object Lock in compliance mode

D. An AWS Config organisation aggregator

◆ PAUSE AND DECIDE

## What should the solutions architect implement?

A Trail per account

*Account administrators can stop their own trail and delete the bucket.*

B New CloudTrail Lake store

*Closed to new customers since 31 May 2026.*

C Organisation trail with Object Lock

Members cannot change it; compliance mode prevents deletion.

D Config aggregator

*Records configuration, not every API call.*

THE SIGNAL

Every account, unchangeable by members, undeletable: organisation trail plus Object Lock.

Meridian Freight's security team needs a copy of application logs from 200 accounts in four Regions, held in one security account with a second copy in a backup Region.

Accounts added to the Workloads OU must be included automatically, and source administrators must not be able to delete the central copy.

## What should the solutions architect implement?

A. A CloudWatch Logs centralisation rule for the Workloads OU, with a destination account and a backup Region

B. CloudWatch cross-account observability with the security account as monitoring account

C. A subscription filter on each log group, streaming to a Firehose stream in each account

D. Nightly export tasks from each log group to S3

◆ PAUSE AND DECIDE

## What should the solutions architect implement?

**A** Centralisation rule

Copies at ingestion, by OU, with a backup Region built in.

**B** Cross-account observability

*Views data in place; source admins still control it.*

**C** Subscription filters

*Works, but per log group, per account, with plumbing to maintain.*

**D** Nightly exports

*Batch, manual and per log group.*

THE SIGNAL

A protected central copy, by OU, with a backup Region: centralisation rules.

> Meridian Freight's security operations centre uses a third-party SIEM and Amazon Athena. It needs CloudTrail, VPC Flow Logs and Route 53 resolver logs from all accounts, plus logs from on-premises firewalls.
>
> All data must be in one open schema in Meridian's own S3, so both tools can query it without custom transformation.

**What should the solutions architect recommend?**

A Security Hub with all integrations enabled

B An OpenSearch Service domain with custom ingestion pipelines

C CloudWatch Logs centralisation rules

D Amazon Security Lake with the AWS sources and a custom source for the firewalls, and subscribers for the SIEM and Athena

◆ PAUSE AND DECIDE

## What should the solutions architect recommend?

A **Security Hub**

*Aggregates findings, not raw flow, DNS and trail logs.*

B **OpenSearch pipelines**

*Custom transformation, which the scenario rules out.*

C **Centralisation rules**

*Copies CloudWatch logs; no open schema or on-premises source.*

D **Security Lake**

OCSF in your S3, custom sources, and subscribers for both tools.

THE SIGNAL

Open schema, many sources including non-AWS, many consumers: Security Lake.

> Meridian Freight's security team receives thousands of GuardDuty, Inspector and configuration findings a week across its organisation, and cannot tell which matter most.
>
> It wants findings correlated, so that a vulnerable, internet-exposed instance with an over-privileged role reaching sensitive data is shown as one prioritised risk.

## What should the solutions architect recommend?

A. Security Hub CSPM with additional standards enabled

B. AWS Security Hub, enabled across the organisation, using its exposure findings and attack paths

C. GuardDuty Extended Threat Detection only

D. Athena queries over Security Lake, written by the team

◆ PAUSE AND DECIDE

## What should the solutions architect recommend?

A More CSPM standards

*Adds more configuration findings to an already noisy pile.*

B Security Hub

Correlates threats, vulnerabilities and misconfigurations into prioritised exposures.

C GuardDuty only

*Correlates threat activity, not vulnerabilities and configuration.*

D Custom Athena queries

*Possible, but building correlation yourself.*

THE SIGNAL

Correlate across GuardDuty, Inspector and CSPM into one prioritised risk: the new Security Hub.

> Meridian Freight's compliance team must retain the full prompts and responses of every Amazon Bedrock call made by its applications, including generated images, for review.
>
> Applications run in 12 accounts in two Regions.

**What should the solutions architect implement?**

A. Model invocation logging to S3 enabled in every account and Region, through infrastructure as code

B. CloudTrail data events for Bedrock in an organisation trail

C. Model invocation logging to CloudWatch Logs only

D. Application code that writes prompts to DynamoDB

◆ PAUSE AND DECIDE

## What should the solutions architect implement?

**A** Invocation logging to S3

Full bodies including images, set in each account and Region.

**B** CloudTrail data events

*Record the call and caller, not prompt and response bodies.*

**C** CloudWatch Logs only

*Cannot hold images or bodies over 100 KB.*

**D** Application code

*Relies on every team doing it, and misses direct calls.*

THE SIGNAL

Prompts and responses, including images: invocation logging with an S3 destination.

> Meridian Freight's network team owns a transit gateway and shared VPC subnets in a central network account.
>
> Workload accounts in the Workloads OU, including future ones, must attach to the transit gateway and launch resources into the shared subnets without the network team creating anything per account.

**What should the solutions architect configure?**

A. A transit gateway in each workload account, peered to the central one

B. VPC peering from each workload VPC to the network VPC

C. IAM roles in the network account that workload teams assume to create resources

D. An AWS RAM resource share of the transit gateway and subnets with the Workloads OU

◆ PAUSE AND DECIDE

## What should the solutions architect configure?

A Transit gateway per account

*Many gateways and peerings; not sharing at all.*

B VPC peering

*Per-VPC connections, and no shared subnets.*

C Roles into network account

*Resources would be owned by the network account, not the workload.*

D RAM share with the OU

One share; current and future accounts attach and launch.

THE SIGNAL

Share once with the OU, and new accounts inherit access: AWS RAM.

# What to carry out of this module

- **Organisation trail** to a locked log archive; CloudTrail Lake is closed to new customers.
- **Centralisation rules copy**; cross-account observability only views.
- **Security Lake** normalises raw logs; **Security Hub** prioritises findings.
- **Invocation logging** for prompts and responses, per account and Region, S3 for large data.
- **RAM shares** with OUs for transit gateways, subnets and resolver rules.

> ON THE EXAM
>
> Name the evidence, copy it out of reach, then analyse it from security tooling.

MODULE 22 · DOMAIN 2 - SECURITY, COMPLIANCE, AND GOVERNANCE

# Compliance Automation and Patch Management

Evaluate every resource continuously, remediate automatically, find vulnerabilities everywhere code runs, and patch across the organisation.

DOMAIN 2 of 5 EXAM WEIGHT 25% MODULE 22 of 52

admin@sthithapragna.com

Compliance is a **loop**: evaluate, report, remediate, and evaluate again, without a person in the middle.

# AWS Config building blocks

| PIECE | WHAT IT DOES |
| --- | --- |
| Managed rules | Hundreds of prebuilt checks, such as encrypted volumes |
| Custom rules | Your logic, in Lambda or Guard policy language |
| Conformance packs | Rules and remediations deployed as one unit |
| Organisation rules and packs | Deployed to every account from one place |
| Remediation | Systems Manager Automation runbooks, manual or automatic |
| Aggregator | Compliance across accounts and Regions in one view |

ON THE EXAM

A framework's checks plus fixes, everywhere at once: an organisation conformance pack.

# Security Hub CSPM

- **Standards:** Foundational Best Practices, CIS, PCI DSS, NIST 800-53.
- **Central configuration** sets standards and controls per OU from the delegated admin.
- **Automation rules** change finding severity or status as findings arrive.
- **Remediation** through EventBridge to Automation runbooks or Lambda.
- **Findings** feed the new Security Hub for correlation.

> ON THE EXAM
>
> Automation rules triage findings. They do not fix resources; EventBridge and runbooks do.

# What Amazon Inspector scans

| TARGET | HOW |
| --- | --- |
| EC2 instances | SSM agent, or agentless from EBS snapshots |
| ECR container images | On push and continuously as new CVEs appear |
| Lambda functions | Packages, and optionally function code |
| Code repositories | Code security: source, dependencies, IaC |
| EC2 operating systems | CIS benchmark assessments |

ON THE EXAM

Inspector Classic support ended 20 May 2026. Any answer naming it is stale.

# Prioritising vulnerabilities

- **Inspector score** adjusts CVSS for your environment, such as network reachability.
- **EPSS** estimates the chance of exploitation in the wild.
- **Exploit available** flags known public exploit code.
- **Suppression rules** hide accepted risks; **SBOM export** lists components.

> ON THE EXAM
>
> Patch first what is reachable and likely to be exploited, not simply the highest CVSS.

# Patch Manager essentials

| CONCEPT | MEANING |
| --- | --- |
| Patch baseline | Which patches are approved, per operating system |
| Auto-approval delay | Approve, say, critical patches 7 days after release |
| Scan or install | Report compliance only, or install and reboot |
| Patch policy | One Quick Setup policy for many accounts and Regions |
| Rate control | Concurrency and error thresholds limit blast radius |

ON THE EXAM

Organisation-wide patching from one configuration: a Quick Setup patch policy.

# Patch in place, or replace?

PATCH IN PLACE

## Patch Manager

- Long-lived instances
- Install on schedule, reboot if needed
- Compliance reported per node
- Suits stateful or legacy servers

REPLACE WITH NEW IMAGE

## Image Builder and redeploy

- Immutable, auto-scaled fleets
- Build and test a new AMI or image
- Roll out with instance refresh
- No drift between nodes

THE TIEBREAKER

Auto Scaling groups and containers: rebuild the image. Pets that must stay up: patch in place.

# Reading the scenario

| WHEN THE QUESTION SAYS | IT IS TESTING |
|---|---|
| Framework checks and fixes in every account | Organisation conformance pack |
| Patch everything, many accounts and Regions | Quick Setup patch policy |
| No agent possible on the instance | Inspector agentless scanning |
| Flaws in source code before deployment | Inspector code security |
| Too many findings, adjust per environment | CSPM automation rules |
| Critical CVE found, fix automatically | EventBridge to a patch runbook |

ON THE EXAM

Detect with Config, CSPM or Inspector. Act with EventBridge and Systems Manager.

> Meridian Freight's payments accounts must demonstrate continuous PCI DSS compliance. Certain violations, such as S3 buckets without default encryption, must be fixed automatically.
>
> The same checks must apply to every account in the Payments OU, including new ones.

**What should the solutions architect implement?**

A Quarterly manual reviews using the AWS Config console

B An organisation conformance pack for PCI DSS deployed to the Payments OU, with automatic remediation using Systems Manager Automation runbooks

C Security Hub CSPM automation rules that mark findings as resolved

D GuardDuty enabled in every payments account

◆ PAUSE AND DECIDE

## What should the solutions architect implement?

A Quarterly reviews

*Neither continuous nor automatic.*

B Conformance pack with remediation

Continuous checks, automatic fixes, deployed to the OU.

C Automation rules

*Change the finding's status; the bucket stays unencrypted.*

D GuardDuty

*Detects threats, not configuration compliance.*

THE SIGNAL

Continuous, framework-mapped, self-fixing, OU-wide: an organisation conformance pack.

> Meridian Freight runs long-lived Linux and Windows EC2 instances across 80 accounts in six Regions. Critical and important security patches must be installed weekly, seven days after release.
>
> The operations team wants one configuration rather than setup in each account and Region.

**What should the solutions architect recommend?**

A. A maintenance window and patch group created in each account and Region

B. Amazon Inspector with automatic patching enabled

C. A Quick Setup patch policy from the management account targeting the organisation, with baselines auto-approving those patches after seven days

D. Rebuild every instance from a new AMI each week

◆ PAUSE AND DECIDE

## What should the solutions architect recommend?

A Per-account windows

*Works, but 480 configurations to build and keep in step.*

B Inspector

*Finds vulnerabilities; it does not install patches.*

C Patch policy

One configuration for every account and Region, with a 7-day approval delay.

D Weekly rebuilds

*Suits immutable fleets, not long-lived servers.*

THE SIGNAL

Many accounts and Regions, one configuration: a Quick Setup patch policy.

> Meridian Freight needs continuous vulnerability scanning of its EC2 fleet, its ECR container images and its Lambda functions.
>
> Some EC2 instances are vendor appliances on which the Systems Manager agent cannot be installed, and they must be scanned too.

**What should the solutions architect implement?**

A. Amazon Inspector with EC2 hybrid scanning, so appliances are scanned agentlessly, plus ECR and Lambda scanning

B. ECR basic scanning, and Inspector Classic for EC2

C. GuardDuty Malware Protection for EC2 and ECR

D. AWS Config rules that check instance software versions

◆ PAUSE AND DECIDE

## What should the solutions architect implement?

**A** Inspector hybrid scanning

Agent where possible, EBS snapshots where not; ECR and Lambda too.

**B** Basic and Classic

*Inspector Classic has ended; basic scanning is not continuous.*

**C** Malware Protection

*Finds malware, not known vulnerabilities.*

**D** Config rules

*Custom version checks, with no vulnerability database.*

THE SIGNAL

No agent possible still means Inspector, scanning agentlessly from snapshots.

> Meridian Freight wants to find vulnerable open-source dependencies, hard-coded secrets and insecure infrastructure-as-code templates in its application repositories.
>
> Developers should see results on pull requests, before anything is built or deployed.

**What should the solutions architect recommend?**

A Inspector ECR enhanced scanning of built images

B Security Hub CSPM with the CIS standard

C AWS Config custom rules

D Amazon Inspector code security connected to the repositories

◆ PAUSE AND DECIDE

## What should the solutions architect recommend?

A ECR scanning

*Runs after the image is built, too late for this requirement.*

B CSPM with CIS

*Checks deployed account configuration, not source code.*

C Config rules

*Evaluate deployed resources, not repositories.*

D Inspector code security

Scans source, dependencies, secrets and IaC in the repository.

THE SIGNAL

Before build, in the repository, on pull requests: Inspector code security.

> Meridian Freight's security team receives thousands of Security Hub CSPM findings a day. Many come from sandbox accounts where certain controls are accepted risks, while the same findings in production should be raised to critical.
>
> The team wants this handled automatically as findings arrive.

**What should the solutions architect configure?**

A. Disable Security Hub CSPM in the sandbox accounts

B. Security Hub CSPM automation rules that suppress the accepted findings in sandbox accounts and raise severity in production

C. A Lambda function that deletes sandbox findings nightly

D. Separate delegated administrators for sandbox and production

◆ PAUSE AND DECIDE

## What should the solutions architect configure?

A Disable in sandbox

*Loses all visibility, including real problems.*

B Automation rules

Adjust status and severity by account as findings arrive.

C Nightly deletion

*Custom code, delayed, and destroys evidence.*

D Two administrators

*One delegated administrator per organisation; does not triage.*

THE SIGNAL

Triage findings by context, automatically, at arrival: automation rules.

> When Amazon Inspector reports a critical vulnerability with a known exploit on a long-lived EC2 instance, Meridian Freight wants the instance patched straight away, without waiting for the weekly window.
>
> The response must be automatic and recorded.

**What should the solutions architect implement?**

A. A Lambda function that terminates the affected instance

B. An email to the instance owner from an SNS topic

C. An EventBridge rule matching critical Inspector findings that starts a Systems Manager Automation runbook running AWS-RunPatchBaseline on the instance

D. An AWS Config rule that marks the instance non-compliant

◆ PAUSE AND DECIDE

## What should the solutions architect implement?

A Terminate

*Destroys a long-lived server instead of fixing it.*

B Email the owner

*Not automatic.*

C EventBridge to patch runbook

Detect, route and act, with the run recorded by Systems Manager.

D Config rule

*Reports again; does not patch.*

THE SIGNAL

Detector, EventBridge, Systems Manager. The standard automatic response chain.

# What to carry out of this module

- **Conformance packs** deploy checks and remediations across OUs.
- **CSPM automation rules triage;** runbooks remediate.
- **Inspector** covers EC2 with or without agent, ECR, Lambda and code.
- **Patch policies** patch the organisation from one configuration.
- **Immutable fleets** get new images, not patches in place.

> ON THE EXAM
>
> Detect with Config, CSPM or Inspector. Route with EventBridge. Act with Systems Manager.

MODULE 23 · DOMAIN 2 - SECURITY, COMPLIANCE, AND GOVERNANCE

# Compliance, Data Residency and Sovereignty

Keep data where the law says, choose the right sovereignty model, keep audit trails for AI, collect evidence, and model threats before they arrive.

DOMAIN 2 of 5 EXAM WEIGHT 25% MODULE 23 of 52

admin@sthithapragna.com

# Residency or sovereignty?

DATA RESIDENCY

## Where data is stored and processed

- Choice of Region
- Deny other Regions by policy
- Control replication and copies
- Watch cross-Region features

DIGITAL SOVEREIGNTY

## Who controls and operates it

- Who can access the data
- Who operates the infrastructure
- Which laws and entities apply
- Control of keys and metadata

THE TIEBREAKER

Residency is solved with Regions and policy. Sovereignty may need a different operating model.

# Enforcing Region choices

- **SCP deny** on aws:RequestedRegion outside the approved list.
- **Exempt global services** such as IAM, Organizations, CloudFront and Route 53.
- **Control Tower Region deny** control packages the same idea.
- **Opt-in Regions** stay disabled unless enabled; default Regions cannot be disabled.
- **Exempt a break-glass role** by principal ARN where needed.

> ON THE EXAM
>
> Default Regions cannot be switched off. Residency is enforced with a deny guardrail, not by disabling Regions.

# Where data can quietly cross a border

| FEATURE | RESIDENCY CONTROL |
| --- | --- |
| S3 replication | Deny replication rules to other Regions |
| AWS Backup copies | Restrict copy destinations by policy |
| Bedrock cross-Region inference | Geographic profile only; deny global profiles |
| Global tables, Aurora Global Database | Add replicas only in approved Regions |
| CloudFront | Edge caches worldwide; use geo restriction or avoid |

ON THE EXAM

A Region deny stops resources. It does not stop features that copy or process data elsewhere.

# Bedrock inference and residency

- **Geographic profiles** (US, EU, APAC, JP) route only within that geography.
- **Global profiles** may route to any supported commercial Region.
- **Stored data stays in the source Region**: logs, knowledge bases, configuration.
- **CloudTrail** logs in the source Region, showing the inference Region used.
- **One Region only?** Invoke the model directly there, without a profile.

> ON THE EXAM
>
> Deny global profiles with an SCP on bedrock:InferenceProfileArn; allow your geography's prefix.

# Sovereignty options on AWS

| OPTION | WHAT IT ADDS |
| --- | --- |
| Standard Region plus controls | Residency, Nitro isolation, your keys, even external |
| Dedicated Local Zones | Infrastructure for one customer, at a chosen location |
| Outposts | AWS infrastructure in your own facility |
| AWS European Sovereign Cloud | Separate partition, EU-resident operations, EU entities |

ON THE EXAM

Operated only by EU residents, independent of other Regions: the European Sovereign Cloud.

# Audit trails for regulated and AI workloads

- **Who did what:** organisation CloudTrail, including Bedrock and AgentCore calls.
- **What was said:** Bedrock model invocation logging to S3.
- **What was blocked:** the guardrail trace, returned in the logged response.
- **Tamper-proof retention:** S3 Object Lock in compliance mode.
- **Separate account:** the log archive, outside workload administrators' reach.

> ON THE EXAM
>
> A regulated AI audit trail needs the call, the content, and the guardrail outcome, all locked.

# Whose evidence is it?

AWS'S CONTROLS

## AWS Artifact

- SOC, ISO, PCI and other reports
- Evidence that AWS meets its share
- Agreements such as a HIPAA BAA
- Downloaded, on demand, self-service

YOUR CONTROLS

## Your evidence pipeline

- Config compliance history
- Security Hub CSPM standard scores
- CloudTrail and invocation logs
- Reports from aggregated data

THE TIEBREAKER

An auditor asking for AWS's certifications or a BAA: AWS Artifact. Proof of your controls: your own data.

# Threat modelling a design

01
### Model
Draw components, data flows and trust boundaries

02
### Identify
Ask what can go wrong, for example with STRIDE

03
### Mitigate
Map each threat to a control or accept it

04
### Validate
Test mitigations; record decisions

05
### Revisit
Repeat when the design changes

ON THE EXAM

Threat modelling happens during design, and again on every significant change.

# Reading the scenario

| WHEN THE QUESTION SAYS | IT IS TESTING |
|---|---|
| Only these Regions, global services still work | SCP Region deny with exemptions |
| AI requests must stay in the EU | EU geographic profile, deny global |
| EU-resident operators, separate from global AWS | European Sovereign Cloud |
| Auditor wants AWS's reports or a BAA | AWS Artifact |
| Prove who prompted what, tamper-proof | CloudTrail, invocation logs, Object Lock |
| Find design risks before launch | Threat model during design |

ON THE EXAM

Separate location from control, and AWS's evidence from yours.

A regulator requires that Meridian Freight's EU subsidiary creates resources only in eu-central-1 and eu-west-1.

Administrators must still be able to use IAM, Route 53 and CloudFront, and the rule must apply to every account in the subsidiary's OU.

**What should the solutions architect implement?**

A Disable all other Regions in each account settings page

B An IAM policy on every role denying other Regions

C An SCP on the OU denying requests where aws:RequestedRegion is not one of the two, exempting global services

D An AWS Config rule that reports resources in other Regions

◆ PAUSE AND DECIDE

## What should the solutions architect implement?

A **Disable Regions**
*Only opt-in Regions can be disabled; default ones cannot.*

B **IAM policy per role**
*Administrators can edit or bypass it.*

C **SCP Region deny**
Every principal in the OU, with global services still working.

D **Config rule**
*Reports after creation; does not prevent it.*

THE SIGNAL

Residency across an OU, preventive, global services intact: SCP with exemptions.

Meridian Freight's EU customer-service assistant uses Amazon Bedrock in eu-central-1 and needs more throughput than one Region provides at peak.

Customer prompts must never be processed outside the EU, and developers must not be able to switch to a profile that could route elsewhere.

## What should the solutions architect implement?

A. A global cross-Region inference profile for maximum throughput

B. Direct invocation in eu-central-1 only

C. Provisioned throughput in a US Region

D. The EU geographic inference profile, with an SCP denying global inference profile ARNs

◆ PAUSE AND DECIDE

## What should the solutions architect implement?

**A** Global profile

*Can route to any supported Region, including outside the EU.*

**B** Direct, one Region

*Keeps data in the EU, but does not add the throughput needed.*

**C** US provisioned throughput

*Processes EU prompts in the US.*

**D** EU profile plus SCP

More capacity across EU Regions, and global profiles blocked.

THE SIGNAL

More throughput, EU only, enforced: geographic profile plus a deny on global profiles.

> A German public-sector customer requires that Meridian Freight's workload runs on infrastructure operated and supported only by EU residents, managed by EU legal entities, and independent of AWS's other Regions.
>
> Customer-created metadata, such as IAM roles and tags, must also stay in the EU.

**What should the solutions architect recommend?**

A Deploy the workload in the AWS European Sovereign Cloud

B Use eu-central-1 with an external key store

C Use eu-central-1 with an SCP Region deny

D Use AWS Outposts in a German colocation facility

◆ PAUSE AND DECIDE

## What should the solutions architect recommend?

**A** European Sovereign Cloud

Separate partition, EU-resident operations, EU entities, EU metadata.

**B** Region plus XKS

*Controls keys, not who operates the infrastructure.*

**C** Region deny

*Residency only; operations are not EU-only or independent.*

**D** Outposts

*Location of hardware, still managed from its parent Region.*

THE SIGNAL

Operators, legal entities and independence are sovereignty words: European Sovereign Cloud.

> Meridian Freight is launching a health-logistics service that handles protected health information in the US. The compliance team must sign a business associate addendum with AWS.
>
> External auditors also want AWS's current SOC 2 and ISO 27001 reports.

**Where should the compliance team obtain these?**

A. A Config conformance pack for HIPAA

B. AWS Artifact, for both the agreement and the reports

C. Security Hub CSPM, with the relevant standard enabled

D. A support case requesting the documents

◆ PAUSE AND DECIDE

## Where should the compliance team obtain these?

A Conformance pack

*Checks Meridian's resources; it is not AWS's paperwork.*

B AWS Artifact

Self-service agreements and AWS compliance reports.

C CSPM

*Scores Meridian's configuration, not AWS's controls.*

D Support case

*Unnecessary; Artifact is self-service.*

THE SIGNAL

AWS's reports and agreements with AWS: Artifact. Proof of your configuration: Config and CSPM.

> A financial regulator requires Meridian Freight's credit-decision assistant to keep, for ten years, a record of who invoked the model, the full prompt and response, and whether a guardrail blocked or masked content.
>
> Records must be impossible to alter or delete, even by administrators.

**What should the solutions architect implement?**

A. CloudWatch Logs in the workload account with ten-year retention

B. An organisation CloudTrail trail only

C. Application logs written to DynamoDB with point-in-time recovery

D. CloudTrail plus model invocation logging, including guardrail results, delivered to the log archive account in S3 with Object Lock in compliance mode

◆ PAUSE AND DECIDE

## What should the solutions architect implement?

A **CloudWatch Logs locally**

*Workload administrators can delete the log group.*

B **CloudTrail only**

*Records who, but not the prompt, response or guardrail result.*

C **DynamoDB logs**

*Mutable by administrators, and depends on application code.*

D **Trail, invocation logs, Object Lock**

Who, what and the guardrail outcome, in immutable storage.

THE SIGNAL

Who, what, and what was blocked, kept immutably outside the workload account.

> Meridian Freight is designing a partner portal that will accept uploaded customs documents and pass them to an AI extraction agent.
>
> The security architect wants to identify risks such as spoofed partners, tampered documents and prompt injection, and agree mitigations before any code is written.

## What should the solutions architect do?

A Commission a penetration test after launch

B Enable GuardDuty and Security Hub in the portal account

C Run a threat model during design, using STRIDE across the data flows and trust boundaries, and record a mitigation for each threat

D Apply the AWS Foundational Security Best Practices standard

◆ PAUSE AND DECIDE

## What should the solutions architect do?

A Penetration test after launch

*Valuable later, but the requirement is before code exists.*

B GuardDuty and Security Hub

*Detect problems in running systems, not design risks.*

C Threat model during design

Structured identification of threats with agreed mitigations, before building.

D Best practices standard

*Generic configuration checks, nothing about this design.*

THE SIGNAL

Design-time risk, specific to this architecture: a threat model.

# What to carry out of this module

- **Residency is location; sovereignty is control** of access and operations.
- **SCP Region deny** with global service exemptions; watch features that copy data.
- **Bedrock:** geographic profiles for residency; deny global profiles.
- **Artifact** for AWS's evidence; your logs and Config for yours.
- **AI audit trail**: who, what, and guardrail outcome, locked in the log archive.

> ON THE EXAM
>
> Separate location from control, and AWS's evidence from yours. Threat model during design.

MODULE 24 · DOMAIN 2 - SECURITY, COMPLIANCE, AND GOVERNANCE

# Responsible AI and AI Security Controls

Filter what goes in and comes out, control what agents may do and as whom, and put a human in front of decisions that matter.

DOMAIN 2 of 5 EXAM WEIGHT 25% MODULE 24 of 52

admin@sthithapragna.com

A model's instructions are **suggestions**. Controls that must hold belong **outside the model**, where a prompt cannot reach them.

# Bedrock Guardrails policies

| POLICY | CATCHES |
| --- | --- |
| Content filters | Hate, violence, sexual, misconduct, prompt attacks; text and images |
| Denied topics | Subjects you define, such as investment advice |
| Word filters | Profanity and custom words or phrases |
| Sensitive information | PII and custom regex: block or mask |
| Contextual grounding | Answers not supported by the source, or off the question |
| Automated Reasoning | Answers that contradict your written rules |

ON THE EXAM

Prompt injection and jailbreak attempts are caught by the prompt attack category of content filters.

# Applying guardrails everywhere

- **Inputs and outputs** are evaluated separately, each with its own action.
- **ApplyGuardrail API** works with any model, including ones outside Bedrock.
- **IAM condition** bedrock:GuardrailIdentifier forces a guardrail on calls.
- **Bedrock policies in Organizations** enforce a guardrail on every call, organisation wide.
- **Versions** pin a tested guardrail; update deliberately.

> ON THE EXAM
>
> A guardrail developers can skip is a suggestion. Enforce it with IAM, or across accounts with a Bedrock policy.

# Contextual grounding or Automated Reasoning?

CONTEXTUAL GROUNDING

## Is it supported by the source?

- Compares answer with retrieved passages
- Also scores relevance to the question
- Threshold you tune
- Suits RAG answers

AUTOMATED REASONING

## Is it consistent with the rules?

- Rules built from your policy documents
- Formal logic, not probability
- Valid, invalid or satisfiable
- Suits eligibility and policy answers

THE TIEBREAKER

Verifiable against written rules, with an explanation of which rule failed: Automated Reasoning.

# AgentCore Identity

| DIRECTION | QUESTION | MECHANISM |
|---|---|---|
| Inbound | Who is calling the agent? | Validate tokens from Cognito, Okta, Entra ID |
| Workload | Which agent is this? | An agent identity, separate from any user |
| Outbound, as itself | Agent calls a service | OAuth client credentials or API key, vaulted |
| Outbound, for a user | Agent acts on a user's behalf | OAuth with user consent; tokens in the vault |

ON THE EXAM

Act with the user's own permissions, not a shared super-account: outbound OAuth on the user's behalf.

# Deciding what an agent may do

- **AgentCore Gateway** exposes tools to agents through one controlled entry point.
- **AgentCore Policy** checks every tool call at the gateway, deny by default.
- **Cedar rules** can test the user, the tool and its parameters, such as an amount.
- **Least privilege** for the agent's own IAM role, as for any workload.
- **Observability** traces every step, for audit and evaluation.

> ON THE EXAM
>
> A hard limit on a tool's parameters, enforced whatever the prompt: a policy at the gateway.

# Which actions need a human?

| TIER | EXAMPLES | APPROVAL |
| --- | --- | --- |
| Read-only | Lookups, status queries | Autonomous |
| Low-risk writes | Routine updates | Single reviewer, or none |
| High-risk | Payments, deletion, external messages | Required; may need several reviewers |

ON THE EXAM

Classify risk with deterministic rules. Never let the model decide whether it needs approval.

# Which approval pattern?

STEP FUNCTIONS TASK TOKEN

## Workflow waits for a reviewer

- Task emits a token and pauses
- Approval app calls SendTaskSuccess or Failure
- Waits up to a year; timeout and Catch
- Execution history records the decision

BEDROCK AGENTS CONFIRMATION

## The end user approves

- User confirmation before a function runs
- Or return of control to the application
- Interactive, in the conversation
- Application handles timeouts

THE TIEBREAKER

A separate reviewer, possibly hours later, with escalation: Step Functions with a task token.

# Reading the scenario

| WHEN THE QUESTION SAYS | IT IS TESTING |
|---|---|
| Block topics, mask PII, stop jailbreaks | Guardrails policies |
| Every account must use the guardrail | Bedrock policy in Organizations |
| Provably consistent with written rules | Automated Reasoning checks |
| Agent acts with the user's own access | AgentCore Identity, OAuth for the user |
| Hard limit on a tool, whatever the prompt | AgentCore Policy at the gateway |
| Separate reviewer, hours, escalation | Step Functions task token |

ON THE EXAM

Every right answer here sits outside the model. A system prompt is never enough.

> Meridian Freight's customer chatbot on Amazon Bedrock must refuse harmful content, never give investment advice about freight futures, mask customers' phone numbers and email addresses in responses, and resist jailbreak attempts.
>
> Compliance requires these controls to hold regardless of how users phrase their requests.

## What should the solutions architect implement?

A. A Bedrock guardrail with content filters including prompt attacks, a denied topic for investment advice, and sensitive information masking

B. System prompt instructions listing each rule

C. AWS WAF in front of the chatbot API

D. Amazon Comprehend PII detection in a Lambda function after each response

◆ PAUSE AND DECIDE

## What should the solutions architect implement?

**A** Guardrail with three policies

Each requirement maps to a policy enforced outside the model.

**B** System prompt

*Instructions a clever prompt can override.*

**C** AWS WAF

*Inspects HTTP traffic, not the meaning of a conversation.*

**D** Comprehend in Lambda

*Covers PII only, and is custom glue.*

THE SIGNAL

Topics, harm, PII and jailbreaks, enforced independently: one guardrail, several policies.

Meridian Freight has 45 accounts where teams build generative AI features on Amazon Bedrock. An audit found some teams calling models without the company's approved guardrail.

The guardrail must apply to every model inference call in every account, without relying on teams to configure it.

**What should the solutions architect implement?**

A. A wiki page describing the guardrail standard

B. A Bedrock policy in AWS Organizations referencing the approved guardrail version, attached to the organisation root

C. An SCP that denies bedrock:InvokeModel entirely

D. A Config rule that reports applications without guardrails

◆ PAUSE AND DECIDE

## What should the solutions architect implement?

A Wiki page

*A convention, which the audit shows is not followed.*

B Bedrock policy

Applies the guardrail to every inference call beneath the root.

C Deny InvokeModel

*Stops all AI features instead of governing them.*

D Config rule

*Reports after the fact, if it can see the calls at all.*

THE SIGNAL

Organisation-wide, without team configuration: a Bedrock policy in Organizations.

> Meridian Freight's assistant answers customers' questions about whether a shipment qualifies for duty relief, based on a 60-page written customs policy.
>
> Compliance wants each answer verified against the policy's rules, with an explanation of which rule an incorrect answer breaks.

## Which control should the solutions architect add?

A Contextual grounding checks with a high threshold

B A denied topic for duty relief

C Setting the model temperature to zero

D Automated Reasoning checks built from the customs policy document

◆ PAUSE AND DECIDE

## Which control should the solutions architect add?

A Contextual grounding

*Scores support from passages; does not prove rule compliance.*

B Denied topic

*Blocks the very questions the assistant must answer.*

C Temperature zero

*More consistent, not more correct.*

D Automated Reasoning

Formal rules from the policy; reports valid, invalid and the rule broken.

THE SIGNAL

Verified against written rules, with the failing rule named: Automated Reasoning checks.

> Meridian Freight is building a scheduling agent on AgentCore. Dispatchers sign in through the company's Okta. The agent must read and update each dispatcher's own calendar in a SaaS calendar service.
>
> The agent must only ever have the access that the signed-in dispatcher has, and must not store passwords.

## What should the solutions architect implement?

A. AgentCore Identity with Okta as the inbound identity provider, and outbound OAuth on the user's behalf with tokens held in the token vault

B. A shared calendar service account whose credentials are in Secrets Manager

C. Each dispatcher's password stored encrypted in DynamoDB

D. An IAM role for the agent with full access to the calendar API

◆ PAUSE AND DECIDE

## What should the solutions architect implement?

**A** AgentCore Identity, user OAuth

Validates the dispatcher, then acts with their consented token only.

**B** Shared service account

*The agent could reach every dispatcher's calendar.*

**C** Stored passwords

*Explicitly ruled out, and a serious liability.*

**D** IAM role

*IAM does not grant access inside a SaaS service.*

THE SIGNAL

Act as the signed-in user, with no stored passwords: inbound IdP plus outbound OAuth for the user.

> Meridian Freight's customer-service agent can issue refunds through a refund tool exposed by AgentCore Gateway. Refunds above 500 dollars must never be issued by the agent, whatever a customer writes.
>
> The limit must be enforced deterministically and be reviewable by auditors.

**What should the solutions architect implement?**

A. A system prompt stating the 500 dollar limit

B. A guardrail denied topic for large refunds

C. An AgentCore Policy rule at the gateway denying refund tool calls with an amount above 500

D. Fine-tune the model on examples of refusing large refunds

◆ PAUSE AND DECIDE

## What should the solutions architect implement?

A System prompt

*Probabilistic; a crafted message can override it.*

B Denied topic

*Judges conversation text, not the tool call's amount parameter.*

C AgentCore Policy

Deterministic check of every tool call's parameters, outside the model.

D Fine-tuning

*Makes refusal likelier, never certain.*

THE SIGNAL

Deterministic, on a tool's parameters, auditable: a Cedar policy at the gateway.

> Meridian Freight's operations agent can propose cancelling shipments. Cancellations worth more than 50,000 dollars must be approved by a duty manager, who may take several hours to respond.
>
> If nobody responds within eight hours, the request must escalate to a second manager, and every decision must be recorded with the reviewer's identity.

**What should the solutions architect implement?**

A. Bedrock Agents user confirmation in the chat session

B. A Step Functions task using waitForTaskToken to an approval app, with an eight-hour timeout and a Catch that escalates

C. A Lambda function that polls an inbox every minute

D. An SNS email asking the manager to reply yes

◆ PAUSE AND DECIDE

## What should the solutions architect implement?

A User confirmation

*The approver is the chat user, not a separate manager hours later.*

B Task token workflow

Pauses for hours, escalates on timeout, records the decision.

C Polling Lambda

*Custom, fragile, and limited to 15 minutes per run.*

D Email reply

*No reliable identity, timeout or record.*

THE SIGNAL

Separate approver, long wait, escalation, audit: Step Functions with a task token.

# What to carry out of this module

- **Controls outside the model;** a system prompt is never the answer.
- **Guardrails** for content, topics, PII, prompt attacks, grounding and rules.
- **Enforce guardrails** with IAM, or organisation-wide with a Bedrock policy.
- **AgentCore Identity** for who; **AgentCore Policy** for what, per tool call.
- **Risk-tiered approval**; Step Functions task tokens for separate reviewers.

> ON THE EXAM
>
> Filter, identify, authorise, approve: four layers, none of them inside the prompt.

MODULE 25 · DOMAIN 3 - COST-OPTIMIZED ARCHITECTURE DESIGN

# Pricing Models and Purchase Options

Match each slice of usage to the right purchase option: commitments for the baseline, Spot for the interruptible, reservations when capacity itself must be guaranteed.

DOMAIN 3 of 5 EXAM WEIGHT 15% MODULE 25 of 52

admin@sthithapragna.com

A discount is not a capacity guarantee, and a capacity guarantee is not a discount. Know which one the question needs.

# Purchase options at a glance

| OPTION | BEST FOR | TRADE-OFF |
|---|---|---|
| On-Demand | Spiky, short-lived, unknown usage | Highest unit price |
| Savings Plans | Steady spend you can commit to | 1 or 3 years of hourly spend |
| Reserved Instances | Steady use of a specific resource | Less flexible than Savings Plans |
| Spot | Interruptible, flexible work | Two-minute interruption notice |
| Capacity reservations | Capacity that must be available | Paid whether used or not |

ON THE EXAM

Commit to the floor, run the peaks On-Demand, and push anything interruptible to Spot.

# Savings Plans types

| PLAN | COVERS | FLEXIBILITY |
|---|---|---|
| Compute | EC2, Fargate, Lambda | Any family, size, Region, OS |
| EC2 Instance | EC2 in one family and Region | Size and OS within the family |
| SageMaker AI | SageMaker AI instance usage | Any instance, Region, component |
| Database | Aurora, RDS, DynamoDB and six more | Engines, Regions, serverless or provisioned |

ON THE EXAM

Usage that will change shape, family or Region: Compute Savings Plan. Locked to one family: EC2 Instance plan, bigger discount.

# Database Savings Plans

- **Covers** Aurora, RDS, DynamoDB, ElastiCache, DocumentDB, Neptune, Keyspaces, Timestream, DMS.
- **One-year term**, committed hourly spend.
- **Up to 35%** on serverless, up to 20% on provisioned instances.
- **Flexible** across engines, Regions and deployment types.
- **Reserved DB instances** still exist, but lock to one instance class.

> ON THE EXAM
>
> Moving from provisioned to Aurora Serverless, or between engines: the Database Savings Plan keeps the discount.

# Commitment discount or capacity guarantee?

SAVINGS PLANS AND REGIONAL RIS

## Pay less

- Discount on matching usage
- No promise capacity exists
- Applies automatically by hour
- Unused commitment is still paid

ON-DEMAND CAPACITY RESERVATIONS

## Be sure it launches

- Capacity held in one AZ
- Immediate or future-dated
- On-Demand price unless discounted
- Combines with Savings Plans

THE TIEBREAKER

Guaranteed launches for an event: a reservation. Then cover it with a Savings Plan for the discount.

# Spot, used well

- **Up to 90% off** On-Demand, for spare capacity AWS can reclaim.
- **Two-minute notice**, plus an earlier rebalance recommendation.
- **Diversify** across many instance types and Availability Zones.
- **Price-capacity-optimised** allocation picks the deepest pools.
- **Fits** batch, CI, stateless web tiers, containers, checkpointed training.

> ON THE EXAM
>
> Spot fails when a design asks for one instance type. Flexibility is what makes it reliable.

# Capacity-based options

| OPTION | USE IT FOR |
| --- | --- |
| On-Demand Capacity Reservation | Any duration, specific AZ, critical events or DR |
| Future-dated reservation | A known date ahead, such as a launch |
| Capacity Blocks for ML | GPU instances for a fixed future window |
| Provisioned throughput or capacity | DynamoDB, Kinesis, Bedrock: pay for a rate |

ON THE EXAM

GPUs for a training run starting on a known date, for a fixed period: Capacity Blocks for ML.

# Sizing and managing commitments

- **Recommendations** in Cost Explorer from past usage, by plan type and term.
- **Coverage** shows how much usage is committed; **utilisation** how much commitment is used.
- **Commit to the floor**, not the average; buy more in steps.
- **Return a Savings Plan** within 7 days, same month, up to 100 dollars an hour.
- **Savings Plans cannot be resold**; Standard EC2 RIs can, on the Marketplace.

> ON THE EXAM
>
> Low utilisation means over-commitment. Low coverage means money left on the table.

# Reading the scenario

| WHEN THE QUESTION SAYS | IT IS TESTING |
|---|---|
| Moving from EC2 to Fargate or Lambda | Compute Savings Plan |
| Fault-tolerant, flexible batch | Spot, diversified |
| Must launch on a specific day, in one AZ | Capacity reservation |
| Databases changing engine or going serverless | Database Savings Plan |
| GPUs for a fixed window, future date | Capacity Blocks for ML |
| Bought the wrong plan yesterday | Return within 7 days |

ON THE EXAM

Read the usage pattern first: steady, spiky, interruptible, changing, or capacity-critical.

> Meridian Freight spends a steady 40 dollars an hour on EC2 across three Regions, plus Fargate and Lambda. Over the next year it plans to move most EC2 workloads to Fargate.
>
> Finance wants the largest discount that will still apply after the migration.

**Which purchase option should the solutions architect recommend?**

A. EC2 Instance Savings Plans for each family and Region

B. Standard Reserved Instances for the current instance types

C. Spot Instances for all EC2 workloads

D. A Compute Savings Plan sized to the steady hourly spend

◆ PAUSE AND DECIDE

## Which purchase option should the solutions architect recommend?

A EC2 Instance plans

*Deeper discount, but stranded when workloads move to Fargate.*

B Standard RIs

*Locked to instance types that are being retired.*

C Spot

*Not suitable for all workloads, and not a commitment.*

D Compute Savings Plan

Applies to EC2, Fargate and Lambda in any Region.

THE SIGNAL

Usage changing from EC2 to containers or functions: Compute Savings Plan.

> Meridian Freight renders route-optimisation maps overnight. Jobs checkpoint every few minutes, can restart on any instance, and run on many compute-optimised instance types.
>
> The team wants the lowest possible compute cost.

**What should the solutions architect recommend?**

A. Spot Instances in an Auto Scaling group spanning many instance types and AZs, with price-capacity-optimised allocation

B. On-Demand Instances of one instance type

C. Three-year Standard Reserved Instances

D. On-Demand Capacity Reservations for the overnight window

◆ PAUSE AND DECIDE

## What should the solutions architect recommend?

**A** Diversified Spot

Deepest discount; checkpoints and diversity absorb interruptions.

**B** On-Demand, one type

*Full price for work that tolerates interruption.*

**C** 3-year RIs

*Pays for 24 hours a day for an overnight job.*

**D** Capacity Reservations

*Buys certainty the workload does not need, at full price.*

THE SIGNAL

Checkpointed, restartable, flexible on instance type: diversified Spot.

> Meridian Freight holds a Compute Savings Plan. Next month, a three-day peak-season sale will need 200 extra instances of a specific type in two Availability Zones.
>
> Leadership requires certainty that the instances will launch on those days.

**What should the solutions architect do?**

A Rely on the Compute Savings Plan to secure the capacity

B Buy one-year zonal Reserved Instances for the 200 instances

C Create future-dated On-Demand Capacity Reservations for the three days in both AZs

D Request Spot capacity for the sale

◆ PAUSE AND DECIDE

## What should the solutions architect do?

A Savings Plan

*Discounts usage; does not hold capacity.*

B 1-year zonal RIs

*Hold capacity, but pay for a year to cover three days.*

C Future-dated reservations

Capacity held for exactly the days needed; the plan still discounts it.

D Spot

*The opposite of certainty.*

THE SIGNAL

Certainty for a known window: a future-dated reservation. The Savings Plan still discounts it.

> Meridian Freight runs Aurora PostgreSQL provisioned clusters and DynamoDB in two Regions. Over the next year it will move several clusters to Aurora Serverless v2 and may add a third Region.
>
> Finance wants a commitment discount that keeps applying through these changes.

**Which purchase option should the solutions architect recommend?**

A. Reserved DB instances for the current Aurora instance classes

B. A Database Savings Plan sized to the steady database spend

C. A Compute Savings Plan

D. DynamoDB reserved capacity only

◆ PAUSE AND DECIDE

## Which purchase option should the solutions architect recommend?

A Reserved DB instances

*Tied to instance classes that become serverless.*

B Database Savings Plan

Follows spend across Aurora, DynamoDB, serverless and Regions.

C Compute Savings Plan

*Does not cover database services.*

D DynamoDB reserved only

*Leaves Aurora uncovered.*

THE SIGNAL

Databases changing shape or Region: the Database Savings Plan.

> Meridian Freight's data science team must fine-tune a forecasting model on 16 GPU instances for two weeks, starting on the first of next month.
>
> The run cannot be interrupted, and the team does not need the GPUs afterwards.

**What should the solutions architect recommend?**

A. Spot GPU instances with checkpointing

B. A one-year EC2 Instance Savings Plan for the GPU family

C. EC2 Capacity Blocks for ML for the two-week window

D. On-Demand Instances launched on the day

◆ PAUSE AND DECIDE

## What should the solutions architect recommend?

A Spot GPUs

*The run must not be interrupted.*

B 1-year Savings Plan

*Discounts a year of spend for two weeks of use, and holds no capacity.*

C Capacity Blocks for ML

Reserved GPUs for exactly the window, from a future date.

D On-Demand on the day

*No guarantee scarce GPUs will be available.*

THE SIGNAL

Uninterrupted GPUs, fixed window, known start date: Capacity Blocks for ML.

> Yesterday, a Meridian Freight engineer bought a one-year EC2 Instance Savings Plan with a commitment of 30 dollars an hour, for the wrong instance family.
>
> Finance asks what can be done.

**What should the solutions architect advise?**

A. Return the Savings Plan, since it is within seven days, in the same month, and under 100 dollars an hour

B. Sell it on the Reserved Instance Marketplace

C. Exchange it for a Compute Savings Plan

D. Nothing; Savings Plans can never be cancelled

◆ PAUSE AND DECIDE

## What should the solutions architect advise?

**A** Return it

Meets every condition: 7 days, same month, 100 dollars an hour or less.

**B** Marketplace

*Only Standard EC2 RIs can be sold; Savings Plans cannot.*

**C** Exchange

*Exchanges apply to Convertible RIs, not Savings Plans.*

**D** Nothing

*Out of date since returns were introduced in 2024.*

THE SIGNAL

A recent, small Savings Plan mistake can be returned. Older or larger ones cannot.

# What to carry out of this module

- **Discounts and capacity are separate**; reservations combine with Savings Plans.
- **Compute Savings Plans** for changing compute; EC2 Instance plans for fixed families.
- **Database Savings Plans** follow databases across engines, Regions, serverless.
- **Spot** for interruptible work, diversified across types and AZs.
- **Capacity Blocks** for GPU windows; return mistaken plans within 7 days.

> ON THE EXAM
>
> Name the usage pattern, then match the option. Most estates layer several.

MODULE 26 · DOMAIN 3 - COST-OPTIMIZED ARCHITECTURE DESIGN

# Cost-Optimised Compute Design

Pick the cheapest compute model that fits the work, right-size it from real metrics, and scale it to the demand you actually have.

DOMAIN 3 of 5 EXAM WEIGHT 15% MODULE 26 of 52

admin@sthithapragna.com

The cheapest unit price does not help if you buy **twice the units you need**. Shape and size come before discounts.

# Compute cost levers

| LEVER | TYPICAL EFFECT |
| --- | --- |
| Graviton (Arm) instances | Better price-performance than comparable x86 |
| Right-size from metrics | Remove unused CPU and memory |
| Scale with demand | Pay for peaks only while they last |
| Serverless for spiky work | No charge while idle |
| Spot or Fargate Spot | Deep discount for interruptible work |

ON THE EXAM

Design levers first, purchase options second.

# Step Functions: Standard or Express?

STANDARD WORKFLOWS

## Long, auditable, exactly once

- Priced per state transition
- Run for up to a year
- Exactly-once execution
- Full history kept, task tokens, human waits

EXPRESS WORKFLOWS

## High volume, short, cheap

- Priced per request and duration
- Run for up to five minutes
- At-least-once when asynchronous
- History sent to CloudWatch Logs

THE TIEBREAKER

Millions of short, idempotent runs: Express. Long-running, waiting or non-idempotent: Standard.

# Lambda cost, decided by design

- **Cost is memory times duration**, plus requests; CPU scales with memory.
- **Arm64** is cheaper per GB-second than x86 for the same memory.
- **Tune memory:** more memory can finish faster and cost less, or not.
- **Provisioned concurrency** removes cold starts, but is paid while idle.
- **Avoid waiting:** call services asynchronously; do not pay to sleep.

> ON THE EXAM
>
> Compute Optimizer recommends Lambda memory sizes from real invocation metrics.

# Lambda or Lambda Managed Instances?

LAMBDA, DEFAULT

## Pay per invocation duration

- Scales to zero
- One request per environment at a time
- Ideal for spiky or low volume
- Compute Savings Plans apply

LAMBDA MANAGED INSTANCES

## Lambda on EC2 you choose

- EC2 price plus a 15% management fee
- No per-request duration charge
- Many requests per environment
- Commitments apply to the EC2 part

THE TIEBREAKER

Steady, very high-volume functions that want EC2 pricing and commitments: Lambda Managed Instances.

# AWS Compute Optimizer

| RECOMMENDS | FOR |
|---|---|
| Instance type and size | EC2 instances and Auto Scaling groups |
| Volume type, size, IOPS | EBS volumes, RDS storage |
| Memory size | Lambda functions |
| CPU and memory | ECS services on Fargate |
| Instance class, I/O-Optimized | RDS and Aurora |
| Idle resources to remove | NAT gateways, caches, SageMaker endpoints, ASGs |

ON THE EXAM

Rightsizing from measured utilisation, across EC2, Lambda, Fargate, EBS and RDS: Compute Optimizer.

# Scaling policies and when they fit

| POLICY | FITS |
| --- | --- |
| Target tracking | Keep a metric near a target, such as 50% CPU |
| Step scaling | Different responses for different breach sizes |
| Scheduled scaling | Known patterns, such as office hours |
| Predictive scaling | Recurring daily or weekly cycles, scale ahead |
| Fargate Spot | Interruptible ECS tasks at a large discount |

ON THE EXAM

Known hours: scheduled. Recurring cycles: predictive. Everything else: target tracking.

# Reading the scenario

| WHEN THE QUESTION SAYS | IT IS TESTING |
|---|---|
| Millions of short, idempotent workflow runs | Step Functions Express |
| Portable code on x86 instances | Move to Graviton |
| Function memory far above what it uses | Compute Optimizer memory sizing |
| Steady, huge Lambda volume | Lambda Managed Instances |
| Idle nights and weekends | Scheduled scaling |
| Interruptible ECS tasks | Fargate Spot capacity provider |

ON THE EXAM

Find the waste first: idle time, oversize, wrong model. Then pick the lever.

> Meridian Freight validates each tracking event with a five-step workflow that finishes in under two seconds. It runs 40 million times a day on Step Functions Standard, and every step is idempotent.
>
> The workflow bill is now larger than the compute it orchestrates.

**What should the solutions architect recommend?**

A Move the workflow to EC2 instances running a custom orchestrator

B Change the workflow to a Step Functions Express workflow

C Buy a Compute Savings Plan

D Add more steps to batch work inside each state

◆ PAUSE AND DECIDE

# What should the solutions architect recommend?

A Custom orchestrator

*Replaces a managed service with code and servers to run.*

B Express workflow

Per-request and duration pricing fits short, high-volume, idempotent runs.

C Compute Savings Plan

*Does not cover Step Functions state transitions.*

D More steps

*More transitions means a bigger Standard bill.*

THE SIGNAL

Short, idempotent, tens of millions of runs: Express, not Standard.

> Meridian Freight runs a Java 21 microservice estate on 300 x86 general-purpose EC2 instances. The container images are already built for both x86 and Arm.
>
> The team wants to reduce compute cost without reducing performance, before buying any new commitments.

## What should the solutions architect recommend first?

A. Move to larger x86 instances and run fewer of them

B. Buy three-year Standard Reserved Instances for the current types

C. Run all services on Spot Instances

D. Migrate the services to equivalent Graviton instance types

◆ PAUSE AND DECIDE

## What should the solutions architect recommend first?

A Larger x86 instances

*Same price-performance, just packaged differently.*

B 3-year RIs on current types

*Locks in the more expensive architecture, and is a commitment.*

C All Spot

*Interruption risk for services not designed for it.*

D Graviton

Better price-performance; images already support Arm.

THE SIGNAL

Portable code, multi-architecture images, before commitments: move to Graviton.

> A Meridian Freight Lambda function that calls partner APIs is configured with 3008 MB of memory on x86. It uses under 200 MB and spends most of its time waiting for responses.
>
> The team wants to cut its cost with minimal effort.

**What should the solutions architect recommend?**

A Add provisioned concurrency

B Apply Compute Optimizer's memory recommendation and switch the function to arm64

C Increase memory so the function runs faster

D Rewrite the function to run on EC2

◆ PAUSE AND DECIDE

## What should the solutions architect recommend?

A Provisioned concurrency

*Adds an always-on charge; cold starts are not the problem.*

B Right-size memory, use arm64

Pays for far less memory, at a lower per-GB-second rate.

C More memory

*Waiting on the network does not get faster with more CPU.*

D Rewrite for EC2

*High effort, and pays for idle servers.*

THE SIGNAL

I/O-bound and oversized: reduce memory. Portable runtime: arm64.

> Meridian Freight's telemetry ingestion function handles a steady 20,000 requests a second, all day, every day. Requests are short and the code is thread-safe.
>
> Finance wants to apply the company's existing commitment discounts to this workload and lower its cost, while keeping the Lambda programming model.

**What should the solutions architect recommend?**

A Provisioned concurrency for the peak level

B Rewrite the service for Amazon ECS on EC2

C Increase the function's memory to reduce duration

D Run the function on Lambda Managed Instances, covered by the existing Savings Plans

◆ PAUSE AND DECIDE

## What should the solutions architect recommend?

A Provisioned concurrency

*Addresses latency, not the cost of steady volume.*

B Rewrite for ECS

*Abandons the Lambda model the team wants to keep.*

C More memory

*Short requests gain little; cost per request may rise.*

D Lambda Managed Instances

EC2 pricing with commitments, many requests per environment, same model.

THE SIGNAL

Steady, huge, thread-safe, keep Lambda, use commitments: Lambda Managed Instances.

> Meridian Freight's internal dispatch portal runs on an Auto Scaling group sized for its weekday peak around the clock. Usage is heavy from 7 a.m. to 7 p.m. on weekdays and near zero otherwise.
>
> During the day, load varies with shipment volume.

## What should the solutions architect configure?

A. Scheduled actions that reduce the group to a minimum outside working hours and restore it each morning, with target tracking during the day

B. A fixed group size equal to the daily peak

C. Step scaling only, on CPU utilisation

D. Three-year Reserved Instances for the peak size

◆ PAUSE AND DECIDE

## What should the solutions architect configure?

A. Scheduled plus target tracking
Removes idle hours; tracks the daytime variation.

B. Fixed at peak
*This is the current waste.*

C. Step scaling only
*Reacts, but keeps a large minimum unless schedules change it.*

D. 3-year RIs at peak
*Commits to capacity that is idle most of the week.*

THE SIGNAL

Known hours: scheduled actions. Variation within them: target tracking. They combine.

> Meridian Freight runs nightly report generation and all development environments as ECS services on Fargate. Tasks can be interrupted and retried without harm.
>
> The team wants to cut cost while keeping a small amount of capacity that is never interrupted.

**What should the solutions architect configure?**

A Move the tasks to Lambda

B Buy Reserved Instances for Fargate

C A capacity provider strategy with a small base on Fargate and the rest weighted to Fargate Spot

D Run all tasks on Fargate On-Demand with larger task sizes

◆ PAUSE AND DECIDE

## What should the solutions architect configure?

A Lambda

*Reports may exceed 15 minutes; a redesign for no stated need.*

B Fargate RIs

*Fargate is discounted by Compute Savings Plans, not RIs.*

C Base plus Fargate Spot

Deep discount on interruptible tasks, with a guaranteed base.

D Larger On-Demand tasks

*Costs more, not less.*

THE SIGNAL

Interruptible ECS tasks with a protected minimum: capacity provider base plus Fargate Spot.

# What to carry out of this module

- **Design before discounts:** model, size and scale, then commit to the floor.
- **Graviton** for portable code; **Express** for short, high-volume workflows.
- **Lambda:** right-size memory, arm64, Managed Instances for steady volume.
- **Compute Optimizer** for rightsizing and idle resources.
- **Scheduled, predictive, target tracking**, and Fargate Spot with a base.

> ON THE EXAM
>
> Name the waste, choose the lever, and commit only to what remains.

MODULE 27 · DOMAIN 3 - COST-OPTIMIZED ARCHITECTURE DESIGN

# AI/ML Cost Optimisation

Choose the tier and model each request deserves, batch what can wait, cache what repeats, and route inference without paying to move data.

DOMAIN 3 of 5 EXAM WEIGHT 15% MODULE 27 of 52

admin@sthithapragna.com

Most AI spend is **tokens times price**. Send fewer tokens, to a cheaper model, at a cheaper tier.

# Bedrock inference options and cost

| OPTION | FITS | COST EFFECT |
|---|---|---|
| On-demand, Standard tier | Interactive, everyday traffic | Baseline per-token price |
| Priority tier | Latency-critical, customer-facing | Premium for faster output |
| Flex tier | Agentic or background, can wait | Discount for lower priority |
| Batch inference | Large jobs, results later | About half the on-demand price |
| Provisioned throughput | Steady high volume, custom models | Pay for model units by the hour |

ON THE EXAM

Results needed tomorrow, not now: batch. Can wait seconds longer: Flex. Must be fastest: Priority.

# Prompt caching

- **Caches a repeated prompt prefix**, such as a long system prompt or document.
- **Cache reads** are billed far below normal input; up to 90% lower cost.
- **TTL** usually 5 minutes, reset on each hit; some models offer 1 hour.
- **Prefix must be identical**; put changing content after the checkpoint.
- **On-demand only**; not available with batch inference.

> ON THE EXAM
>
> The same long context sent with every request: prompt caching.

# Prompt routing or distillation?

INTELLIGENT PROMPT ROUTING

## Pick a model per request

- Router chooses within a model family
- Simple prompts go to the smaller model
- Up to 30% lower cost
- No training needed

MODEL DISTILLATION

## Train a small model to copy a big one

- Teacher model generates training data
- Student model learns one task
- Much faster and cheaper to run
- Best for narrow, high-volume tasks

THE TIEBREAKER

Mixed difficulty, no training effort: routing. One narrow task at huge volume: distillation.

# SageMaker AI inference options

| OPTION | FITS |
| --- | --- |
| Real-time endpoint | Steady, low-latency traffic |
| Serverless inference | Intermittent traffic; scales to zero; cold starts |
| Asynchronous inference | Large payloads, long processing; scales to zero |
| Batch transform | Whole datasets offline; no endpoint kept |
| Multi-model and inference components | Many models sharing one endpoint's instances |

ON THE EXAM

Idle most of the day and cold starts acceptable: serverless. Many small models: share an endpoint.

# Training cost levers

- **Managed Spot training** with checkpoints, for large discounts.
- **SageMaker AI Savings Plans** for steady training and inference.
- **Right-size instances**; stop idle notebooks and endpoints.
- **Capacity Blocks or HyperPod** for long, large GPU runs.
- **Fine-tune or distil** a small model instead of always calling a large one.

> ON THE EXAM
>
> Checkpointed training jobs: managed Spot. Idle endpoints: Compute Optimizer finds them.

# Calling another Region, or cross-Region inference?

APPLICATION CALLS A REMOTE REGION

## You move the data

- Inter-Region data transfer charges
- Added latency on every call
- Your code manages failover
- May break residency rules

CROSS-REGION INFERENCE PROFILE

## Bedrock routes for you

- Call your local Region only
- Bedrock routes over the AWS network
- Priced at the source Region
- Geographic or global profiles

THE TIEBREAKER

More capacity without paying to move prompts between Regions: a cross-Region inference profile.

# Reading the scenario

| WHEN THE QUESTION SAYS | IT IS TESTING |
|---|---|
| Millions of prompts, results by morning | Batch inference |
| Same long context every request | Prompt caching |
| Mixed easy and hard questions | Intelligent prompt routing |
| One narrow task, huge volume | Model distillation |
| Model idle most of the day | SageMaker serverless inference |
| Calling another Region for capacity | Cross-Region inference profile |

ON THE EXAM

Find the waste: repeated tokens, oversized model, wrong tier, idle endpoint, or data moved needlessly.

> Each night, Meridian Freight summarises two million customs documents with a Bedrock model. Summaries are read by analysts the next morning.
>
> The job currently runs on-demand and is the largest line on the AI bill.

**What should the solutions architect recommend?**

A Switch the job to the Priority service tier

B Buy provisioned throughput for the overnight window

C Submit the documents as a Bedrock batch inference job

D Enable prompt caching on each request

◆ PAUSE AND DECIDE

## What should the solutions architect recommend?

A Priority tier

*Pays more for speed nobody needs overnight.*

B Provisioned throughput

*Hourly commitment for a job batch handles more cheaply.*

C Batch inference

Asynchronous, large-scale, at a large discount to on-demand.

D Prompt caching

*Each document differs, and caching is not available in batch.*

THE SIGNAL

Large volume, results later: batch inference.

> Meridian Freight's customs assistant sends a 25,000-token system prompt, including the full tariff guide, with every question. Questions arrive several times a minute all day.
>
> Most of each request's input cost is the unchanging guide.

## What should the solutions architect recommend?

A Use prompt caching, with a cache checkpoint after the system prompt and guide

B Move the assistant to batch inference

C Switch to a larger model with a bigger context window

D Buy provisioned throughput

◆ PAUSE AND DECIDE

## What should the solutions architect recommend?

**A** Prompt caching

The guide is read from cache at a fraction of the input price.

**B** Batch

*An interactive assistant cannot wait for a batch job.*

**C** Larger model

*Costs more per token, and the context already fits.*

**D** Provisioned throughput

*Commits spend without removing the repeated tokens.*

THE SIGNAL

An identical long prefix, requested often enough to stay warm: prompt caching.

> Meridian Freight's support assistant uses a large model for every question. Analysis shows most questions are simple tracking lookups, while some are complex claims disputes.
>
> The team wants lower cost without building or training anything.

## What should the solutions architect recommend?

A Distil a small model from the large one

B Switch every question to the smallest model

C Use the Priority tier

D Use Bedrock intelligent prompt routing across a small and large model in the same family

◆ PAUSE AND DECIDE

# What should the solutions architect recommend?

A Distillation

*Involves training, which the team ruled out.*

B Smallest model for all

*Cheaper, but complex disputes would suffer.*

C Priority tier

*Costs more.*

D Prompt routing

Simple questions go to the small model, hard ones to the large.

THE SIGNAL

Mixed difficulty, no training: intelligent prompt routing.

> Meridian Freight extracts the same 12 fields from millions of bills of lading a day. A large model does this accurately, but cost and latency are too high.
>
> The team accepts a small accuracy loss and is willing to invest in a one-off customisation.

**What should the solutions architect recommend?**

A. Enable prompt caching for each document

B. Use Bedrock Model Distillation to train a smaller model on the large model's outputs for this task

C. Use intelligent prompt routing

D. Buy provisioned throughput for the large model

◆ PAUSE AND DECIDE

## What should the solutions architect recommend?

A Prompt caching

*Each document differs; little to cache.*

B Distillation

A small model learns this one task, far cheaper and faster.

C Prompt routing

*Every request is the same difficulty; routing adds little.*

D Provisioned throughput

*Still runs the expensive model.*

THE SIGNAL

One narrow task, huge volume, customisation acceptable: distillation.

> Meridian Freight hosts a damage-photo classification model on a SageMaker AI real-time endpoint. Requests arrive in bursts a few times a day; the endpoint is idle over 90% of the time.
>
> A delay of a few seconds on the first request after idle is acceptable.

**What should the solutions architect recommend?**

A Move the model to SageMaker AI Serverless Inference

B Buy a SageMaker AI Savings Plan for the endpoint

C Move to a larger instance type for faster responses

D Run a batch transform job every minute

◆ PAUSE AND DECIDE

## What should the solutions architect recommend?

**A** Serverless inference

Scales to zero when idle; cold starts are accepted.

**B** Savings Plan

*Discounts an endpoint that is idle 90% of the time.*

**C** Larger instance

*More cost for idle capacity.*

**D** Batch every minute

*Clumsy, and not real-time request handling.*

THE SIGNAL

Idle most of the time, cold starts acceptable: serverless inference.

> Meridian Freight's application in eu-west-1 calls a Bedrock model endpoint in us-east-1 directly, because it needed more capacity at peak. The team now sees inter-Region data transfer charges and higher latency.
>
> Processing anywhere within the EU is acceptable.

**What should the solutions architect recommend?**

A Move the application to us-east-1

B Buy provisioned throughput in us-east-1

C Add a VPC peering connection between the Regions

D Call Bedrock in eu-west-1 using the EU geographic cross-Region inference profile

◆ PAUSE AND DECIDE

## What should the solutions architect recommend?

A Move to us-east-1

*A large migration, and moves data out of the EU.*

B Provisioned in us-east-1

*Keeps the cross-Region calls and their charges.*

C VPC peering

*Still inter-Region traffic, still charged.*

D EU inference profile

Local calls; Bedrock adds EU capacity, priced at the source Region.

THE SIGNAL

Need more capacity without paying to move prompts: cross-Region inference from the local Region.

# What to carry out of this module

- **Tokens times price:** fewer tokens, cheaper model, cheaper tier.
- **Batch** for later; **Flex** for patient; **Priority** only for latency-critical.
- **Caching** for repeated prefixes; **routing** or **distillation** for cheaper models.
- **SageMaker:** serverless or async for idle endpoints, Spot for training.
- **Cross-Region inference** instead of calling remote Regions yourself.

> ON THE EXAM
>
> Find the AI waste, then use the feature built for it.

MODULE 28 · DOMAIN 3 - COST-OPTIMIZED ARCHITECTURE DESIGN

# Content Delivery and Data Transfer Costs

Serve from the edge, shield the origin, keep traffic private and in its own Availability Zone, and pick the network path that charges least per gigabyte.

DOMAIN 3 of 5 EXAM WEIGHT 15% MODULE 28 of 52

admin@sthithapragna.com

Every gigabyte has a path, and every hop on the path may charge. Shorten the path, or move it onto free hops.

# Where gigabytes cost money

| PATH | CHARGE |
| --- | --- |
| Within one AZ, private IP | Free |
| Between AZs in a Region | Charged in each direction |
| Between Regions | Charged per GB, higher |
| To the internet | Charged; lower through CloudFront |
| AWS origin to CloudFront | Free |
| NAT gateway, TGW, interface endpoint | Per-GB processing on top |

ON THE EXAM

Processing charges stack: a byte through a NAT gateway and across AZs pays twice.

# CloudFront as a cost tool

- **Cache hits** never reach the origin: less compute and less egress.
- **Origin fetches** from AWS origins carry no data transfer charge.
- **Cache policies**: forward only the headers and query strings that matter.
- **Origin groups** fail over to a secondary origin on errors.
- **Price classes** limit edge locations to cut cost where reach allows.

> ON THE EXAM
>
> A low cache hit ratio is usually a cache key that includes things that do not change the response.

# Longer TTLs, or Origin Shield?

TUNE CACHING

## Fewer misses at each edge

- Longer TTLs where content allows
- Narrower cache keys
- Versioned file names
- Free to change

ORIGIN SHIELD

## One extra cache layer

- A Regional cache in front of the origin
- Edges' misses collapse into one fetch
- Charged per request through it
- Best with global audiences or several CDNs

THE TIEBREAKER

Caching already tuned, origin still flooded by misses from many locations: Origin Shield.

# Private paths to AWS services

| PATH | HOURLY | PER GB |
|---|---|---|
| Gateway endpoint (S3, DynamoDB) | None | None |
| Interface endpoint (PrivateLink) | Per AZ | Low processing charge |
| NAT gateway | Per gateway | Processing charge, higher |
| Regional NAT gateway | Spans AZs automatically | Processing charge |

ON THE EXAM

Heavy S3 or DynamoDB traffic through a NAT gateway: add free gateway endpoints.

# Availability Zone-aware design

- **Keep chatty tiers in the same AZ**: zonal affinity for calls and caches.
- **NAT and endpoints in every AZ** used, so traffic stays local.
- **Load balancer cross-zone** settings affect where requests go.
- **Replicas read locally**: read from the replica in your own AZ.
- **Never trade resilience for this**: stay multi-AZ, just route locally.

> ON THE EXAM
>
> Cut inter-AZ charges by routing within each zone, not by collapsing into one zone.

# Connecting VPCs: cost per gigabyte

| OPTION | PER-GB PROCESSING | FITS |
|---|---|---|
| VPC peering | None; data transfer only | A few high-volume pairs |
| Transit Gateway | Per GB, per attachment hop | Many VPCs, central routing |
| PrivateLink | Per GB, lower | Expose one service, overlapping CIDRs |
| Cloud WAN | Per GB plus core network | Global, policy-based networks |

ON THE EXAM

One pair of VPCs moving huge volumes through a transit gateway: add a peering connection for that pair.

# CloudFront flat-rate plans

- **Monthly tiers**: Free, Pro, Business and Premium, since November 2025.
- **Bundles** delivery, WAF and DDoS protection, Route 53 DNS, logs and edge compute.
- **No overage charges**, even during traffic spikes or attacks.
- **Pay-as-you-go** remains; choose per distribution.

> ON THE EXAM
>
> Predictable website cost with security included, no surprise bills: a flat-rate plan.

# Reading the scenario

| WHEN THE QUESTION SAYS | IT IS TESTING |
|---|---|
| Global downloads served from one Region | CloudFront with S3 origin |
| Origin flooded despite good TTLs | Origin Shield |
| S3 or DynamoDB traffic through NAT | Gateway endpoints |
| High inter-AZ charges between tiers | Zonal affinity, stay multi-AZ |
| One heavy VPC pair on a transit gateway | Peer that pair |
| Predictable cost, fear of attack bills | CloudFront flat-rate plan |

ON THE EXAM

Trace the path, find the charged hop, and move the traffic to a free or cheaper one.

> Meridian Freight's customers worldwide download route-planning map packs of 200 MB each directly from an S3 bucket in eu-west-1. Downloads are slow outside Europe.
>
> Data transfer out is now the largest item on the bill.

**What should the solutions architect recommend?**

A Enable S3 Transfer Acceleration on the bucket

B Serve the map packs through a CloudFront distribution with the bucket as an origin using origin access control

C Replicate the bucket to six Regions with Cross-Region Replication

D Move the bucket to the S3 Express One Zone storage class

◆ PAUSE AND DECIDE

## What should the solutions architect recommend?

A Transfer Acceleration

*Adds a fee per GB, and every download still comes from the bucket.*

B CloudFront with OAC

Cached at the edge, free origin fetches, cheaper delivery.

C Replicate to six Regions

*Six copies of storage plus replication transfer.*

D Express One Zone

*For low-latency access in one AZ, not global delivery.*

THE SIGNAL

Popular objects downloaded worldwide: cache them at the edge.

> Meridian Freight streams live depot camera feeds to viewers worldwide through CloudFront, from a single origin in us-east-1. Cache settings are already tuned.
>
> Requests from many edge locations still reach the origin for the same segments, and the origin is struggling.

**What should the solutions architect add?**

A. A second origin in another Region

B. AWS Global Accelerator in front of the origin

C. CloudFront Origin Shield in us-east-1

D. Lambda@Edge to rewrite requests

◆ PAUSE AND DECIDE

## What should the solutions architect add?

A Second origin

*Doubles origin infrastructure instead of reducing fetches.*

B Global Accelerator

*Speeds the network path; caches nothing.*

C Origin Shield

Collapses edge misses into one fetch per object.

D Lambda@Edge

*Adds compute, not a cache layer.*

THE SIGNAL

Many edges missing on the same objects, caching already tuned: Origin Shield.

> Meridian Freight's analytics instances in private subnets read 40 TB a month from S3 and write heavily to DynamoDB. All this traffic leaves through NAT gateways.
>
> NAT gateway processing charges have become significant.

## What should the solutions architect do?

A. Add S3 and DynamoDB gateway endpoints to the private subnets' route tables

B. Add interface endpoints for S3 and DynamoDB

C. Move the instances to public subnets with public IP addresses

D. Replace the NAT gateways with larger NAT instances

◆ PAUSE AND DECIDE

## What should the solutions architect do?

**A** Gateway endpoints

No hourly or per-GB charge; traffic bypasses NAT.

**B** Interface endpoints

*Private, but still charged hourly and per GB.*

**C** Public subnets

*Weakens security to save money.*

**D** NAT instances

*More to operate; traffic still detours.*

THE SIGNAL

S3 and DynamoDB from inside a VPC: gateway endpoints, which are free.

> Meridian Freight's pricing service runs in three AZs and calls a cache cluster many times per request. Cost reports show large inter-AZ data transfer charges between the two tiers.
>
> The service must remain resilient to the loss of an AZ.

**What should the solutions architect recommend?**

A Move both tiers into a single AZ

B Add a transit gateway between the tiers

C Use larger cache nodes to reduce the number of calls

D Route each service instance to cache nodes in its own AZ, keeping capacity in all three AZs

◆ PAUSE AND DECIDE

## What should the solutions architect recommend?

A Single AZ

*Removes the charge and the resilience together.*

B Transit gateway

*Adds a per-GB processing charge.*

C Larger nodes

*The call count comes from the application, not node size.*

D Zonal affinity

Calls stay within each zone; all zones still serve.

THE SIGNAL

Inter-AZ charges with a resilience requirement: route within each zone.

> Meridian Freight connects 60 VPCs through a transit gateway. One analytics VPC pulls about 300 TB a month from a data VPC, and this pair accounts for most of the transit gateway's processing charges.
>
> The CIDR ranges do not overlap, and everything else should stay on the transit gateway.

**What should the solutions architect recommend?**

A. Move all 60 VPCs to VPC peering

B. Add a VPC peering connection between the analytics and data VPCs, with more specific routes for that pair

C. Add a second transit gateway for the analytics traffic

D. Expose the data VPC through AWS PrivateLink

◆ PAUSE AND DECIDE

## What should the solutions architect recommend?

A Peer all 60

*Thousands of connections to manage, for one heavy pair.*

B Peer the heavy pair

No processing charge for that traffic; the rest stays central.

C Second transit gateway

*Still charges per GB processed.*

D PrivateLink

*Lower per-GB charge, but not zero, and built for one service.*

THE SIGNAL

One heavy pair, non-overlapping CIDRs: peer it, and keep the hub for everything else.

> Meridian Freight's marketing website runs on CloudFront and S3. The small marketing team wants a predictable monthly bill that includes WAF and DDoS protection.
>
> Last year a traffic spike during a bot attack produced an unexpected bill.

**What should the solutions architect recommend?**

A Subscribe to AWS Shield Advanced

B Keep pay-as-you-go pricing and add an AWS Budgets alert

C Move the distribution to a CloudFront flat-rate pricing plan

D Put AWS Global Accelerator in front of CloudFront

◆ PAUSE AND DECIDE

## What should the solutions architect recommend?

A **Shield Advanced**

*Strong protection, but a large monthly fee for a marketing site.*

B **Budgets alert**

*Reports the surprise; does not prevent it.*

C **Flat-rate plan**

Fixed monthly price with WAF and DDoS included, no overages.

D **Global Accelerator**

*Adds cost and does nothing for billing predictability.*

THE SIGNAL

Predictable bill, security included, no spike charges: CloudFront flat-rate plan.

# What to carry out of this module

- **Trace the path**: distance charges plus per-GB processing hops.
- **CloudFront** for popular content; **Origin Shield** when edges flood the origin.
- **Gateway endpoints** for S3 and DynamoDB; never pay NAT for them.
- **Zonal affinity**, not single-AZ, to cut inter-AZ charges.
- **Peer heavy pairs** beside a transit gateway; flat-rate plans for predictability.

> ON THE EXAM
>
> Move bytes onto free or cheaper paths without giving up resilience.

MODULE 29 · DOMAIN 3 - COST-OPTIMIZED ARCHITECTURE DESIGN

# Cost Allocation, Tagging and Replication Cost

Design tags that finance can use, enforce them before resources exist, and replicate data across Regions only as much as recovery needs.

DOMAIN 3 of 5 EXAM WEIGHT 15% MODULE 29 of 52

admin@sthithapragna.com

Allocation starts with **accounts**, and tags fill in the rest. A tag nobody enforces is a tag nobody can trust.

# A practical tagging strategy

| TAG | ANSWERS | EXAMPLE VALUES |
|---|---|---|
| CostCentre | Who pays? | CC-4100, CC-4200 |
| Environment | Which stage? | prod, staging, dev |
| Application | Which workload? | pricing, tracking |
| Owner | Who to ask? | team or role, never a person's name |

ON THE EXAM

Few mandatory keys, fixed allowed values, defined once centrally.

# From tags to the bill

- **Activate** user-defined tags as cost allocation tags in the management account.
- **AWS-generated tags**, such as createdBy, can be activated too.
- **Backfill** activation for up to twelve months of history.
- **Only where the tag existed**: backfill cannot invent past tags.
- **Then** Cost Explorer, CUR 2.0 and Budgets can group by the tag.

> ON THE EXAM
>
> Tags present but missing from Cost Explorer: they were never activated as cost allocation tags.

# Enforcing tags: three tools, three jobs

| TOOL | DOES | DOES NOT |
| --- | --- | --- |
| `Tag policy` | Standardises keys and allowed values | Require a tag on most creates |
| `Tag policy, required tags` | Validates IaC deployments for required keys | Cover console or CLI creates |
| `SCP with aws:RequestTag` | Denies creation without a tag | Check values easily or fix old resources |
| `Config required-tags rule` | Finds untagged resources; can remediate | Prevent creation |

ON THE EXAM

Consistent values: tag policy. Must exist at creation: SCP. Find and fix existing gaps: Config.

# Accounts, OUs and cost categories

- **Account per team or product**: allocation without tags.
- **Cost categories** group accounts, tags and services into business units.
- **Rules apply to history**, so reorganisations do not need re-tagging.
- **Shared accounts** still need tags or split rules for their costs.

> ON THE EXAM
>
> Map accounts and tags to business units with cost categories, not by renaming tags.

# What replication costs

| REPLICATION | YOU PAY FOR |
| --- | --- |
| S3 Cross-Region Replication | Second copy, inter-Region transfer, requests |
| S3 Replication Time Control | Extra per GB for the 15-minute SLA |
| DynamoDB global tables | Replicated writes in every replica Region, storage |
| Aurora Global Database | Replicated write I/O, secondary clusters, transfer |

ON THE EXAM

Every extra Region multiplies storage, writes and transfer. Add Regions only for a reason.

# Replicating cost-consciously

- **Filter S3 replication** by prefix or tag: copy what recovery needs.
- **Cheaper destination class**, such as Standard-IA or Glacier tiers.
- **RTC only** when a 15-minute replication objective is required.
- **Fewest replica Regions** that meet recovery and latency needs.
- **Backups instead of live replicas** where recovery time allows.

> ON THE EXAM
>
> Match replication to the recovery objective, not to every object or every Region.

# Reading the scenario

| WHEN THE QUESTION SAYS | IT IS TESTING |
|---|---|
| Tags on resources, missing in Cost Explorer | Activate, then backfill |
| prod, Production and PRD all in use | Tag policy with allowed values |
| No resource without a cost centre | SCP on aws:RequestTag |
| Replicating everything, only some needed | Filtered replication, cheaper class |
| A replica Region nobody needs | Remove it |
| Business units span many accounts | Cost categories |

ON THE EXAM

Separate the jobs: activate, standardise, require, detect, and group.

> Meridian Freight's resources have carried a CostCentre tag for the past eight months, but the tag does not appear in Cost Explorer.
>
> Finance wants costs grouped by CostCentre, including the last six months.

**What should the solutions architect do?**

A Activate CostCentre as a cost allocation tag in the management account, and request a backfill for the past six months

B Activate the tag in each member account

C Re-tag every resource with a new key

D Create a cost category without activating the tag

◆ PAUSE AND DECIDE

## What should the solutions architect do?

**A** Activate and backfill

Makes the tag visible, and applies it to past months where it existed.

**B** Activate per member account

*Activation is done in the management account.*

**C** Re-tag

*The tags already exist; they are just not activated.*

**D** Cost category only

*Tag rules need the tag to be in the billing data.*

THE SIGNAL

Tagged but invisible: activate. Need history: backfill, up to twelve months.

> Meridian Freight's cost reports show Environment values of prod, Production, PRD and live for the same thing. Teams tag through the console, the CLI and infrastructure as code.
>
> The company wants one approved set of values across the organisation, and non-compliant values blocked on supported resources.

## What should the solutions architect implement?

A. A wiki page listing the approved values

B. A monthly script that renames tag values

C. A tag policy defining the Environment key's allowed values, with enforcement for the relevant resource types

D. An AWS Budgets alert per value

◆ PAUSE AND DECIDE

## What should the solutions architect implement?

A **Wiki page**
*A convention; the reports show it is not followed.*

B **Rename script**
*Cleans up after the fact, every month, forever.*

C **Tag policy**
One definition of allowed values, enforced organisation-wide.

D **Budgets alerts**
*Unrelated to tag consistency.*

THE SIGNAL

Consistent values across the organisation: a tag policy.

> Meridian Freight requires every new EC2 instance and RDS database to carry a CostCentre tag when it is created, whether created by console, CLI or code.
>
> Creation without the tag must be blocked in every member account.

**What should the solutions architect implement?**

A. A Config required-tags rule with automatic remediation

B. A tag policy listing CostCentre

C. A cost category that groups untagged resources

D. An SCP denying ec2:RunInstances and rds:CreateDBInstance when aws:RequestTag/CostCentre is null

◆ PAUSE AND DECIDE

## What should the solutions architect implement?

A **Config rule**
*Detects after creation; does not block.*

B **Tag policy**
*Standardises values; does not block untagged creation from every tool.*

C **Cost category**
*Reports untagged cost; blocks nothing.*

D **SCP on RequestTag**
Denies the create call itself when the tag is missing.

THE SIGNAL

Block creation without a tag, from any tool: an SCP with a Null condition on aws:RequestTag.

> Meridian Freight replicates an entire 900 TB S3 bucket from eu-west-1 to eu-central-1 for disaster recovery, using Standard storage and Replication Time Control.
>
> Only the shipments/ prefix, about 150 TB, is needed for recovery, and a recovery point of a few hours is acceptable.

## What should the solutions architect change?

A Turn off replication and rely on versioning in one Region

B Filter the replication rule to the shipments/ prefix, store replicas in a cheaper storage class, and remove Replication Time Control

C Replicate to a third Region as well

D Switch to Same-Region Replication

◆ PAUSE AND DECIDE

## What should the solutions architect change?

A No replication

*Loses Regional disaster recovery entirely.*

B Filter, cheaper class, drop RTC

Copies one-sixth the data, stores it cheaply, drops an unneeded SLA.

C Third Region

*Adds cost with no stated need.*

D Same-Region

*Does not survive a Regional outage.*

THE SIGNAL

Replicate what recovery needs, to the cheapest class that recovery tolerates.

> Meridian Freight's write-heavy shipment-events DynamoDB global table has replicas in three Regions. Analysis shows the third Region receives almost no reads and is not part of any recovery plan.
>
> The recovery requirement is met by the other two Regions.

**What should the solutions architect recommend?**

A Switch the table to provisioned capacity in all three Regions

B Enable DynamoDB Accelerator in the third Region

C Remove the third Region's replica

D Convert to multi-Region strong consistency

◆ PAUSE AND DECIDE

## What should the solutions architect recommend?

A Provisioned capacity

*May help, but still pays replicated writes in the unused Region.*

B DAX

*Adds cost in a Region with no reads.*

C Remove the replica

Ends a third of the replicated write and storage cost.

D Strong consistency

*Changes consistency, not cost; needs three Regions anyway.*

THE SIGNAL

A replica Region nobody reads and no plan needs is pure cost.

> Meridian Freight reports costs to four business units. Each business unit owns several accounts in its own OU, but the shared platform account hosts resources for all four, tagged by CostCentre.
>
> Finance wants every report to show costs by business unit, and the mapping must survive future reorganisations.

## What should the solutions architect implement?

A. Tag every resource in every account with a BusinessUnit tag

B. Move all resources into one account per business unit, including platform

C. Export the bill to spreadsheets each month

D. A cost category with rules mapping accounts to business units, and the platform account's CostCentre tags to business units

◆ PAUSE AND DECIDE

## What should the solutions architect implement?

A **Tag everything**
*Huge effort, and must be redone at every reorganisation.*

B **Split the platform**
*Duplicates shared infrastructure for an accounting view.*

C **Spreadsheets**
*Manual and error-prone.*

D **Cost category**
Accounts and tags mapped by rule; change rules, not resources.

THE SIGNAL

Business terms over accounts and tags, resilient to reorganisation: cost categories.

# What to carry out of this module

- **Accounts first, tags second**; few mandatory keys with fixed values.
- **Activate** cost allocation tags; **backfill** up to twelve months.
- **Tag policy** for values, **SCP** for presence, **Config** for existing gaps.
- **Cost categories** turn accounts and tags into business units.
- **Replicate only what recovery needs**, in the fewest Regions, cheapest class.

> ON THE EXAM
>
> Allocate structurally, enforce tags, and size replication to the recovery objective.

MODULE 30 · DOMAIN 3 - COST-OPTIMIZED ARCHITECTURE DESIGN

# Cost Visibility, Chargeback and Alerting

Get detailed billing data where you can query it, charge shared platforms back fairly, including AI tokens, and hear about overspend before the invoice.

DOMAIN 3 of 5 EXAM WEIGHT 15% MODULE 30 of 52

admin@sthithapragna.com

# Showback or chargeback?

SHOWBACK

## Show teams what they used

- Reports, no money moves
- Builds awareness
- Tolerates rough allocation
- A common first step

CHARGEBACK

## Bill teams for what they used

- Costs move between budgets
- Needs defensible allocation
- Shared costs must be split fairly
- Drives real behaviour change

THE TIEBREAKER

Chargeback needs allocation that teams will accept: measured usage, and fair rules for shared costs.

# Where cost data lives

| TOOL | GRANULARITY | BEST FOR |
|---|---|---|
| Cost Explorer | Daily or monthly, some hourly | Interactive analysis, forecasts |
| Data Exports: CUR 2.0 | Hourly line items, resource IDs | Detailed analysis in Athena or BI |
| Data Exports: FOCUS | Open billing standard schema | Multi-cloud FinOps tools |
| Cost categories | Any of the above | Business-unit views and rules |

ON THE EXAM

Line-item, resource-level detail for your own queries: CUR 2.0 through Data Exports.

# Split cost allocation data

- **ECS tasks and EKS pods** get their own cost lines in CUR.
- **Based on** each container's share of the instance's CPU and memory.
- **EKS accelerated instances:** GPU, Trainium and Inferentia shares too.
- **Kubernetes attributes as tags:** cluster, namespace, workload.
- **Enable** in the management account's cost management preferences.

> ON THE EXAM
>
> One shared cluster, many teams, billed by what their pods consumed: split cost allocation data.

# Monitoring Bedrock token usage

| NEED | MECHANISM |
| --- | --- |
| Tokens by model, live | CloudWatch metrics: input and output token counts |
| Cost by application | Application inference profiles with cost allocation tags |
| Cost by caller | IAM principal cost allocation, with tagged roles |
| Per-request detail | Model invocation logs with token counts |

ON THE EXAM

Several applications on one model, charged back separately: a tagged inference profile per application.

# Cost categories and split charges

- **Rules** map accounts, tags, services and other categories to values.
- **Split charge rules** share a cost across values: even, proportional, or fixed.
- **Typical shared costs**: support, platform accounts, untagged spend.
- **Visible** in Cost Explorer, Budgets and CUR.

> ON THE EXAM
>
> Distribute shared costs like support fees across business units: split charge rules.

# Budgets or Cost Anomaly Detection?

AWS BUDGETS

## Did we cross a line?

- Thresholds you set: cost, usage, coverage
- Actual or forecasted alerts
- Budget actions: IAM or SCP policy, stop instances
- Good for known limits

COST ANOMALY DETECTION

## Is this unusual?

- Machine learning on spend patterns
- Managed monitors by service, account, tag, category
- Root cause, with AI investigations
- Good for unknown surprises

THE TIEBREAKER

A known limit: Budgets. A surprise nobody set a threshold for: Cost Anomaly Detection. Use both.

# Reading the scenario

| WHEN THE QUESTION SAYS | IT IS TESTING |
|---|---|
| Hourly, resource-level data in Athena | CUR 2.0 through Data Exports |
| Teams share one Kubernetes cluster | Split cost allocation data |
| Apps share one Bedrock model | Tagged application inference profiles |
| Forecast exceeds a limit, act automatically | Budgets with budget actions |
| Unexpected spikes, every team, no thresholds | Cost Anomaly Detection |
| Spread support fees across units | Cost category split charges |

ON THE EXAM

Detail is CUR, sharing is split allocation, limits are Budgets, surprises are anomalies.

> Meridian Freight's FinOps team wants hourly cost data at resource level for all accounts, queried with SQL and joined to the company's own project database.
>
> The data must be refreshed automatically.

**What should the solutions architect configure?**

A Cost Explorer saved reports

B A CUR 2.0 export through Data Exports to S3, queried with Athena

C Monthly billing PDFs

D AWS Budgets reports

◆ PAUSE AND DECIDE

## What should the solutions architect configure?

A Cost Explorer

*Interactive and aggregated; not raw line items for SQL joins.*

B CUR 2.0 to S3

Hourly line items with resource IDs, refreshed, queryable in Athena.

C Billing PDFs

*Summary documents, not data.*

D Budgets reports

*Track budgets, not line items.*

THE SIGNAL

SQL over line-item, resource-level, hourly data: CUR 2.0.

> Eight Meridian Freight teams share one EKS cluster, each in its own namespace, including GPU nodes used by the data science team.
>
> Finance wants to charge each team for the compute its pods actually reserved, including GPUs, without separate clusters.

**What should the solutions architect enable?**

A Split cost allocation data for EKS, charging back by the namespace tag

B A cost allocation tag on each node

C Divide the cluster cost evenly by eight

D A separate account per team

◆ PAUSE AND DECIDE

## What should the solutions architect enable?

**A** Split cost allocation

Pod-level costs from CPU, memory and GPU reservations, tagged by namespace.

**B** Node tags

*Nodes run pods from many teams.*

**C** Even split

*Not what each team actually used.*

**D** Account per team

*Means separate clusters, which is ruled out.*

THE SIGNAL

Shared cluster, charge by what pods used, GPUs included: split cost allocation data.

> Four Meridian Freight applications in one account call the same Bedrock model. Finance must charge each application's owning team for its token spend.
>
> The team wants the split to appear in Cost Explorer without parsing logs.

**What should the solutions architect implement?**

A Move each application to its own AWS account

B Use CloudWatch token metrics grouped by model ID

C Parse model invocation logs nightly

D Create an application inference profile per application, with an activated cost allocation tag

◆ PAUSE AND DECIDE

## What should the solutions architect implement?

A Account per application

*Works, but a large restructure for a billing view.*

B Metrics by model

*All four apps share the model, so they share the metric.*

C Parse logs

*Custom work the team wants to avoid.*

D Tagged inference profiles

Each application's calls carry its own tag into billing.

THE SIGNAL

Many applications, one model, split in billing: tagged application inference profiles.

> Meridian Freight's development accounts have a monthly limit of 20,000 dollars. The team wants a warning when spend is forecast to exceed the limit.
>
> If actual spend reaches the limit, new resources must be blocked automatically until next month.

**What should the solutions architect configure?**

A. Cost Anomaly Detection with an email subscription

B. A CloudWatch billing alarm

C. An AWS Budget with a forecasted alert, and a budget action that applies a restrictive SCP at 100% of actual spend

D. A weekly Cost Explorer report

◆ PAUSE AND DECIDE

## What should the solutions architect configure?

A Anomaly Detection

*Flags unusual spend, not a fixed limit.*

B Billing alarm

*Alerts on actual charges only; cannot apply an SCP.*

C Budget with action

Forecast warning, and an automatic SCP when the limit is hit.

D Weekly report

*Neither timely nor automatic.*

THE SIGNAL

A known limit, a forecast warning and an automatic response: Budgets with budget actions.

> Meridian Freight has 40 teams, identified by a Team cost allocation tag, and new teams appear every quarter. Last month one team's mistake doubled its spend for a week before anyone noticed.
>
> The company wants unusual spend for any team flagged quickly, with its likely cause, without maintaining thresholds.

**What should the solutions architect configure?**

A. Cost Anomaly Detection with an AWS managed monitor on the Team tag, alert subscriptions, and investigations with Amazon Q

B. One AWS Budget per team with fixed thresholds

C. A CloudWatch alarm per team

D. Monthly Cost Explorer reviews

◆ PAUSE AND DECIDE

## What should the solutions architect configure?

**A** Managed anomaly monitor

Learns each team's pattern; new tag values monitored automatically.

**B** Budget per team

*Forty thresholds to maintain, and more every quarter.*

**C** Alarm per team

*Thresholds again, built by hand.*

**D** Monthly reviews

*Weeks too slow.*

THE SIGNAL

Unusual, any team, no thresholds, new teams included: Cost Anomaly Detection managed monitor.

> Meridian Freight bills four business units monthly. Enterprise Support fees and a shared networking account cannot be tagged to any one unit.
>
> Finance wants these shared costs distributed in proportion to each unit's own spend, shown in Cost Explorer.

**What should the solutions architect configure?**

A. Tag the support charges with each business unit

B. A business-unit cost category with split charge rules distributing the shared costs proportionally

C. A separate organisation per business unit

D. Leave shared costs unallocated

◆ PAUSE AND DECIDE

## What should the solutions architect configure?

A Tag support charges

*Support fees are not resources and cannot carry tags.*

B Split charge rules

Shared costs distributed proportionally, visible in Cost Explorer.

C Separate organisations

*Duplicates support and networking.*

D Unallocated

*Chargeback then misses real costs.*

THE SIGNAL

Costs that belong to everyone, split by rule: cost category split charges.

# What to carry out of this module

- **CUR 2.0** for detail; **Cost Explorer** for interactive analysis.
- **Split cost allocation** for shared clusters, GPUs included.
- **Bedrock chargeback** by tagged inference profiles or IAM principals.
- **Budgets** for known limits and actions; **anomaly detection** for surprises.
- **Split charges** distribute costs nobody owns.

> ON THE EXAM
>
> Measure shared usage, split shared costs by rule, and alert on both limits and surprises.

MODULE 31 · DOMAIN 3 - COST-OPTIMIZED ARCHITECTURE DESIGN

# Storage, Database and Observability Cost

Tier data by how it is used, provision performance separately from size, choose database capacity modes deliberately, and stop paying to keep logs nobody reads.

DOMAIN 3 of 5 EXAM WEIGHT 15% MODULE 31 of 52

admin@sthithapragna.com

Data costs grow quietly because nothing **deletes** it. Every store needs a rule for where data goes as it ages.

# S3 storage classes by access pattern

| CLASS | FITS | WATCH FOR |
|---|---|---|
| Intelligent-Tiering | Unknown or changing access | Small monitoring fee per object |
| Standard-IA | Known infrequent, instant access | Retrieval fee, 30-day minimum |
| Glacier Instant Retrieval | Rarely read, milliseconds | 90-day minimum |
| Glacier Flexible Retrieval | Archive, minutes to hours | 90-day minimum |
| Glacier Deep Archive | Compliance archive, hours | 180-day minimum |

ON THE EXAM

Unknown access pattern: Intelligent-Tiering. Known and predictable: a lifecycle rule to the right class.

# Lifecycle rules, done well

- **Transition** by age, prefix or tag; **expire** what no rule requires.
- **Clean up** old versions and incomplete multipart uploads.
- **Minimum durations**: early deletion still bills the minimum.
- **Tiny objects** cost more in IA and Glacier per object; aggregate first.
- **EFS lifecycle**: Infrequent Access and Archive tiers, with return on access.

> ON THE EXAM
>
> A versioned bucket growing without explanation: noncurrent versions with no expiry rule.

# EBS volume choice

| VOLUME | PERFORMANCE MODEL | FITS |
|---|---|---|
| gp3 | IOPS and throughput set apart from size | Most workloads; default |
| gp2 | IOPS grow with size, burst credits | Legacy; migrate to gp3 |
| io2 Block Express | High provisioned IOPS, high durability | Critical, latency-sensitive databases |
| st1, sc1 | Throughput-optimised HDD | Large sequential, cold data |

ON THE EXAM

Over-sized gp2 volumes bought for IOPS: move to gp3 and provision the IOPS directly.

# Database capacity choices

| CHOICE | FITS |
| --- | --- |
| DynamoDB on-demand | Unknown or spiky traffic; pay per request |
| DynamoDB provisioned plus auto scaling | Steady, predictable traffic, high utilisation |
| Aurora Standard | Low or moderate I/O |
| Aurora I/O-Optimized | I/O over about a quarter of Aurora spend |
| Aurora Serverless v2 | Variable load; can scale to zero |
| Reserved instances or Database Savings Plans | Steady database spend |

ON THE EXAM

I/O charges dominating an Aurora bill: switch the cluster to I/O-Optimized.

# Backup retention without waste

- **AWS Backup lifecycle** moves recovery points to cold storage, then deletes.
- **Data Lifecycle Manager** automates EBS snapshots and AMIs, with retention.
- **EBS Snapshots Archive** for long retention, rarely restored.
- **Retention by tier**: frequent short-term points, few long-term ones.
- **Cross-Region copies** only for what recovery needs.

> ON THE EXAM
>
> Seven-year snapshot retention, rarely restored: archive tier, not standard snapshots.

# Cost-effective observability

| LEVER | EFFECT |
| --- | --- |
| Filter at source | Do not ship debug logs nobody reads |
| Log group retention | Default is never expire; set it |
| Infrequent Access log class | Lower ingestion price for rarely queried logs |
| CloudWatch Logs intelligent tiering | Ageing logs move to cheaper storage tiers |
| Metric aggregation | Fewer dimensions, standard resolution, EMF |
| Trace sampling | Keep a representative sample, not every request |

ON THE EXAM

Log groups with no retention setting keep everything forever and bill for it.

# Reading the scenario

| WHEN THE QUESTION SAYS | IT IS TESTING |
|---|---|
| Access pattern unknown or changing | S3 Intelligent-Tiering |
| Kept years for compliance, hours to restore | Lifecycle to Deep Archive |
| Big gp2 volumes bought for IOPS | gp3 with provisioned IOPS |
| Aurora bill dominated by I/O | Aurora I/O-Optimized |
| Years of snapshots, rarely restored | Snapshot archive, lifecycle |
| Logs kept forever, rarely read | Retention, IA class, filtering |

ON THE EXAM

Ask how data is used as it ages, then match the tier and the deletion rule.

> Meridian Freight's document store holds 400 TB of shipment files, mostly over 1 MB. Some files are read daily for weeks, others never again, and the pattern differs by customer and cannot be predicted.
>
> The team wants lower storage cost without retrieval surprises.

**What should the solutions architect recommend?**

A. A lifecycle rule moving everything to Standard-IA after 30 days

B. Move everything to Glacier Flexible Retrieval

C. S3 Intelligent-Tiering for the bucket

D. Keep everything in S3 Standard

◆ PAUSE AND DECIDE

## What should the solutions architect recommend?

A Standard-IA after 30 days

*Files still read daily would incur retrieval fees.*

B Glacier Flexible

*Active files would take minutes to hours to read.*

C Intelligent-Tiering

Tiers each object by its own access, with no retrieval fees.

D Standard

*Pays the top rate for files nobody reads.*

THE SIGNAL

Unpredictable access per object, large objects: Intelligent-Tiering.

> Meridian Freight must keep signed customs declarations for seven years. After 90 days they are almost never read, and regulators accept retrieval within 48 hours.
>
> The files are currently in S3 Standard.

**What should the solutions architect configure?**

A. S3 Intelligent-Tiering with default settings

B. A lifecycle rule to Standard-IA after 90 days

C. A lifecycle rule to Glacier Instant Retrieval after 90 days

D. A lifecycle rule to Glacier Deep Archive after 90 days, expiring after seven years

◆ PAUSE AND DECIDE

## What should the solutions architect configure?

A Intelligent-Tiering

*Pays monitoring fees on a pattern that is already known.*

B Standard-IA

*Far more expensive than an archive class for seven years.*

C Glacier Instant

*Pays for millisecond access nobody needs.*

D Deep Archive, then expire

Cheapest class, retrieval within hours, deleted at the end.

THE SIGNAL

Known pattern, long retention, hours acceptable: lifecycle to Deep Archive, then expire.

> Meridian Freight's database servers use 2 TB gp2 volumes. The data is only 300 GB, but the volumes were enlarged years ago to get 6,000 IOPS.
>
> The team wants the same performance at lower cost.

## What should the solutions architect recommend?

A. Move the data to new 400 GB gp3 volumes with 6,000 provisioned IOPS

B. Modify the volumes to io2 Block Express

C. Move the data to st1 volumes

D. Keep gp2 and buy a Savings Plan

◆ PAUSE AND DECIDE

## What should the solutions architect recommend?

**A** gp3, right-sized, IOPS provisioned

Pays for 400 GB and the IOPS needed, not 2 TB.

**B** io2 Block Express

*Premium performance the workload does not need.*

**C** st1

*HDD throughput volumes suit sequential data, not databases.*

**D** Savings Plan

*Savings Plans do not apply to EBS storage.*

THE SIGNAL

Capacity bought to get IOPS: gp3, sized for data, IOPS provisioned separately.

> Cost Explorer shows that I/O charges make up 60% of the spend on Meridian Freight's busiest Aurora PostgreSQL cluster. Load is steady and the instances are correctly sized.
>
> The team wants to reduce the cluster's cost without changing the application.

**What should the solutions architect recommend?**

A Migrate to Aurora Serverless v2

B Switch the cluster's storage configuration to Aurora I/O-Optimized

C Move the database to self-managed PostgreSQL on EC2

D Add read replicas

◆ PAUSE AND DECIDE

## What should the solutions architect recommend?

A Serverless v2

*For variable load; still charges per I/O on Standard.*

B I/O-Optimized

No per-I/O charges; wins when I/O exceeds about a quarter of spend.

C Self-managed on EC2

*Large operational cost and an application risk.*

D Read replicas

*More instances, and the I/O is still charged.*

THE SIGNAL

I/O dominating the Aurora bill: I/O-Optimized.

> Meridian Freight keeps a daily EBS snapshot of each finance server for seven years, all in the standard snapshot tier, created and deleted by scripts that often fail.
>
> Restores of anything older than a month are rare, and a slower restore is acceptable for those.

**What should the solutions architect implement?**

A. Keep daily standard snapshots, and fix the scripts

B. Copy snapshots to S3 manually each month

C. Create AMIs instead of snapshots

D. A Data Lifecycle Manager policy keeping recent daily snapshots, archiving monthly ones to the snapshot archive tier, and deleting at seven years

◆ PAUSE AND DECIDE

## What should the solutions architect implement?

A Fix scripts

*Keeps seven years of daily points at full price.*

B Manual copies

*Manual, and snapshots cannot simply be copied to your own bucket.*

C AMIs

*Still snapshots underneath, at the same price.*

D DLM with archive tier

Automated, tiered retention, archived long-term points, deletion.

THE SIGNAL

Long retention, rare restores: few long-term points, archived, managed by policy.

> Meridian Freight's CloudWatch Logs bill doubled in a year. Most log groups have no retention setting, services log at debug level in production, and most logs are only queried during audits.
>
> Logs must stay searchable for one year.

**What should the solutions architect recommend?**

A. Reduce production log level, set one-year retention on every log group, and use the Infrequent Access log class for audit-only logs

B. Export all logs to Glacier daily and delete them from CloudWatch

C. Turn off logging for most services

D. Move to high-resolution metrics instead of logs

◆ PAUSE AND DECIDE

## What should the solutions architect recommend?

**A** Level, retention, IA class

Less ingested, nothing kept past a year, cheaper ingestion for audit logs.

**B** Glacier export

*No longer searchable, which is required.*

**C** Turn off logging

*Fails audit and operations needs.*

**D** High-resolution metrics

*Costs more, and metrics are not logs.*

THE SIGNAL

Logs growing without limit: filter at source, set retention, choose the cheaper class.

# What to carry out of this module

- **Unknown access:** Intelligent-Tiering. **Known:** lifecycle, then expire.
- **gp3**: size for data, provision IOPS separately.
- **Capacity modes:** on-demand vs provisioned; I/O-Optimized when I/O dominates.
- **Backups and snapshots:** tiered retention, archive, managed deletion.
- **Logs:** filter at source, set retention, use the cheaper class.

> ON THE EXAM
>
> Every store needs a rule for where data goes as it ages, and when it is deleted.

MODULE 32 · DOMAIN 4 - RESILIENCE, MIGRATION AND CONTINUITY

# Discovery and Wave Planning

Find out what you really have, how it depends on itself, and which pieces must move together, before anything moves at all.

DOMAIN 4 of 5 EXAM WEIGHT 15% MODULE 32 of 52

admin@sthithapragna.com

Migrations fail on what nobody knew was there. Discovery turns **assumptions** into an inventory, and dependencies into **waves**.

# The discovery stack, then and now

| NEED | C02-ERA TOOL | NOW |
|---|---|---|
| Collect inventory and dependencies | Application Discovery Service | AWS Transform discovery |
| Track and orchestrate the programme | Migration Hub | AWS Transform |
| Business case and TCO | Migration Evaluator | AWS Transform assessment |
| Rehost servers | Application Migration Service | AWS Transform MGN |

ON THE EXAM

Migration Hub and Application Discovery Service closed to new customers on 7 November 2025.

# What discovery collects

| DATA | USED FOR |
| --- | --- |
| Server inventory and specifications | Scope, licensing, target sizing |
| CPU, memory, disk and network utilisation | Right-sizing, not like-for-like |
| Network connections, ports, processes | Dependency mapping, waves |
| Database metadata and metrics | Database migration path |
| Business owner, criticality, change windows | Wave sequencing and timing |

ON THE EXAM

Collect for one to two weeks at least, so monthly and weekly jobs appear in the data.

# How data is collected

AGENTLESS COLLECTOR

## One appliance, many servers

- Virtual appliance in vCenter
- VM inventory and utilisation
- Connections via OS credentials
- No software on each server

IMPORTS

## Data you already have

- RVTools exports
- Existing tool and CMDB data
- Fastest start
- Thinner on dependencies

THE TIEBREAKER

No agents allowed, air-gapped site: deploy the discovery appliance on-premises and upload its export.

# The seven Rs

| STRATEGY | MEANS | TYPICAL SIGNAL |
|---|---|---|
| Retire | Switch it off | No users, duplicate function |
| Retain | Leave it for now | Recent investment, not ready |
| Rehost | Lift and shift to EC2 | Speed, data centre exit date |
| Relocate | Move the hypervisor estate | VMware estate, minimal change |
| Repurchase | Move to SaaS | Commodity function, licence renewal |
| Replatform | Lift, tinker, shift to managed | Reduce operations, little code change |
| Refactor | Re-architect | Scale, agility, business-critical change |

ON THE EXAM

Every application gets one R. Retiring what nobody uses is the cheapest migration of all.

# Building waves from dependencies

- **Group tightly coupled systems**: chatty, low-latency links move together.
- **Loose links can span waves** through hybrid connectivity.
- **Pilot wave first**: low risk, few dependencies, representative patterns.
- **Respect business calendars**: freezes, peaks, change windows.
- **Shared services early**: identity, DNS, monitoring ready before workloads.

> ON THE EXAM
>
> Splitting a chatty application from its database across waves turns LAN latency into WAN latency.

# A migration programme, end to end

01
### Discover
Inventory, utilisation, connections

02
### Assess
Seven Rs, business case

03
### Plan
Application groups and waves

04
### Prepare
Landing zone, connectivity, shared services

05
### Migrate
Pilot, then waves, then cutovers

ON THE EXAM

The landing zone and connectivity come before the first wave, not during it.

# Reading the scenario

| WHEN THE QUESTION SAYS | IT IS TESTING |
|---|---|
| Starting discovery in 2026 | AWS Transform, not Migration Hub |
| Agents not allowed, air-gapped | Discovery appliance, export uploaded |
| App and database talk constantly | Same wave |
| Unused for months | Retire |
| Commodity function, licence renewal | Repurchase |
| Choosing the first wave | Low-risk, representative pilot |

ON THE EXAM

If an answer names Application Discovery Service or Migration Hub for a new programme, it is stale.

> Meridian Freight is starting a new data centre exit in 2026 covering 1,200 VMware virtual machines. It has never used AWS migration tooling before.
>
> Leadership wants an inventory, utilisation-based sizing, a dependency map, proposed waves and a business case.

**What should the solutions architect use?**

A AWS Application Discovery Service agents with AWS Migration Hub

B AWS Transform, with its discovery tool and assessment

C A spreadsheet survey of application owners

D AWS Transform MGN replication agents on every server

◆ PAUSE AND DECIDE

## What should the solutions architect use?

A ADS with Migration Hub

*Closed to new customers since November 2025.*

B AWS Transform

Discovery, dependencies, waves and business case in one service.

C Spreadsheet survey

*Opinions, not measured data; misses dependencies.*

D MGN agents

*Replicates servers for migration; not a discovery tool.*

THE SIGNAL

New customer, new programme, discovery to waves: AWS Transform.

> Meridian Freight's dependency map shows the billing application making thousands of small queries per transaction to an Oracle database. The database is also read nightly by a reporting system.
>
> The team is assigning these three systems to waves.

## How should the solutions architect plan the waves?

A Billing first, then the database a month later

B The database first, then billing and reporting later

C Billing and its database in the same wave; reporting in a later wave over hybrid connectivity

D All three in separate waves, by business owner

◆ PAUSE AND DECIDE

## How should the solutions architect plan the waves?

A **Billing first**

*Thousands of queries per transaction would cross the WAN for a month.*

B **Database first**

*Same problem in reverse for billing.*

C **Chatty pair together**

Keeps the latency-sensitive link local; batch reads tolerate WAN.

D **By business owner**

*Ignores the technical dependency entirely.*

THE SIGNAL

Chatty and latency-sensitive: same wave. Batch and tolerant: can span waves.

> During assessment, Meridian Freight finds a self-hosted expenses application on four servers. Its licence and support contract expire in six months, and several SaaS products provide the same function.
>
> No custom features are required.

**Which migration strategy fits this application?**

A Repurchase: move to a SaaS expenses product

B Rehost the four servers to EC2

C Refactor into microservices on AWS

D Retain on-premises indefinitely

◆ PAUSE AND DECIDE

# Which migration strategy fits this application?

**A** Repurchase

Commodity function, expiring licence, no customisation: buy it as SaaS.

**B** Rehost

*Moves servers whose licence is about to lapse.*

**C** Refactor

*Rebuilding a commodity function is wasted effort.*

**D** Retain

*Blocks the data centre exit.*

THE SIGNAL

Commodity, licence renewal due, nothing custom: repurchase.

> Meridian Freight has 40 planned waves. The programme lead must choose the first wave to prove the migration process, tooling and runbooks.
>
> The board is watching the first wave closely.

## Which applications should form the first wave?

A The customer booking platform, to show value quickly

B The largest applications, to reduce the remaining scope

C A random sample from every business unit

D A few low-risk applications with few dependencies that use the common technology patterns

◆ PAUSE AND DECIDE

# Which applications should form the first wave?

A Booking platform first

*Highest risk while the process is still unproven.*

B Largest first

*Big and complex before the team has learned anything.*

C Random sample

*Ignores risk and dependencies.*

D Low-risk, representative pilot

Proves the factory safely on patterns that recur later.

THE SIGNAL

First wave: low risk, few dependencies, representative of what follows.

> A Meridian Freight data centre in a regulated subsidiary has no internet access, and its security policy forbids installing software on production servers.
>
> The team still needs inventory, utilisation and network dependency data for assessment.

## How should the team collect discovery data?

A Install discovery agents on each server

B Ask application owners to document dependencies

C Deploy the AWS Transform discovery tool appliance in vCenter, collect offline, and upload the export when approved

D Start replicating servers with AWS Transform MGN and observe traffic in AWS

◆ PAUSE AND DECIDE

# How should the team collect discovery data?

A Agents per server

*Forbidden by the security policy.*

B Owner documentation

*Incomplete and unmeasured.*

C Discovery appliance, offline

No per-server software; works air-gapped; export uploaded later.

D Replicate first

*Installs replication agents, and migrates before assessing.*

THE SIGNAL

No agents, no internet: the on-premises discovery appliance and an offline export.

> Meridian Freight's discovery data shows 140 servers with near-zero CPU and network activity for six months. Owners for 120 of them confirm the systems were replaced years ago.
>
> The programme must cut migration scope and cost.

**What should the solutions architect recommend for those 120 servers?**

A Rehost them in the last wave

B Retire them, after confirming no hidden dependencies and archiving data as required

C Retain them on-premises

D Replatform them to managed services

◆ PAUSE AND DECIDE

## What should the solutions architect recommend for those 120 servers?

A **Rehost later**

*Pays to move systems nobody uses.*

B **Retire**

Removes scope and cost; checks and archiving cover the risk.

C **Retain**

*Keeps paying for idle servers, and blocks the exit.*

D **Replatform**

*Effort spent modernising dead systems.*

THE SIGNAL

Measured idle, owners confirm replaced: retire, with care.

# What to carry out of this module

- **Measure, do not ask**: inventory, utilisation and connections over weeks.
- **AWS Transform** for new programmes; Migration Hub and ADS are closed to new customers.
- **One of seven Rs** per application; retire whatever you can.
- **Chatty dependencies move together**; loose ones can span waves.
- **Pilot first**: low risk, representative, after the landing zone is ready.

> ON THE EXAM
>
> Discover, assess, plan, prepare, then migrate.

MODULE 33 · DOMAIN 4 - RESILIENCE, MIGRATION AND CONTINUITY

# Rehosting with AWS Transform MGN

Replicate servers continuously into AWS, test without touching production, cut over in minutes, and know when relocating the whole VMware estate fits better.

DOMAIN 4 of 5 EXAM WEIGHT 15% MODULE 33 of 52

admin@sthithapragna.com

Rehosting is not a copy. It is **continuous replication**, so the cutover is a short switch rather than a long outage.

# The MGN lifecycle

01
### Replicate
Agent or vCenter appliance streams changes

02
### Stage
Low-cost replication servers and EBS

03
### Test
Launch test instances, validate

04
### Cut over
Stop source, final sync, launch

05
### Finalise
Archive source, stop replication

ON THE EXAM

Test as many times as needed; replication keeps running between tests.

# Agent or agentless replication?

REPLICATION AGENT

## On each server

- Physical, virtual or other clouds
- Any supported hypervisor
- Agent installed in the guest OS
- The default and most general

AGENTLESS

## Through vCenter

- vCenter client appliance on-premises
- VMware VMs only
- Nothing installed in the guests
- Snapshot-based replication

THE TIEBREAKER

No software allowed inside VMware guests: agentless replication through the vCenter appliance.

# Network and staging design

- **Replication traffic** over Direct Connect or VPN, using private IPs.
- **Staging subnet**: private, sized for replication servers.
- **Interface endpoints** for MGN, EC2 and S3 keep control traffic private.
- **Bandwidth throttling** protects the production network link.
- **Encrypted in transit**; replicated data stays in your VPC.

> ON THE EXAM
>
> Replication must not cross the internet: private IP over Direct Connect, plus interface endpoints.

# Launching safely

- **Launch templates** set instance type, subnet, security groups, licensing.
- **Right-size** from discovery data, not the source hardware.
- **Isolated test subnet** so test instances cannot reach production systems.
- **Domain controllers**: launch first, or keep them in the source.
- **Applications and waves** group servers to test and cut over together.

> ON THE EXAM
>
> Test instances that can reach production directories or databases can cause real damage.

# Post-launch actions

| ACTION | PURPOSE |
| --- | --- |
| Install SSM agent | Manage the new instance immediately |
| Install CloudWatch agent | Metrics and logs from day one |
| Upgrade Windows OS | Clone and upgrade an out-of-support version |
| Convert licences | Move to AWS-provided licensing |
| Custom SSM documents | Your own hardening and configuration |

ON THE EXAM

Standard changes on every migrated server, without logging in to each one: post-launch actions.

# Rehost to EC2, or relocate with EVS?

REHOST WITH MGN

## VMs become EC2 instances

- Per-server replication and cutover
- EC2 operations, pricing, scaling
- Leaves VMware licensing behind
- Path to later modernisation

RELOCATE WITH AMAZON EVS

## Run VMware in your VPC

- VMware Cloud Foundation on AWS metal
- Same vSphere tools and runbooks
- Bring your own VCF licence
- You operate the VCF stack

THE TIEBREAKER

Exit fast, change nothing in operations, keep the VCF licences: relocate to Amazon EVS.

# AWS Transform for rehosting

- **Agentic workflow**: discovery, waves, network, landing zone, rehost.
- **Network conversion**: target VPCs generated from source segments as CloudFormation.
- **Rehosting runs on MGN**; switch to the MGN console at any time.
- **Humans approve** plans and changes before they run.

> ON THE EXAM
>
> A large VMware exit wanting automated planning and network build: AWS Transform orchestrating MGN.

# Reading the scenario

| WHEN THE QUESTION SAYS | IT IS TESTING |
|---|---|
| Minimal downtime, many servers | MGN continuous replication |
| No agents in VMware guests | Agentless replication via vCenter |
| Replication must stay private | Private IP over DX or VPN, endpoints |
| Testing must not affect production | Isolated test subnet |
| Keep vSphere operations, BYO VCF licence | Amazon EVS |
| Same fix-ups on every migrated server | Post-launch actions |

ON THE EXAM

Application Migration Service in an older question is AWS Transform MGN in a newer one.

> Meridian Freight must move 300 Linux and Windows servers, a mix of physical and VMware, to EC2. Each application can be down for at most 30 minutes during cutover.
>
> Teams want to test each application in AWS several times before cutover.

**What should the solutions architect use?**

A AWS Transform MGN with replication agents, test launches, then cutover

B VM Import/Export of each server's disk image

C AWS DataSync to copy each server's files

D Rebuild every server from new AMIs and reinstall applications

◆ PAUSE AND DECIDE

## What should the solutions architect use?

**A** MGN with agents

Continuous replication; repeatable tests; minutes of cutover downtime.

**B** VM Import/Export

*One-off image copy, long downtime, VMware only.*

**C** DataSync

*Copies files, not bootable servers.*

**D** Rebuild

*That is a replatform effort, and slow.*

THE SIGNAL

Many servers, physical and virtual, minimal downtime, repeated tests: MGN with agents.

> In another Meridian Freight data centre, all 600 servers are VMware virtual machines. The security team forbids installing any additional software inside guest operating systems.
>
> The servers must be rehosted to EC2 with minimal downtime.

## How should replication be configured?

A Install the MGN replication agent on each VM

B Use VM Import/Export

C Use AWS Elastic Disaster Recovery agents

D Deploy the MGN vCenter client appliance and use agentless replication

◆ PAUSE AND DECIDE

## How should replication be configured?

A Agent per VM

*Installs software in the guests, which is forbidden.*

B VM Import/Export

*No continuous replication, so long downtime.*

C DRS agents

*Still an agent inside each guest.*

D Agentless via vCenter

Replicates from vCenter snapshots; nothing in the guests.

THE SIGNAL

All VMware, nothing in the guests: agentless replication.

> Meridian Freight's financial regulator forbids migration data crossing the public internet. The company has a 10 Gbps Direct Connect connection to its landing zone.
>
> Replication for 200 servers is about to start.

**What should the solutions architect configure?**

A. Default replication settings, since data is encrypted in transit

B. Private IP replication over Direct Connect, a private staging subnet, and interface endpoints for MGN and related services

C. Ship disks on AWS Snowball devices

D. A Site-to-Site VPN over the internet

◆ PAUSE AND DECIDE

## What should the solutions architect configure?

A Defaults

*Encrypted, but may use public paths.*

B Private over Direct Connect

Data and control traffic stay on private paths.

C Snowball

*Closed to new customers, and no continuous replication.*

D VPN over internet

*Encrypted, but still crosses the public internet.*

THE SIGNAL

Not over the internet: private IPs on Direct Connect, plus interface endpoints.

> During Meridian Freight's first wave, a test instance of the order service started processing real orders from the on-premises message broker, because it could reach the corporate network.
>
> The team must keep testing before cutover without this happening again.

## What should the solutions architect change?

A Stop testing and cut over directly

B Launch test instances in the production subnet

C Set the launch template for tests to an isolated subnet with no route to on-premises production systems

D Shut down the on-premises broker during tests

◆ PAUSE AND DECIDE

## What should the solutions architect change?

A Skip testing

*Removes the safety the test stage provides.*

B Production subnet

*Makes the problem worse.*

C Isolated test subnet

Tests run on real data without touching production.

D Stop the broker

*Causes a production outage for every test.*

THE SIGNAL

Test copies are full copies: isolate them from anything real.

> Meridian Freight must leave a co-location facility within four months. Its 2,000 VMware VMs are run by a team with mature vSphere and NSX runbooks, and the company has recently bought VMware Cloud Foundation licences.
>
> Leadership wants no change to VMs or operating procedures during the move.

**What should the solutions architect recommend?**

A Relocate to Amazon Elastic VMware Service in the company's VPC, using its VCF licences

B Rehost all 2,000 VMs to EC2 with MGN

C Refactor the applications to containers

D Retain on-premises in a new facility

◆ PAUSE AND DECIDE

## What should the solutions architect recommend?

**A** Amazon EVS

Same VMware stack and runbooks, in AWS, with owned licences.

**B** Rehost to EC2

*Changes the operating model, which leadership ruled out for now.*

**C** Refactor

*Far too slow for four months.*

**D** New facility

*Not a cloud migration at all.*

THE SIGNAL

No change to VMs or operations, VCF licences owned, tight deadline: relocate with EVS.

> Every server Meridian Freight migrates needs the Systems Manager and CloudWatch agents, a hardening script, and, for 40 servers, an upgrade from an unsupported Windows Server version.
>
> The team wants this done automatically as part of each launch.

**What should the solutions architect configure?**

A. A runbook for engineers to log in to each instance after cutover

B. User data scripts written separately for each server

C. EC2 Image Builder pipelines for every source server

D. MGN post-launch actions: predefined agent installs and Windows upgrade, plus a custom SSM document for hardening

◆ PAUSE AND DECIDE

## What should the solutions architect configure?

A Manual runbook

*Hundreds of logins; slow and inconsistent.*

B Per-server user data

*Custom scripting for each server.*

C Image Builder

*Builds new images; rehosted servers are replicated, not built.*

D Post-launch actions

Applied automatically to every test and cutover launch.

THE SIGNAL

Standard changes on every rehosted server: post-launch actions.

# What to carry out of this module

- **AWS Transform MGN** is Application Migration Service, renamed June 2026.
- **Continuous replication**, repeatable tests, minutes of cutover.
- **Agent anywhere**; **agentless** for VMware with no guest software.
- **Private replication**, isolated tests, post-launch actions.
- **Relocate with EVS** when VMware operations must not change.

ON THE EXAM

Replicate, stage, test, cut over, finalise.

MODULE 34 · DOMAIN 4 - RESILIENCE, MIGRATION AND CONTINUITY

# Database and Data Migration

Move databases with minimal downtime, convert schemas between engines, and move files and bulk data online, or physically when the network cannot.

DOMAIN 4 of 5 EXAM WEIGHT 15% MODULE 34 of 52

admin@sthithapragna.com

Copy everything once, then **keep copying the changes** until the moment you switch. Downtime is only the final catch-up.

# Homogeneous or heterogeneous?

SAME ENGINE

## MySQL to RDS for MySQL

- No schema conversion
- Native tools or DMS homogeneous migrations
- Full load plus replication
- Lowest risk path

DIFFERENT ENGINE

## Oracle to Aurora PostgreSQL

- Schemas and code must be converted
- DMS Schema Conversion, then DMS
- Full load plus change data capture
- Test application SQL thoroughly

THE TIEBREAKER

**Changing engine adds a conversion step before any data moves.**

# AWS DMS building blocks

| PIECE | ROLE |
| --- | --- |
| Schema Conversion | Converts schemas and code; rules first, generative AI for the rest |
| Full load | Copies existing data |
| Change data capture | Streams ongoing changes until cutover |
| Replication instance or DMS Serverless | Runs the task; serverless scales itself |
| Data validation | Compares source and target rows |

ON THE EXAM

Heterogeneous with minimal downtime: Schema Conversion, then full load plus CDC, then validate.

# Database migration practices

- **Source prerequisites**: archive logs or binary logs enabled for CDC.
- **Large tables**: parallel full load by partition or range.
- **LOBs** slow tasks; choose limited LOB mode where sizes allow.
- **Secondary indexes and triggers** after full load, before cutover.
- **Cutover**: stop writes, wait for CDC lag zero, validate, switch.

> ON THE EXAM
>
> CDC needs the source's transaction logs available and retained long enough.

# Moving files and objects

| NEED | SERVICE |
| --- | --- |
| NFS, SMB, HDFS, object stores to S3, EFS, FSx | AWS DataSync |
| Other clouds' storage to S3 | DataSync Enhanced mode, agentless |
| Partners keep sending by SFTP or FTPS | AWS Transfer Family |
| Ongoing hybrid file access | Storage Gateway (not a migration tool) |
| Petabytes, network too slow | AWS Data Transfer Terminal |

ON THE EXAM

One-off or scheduled bulk copy with verification and incremental passes: DataSync.

# When the network is too slow

| OPTION | STATUS |
| --- | --- |
| AWS Snowball Edge and Snow Family | Closed to new customers |
| AWS Data Transfer Terminal | Bring your devices to an AWS facility |
| More bandwidth: Direct Connect upgrade | Weeks to provision |
| DataSync over existing links | Fine if the time budget allows |

ON THE EXAM

A Snowball answer for a new customer is stale. Data Transfer Terminal is AWS's named replacement.

# Do the arithmetic

- **1 Gbps** fully used moves roughly 10 TB a day.
- **Real links** rarely sustain more than about 80% of line rate.
- **500 TB at 1 Gbps**: about two months, if nothing else uses the link.
- **2 PB at 1 Gbps**: over half a year. Move it physically.
- **Then sync the deltas** online after the bulk copy lands.

> ON THE EXAM
>
> Bulk physically, then catch up the changes online with DataSync.

# Reading the scenario

| WHEN THE QUESTION SAYS | IT IS TESTING |
|---|---|
| Oracle to PostgreSQL, minimal downtime | Schema Conversion, DMS full load plus CDC |
| Same engine, minimal downtime | Homogeneous migration or native replication |
| Petabytes, slow link, new customer | Data Transfer Terminal |
| NAS shares to EFS or FSx, then cutover | DataSync incremental tasks |
| Partners must keep using SFTP | Transfer Family |
| Variable load, no sizing | DMS Serverless |

ON THE EXAM

Engine change means conversion first. Network too slow means physical. Snowball means stale.

> Meridian Freight is moving its 3 TB Oracle shipment database to Aurora PostgreSQL to end Oracle licensing. It has hundreds of PL/SQL procedures.
>
> The application can be offline for no more than 15 minutes at cutover.

## What should the solutions architect recommend?

A. AWS DMS full load only, with the application offline during the copy

B. DMS Schema Conversion for schema and code, then a DMS task with full load and change data capture until cutover

C. Rehost the Oracle server to EC2 with AWS Transform MGN

D. Export to CSV, load into Aurora, and rewrite procedures manually

◆ PAUSE AND DECIDE

## What should the solutions architect recommend?

A Full load only

*Offline for the whole copy, far beyond 15 minutes.*

B Schema Conversion plus full load and CDC

Converts code, then keeps the target current until a short cutover.

C Rehost Oracle

*Keeps the Oracle licence the company wants to end.*

D CSV and manual rewrite

*Long downtime and slow, error-prone conversion.*

THE SIGNAL

Engine change, code to convert, minutes of downtime: Schema Conversion, then full load plus CDC.

> Meridian Freight's 5 TB on-premises MySQL 8.0 database must move to Amazon RDS for MySQL 8.0 with less than 10 minutes of downtime.
>
> The team prefers the engine's native replication mechanisms over row-by-row copying.

**What should the solutions architect use?**

A DMS Schema Conversion to PostgreSQL

B mysqldump with the database offline

C DMS homogeneous data migration, using native MySQL tools for full load and ongoing replication

D AWS DataSync of the MySQL data directory

◆ PAUSE AND DECIDE

## What should the solutions architect use?

A Convert to PostgreSQL

*Changes engine for no stated reason.*

B Offline dump

*Hours of downtime for 5 TB.*

C Homogeneous migration

Native tools, full load then replication, short cutover.

D Copy data files

*Not consistent, and RDS does not accept raw data directories.*

THE SIGNAL

Same engine, native mechanisms, short cutover: homogeneous data migration.

> Meridian Freight's media archive of 2 PB of scanned documents sits in a Los Angeles data centre with a 1 Gbps internet link. The archive must be in Amazon S3 within six weeks.
>
> The company has never used AWS Snow Family devices.

**What should the solutions architect recommend?**

A Order AWS Snowball Edge devices

B Copy the archive to drives and upload it at an AWS Data Transfer Terminal, then sync recent changes with DataSync

C AWS DataSync over the existing 1 Gbps link

D S3 Transfer Acceleration

◆ PAUSE AND DECIDE

## What should the solutions architect recommend?

A Snowball Edge
*Not available to new customers.*

B Data Transfer Terminal plus DataSync
Physical bulk upload, then online catch-up.

C DataSync over 1 Gbps
*Over half a year for 2 PB.*

D Transfer Acceleration
*Still limited by the 1 Gbps link.*

THE SIGNAL

Too much data for the link, new customer: Data Transfer Terminal, not Snowball.

> Meridian Freight is moving 400 TB of NFS file shares to Amazon EFS over a 10 Gbps Direct Connect link. Users keep working on the shares until a weekend cutover.
>
> Every file must be verified, and the cutover window is four hours.

## What should the solutions architect use?

A. A Storage Gateway File Gateway in front of EFS

B. Custom rsync scripts on several servers

C. AWS DataSync: an initial full copy, scheduled incremental tasks, and a final incremental run at cutover with verification

D. AWS Transfer Family

◆ PAUSE AND DECIDE

## What should the solutions architect use?

A File Gateway

*Hybrid access to S3, not a migration to EFS.*

B rsync scripts

*Works, but custom, slower, and verification is yours to build.*

C DataSync incremental

Bulk copy early, small final delta, built-in verification.

D Transfer Family

*For SFTP and FTP clients, not bulk NFS migration.*

THE SIGNAL

Large shares, live until cutover, verified: DataSync, full then incremental.

> Forty customs brokers send files to Meridian Freight's on-premises SFTP server, which is being retired. Brokers cannot change their software, credentials or the hostname they connect to.
>
> Files must land in Amazon S3.

**What should the solutions architect implement?**

A. An AWS Transfer Family SFTP server backed by S3, with brokers' keys imported and the hostname's DNS record pointed at it

B. Ask brokers to upload with the AWS CLI

C. AWS DataSync from the old SFTP server, kept running indefinitely

D. An EC2 instance running an SFTP daemon that copies to S3

◆ PAUSE AND DECIDE

## What should the solutions architect implement?

**A** Transfer Family

Managed SFTP into S3; same hostname and keys for brokers.

**B** AWS CLI

*Brokers cannot change their software.*

**C** DataSync forever

*Keeps the server that is being retired.*

**D** Self-managed SFTP

*Works, but an EC2 server to patch and scale.*

THE SIGNAL

Partners' SFTP must keep working, data into S3: Transfer Family.

> Meridian Freight runs several DMS migrations with full load and change data capture. Load varies widely, from heavy initial loads to near-idle replication overnight.
>
> The team does not want to choose or resize replication instances.

**What should the solutions architect recommend?**

A The largest replication instance class for every task

B AWS Glue jobs instead of DMS

C Lambda functions polling the source tables

D AWS DMS Serverless replications

◆ PAUSE AND DECIDE

## What should the solutions architect recommend?

A Largest instances

*Pays for peak capacity overnight.*

B Glue

*ETL, not log-based change data capture.*

C Polling Lambda

*Misses deletes and adds load to the source.*

D DMS Serverless

Provisions and scales capacity automatically.

THE SIGNAL

DMS without sizing instances, load varies: DMS Serverless.

# What to carry out of this module

- **Full copy, then changes**: downtime is only the final catch-up.
- **Engine change**: Schema Conversion first, then DMS full load plus CDC.
- **DataSync** for files, with incremental passes and verification.
- **Snowball is closed** to new customers; use Data Transfer Terminal.
- **Do the arithmetic**: about 10 TB a day per fully used Gbps.

> ON THE EXAM
>
> Convert if needed, copy in bulk, stream the changes, cut over briefly.

MODULE 35 · DOMAIN 4 - RESILIENCE, MIGRATION AND CONTINUITY

# Replatforming and Refactoring

Swap self-managed parts for managed services with little code change, and break monoliths apart one route at a time with the strangler fig pattern.

DOMAIN 4 of 5 EXAM WEIGHT 15% MODULE 35 of 52

admin@sthithapragna.com

# Replatform or refactor?

REPLATFORM

## Lift, tinker and shift

- Managed database, broker, container platform
- Little or no code change
- Removes undifferentiated operations
- Weeks per application

REFACTOR

## Change the architecture

- Microservices, events, serverless
- Significant code change
- Unlocks scale and release speed
- Months, done incrementally

THE TIEBREAKER

Reduce operations with little code change: replatform. New capabilities the old design blocks: refactor.

# Common replatform moves

| FROM | TO | REMOVES |
|---|---|---|
| Self-managed MySQL, PostgreSQL | RDS or Aurora | Patching, backups, failover |
| Oracle or SQL Server on servers | RDS for that engine | Infrastructure work, keeps engine |
| App servers on VMs | ECS on Fargate | Server management |
| Scheduled scripts on a server | Lambda with EventBridge Scheduler | An always-on server |
| ActiveMQ or RabbitMQ | Amazon MQ | Broker operations, same protocols |
| Self-managed Kafka | Amazon MSK | Cluster operations |

ON THE EXAM

Keep the protocol or engine the code expects; change only who runs it.

Big-bang rewrites fail. Replace a monolith **one capability at a time**, while it keeps serving customers.

# The strangler fig pattern

01
### Front door
Put a router in front of the monolith

02
### Build
Implement one capability as a new service

03
### Route
Send that path to the new service

04
### Retire
Remove the code from the monolith

05
### Repeat
Until the monolith is gone

ON THE EXAM

The router is the key piece: ALB rules, API Gateway routes or CloudFront behaviours.

# Patterns that make decomposition work

- **Anti-corruption layer** translates between old and new models.
- **Database per service**, fed by events or CDC, not a shared schema.
- **Events** through EventBridge or SNS decouple services.
- **Branch by abstraction** swaps implementations behind an interface.
- **Sagas** replace distributed transactions across services.

ON THE EXAM

New services reading the monolith's tables directly recreate the coupling you are removing.

# Modernisation tooling, now

| NEED | CURRENT OPTION |
| --- | --- |
| Incremental routing for strangler fig | ALB, API Gateway, CloudFront routing |
| Managed strangler fig environment | Refactor Spaces: closed to new customers |
| .NET Framework on Windows to Linux | AWS Transform for .NET |
| Assess and plan modernisation paths | AWS Transform |
| Containerise applications | AWS Transform, then ECS or EKS |

ON THE EXAM

Migration Hub Refactor Spaces closed to new customers on 7 November 2025, with Migration Hub.

# Reading the scenario

| WHEN THE QUESTION SAYS | IT IS TESTING |
|---|---|
| Reduce DBA work, no code change | Replatform to RDS or Aurora |
| Containers, no servers to manage | ECS on Fargate |
| Replace the monolith gradually | Strangler fig behind a router |
| New service needs old data, no coupling | Anti-corruption layer, events |
| .NET on Windows, cut licence cost | AWS Transform for .NET |
| Self-managed broker, same protocols | Amazon MQ |

ON THE EXAM

Prefer the least change that meets every requirement, and change incrementally when more is needed.

> Meridian Freight runs a self-managed MySQL 8.0 cluster on EC2 for its booking system. Two DBAs spend most of their time on patching, backups and replica failover.
>
> The application must not be rewritten.

**What should the solutions architect recommend?**

A Refactor the data layer to DynamoDB

B Automate patching on EC2 with Systems Manager

C Rehost the cluster with AWS Transform MGN

D Replatform to Amazon Aurora MySQL

◆ PAUSE AND DECIDE

## What should the solutions architect recommend?

A DynamoDB

*Requires rewriting the application, which is ruled out.*

B Automate patching

*Leaves backups, failover and the rest self-managed.*

C Rehost

*Already on EC2; moves nothing off the DBAs.*

D Aurora MySQL

Managed patching, backups and failover; MySQL-compatible.

THE SIGNAL

Operational pain, same engine, no rewrite: replatform to a managed database.

> Meridian Freight's Java tracking application runs on 30 EC2 instances that the operations team patches monthly. The team has already containerised it for testing.
>
> Operations wants to stop managing servers, with no changes to the application code.

**What should the solutions architect recommend?**

A Run the containers on Amazon ECS with AWS Fargate

B Amazon EKS with self-managed node groups

C Rewrite the application as Lambda functions

D Larger EC2 instances, so there are fewer to patch

◆ PAUSE AND DECIDE

# What should the solutions architect recommend?

**A** ECS on Fargate

Runs the existing containers with no servers to manage.

**B** EKS self-managed nodes

*Still servers to patch, plus Kubernetes to run.*

**C** Lambda rewrite

*A code change, which is ruled out.*

**D** Fewer, larger instances

*Still patching servers.*

THE SIGNAL

Containers exist, no servers wanted, no code change: ECS on Fargate.

> Meridian Freight wants to replace its customer portal monolith gradually. The tracking pages should move first to a new service, while every other page keeps running on the monolith.
>
> Customers must not notice any change of URL, and the team wants to move one feature at a time.

**What should the solutions architect implement?**

A Rewrite the whole portal, then switch DNS

B Put an Application Load Balancer in front of the monolith, and add a path rule sending /tracking to the new service

C Create AWS Migration Hub Refactor Spaces environments

D Give the new service its own domain name

◆ PAUSE AND DECIDE

## What should the solutions architect implement?

A Big-bang rewrite

*The opposite of one feature at a time.*

B ALB path routing

The strangler fig front door; move routes one by one.

C Refactor Spaces

*Closed to new customers since November 2025.*

D New domain

*Customers would see the change.*

THE SIGNAL

Gradual replacement behind the same URL: a router in front, one path at a time.

> Meridian Freight's new tracking service needs shipment data that the monolith stores in its own relational schema. The monolith's schema changes often and is poorly documented.
>
> The new service must not break when the monolith's schema changes.

## How should the new service get the data?

A Query the monolith's database tables directly

B Copy the monolith's tables to the new service nightly

C Publish shipment events from the monolith, via change data capture, through an anti-corruption layer into the service's own data store

D Call the monolith's stored procedures

◆ PAUSE AND DECIDE

# How should the new service get the data?

A Direct queries

*Breaks whenever the monolith's schema changes.*

B Nightly copy

*Stale data, and still bound to the old schema.*

C Events through an ACL

The translation absorbs schema changes; the service owns its data.

D Stored procedures

*Couples the service to the monolith's internals.*

THE SIGNAL

New services own their data; translate the old model at the boundary.

> Meridian Freight has 60 ASP.NET applications on .NET Framework running on Windows Server EC2 instances. Windows licensing is a large share of their cost.
>
> The team wants to modernise the portfolio consistently and run the applications on Linux.

**What should the solutions architect recommend?**

A Rehost the instances with AWS Transform MGN

B Buy Reserved Instances for the Windows servers

C Rewrite each application in Java by hand

D Use AWS Transform for .NET to port the applications to cross-platform .NET for Linux

◆ PAUSE AND DECIDE

## What should the solutions architect recommend?

A Rehost

*Still Windows, still licensed.*

B Reserved Instances

*Discounts the licence cost; does not remove it.*

C Manual Java rewrite

*Slow, risky and inconsistent across 60 apps.*

D AWS Transform for .NET

Agentic porting to Linux, consistent across the portfolio.

THE SIGNAL

.NET on Windows, move to Linux at portfolio scale: AWS Transform for .NET.

> Meridian Freight's depot systems publish messages to a self-managed ActiveMQ broker using JMS and AMQP. The broker crashes several times a year and nobody wants to maintain it.
>
> The depot systems cannot be changed this year.

**What should the solutions architect recommend?**

A Amazon MQ for ActiveMQ in an active/standby deployment

B Amazon SQS with code changes in each depot system

C Amazon MSK

D Amazon EventBridge

◆ PAUSE AND DECIDE

## What should the solutions architect recommend?

**A** Amazon MQ

Same protocols, managed and highly available.

**B** SQS

*Requires code changes, which are ruled out.*

**C** MSK

*Kafka protocol, not JMS or AMQP.*

**D** EventBridge

*Different API; the depot systems would need changes.*

THE SIGNAL

Existing JMS or AMQP clients that cannot change: Amazon MQ.

# What to carry out of this module

- **Replatform**: same interface, managed operator, little code change.
- **Refactor incrementally**: strangler fig behind a router.
- **Own your data**: events, CDC and an anti-corruption layer.
- **AWS Transform for .NET** to move Windows .NET to Linux.
- **Refactor Spaces** is closed to new customers; routing rules do the job.

> ON THE EXAM
>
> Least change that meets the need, and incremental change when more is needed.

MODULE 36 · DOMAIN 4 - RESILIENCE, MIGRATION AND CONTINUITY

# Mainframe and Legacy Modernisation

Understand the code before changing it, choose between replatform, refactor and reimagine, prove equivalence with tests, and modernise in increments.

DOMAIN 4 of 5 EXAM WEIGHT 15% MODULE 36 of 52

admin@sthithapragna.com

The hardest part of a legacy system is not the platform. It is the **business logic nobody can explain** any more.

# Mainframe modernisation paths

| PATH | WHAT CHANGES | FITS |
|---|---|---|
| Replatform | COBOL kept, emulating runtime | Fast exit, COBOL skills |
| Refactor | COBOL to Java, automatically | Logic preserved, Java teams |
| Reimagine | Rules extracted, new design | Batch to real-time |
| Replace | Commercial or SaaS product | Non-differentiating function |
| Augment | Data and APIs extended to AWS | Mainframe staying for now |

ON THE EXAM

Speed with least change: replatform. Logic preserved in Java: refactor. New architecture: reimagine.

# AWS Transform for mainframe

| STAGE | WHAT THE AGENTS DO |
|---|---|
| Analyse | Inventory COBOL, PL/I, JCL, CICS, BMS, Db2, VSAM, IMS |
| Document | Generate technical documentation and business rules |
| Decompose | Group code into business domains, approved by people |
| Plan | Order domains into modernisation waves |
| Refactor or reimagine | Java with logic preserved, or new specs and services |
| Test | Test plans, data collection scripts, automated functional tests |

ON THE EXAM

Every stage has humans approving the output: decomposition, waves, specifications.

# Refactor or reimagine?

REFACTOR

## Same behaviour, new language

- COBOL to Java, logic preserved
- Same batch and transaction structure
- Functional equivalence is the goal
- Faster, lower risk

REIMAGINE

## Same rules, new architecture

- Reverse-engineer business rules to specs
- Forward-engineer microservices and data model
- Batch can become real-time
- Slower, more validation by experts

THE TIEBREAKER

Keep how it works, change the language: refactor. Keep what it decides, change how it works: reimagine.

# Proving equivalence

- **Test plans** generated from code, business logic and scheduler plans.
- **Data collection scripts** capture real inputs from VSAM and Db2.
- **Functional tests** run the same cases against the new application.
- **Parallel runs** compare outputs before the old system is switched off.
- **Batch order matters**: tests follow the JCL sequence.

> ON THE EXAM
>
> No equivalence evidence, no cutover. Automated test generation is part of the answer.

# What changed in the mainframe service

| OFFERING | STATUS FOR NEW CUSTOMERS |
|---|---|
| Managed runtime environment (Rocket) | Closed; use the self-managed runtime |
| Self-managed partner capabilities | Closed; vendor-direct or AWS Transform |
| Self-managed runtime for Rocket replatform | Available |
| Runtime for AWS Transform refactored code | Available |
| AWS Transform for mainframe | Available |

ON THE EXAM

An answer offering the managed Mainframe Modernization runtime to a new customer is stale.

# Modernising in increments

- **Domains move one at a time**, in the waves AWS Transform proposes.
- **APIs in front**: mainframe transactions exposed through API Gateway.
- **Route by route**: switch an API to the modernised service when ready.
- **Data in step**: CDC keeps Db2 and the new database synchronised.
- **Analytics first**: offload reporting to AWS before moving transactions.

> ON THE EXAM
>
> The strangler fig works for mainframes too: APIs in front, domains moved behind them.

# Reading the scenario

| WHEN THE QUESTION SAYS | IT IS TESTING |
|---|---|
| COBOL to Java, logic preserved | AWS Transform refactor |
| Batch to real-time, new architecture | AWS Transform reimagine |
| Exit hardware fast, keep COBOL | Replatform on self-managed runtime |
| Mainframe stays; cloud needs its data | CDC replication to AWS |
| Prove the new system matches | Generated test plans and data |
| Move transactions gradually | APIs in front, strangler fig |

ON THE EXAM

Understand first, choose the path by how much must change, then prove equivalence.

> Meridian Freight's billing runs on 2 million lines of COBOL with CICS and Db2. The last COBOL developers retire next year, and the company's teams work in Java.
>
> The business logic must be preserved exactly, and the team wants as much automation as possible.

## What should the solutions architect recommend?

A Rewrite the application in Java by hand from interviews

B AWS Transform for mainframe to analyse, decompose and refactor the COBOL to Java

C Replatform the COBOL onto an emulating runtime

D Buy a SaaS billing product

◆ PAUSE AND DECIDE

## What should the solutions architect recommend?

A Manual rewrite

*Slow, and logic is lost when nobody can explain it.*

B AWS Transform refactor

Automated analysis and COBOL-to-Java with logic preserved.

C Replatform

*Keeps COBOL, which nobody will be able to maintain.*

D SaaS

*Does not preserve Meridian's specific billing logic.*

THE SIGNAL

Skills leaving, Java teams, logic preserved, automated: refactor with AWS Transform.

> Meridian Freight's mainframe calculates customs duties in an overnight batch, so customers wait until the next day for a quote. The business wants instant quotes.
>
> The duty rules themselves must stay the same.

## Which modernisation approach fits best?

A Replatform the batch to an emulating runtime on AWS

B Refactor the batch COBOL to Java batch jobs

C Reimagine with AWS Transform: extract the duty rules, then build them as real-time services

D Run the batch every hour instead of nightly

◆ PAUSE AND DECIDE

# Which modernisation approach fits best?

A **Replatform**
*Still an overnight batch.*

B **Refactor**
*Same batch structure, just in Java.*

C **Reimagine**
Same rules, new real-time architecture.

D **Hourly batch**
*Faster, but still not instant.*

THE SIGNAL

**Same rules, different architecture: reimagine.**

> Meridian Freight's mainframe hardware lease ends in nine months. The operations team has deep COBOL skills, and the company has no budget to change application code this year.
>
> Meridian has never used AWS Mainframe Modernization.

**What should the solutions architect recommend?**

A. Replatform onto the self-managed Rocket runtime from AWS Mainframe Modernization on EC2

B. The AWS Mainframe Modernization managed runtime environment

C. Reimagine the whole estate as microservices

D. Sign a new five-year mainframe lease

◆ PAUSE AND DECIDE

# What should the solutions architect recommend?

**A** Self-managed replatform

COBOL unchanged, available to new customers, fits nine months.

**B** Managed runtime

*No longer open to new customers.*

**C** Reimagine

*Far too long, and changes code.*

**D** New lease

*Abandons the migration.*

THE SIGNAL

Fast exit, no code change, new customer: the self-managed replatform runtime.

> Meridian Freight will keep its mainframe for at least three more years. The analytics team wants shipment data from Db2 for z/OS in AWS within minutes of each change.
>
> Running analytical queries on the mainframe is expensive and slows transactions.

**What should the solutions architect recommend?**

A Nightly file extracts sent by FTP to S3

B Run the analytics queries directly against Db2 from AWS

C Migrate the whole mainframe first

D Change data capture replication from Db2 for z/OS into AWS data stores

◆ PAUSE AND DECIDE

## What should the solutions architect recommend?

A **Nightly FTP**
*A day old, not minutes.*

B **Direct queries**
*The expensive mainframe processing the business wants to avoid.*

C **Migrate first**
*Years away; the mainframe is staying.*

D **CDC replication**
Changes reach AWS in minutes; analytics run off the mainframe.

THE SIGNAL

Mainframe stays, cloud needs fresh data: augment with change data capture.

> Meridian Freight has refactored a batch settlement application from COBOL to Java. Auditors require evidence that every batch job produces identical results to the mainframe before cutover.
>
> The batch jobs run in a strict scheduler sequence.

## What should the solutions architect recommend?

A Rely on the Java unit tests produced during refactoring

B Use AWS Transform's generated test plans, data collection scripts and automated functional tests, following the scheduler sequence

C Ask users to check a sample of reports after cutover

D Compare row counts between the two databases once

◆ PAUSE AND DECIDE

## What should the solutions architect recommend?

A Unit tests

*Test code units, not end-to-end equivalence with the mainframe.*

B Generated functional tests

Real data, same cases, same sequence, repeatable evidence.

C User sampling after cutover

*Too late, and not evidence for every job.*

D Row counts

*Equal counts can hide different values.*

THE SIGNAL

Equivalence evidence for every batch job, in sequence, before cutover: generated functional tests.

> Meridian Freight's mainframe handles booking, tracking and invoicing as CICS transactions called by web and partner systems. AWS Transform has decomposed the code into these three domains.
>
> The company wants to move one domain at a time while the others keep running on the mainframe.

**What should the solutions architect implement?**

A. A single weekend cutover of all three domains

B. Run a full copy of the system on AWS in parallel for two years

C. Expose the transactions as APIs through API Gateway, switch each domain's routes to its modernised service when ready, and keep data in step with CDC

D. Freeze all mainframe changes until modernisation completes

◆ PAUSE AND DECIDE

## What should the solutions architect implement?

A Weekend cutover

*The big bang the company is avoiding.*

B Two-year parallel run

*Doubles cost and effort without incremental value.*

C APIs, route switching, CDC

The strangler fig, domain by domain.

D Change freeze

*Stops the business for the length of the programme.*

THE SIGNAL

One domain at a time behind stable interfaces: the strangler fig for mainframes.

# What to carry out of this module

- **Understand first**: analysis, documentation, decomposition into domains.
- **Replatform** for speed, **refactor** to Java, **reimagine** for new architecture.
- **Prove equivalence** with generated tests on real data.
- **Managed runtime is closed** to new customers; use self-managed.
- **Augment and strangle**: CDC for data, APIs for gradual moves.

> ON THE EXAM
>
> Understand, choose how much to change, prove it, move domain by domain.

MODULE 37 · DOMAIN 4 - RESILIENCE, MIGRATION AND CONTINUITY

# Disaster Recovery Design

Match the strategy to the RTO, RPO and budget, replicate continuously where minutes matter, and fail over without depending on the Region that failed.

DOMAIN 4 of 5 EXAM WEIGHT 15% MODULE 37 of 52

admin@sthithapragna.com

# RTO, RPO and the four strategies

| STRATEGY | TYPICAL RTO AND RPO | COST |
|---|---|---|
| Backup and restore | Hours; RPO hours | Lowest |
| Pilot light | Tens of minutes; RPO seconds to minutes | Low |
| Warm standby | Minutes; RPO seconds | Medium |
| Multi-site active/active | Near zero; RPO near zero | Highest |

ON THE EXAM

Pick the cheapest strategy that meets both numbers. Never the strongest by default.

# Pilot light or warm standby?

- **Pilot light**: data live, compute off or minimal; provision on failover.
- **Warm standby**: full stack running small; scale up on failover.
- **Warm standby can take traffic immediately**, at reduced capacity.
- **Pilot light depends on launching** capacity during the event.
- **Both** replicate data continuously to keep RPO low.

> ON THE EXAM
>
> If the application must answer at once, even slowly, it needs warm standby.

# AWS Elastic Disaster Recovery

| FEATURE | DETAIL |
| --- | --- |
| Continuous replication | Block-level, seconds of RPO |
| Low-cost staging area | Small replication servers and EBS |
| Recovery instances | Launched only during drills or disasters |
| Recovery plans | Ordered steps, waits, approvals, drill mode |
| Failback | Back to the source when it recovers |
| Sources | On-premises, other clouds, AWS Regions and AZs |

ON THE EXAM

Seconds of RPO, minutes of RTO, servers of any kind, low standing cost: Elastic Disaster Recovery.

# Replicating data across Regions

| DATA | MECHANISM | FAILOVER |
|---|---|---|
| Aurora | Global Database, under a second lag | Switchover, or failover |
| DynamoDB | Global tables, multi-active | Already writable everywhere |
| S3 | Cross-Region Replication, optional RTC | Point clients at the replica |
| EBS and servers | Elastic Disaster Recovery | Launch recovery instances |
| Backups | AWS Backup cross-Region copies | Restore |

ON THE EXAM

Aurora switchover loses no data, but needs both Regions healthy. Failover accepts some loss.

# Shifting traffic: DNS or anycast?

ROUTE 53 FAILOVER

## DNS answers change

- Health checks drive failover records
- Clients follow after TTL expiry
- Some clients cache too long
- Low cost, very common

GLOBAL ACCELERATOR

## Same IPs, new destination

- Two static anycast IP addresses
- Endpoint groups per Region
- Shift in seconds, no DNS caching
- Fits allow-listed or hard-coded IPs

THE TIEBREAKER

Clients that allow-list IPs or ignore DNS TTLs: Global Accelerator.

# Application Recovery Controller

| CAPABILITY | DOES |
| --- | --- |
| Routing controls | Highly reliable on/off switches for traffic |
| Readiness checks | Confirm the standby has matching capacity |
| Zonal shift and autoshift | Move traffic away from an impaired AZ |
| Region switch plans | Orchestrate a whole multi-Region failover |

ON THE EXAM

Failover must not depend on the failed Region or a control plane: ARC, from the healthy side.

# ARC Region switch plans

- **Workflows** of steps, in sequence or parallel, per Region activated.
- **Execution blocks**: scale EC2, ECS, EKS; Aurora or DocumentDB failover; DNS; Lambda.
- **Manual approval** steps for human checkpoints.
- **Runs from the Region being activated**, not the failed one.
- **Execution reports** with timeline and measured RTO, for auditors.

ON THE EXAM

Many teams' runbooks, scripts and approvals in one validated, auditable plan: Region switch.

# Reading the scenario

| WHEN THE QUESTION SAYS | IT IS TESTING |
|---|---|
| RTO hours, lowest cost | Backup and restore |
| Must answer immediately at reduced capacity | Warm standby |
| Servers, seconds RPO, low standing cost | Elastic Disaster Recovery |
| Failover must not rely on control planes | ARC routing controls |
| Orchestrate many steps with approvals | ARC Region switch plan |
| Partners allow-list fixed IPs | Global Accelerator |

ON THE EXAM

Size the strategy to the numbers, then make failover independent of what failed.

> Meridian Freight must protect 150 on-premises Windows and Linux servers. The business requires an RPO of seconds and an RTO under one hour in AWS.
>
> The recovery site should cost as little as possible until it is needed, and the company must be able to return to its data centre afterwards.

**What should the solutions architect recommend?**

A Nightly AWS Backup of the servers to S3

B A full active/active copy of every server in AWS

C AWS Transform MGN replication, with test launches as needed

D AWS Elastic Disaster Recovery with continuous replication, recovery plans and failback

◆ PAUSE AND DECIDE

## What should the solutions architect recommend?

A Nightly backup

*RPO of a day, not seconds.*

B Active/active

*Meets the numbers at the highest cost.*

C MGN

*A migration tool; no failback to the data centre.*

D Elastic Disaster Recovery

Seconds RPO, quick launch, low standing cost, failback.

THE SIGNAL

Seconds RPO, low standing cost, failback required: Elastic Disaster Recovery.

> Meridian Freight's internal reporting system can be unavailable for up to eight hours in a regional disaster, and can lose up to 24 hours of data.
>
> Finance wants the lowest possible ongoing cost for its DR.

## Which DR strategy should the solutions architect choose?

A. Backup and restore, with daily backups copied to a second Region and infrastructure as code to rebuild

B. Pilot light with continuous database replication

C. Warm standby at 25% capacity

D. Multi-site active/active

◆ PAUSE AND DECIDE

# Which DR strategy should the solutions architect choose?

**A** Backup and restore

Meets eight hours and a day of data loss, at the lowest cost.

**B** Pilot light

*Better than required, and costs more.*

**C** Warm standby

*Far better than required, and costs more.*

**D** Active/active

*The most expensive option for a tolerant system.*

THE SIGNAL

Loose objectives and lowest cost: backup and restore.

> Meridian Freight's customer booking service must keep answering requests within five minutes of a regional failure, even at reduced capacity, and lose at most a second of data. It uses ECS and Aurora PostgreSQL.
>
> Cost matters, but availability matters more.

## Which design should the solutions architect choose?

A. Backup and restore with cross-Region snapshot copies

B. Pilot light: Aurora Global Database, with no ECS tasks in the second Region

C. Warm standby: Aurora Global Database plus a small running ECS service in the second Region, scaled up on failover

D. A single Region across three Availability Zones

◆ PAUSE AND DECIDE

## Which design should the solutions architect choose?

A Backup and restore

*Hours to recover, and loses far more than a second.*

B Pilot light

*Data is ready, but compute must be launched first.*

C Warm standby

Answers immediately at small scale; seconds of RPO.

D Single Region

*Does not survive a regional failure.*

THE SIGNAL

Answer immediately, even at reduced capacity: warm standby.

> During a past regional incident, Meridian Freight's engineers struggled to edit DNS records because the API calls they depended on were slow and failing.
>
> The company wants a highly reliable, manually triggered way to move traffic between its two Regions.

**What should the solutions architect implement?**

A. A Lambda function that rewrites the Route 53 records

B. ARC routing controls attached to Route 53 health checks on failover records

C. A runbook to edit DNS records in the console

D. Lower the DNS TTL to five seconds

◆ PAUSE AND DECIDE

## What should the solutions architect implement?

A Lambda rewrite

*Still calls the record-editing APIs that failed.*

B ARC routing controls

Flips health checks through a highly available data plane.

C Console runbook

*The same failing path, done by hand.*

D Lower TTL

*Faster propagation, but someone still has to change the record.*

THE SIGNAL

Reliable manual failover without control-plane edits: ARC routing controls.

> Failing Meridian Freight's platform over to its second Region takes 40 manual steps across six teams: scaling EKS and ECS, switching over Aurora, changing routing, and waiting for a director's approval.
>
> Auditors want evidence of each run, including the recovery time achieved.

## What should the solutions architect implement?

A. An ARC Region switch plan with execution blocks for scaling, Aurora switchover, routing and a manual approval step

B. A shared wiki runbook updated after each test

C. A Step Functions workflow running in the primary Region

D. A spreadsheet tracking each team's steps

◆ PAUSE AND DECIDE

## What should the solutions architect implement?

**A** Region switch plan

Orchestrated blocks, approval step, runs from the target Region, reports RTO.

**B** Wiki runbook

*Still 40 manual steps, and no evidence.*

**C** Step Functions in primary

*Depends on the Region that has failed.*

**D** Spreadsheet

*Tracks the problem, does not solve it.*

THE SIGNAL

Many cross-service failover steps, approvals and audit evidence: ARC Region switch.

> Meridian Freight's partner API is called by customs systems that allow-list destination IP addresses and cannot change them quickly. Some of those systems also cache DNS for hours.
>
> The API runs in two Regions and must fail over in under a minute.

**What should the solutions architect use?**

A Route 53 latency-based routing

B Route 53 failover routing with a 60-second TTL

C AWS Global Accelerator with an endpoint group in each Region

D A CloudFront distribution with two origins

◆ PAUSE AND DECIDE

## What should the solutions architect use?

A **Latency routing**
*DNS-based; caching clients would not follow.*

B **Failover with short TTL**
*Clients caching for hours ignore the TTL.*

C **Global Accelerator**
Fixed anycast IPs to allow-list; shifts in seconds, no DNS.

D **CloudFront**
*Edge IPs change; not suited to allow-listing.*

THE SIGNAL

Fixed IPs to allow-list and DNS caching clients: Global Accelerator.

# What to carry out of this module

- **Cheapest strategy that meets RTO and RPO**, not the strongest.
- **Warm standby answers immediately**; pilot light must launch first.
- **Elastic Disaster Recovery** for servers: seconds RPO, plans, failback.
- **ARC**: routing controls, readiness, zonal shift, Region switch plans.
- **Global Accelerator** when clients allow-list IPs or cache DNS.

> ON THE EXAM
>
> Size to the numbers; fail over from the healthy side.

MODULE 38 · DOMAIN 4 - RESILIENCE, MIGRATION AND CONTINUITY

# DR Testing and Chaos Engineering

Assess resilience against stated objectives, automate recovery steps, and prove them by injecting real failures under a steady-state hypothesis with stop conditions.

DOMAIN 4 of 5 EXAM WEIGHT 15% MODULE 38 of 52

admin@sthithapragna.com

A recovery plan nobody has tested is a **hypothesis**. Testing turns it into evidence.

# AWS Resilience Hub, next generation

| ELEMENT | PURPOSE |
| --- | --- |
| Resilience policy | SLOs, RTO and RPO, multi-AZ and multi-Region requirements |
| System, journeys, services | Model of the application and what users depend on |
| Dependency discovery | Finds hidden calls from VPC DNS query logs |
| Failure mode assessment | AI agents find gaps against policy and best practice |
| Recommended resilience tests | FIS experiments with pass or fail results |

ON THE EXAM

Assess against stated RTO and RPO, across accounts, with fixes and tests: Resilience Hub.

# Recovery procedures as code

- **Systems Manager Automation runbooks** encode each recovery step.
- **Predefined runbooks** exist for common actions, such as restoring a database.
- **Approval steps** pause for a person where judgement is needed.
- **Run from the recovery Region**, not the one that failed.
- **Every run is logged**, which doubles as evidence.

> ON THE EXAM
>
> Procedures that run the same way every time, with an audit trail: Automation runbooks.

# A chaos experiment

01
### Steady state
Define normal in business metrics

02
### Hypothesis
Steady state holds when X fails

03
### Inject
Run the fault with FIS

04
### Observe
Stop if alarms breach

05
### Learn
Fix gaps, rerun, automate

ON THE EXAM

The hypothesis is written in customer-visible metrics, not CPU or instance counts.

# AWS Fault Injection Service

| ELEMENT | ROLE |
| --- | --- |
| Experiment template | Actions, targets, duration, role |
| Actions | Stop instances, stress CPU, add latency, disrupt network |
| Targets | Resources selected by tag, ID or filter, with a percentage |
| Stop conditions | CloudWatch alarms that halt the experiment |
| Scenario library | Ready-made AZ power, cross-AZ, cross-Region, EKS, EBS scenarios |
| Multi-account | Run one experiment across several accounts |

ON THE EXAM

Stop conditions are what make chaos safe in production.

# Measuring recovery time

- **Start the clock** when the fault is injected, not when someone notices.
- **Route 53 health checks** record when an endpoint failed and when traffic moved.
- **CloudWatch alarms and synthetic canaries** mark when customers were served again.
- **Region switch reports** record each step's timing and the RTO achieved.
- **Compare to the policy**; a miss is a finding to fix, not a footnote.

> ON THE EXAM
>
> Measured recovery time is the time until customers are served again, not until servers start.

# Reading the scenario

| WHEN THE QUESTION SAYS | IT IS TESTING |
|---|---|
| Assess against RTO and RPO across many apps | Resilience Hub policies and assessments |
| Hidden dependencies nobody documented | Resilience Hub dependency discovery |
| Repeatable recovery steps with audit trail | SSM Automation runbooks |
| Prove it survives an AZ power loss | FIS AZ power interruption scenario |
| Stop if customers are affected | FIS stop conditions on alarms |
| What should the hypothesis measure? | Customer-facing steady-state metrics |

ON THE EXAM

**Assess, automate, then inject and measure, with a safety stop.**

> Meridian Freight's 40 critical applications across 25 accounts each have a stated RTO and RPO. Nobody knows which applications can actually meet them.
>
> The resilience team wants continuous assessment against those objectives, with specific gaps and fixes, managed from one account.

**What should the solutions architect recommend?**

A. A one-off Well-Architected review of each application

B. AWS Resilience Hub with resilience policies, failure mode assessments, and an Organizations delegated administrator

C. AWS Config rules checking Multi-AZ settings

D. A spreadsheet in which owners self-certify

◆ PAUSE AND DECIDE

## What should the solutions architect recommend?

A One-off review

*Not continuous, and not tied to each RTO and RPO.*

B Resilience Hub

Policies per objective, ongoing assessment, gaps and fixes, central.

C Config rules

*Check settings, not whether objectives can be met.*

D Self-certification

*Opinion, not assessment.*

THE SIGNAL

Objectives stated, gaps unknown, many accounts: Resilience Hub.

> Meridian Freight's tracking service is designed to survive the loss of an Availability Zone, but it has never been tested. The team wants to test it in production during business hours.
>
> If the order success rate falls below 99.5%, the test must stop immediately.

## What should the solutions architect implement?

A. Manually stop the instances in one AZ and watch dashboards

B. Delete the subnets in one AZ

C. Run a Resilience Hub assessment instead of a test

D. An FIS experiment from the AZ power interruption scenario, with a stop condition on an order success rate alarm

◆ PAUSE AND DECIDE

## What should the solutions architect implement?

A Manual stop

*Partial simulation, and no automatic stop.*

B Delete subnets

*Destructive and irreversible.*

C Assessment only

*Analysis is not a test.*

D FIS AZ power scenario

Realistic AZ failure symptoms, halted automatically by the alarm.

THE SIGNAL

Realistic AZ failure, in production, with an automatic stop: FIS scenario plus stop condition.

> Meridian Freight's team is writing the steady-state hypothesis for its first chaos experiment on the booking service.
>
> The hypothesis must show whether customers are affected.

## Which steady state should the hypothesis use?

A Average CPU utilisation stays below 70%

B The number of running instances stays constant

C Booking success rate stays above 99.9% and p99 latency below 400 ms

D No errors appear in the application logs

◆ PAUSE AND DECIDE

# Which steady state should the hypothesis use?

A CPU

*Internal; customers may suffer at low CPU.*

B Instance count

*Expected to change when a fault is injected.*

C Success rate and latency

What customers experience, measured continuously.

D No log errors

*Any real failure produces some errors; too brittle.*

THE SIGNAL

**Steady state is what customers experience: success rate and latency.**

> Meridian Freight's auditors want quarterly evidence of how long the platform takes to recover when the primary Region loses connectivity to the secondary, measured from the moment of failure.
>
> The test should exercise the real failover path, including DNS.

## What should the solutions architect design?

A. Run the FIS cross-Region connectivity scenario, and measure from injection to recovery using Route 53 health check history and canary alarms

B. Ask teams to estimate recovery time in a tabletop exercise

C. Read the Aurora replica lag metric

D. Restore last night's backup in a test account and time it

◆ PAUSE AND DECIDE

## What should the solutions architect design?

**A** FIS plus measured timeline

Real fault, real failover path, timestamps from injection to service.

**B** Tabletop estimate

*Useful practice, but not measurement.*

**C** Replica lag

*Indicates RPO, not recovery time.*

**D** Backup restore

*Tests a different path from the live failover.*

THE SIGNAL

Measured recovery time: inject a real fault, timestamp until customers are served.

> Meridian Freight's DR procedure for its claims system has 14 manual steps, including restoring an RDS snapshot, updating a Parameter Store value and restarting ECS services. Steps are often missed under pressure.
>
> The company wants the steps to run identically every time, with a record of each run.

**What should the solutions architect implement?**

A. A more detailed wiki page with screenshots

B. A Systems Manager Automation runbook encoding the steps, run from the recovery Region

C. A cron job on a server in the primary Region

D. Assign one engineer to own the procedure

◆ PAUSE AND DECIDE

## What should the solutions architect implement?

A Better wiki

*Still manual, still missed under pressure.*

B Automation runbook

Same steps every time, logged, independent of the failed Region.

C Cron in primary

*Lives in the Region that has failed.*

D One owner

*A single point of failure in people.*

THE SIGNAL

Repeatable recovery steps with a record: an Automation runbook.

> Meridian Freight's checkout path spans 12 accounts: web, payments, inventory and shared networking. The resilience team wants one experiment that injects latency into several of them at once.
>
> Each account's owners must keep control over what can be targeted in their account.

## What should the solutions architect use?

A. Twelve separate experiments started at the same moment

B. A Lambda function with cross-account admin roles that stops resources

C. A Resilience Hub assessment of each account

D. An FIS multi-account experiment from an orchestrator account, with target account configurations and roles scoped by each account

◆ PAUSE AND DECIDE

## What should the solutions architect use?

A Twelve experiments

*Hard to coordinate, and stop conditions do not span them.*

B Custom Lambda

*Broad admin roles and no built-in safety.*

C Assessments

*Analysis, not an experiment.*

D FIS multi-account

One experiment, one set of stop conditions, owner-scoped roles.

THE SIGNAL

One fault across many accounts, with owner control: FIS multi-account experiments.

# What to carry out of this module

- **Resilience Hub**: policies, dependency discovery, AI assessments, recommended tests.
- **Automation runbooks**: recovery steps as code, logged, from the healthy Region.
- **Hypothesis in customer metrics**; stop conditions on the same alarms.
- **FIS scenarios** for AZ power, cross-AZ and cross-Region failures.
- **Measure recovery** from injection until customers are served again.

> ON THE EXAM
>
> Assess, automate, inject, measure, and repeat.

MODULE 39 · DOMAIN 4 - RESILIENCE, MIGRATION AND CONTINUITY

# Resilient Architecture, Backup and Ransomware

Design systems that heal themselves, run containers across more than one cluster, govern backups centrally, and keep recovery copies out of an attacker's reach.

DOMAIN 4 of 5 EXAM WEIGHT 15% MODULE 39 of 52

admin@sthithapragna.com

# Resilience design principles

| PRINCIPLE | IN PRACTICE |
| --- | --- |
| Redundancy | At least two of everything, across AZs |
| Fault isolation | Cells, shards and accounts limit blast radius |
| Static stability | Pre-provision; do not need to launch to recover |
| Self-healing | Health checks replace what fails, automatically |
| Graceful degradation | Shed optional features, keep the core working |

ON THE EXAM

If recovery depends on launching capacity or calling a control plane during the failure, it is not statically stable.

# Self-healing building blocks

| MECHANISM | HEALS |
| --- | --- |
| Auto Scaling health checks | Replace unhealthy instances, using ELB health |
| ECS service scheduler | Restart failed tasks to the desired count |
| Kubernetes controllers | Reschedule failed pods; probes restart containers |
| Route 53 health checks | Stop sending traffic to failed endpoints |
| Aurora and RDS Multi-AZ | Automatic database failover |

ON THE EXAM

Use load balancer health checks in the Auto Scaling group, or broken-but-running instances stay in service.

# One cluster, or several?

SINGLE CLUSTER, MULTI-AZ

## Survives node and AZ loss

- Nodes and pods across AZs
- Simplest to operate
- One control plane, one config
- A bad upgrade affects everything

MULTIPLE CLUSTERS

## Survives cluster and Region loss

- Clusters in different AZ groups or Regions
- Same workloads deployed to each via GitOps
- Traffic split by Route 53 or Global Accelerator
- Upgrade one cluster at a time

THE TIEBREAKER

A cluster is itself a failure domain. Upgrades and misconfiguration can take a whole cluster down.

# Centralised backup governance

| PIECE | ROLE |
| --- | --- |
| Backup policies in Organizations | Plans, schedules and retention pushed to accounts |
| Delegated administrator | Manage backups from a non-management account |
| Tag-based resource selection | New resources protected automatically |
| Cross-account and cross-Region copy | Copies outside the source account and Region |
| Backup Audit Manager | Reports on compliance with backup controls |
| Restore testing | Scheduled restores prove backups work |

ON THE EXAM

Teams cannot opt out of a backup policy attached to their OU.

# Immutability controls

| CONTROL | PROTECTS | STRONGEST MODE |
|---|---|---|
| S3 Object Lock | Object versions in a bucket | Compliance: nobody can delete, even root |
| EBS snapshot lock | Individual EBS snapshots | Compliance, after a cooling-off period |
| Backup Vault Lock | All recovery points in a vault | Compliance: lock itself immutable |
| Logically air-gapped vault | Backups isolated from the source account | Compliance-locked, AWS-isolated |

ON THE EXAM

Governance mode can be bypassed with permission. Compliance mode cannot be bypassed by anyone.

# Logically air-gapped vaults

- **Compliance-locked** vault, isolated from the account that created the backups.
- **Shareable to a recovery account** to restore if the source is compromised.
- **Multi-party approval** restores access even if the owning account is lost.
- **Malware scanning** of recovery points with GuardDuty before restore.
- **Covers** EC2, EBS, RDS, Aurora, S3, FSx, EKS and more.

> ON THE EXAM
>
> Admin credentials stolen in the workload account: recovery copies in a locked, air-gapped vault elsewhere.

# Reading the scenario

| WHEN THE QUESTION SAYS | IT IS TESTING |
|---|---|
| Attackers may hold admin credentials | Compliance-mode locks, air-gapped vault |
| Every account backed up, no opt-out | Organizations backup policies |
| WORM records, even root cannot delete | S3 Object Lock compliance mode |
| Protect specific EBS snapshots | EBS snapshot lock |
| Is this backup clean before restoring? | Malware scanning, restore testing |
| A bad cluster upgrade took everything down | Multiple clusters |

ON THE EXAM

Ransomware answers assume the attacker is an administrator. Design for that.

> After a ransomware incident at a competitor, Meridian Freight assumes an attacker could gain administrator access to any workload account. Today, backups are stored in each workload account.
>
> Backups must survive such an attack, and recovery must remain possible even if a workload account is lost.

**What should the solutions architect recommend?**

A. Copy backups to a logically air-gapped vault, compliance-locked and shared with a recovery account, with multi-party approval configured

B. Add an IAM policy in each workload account denying backup deletion

C. Enable S3 versioning on the backup bucket

D. Take snapshots twice as often

◆ PAUSE AND DECIDE

## What should the solutions architect recommend?

**A** Air-gapped vault with MPA

Out of the attacker's reach, locked, restorable elsewhere.

**B** IAM deny

*An administrator can remove the policy.*

**C** Versioning

*Versions can be deleted by an administrator.*

**D** More snapshots

*Still in the compromised account.*

THE SIGNAL

Assume the admin is compromised: isolate, lock in compliance mode, restore elsewhere.

> Meridian Freight's 200 accounts back up inconsistently; some teams have no backups at all. Policy says every RDS database and EBS volume tagged backup=daily needs daily backups kept 35 days, plus a copy in the central backup account.
>
> Teams must not be able to remove the arrangement.

## What should the solutions architect implement?

A Ask each team to create AWS Backup plans

B Data Lifecycle Manager policies in each account

C AWS Backup policies in Organizations, attached to the OUs, with tag-based selection and cross-account copy, managed by a delegated administrator

D A Lambda function in each account taking snapshots

◆ PAUSE AND DECIDE

## What should the solutions architect implement?

A Team-created plans

*The current inconsistency, repeated.*

B DLM per account

*EBS only, not RDS, and removable by teams.*

C Organizations backup policies

Central, tag-driven, cross-account, not removable by teams.

D Lambda per account

*Custom code, and removable by account admins.*

THE SIGNAL

Every account, no opt-out, central copies: backup policies in Organizations.

> A regulator requires Meridian Freight to keep customs declaration files in S3 for seven years in write-once, read-many form.
>
> Nobody, including the root user and AWS account administrators, may delete or overwrite them during that period.

**What should the solutions architect configure?**

A. S3 Object Lock in governance mode

B. MFA Delete on a versioned bucket

C. A bucket policy denying s3:DeleteObject

D. S3 Object Lock in compliance mode with a seven-year default retention

◆ PAUSE AND DECIDE

## What should the solutions architect configure?

A Governance mode

*Users with bypass permission can delete.*

B MFA Delete

*The root user with MFA can still delete.*

C Bucket policy

*An administrator can change the policy.*

D Compliance mode

No one can delete or shorten retention, root included.

THE SIGNAL

Even root cannot delete: Object Lock compliance mode.

> During an active security incident, Meridian Freight's responders want to make sure the latest EBS snapshots of its core database servers cannot be deleted for the next 30 days.
>
> The snapshots are not managed by AWS Backup, and protection should apply to those specific snapshots.

## What should the solutions architect do?

A Copy the snapshots to S3 Glacier

B Apply EBS snapshot lock in compliance mode with a 30-day duration to those snapshots

C Tag the snapshots do-not-delete

D Turn on Recycle Bin with a one-day retention

◆ PAUSE AND DECIDE

## What should the solutions architect do?

A Copy to Glacier

*Snapshots cannot simply be copied to your own Glacier storage.*

B EBS snapshot lock

Per-snapshot, compliance mode, fixed duration.

C Tag

*A label, not a control.*

D Recycle Bin, one day

*Recovers deleted snapshots briefly; does not prevent deletion.*

THE SIGNAL

Lock specific EBS snapshots, outside AWS Backup: EBS snapshot lock.

> Meridian Freight is about to restore servers from AWS Backup after a ransomware attack. The team suspects some recent recovery points may already contain the malware.
>
> They want to identify clean recovery points before restoring into production.

## What should the solutions architect recommend?

A. Restore the newest recovery point and scan it in production

B. Restore the oldest recovery point available

C. Scan recovery points with GuardDuty Malware Protection for AWS Backup, and restore the newest clean one into an isolated environment first

D. Ask application owners which date to restore from

◆ PAUSE AND DECIDE

## What should the solutions architect recommend?

A Newest, in production

*May reinfect production.*

B Oldest

*Probably clean, but loses far more data than needed.*

C Scan, then isolated restore

Newest clean point, verified before production.

D Ask owners

*A guess, not evidence.*

THE SIGNAL

Find the newest clean point by scanning, and restore it somewhere isolated first.

A faulty add-on upgrade on Meridian Freight's single production EKS cluster took every service offline for three hours, although all three AZs were healthy.

The platform team wants to prevent one cluster problem from taking down production again, and also survive a Regional outage.

## What should the solutions architect recommend?

A. Run production on two EKS clusters in different Regions, deployed identically through GitOps, with traffic shared by Global Accelerator, and upgrade one cluster at a time

B. Add more node groups to the existing cluster

C. Spread the existing cluster across more Availability Zones

D. Disable cluster add-on upgrades permanently

◆ PAUSE AND DECIDE

## What should the solutions architect recommend?

**A** Two clusters, two Regions

A cluster or Region failure leaves the other serving.

**B** More node groups

*Still one cluster, one failure domain.*

**C** More AZs

*The AZs were healthy; the cluster was the problem.*

**D** No upgrades

*Swaps an outage for a security risk.*

THE SIGNAL

The cluster failed while the AZs were fine: the cluster is a failure domain. Run more than one.

# What to carry out of this module

- **Redundant, isolated, statically stable, self-healing** designs.
- **Clusters are failure domains**; run more than one for critical services.
- **Backup policies in Organizations** with a delegated administrator.
- **Compliance-mode locks**: Object Lock, snapshot lock, Vault Lock.
- **Air-gapped vaults, MPA, malware scans** for ransomware recovery.

> ON THE EXAM
>
> Assume the administrator is compromised, and design recovery so it still works.

MODULE 40 · DOMAIN 5 - OPERATIONAL EXCELLENCE AND AUTOMATION

# Infrastructure as Code

Choose declarative or imperative authoring, keep secrets out of templates, protect what must survive, and deploy the same stack to many accounts and Regions.

DOMAIN 5 of 5 EXAM WEIGHT 20% MODULE 40 of 52

admin@sthithapragna.com

# Declarative or imperative?

DECLARATIVE

## Describe the end state

- CloudFormation templates in YAML or JSON
- Engine works out the changes
- Change sets preview each update
- Easy to review, harder to abstract

IMPERATIVE

## Write code that builds it

- AWS CDK in TypeScript, Python, Java and more
- Loops, types, tests, reusable constructs
- Synthesises to CloudFormation
- SDK scripts alone keep no state

THE TIEBREAKER

The CDK is imperative to write but declarative to deploy, because it produces CloudFormation.

# CDK construct levels

| LEVEL | WHAT IT IS | EXAMPLE |
|---|---|---|
| L1 | One-to-one with a CloudFormation resource | CfnBucket |
| L2 | Sensible defaults and helper methods | Bucket with grantRead() |
| L3 patterns | Several resources wired together | An ALB-fronted Fargate service |
| Your constructs | Company standards packaged once | A compliant bucket with logging |

ON THE EXAM

Company-wide standards shipped as a construct library, reused by every team.

# Safe CloudFormation operations

- **Change sets** preview creates, modifications and replacements.
- **Drift detection** finds changes made outside IaC.
- **Drift-aware change sets** revert drift, previewed, since November 2025.
- **IaC generator and resource import** adopt existing resources.
- **Rollback** returns the stack to its last good state on failure.

> ON THE EXAM
>
> A change set that shows Replacement for a database is a warning, not a detail.

# Protecting resources that must survive

| CONTROL | PREVENTS |
| --- | --- |
| `DeletionPolicy: Retain or Snapshot` | Data lost when a resource leaves the stack |
| `UpdateReplacePolicy` | Data lost when an update replaces a resource |
| `Stack policy` | Updates to named resources unless overridden |
| `Termination protection` | Deleting the whole stack by mistake |

> ON THE EXAM
>
> Production databases: Snapshot or Retain on both policies, plus a stack policy.

# Secrets in infrastructure code

| APPROACH | VERDICT |
| --- | --- |
| Password in template or parameter file | Never: stored in source control |
| NoEcho parameter | Hidden in console, still supplied as plain text |
| Dynamic reference to Secrets Manager | Resolved at deploy time, never stored |
| SSM SecureString dynamic reference | For supported properties and simple values |
| RDS ManageMasterUserPassword | Database generates and rotates its own secret |

ON THE EXAM

No human should ever see the database password: let RDS manage it in Secrets Manager.

# StackSets permission models

SELF-MANAGED

## You create the roles

- Administration and execution roles per account
- List target accounts explicitly
- Works without Organizations
- New accounts added by hand

SERVICE-MANAGED

## Organizations does it

- Target OUs, not account lists
- Roles created automatically
- Automatic deployment to new accounts
- Delegated administrator supported

THE TIEBREAKER

Every account in an OU, including new ones, with no manual steps: service-managed with auto-deployment.

# Reading the scenario

| WHEN THE QUESTION SAYS | IT IS TESTING |
| --- | --- |
| Loops, types, reusable components | AWS CDK |
| Password must never be seen or stored | ManageMasterUserPassword, dynamic references |
| Every account in an OU, including new ones | Service-managed StackSets, auto-deployment |
| Console changes should be reverted | Drift-aware change sets |
| Existing resources into IaC, no recreation | IaC generator and resource import |
| Database must survive template mistakes | Deletion and replace policies, stack policy |

ON THE EXAM

Code the infrastructure, keep secrets out, protect the data, and scale by OU.

> Meridian Freight's platform team maintains 40 near-identical CloudFormation templates for regional depots, edited by copy and paste. They want loops, type checking, unit tests and a shared library of company components.
>
> Security reviewers still want to review the deployed CloudFormation.

**What should the solutions architect recommend?**

A Keep YAML templates and add more nested stacks

B Use the AWS CDK with a shared construct library, reviewing the synthesised templates

C Write Python scripts that call the AWS SDK directly

D Create resources in the console and document them

◆ PAUSE AND DECIDE

# What should the solutions architect recommend?

A More nested stacks

*Helps reuse, but still no loops, types or unit tests.*

B CDK with constructs

Programming features, shared components, and CloudFormation output.

C SDK scripts

*No state, no change sets, no rollback.*

D Console

*Not infrastructure as code at all.*

THE SIGNAL

Programming features with reviewable CloudFormation: the CDK.

> Meridian Freight's CloudFormation template creates an Aurora cluster. Today the master password is passed as a NoEcho parameter from a file in the pipeline.
>
> Auditors require that no person or file ever holds the password, and that it rotates automatically.

## What should the solutions architect change?

A Encrypt the parameter file with KMS

B Store the password as a plain Parameter Store String

C Hard-code the password in the template and restrict repository access

D Set ManageMasterUserPassword so Aurora generates and rotates the password in Secrets Manager

◆ PAUSE AND DECIDE

## What should the solutions architect change?

A Encrypted file

*A file still holds the password, and it does not rotate.*

B Plain String parameter

*Stored unencrypted, and still set by a person.*

C Hard-coded

*The worst place for a secret.*

D Managed master password

Generated and rotated by the service; nobody sees it.

THE SIGNAL

No person or file holds the secret, and it rotates: let the database manage it.

> Every account in Meridian Freight's Workloads OU needs a standard set of IAM roles, CloudWatch alarms and an SNS topic, in four Regions.
>
> New accounts are added weekly and must receive the baseline automatically; accounts that leave the OU should have it removed.

**What should the solutions architect implement?**

A. A CloudFormation StackSet with service-managed permissions targeting the OU, with automatic deployment enabled, in four Regions

B. A pipeline that deploys a stack into each account in turn

C. A self-managed StackSet with a list of account IDs

D. A CDK app run manually by each account owner

◆ PAUSE AND DECIDE

## What should the solutions architect implement?

**A** Service-managed StackSet

Targets the OU; deploys to joiners and removes from leavers.

**B** Pipeline per account

*Needs updating every week as accounts change.*

**C** Self-managed list

*New accounts must be added by hand.*

**D** Run by each owner

*Inconsistent and easily skipped.*

THE SIGNAL

Every account in an OU, automatically, joiners and leavers: service-managed StackSets.

> An engineer changed a production security group in the console during an incident, and a load balancer listener was deleted by hand. Both resources belong to a CloudFormation stack.
>
> The team wants the next deployment to restore the template's configuration, with a preview of what will change first.

**What should the solutions architect use?**

A Delete and recreate the stack

B A standard change set with an unchanged template

C A drift-aware change set, previewed and then executed

D Fix both resources by hand in the console

◆ PAUSE AND DECIDE

## What should the solutions architect use?

A Recreate the stack

*Disruptive, and risks data in other resources.*

B Standard change set

*Compares templates only; sees no difference, changes nothing.*

C Drift-aware change set

Compares template with actual state; restores and recreates.

D Manual fix

*More console changes, no preview, no record.*

THE SIGNAL

Revert out-of-band changes through IaC, with a preview: drift-aware change sets.

> Meridian Freight's analytics account holds about 200 resources created by hand over several years, including S3 buckets, IAM roles and Glue jobs. They must come under CloudFormation management.
>
> No resource may be deleted or recreated in the process.

## What should the solutions architect use?

A Write new templates and deploy them alongside the old resources

B The CloudFormation IaC generator to produce templates, then import the resources into stacks

C Delete the resources and redeploy them from new templates

D Tag the resources as managed

◆ PAUSE AND DECIDE

## What should the solutions architect use?

A New templates alongside
*Creates duplicates; the originals stay unmanaged.*

B IaC generator and import
Templates from what exists, adopted without recreation.

C Delete and redeploy
*Explicitly ruled out, and loses data.*

D Tags
*Labels, not management.*

THE SIGNAL

Bring existing resources under IaC without touching them: IaC generator and resource import.

> A Meridian Freight developer renamed a property in a template, which caused CloudFormation to replace the production RDS database. Data was lost.
>
> The team wants to make sure stack changes can never silently destroy the production database or its data.

**What should the solutions architect configure?**

A Enable termination protection only

B Move the database out of CloudFormation entirely

C Add a CloudWatch alarm on database connections

D Snapshot as both DeletionPolicy and UpdateReplacePolicy, a stack policy denying replacement of the database, and change set review

◆ PAUSE AND DECIDE

## What should the solutions architect configure?

A Termination protection

*Stops stack deletion, not resource replacement in an update.*

B Remove from IaC

*Gives up the benefits of IaC.*

C Connection alarm

*Reports the loss after it happens.*

D Policies plus review

Blocks replacement, keeps a snapshot, and surfaces it in previews.

THE SIGNAL

Replacement during an update is blocked by a stack policy, and caught by UpdateReplacePolicy.

# What to carry out of this module

- **CDK** for programming features, synthesising reviewable CloudFormation.
- **No secrets in templates**: managed passwords and dynamic references.
- **Protect data**: Deletion and UpdateReplace policies, stack policies.
- **Drift-aware change sets** revert; IaC generator and import adopt.
- **Service-managed StackSets** follow the OU, joiners and leavers.

> ON THE EXAM
>
> Code it, keep secrets out, protect the data, preview every change, scale by OU.

MODULE 41 · DOMAIN 5 - OPERATIONAL EXCELLENCE AND AUTOMATION

# Policy as Code and Drift Remediation

Check infrastructure against rules at every stage, from the developer's laptop to running resources, and put it right automatically when it drifts.

DOMAIN 5 of 5 EXAM WEIGHT 20% MODULE 41 of 52

admin@sthithapragna.com

Catch a violation as **early** as possible, block it where it cannot be bypassed, and **detect and fix** anything that slips through.

# Where each tool acts

| MOMENT | TOOL | EFFECT |
|---|---|---|
| Synthesis | CDK aspects, cdk-nag | Fix or flag constructs in code |
| Pipeline | cfn-guard, cfn-lint, policy checks | Fail the build |
| Deployment | CloudFormation Hooks | Warn or block before provisioning |
| Any API call | SCPs, RCPs, declarative policies | Deny regardless of tool |
| After creation | AWS Config rules | Detect, then remediate |

ON THE EXAM

Hooks cover CloudFormation and Cloud Control API. Console and CLI changes need SCPs or Config.

# CDK aspects

- **Visit every construct** in an app before it is synthesised.
- **Fix**: set encryption, tags or removal policies automatically.
- **Flag**: add errors or warnings that stop synthesis.
- **cdk-nag** packages rule packs as aspects.
- **Only CDK apps**: other templates need other checks.

> ON THE EXAM
>
> Enforce or correct a standard across every construct in every CDK app: an aspect.

# CloudFormation Hooks

| TYPE | RULE WRITTEN IN | FITS |
|---|---|---|
| Guard Hook | Guard policy language | Declarative property rules |
| Lambda Hook | Your Lambda code | Lookups and complex logic |
| Proactive control Hook | Control Tower Control Catalog | AWS-managed standard rules |
| Stack-level Hook | Whole template | Rules across resources |

ON THE EXAM

Start in warn mode, read the results, then switch to fail.

# Detect and remediate with AWS Config

| PIECE | ROLE |
| --- | --- |
| Managed and custom rules | Evaluate every resource, whatever created it |
| Proactive evaluation mode | Check a resource definition before creation |
| Automatic remediation | Run an SSM Automation runbook to fix |
| Conformance packs | Rules and remediations deployed together |
| Aggregator | Compliance across accounts and Regions |

ON THE EXAM

Resources created any way at all, found and fixed: Config rules with remediation.

# Two kinds of drift

DRIFT FROM THE TEMPLATE

## Stack resources changed by hand

- CloudFormation drift detection
- Drift-aware change sets revert it
- The template is the truth
- Previewed before applied

DRIFT FROM POLICY

## Any resource breaking a rule

- Config rules detect it
- Remediation runbooks fix it
- The rule is the truth
- Covers resources outside stacks

THE TIEBREAKER

A stack resource changed in the console: drift-aware change set. Any resource breaking a rule: Config remediation.

# Reading the scenario

| WHEN THE QUESTION SAYS | IT IS TESTING |
|---|---|
| Fix every CDK construct automatically | CDK aspect |
| Block bad resources before provisioning | CloudFormation Guard Hook |
| Rule needs a lookup or custom logic | Lambda Hook |
| Created by hand, found and fixed | Config rule with remediation |
| Roll out a new rule without breaking teams | Hook in warn mode first |
| Deny regardless of tool used | SCP, RCP or declarative policy |

ON THE EXAM

Earliest friendly check, unbypassable block, and detection with fix.

Meridian Freight's 30 teams build infrastructure with the AWS CDK. Security requires every S3 bucket to have encryption, versioning and access logging.

The platform team wants this applied automatically in every app, before templates are produced, without each team writing it.

**What should the solutions architect implement?**

A. An SCP denying s3:CreateBucket without encryption headers

B. An AWS Config rule for bucket settings

C. A CDK aspect in a shared library that sets these properties on every bucket construct

D. A code review checklist

◆ PAUSE AND DECIDE

## What should the solutions architect implement?

A SCP

*Blocks at the API, but does not apply settings, and covers one of three.*

B Config rule

*Acts after deployment, not before templates exist.*

C CDK aspect

Applies the settings to every bucket at synthesis, automatically.

D Checklist

*Manual and inconsistent.*

THE SIGNAL

Applied automatically in CDK apps before synthesis: an aspect.

> Some Meridian Freight teams use CloudFormation directly and others use Terraform with the AWS Cloud Control provider. Security wants any RDS instance without storage encryption rejected before it is provisioned, in all accounts.
>
> The rule is a simple check of resource properties.

**What should the solutions architect implement?**

A. A CloudFormation Guard Hook in fail mode, deployed to all accounts

B. A CDK aspect

C. An AWS Config rule with remediation

D. A monthly compliance report

◆ PAUSE AND DECIDE

## What should the solutions architect implement?

**A** Guard Hook, fail mode

Blocks before provisioning, for CloudFormation and Cloud Control API.

**B** CDK aspect

*These teams do not use the CDK.*

**C** Config remediation

*Acts after the instance exists; encryption cannot be added in place.*

**D** Monthly report

*Too late, and not enforcement.*

THE SIGNAL

Block before provisioning, CloudFormation and Cloud Control users alike: a Guard Hook.

> Meridian Freight only allows EC2 instances launched from AMIs in its approved catalogue, a DynamoDB table updated daily by the image team.
>
> Stacks that reference any other AMI must be stopped before resources are created.

**What should the solutions architect implement?**

A. A Guard Hook with the AMI IDs written into the rule

B. An SCP listing allowed AMI IDs

C. A CDK aspect

D. A Lambda Hook that checks each AMI ID against the catalogue table

◆ PAUSE AND DECIDE

# What should the solutions architect implement?

A Guard with fixed IDs

*Out of date the day after each catalogue change.*

B SCP with ID list

*Edited daily, and policy size limits bite.*

C CDK aspect

*Only for CDK apps, and still needs the lookup.*

D Lambda Hook

Code can query the live catalogue at deployment time.

THE SIGNAL

A rule that needs a live lookup: Lambda Hook.

> An audit found security groups allowing SSH from the internet in several Meridian Freight accounts, created by hand in the console over the years. Hooks did not catch them.
>
> Security wants all such rules found across accounts, and removed automatically.

**What should the solutions architect implement?**

A. A stricter CloudFormation Hook

B. An AWS Config rule for unrestricted SSH, with automatic remediation through an SSM Automation runbook, deployed organisation-wide

C. A drift-aware change set on every stack

D. A CDK aspect

◆ PAUSE AND DECIDE

## What should the solutions architect implement?

A Stricter Hook

*Hooks never see console changes.*

B Config with remediation

Finds every such rule, however created, and removes it.

C Drift-aware change sets

*Only for stack resources; these were made by hand.*

D CDK aspect

*Only affects CDK apps.*

THE SIGNAL

Created outside IaC, found and fixed: Config rules with remediation.

> Meridian Freight's security team has written 25 new Guard rules. Nobody knows how many existing deployments would fail them.
>
> The team wants to enforce the rules without suddenly breaking dozens of pipelines.

**How should the solutions architect roll out the Hooks?**

A Activate all 25 in fail mode immediately

B Ask teams to run the rules locally first

C Activate the Hooks in warn mode, review invocation results and annotations, help teams fix findings, then switch to fail mode

D Apply the rules only to new accounts

◆ PAUSE AND DECIDE

## How should the solutions architect roll out the Hooks?

A Fail immediately

*Breaks many pipelines at once.*

B Local runs

*Voluntary; no central picture.*

C Warn, review, then fail

Measures impact safely, then enforces.

D New accounts only

*Leaves existing risk unaddressed.*

THE SIGNAL

New enforcement rules: warn mode first, results reviewed, then fail.

> Meridian Freight must guarantee that nobody can turn off S3 Block Public Access at account level or delete CloudTrail trails, whether they use CloudFormation, Terraform, the CLI or the console.
>
> The guarantee must hold in every member account.

**Which policy-as-code layer should the solutions architect use?**

A. An SCP denying s3:PutAccountPublicAccessBlock and cloudtrail:DeleteTrail, with a break-glass exception

B. A CloudFormation Hook

C. A CDK aspect

D. A Config rule with remediation

◆ PAUSE AND DECIDE

# Which policy-as-code layer should the solutions architect use?

**A** SCP

Denies the API call itself, whatever tool makes it.

**B** Hook

*Misses the CLI and console.*

**C** Aspect

*Only CDK apps.*

**D** Config remediation

*Repairs after the fact; a window exists.*

THE SIGNAL

Guarantee across every tool: deny at the API with an organisation policy.

# What to carry out of this module

- **Layers**: aspects, pipeline checks, Hooks, organisation policies, Config.
- **Guard Hooks** for property rules; **Lambda Hooks** for lookups.
- **Hooks miss console and CLI**; SCPs and Config cover them.
- **Warn mode first**, then fail, for new rules.
- **Template drift**: drift-aware change sets. **Policy drift**: Config remediation.

> ON THE EXAM
>
> Earliest friendly check, unbypassable block, detection and repair.

MODULE 42 · DOMAIN 5 - OPERATIONAL EXCELLENCE AND AUTOMATION

# CI/CD Pipeline Design

Build once, promote the same artefact through every account, and let the pipeline itself decide when a release may enter or leave a stage.

DOMAIN 5 of 5 EXAM WEIGHT 20% MODULE 42 of 52

admin@sthithapragna.com

One pipeline in a **tooling account** builds an artefact **once**, then assumes a role in each target account to deploy that same artefact.

# The developer tools

| SERVICE | JOB | EXAM NOTE |
|---|---|---|
| CodeCommit | Managed Git | Back to full GA for new customers, Nov 2025 |
| CodeConnections | Link GitHub, GitLab, Bitbucket | Source and triggers |
| CodeBuild | Build and test | Also runs pipeline rules |
| CodeDeploy | Deploy to EC2, Lambda, ECS | Traffic shifting, alarm rollback |
| CodePipeline V2 | Orchestrate stages | Triggers, variables, conditions |

ON THE EXAM

CodeCommit is open to new customers again. Older material saying otherwise is out of date.

# Cross-account deployment

01
### Tooling account
Pipeline and artefact bucket

02
### Customer managed key
Key policy allows target accounts

03
### Assume deploy role
Role in each target account

04
### Deploy
CloudFormation, CodeDeploy or ECS

ON THE EXAM

The AWS managed S3 key cannot be shared across accounts. Use a customer managed KMS key.

# CodePipeline V2 controls

| FEATURE | WHAT IT DOES |
| --- | --- |
| Trigger filters | Start on branch, file path, tag or pull request |
| Variables | Pass values at start and between actions |
| Execution mode | Superseded, queued or parallel |
| Entry condition | Gate a stage before it starts |
| On-success, on-failure | Roll back, fail, retry or skip |
| Rules | CloudWatch alarm, deploy window, Lambda, commands |

ON THE EXAM

Stage rollback is not available in parallel execution mode.

# Build once or build per environment?

BUILD ONCE, PROMOTE

## Same artefact everywhere

- Image digest or package version
- What was tested is what ships
- Config from Parameter Store
- One pipeline, many stages

BUILD PER ENVIRONMENT

## Rebuild for each stage

- Dependencies may differ
- Prod runs untested bits
- Config baked into builds
- Often one pipeline per account

THE TIEBREAKER

Production must run exactly what was tested: build once and promote the artefact.

# Reading the scenario

| WHEN THE QUESTION SAYS | IT IS TESTING |
|---|---|
| Access denied reading artefacts in target account | Customer managed KMS key and policies |
| Monorepo, run only the affected service | Trigger file path filters |
| Only during the change window | Deployment window rule |
| Alarm after release, return to last good | On-success condition, rollback |
| What was tested differs from prod | Build once, promote |
| Rapid commits, deploy only the latest | Superseded execution mode |

ON THE EXAM

Find the word that names the failure, then the pipeline feature that removes it.

> Tallis Insurance runs CodePipeline in a tooling account. The artefact bucket uses default SSE-KMS with the AWS managed key.
>
> A new CloudFormation deploy action into the production account fails with access denied when reading the artefact.

**What should the solutions architect do?**

A. Make the artefact bucket readable by the production account without encryption

B. Re-encrypt with a customer managed KMS key whose key policy, and the bucket policy, allow the production deployment role

C. Add a grant for the production account on the AWS managed key

D. Copy artefacts to a bucket in the production account by hand

◆ PAUSE AND DECIDE

## What should the solutions architect do?

A **Remove encryption**

*Weakens security and is not needed.*

B **Customer managed key**

Its policy can allow another account; bucket policy grants read.

C **Grant on AWS managed key**

*AWS managed key policies cannot be changed for other accounts.*

D **Manual copy**

*Breaks automation.*

THE SIGNAL

Cross-account artefacts: customer managed KMS key shared through its key policy.

> Tallis Insurance keeps six microservices in one GitHub monorepo, each in its own folder with its own pipeline. Every push currently starts all six pipelines.
>
> The team wants each pipeline to start only when its own folder changes.

**What should the solutions architect configure?**

A Split the monorepo into six repositories

B A Lambda function that inspects each webhook and starts the right pipeline

C Polling every five minutes

D V2 pipeline triggers with file path include filters for each service folder

◆ PAUSE AND DECIDE

## What should the solutions architect configure?

A Split repo

*Large change to the team's workflow.*

B Lambda dispatcher

*Custom code for a built-in feature.*

C Polling

*Still starts on any change, and slower.*

D Path filters

Native trigger filtering per folder.

THE SIGNAL

Monorepo, start only the affected pipeline: trigger file path filters.

> Tallis Insurance policy allows production deployments only between 09:00 and 17:00, Tuesday to Thursday. Pipelines currently run at any hour.
>
> Releases that arrive outside the window should wait automatically, without an engineer approving each one.

**What should the solutions architect implement?**

A. An entry condition on the production stage with a deployment window rule

B. A manual approval action before production

C. EventBridge schedules that disable and enable the stage transition

D. A change freeze announced by email

◆ PAUSE AND DECIDE

## What should the solutions architect implement?

A **Deployment window rule**
The stage waits until the window opens.

B **Manual approval**
*Needs a person for each release.*

C **Scheduled transitions**
*Works, but is custom scheduling glue.*

D **Email freeze**
*Not enforced.*

THE SIGNAL

Deploy only in a time window, without people: entry condition with a window rule.

> Tallis Insurance deploys a CloudFormation stack in its production stage. Twice, a release passed tests but raised the error rate alarm within 20 minutes.
>
> Each time, engineers spent an hour redeploying the previous version. The pipeline should do this automatically.

**What should the solutions architect configure?**

A Switch the pipeline to parallel execution mode

B A runbook for the on-call engineer

C An on-success condition on the production stage with a CloudWatch alarm rule and a rollback result

D Longer integration tests

◆ PAUSE AND DECIDE

## What should the solutions architect configure?

A Parallel mode

*Stage rollback is not available in parallel mode.*

B Runbook

*Still manual.*

C On-success alarm rule, rollback

Watches the alarm, then redeploys the last good run.

D Longer tests

*Helpful, but these faults appear only in production.*

THE SIGNAL

Alarm after a stage, return to the last good release: on-success condition with rollback.

> Tallis Insurance has one pipeline per environment account. Each builds a container image from the main branch. A production incident was traced to a library version that differed from the one tested in staging.
>
> The team wants production to run exactly what passed staging.

**What should the solutions architect recommend?**

A Pin more library versions

B Run tests again in the production pipeline

C Rebuild production only on weekends

D One pipeline in a tooling account that builds the image once and promotes the same digest to each account

◆ PAUSE AND DECIDE

## What should the solutions architect recommend?

A Pin versions

*Reduces drift but still rebuilds.*

B Retest in production

*Tests a different build again.*

C Weekend rebuilds

*Changes timing, not the cause.*

D Build once, promote digest

The tested artefact is the shipped artefact.

THE SIGNAL

Production must match what was tested: build once and promote by digest.

> A new Tallis Insurance subsidiary, with a brand new AWS account, needs Git hosting that stays inside AWS, uses IAM for access, and needs no third-party contract.
>
> An engineer says CodeCommit is closed to new customers, so they must use GitHub.

**What should the solutions architect recommend?**

A GitHub through CodeConnections

B AWS CodeCommit, which is generally available to new customers again

C Git repositories on an EC2 instance

D Store source in S3 as zip files

◆ PAUSE AND DECIDE

## What should the solutions architect recommend?

A GitHub

*Third party; fails the stated requirement.*

B CodeCommit

Managed, IAM-based, and open to new accounts since Nov 2025.

C Git on EC2

*Self-managed undifferentiated work.*

D S3 zips

*Not version control.*

THE SIGNAL

AWS-native managed Git with IAM: CodeCommit, open to new customers again.

# What to carry out of this module

- **Tooling account** pipeline, deploy roles in target accounts.
- **Customer managed KMS key** for cross-account artefacts.
- **Build once, promote** the same artefact by digest or version.
- **V2 controls**: path filters, window rules, alarm rollback.
- **CodeCommit** is open to new customers again.

> ON THE EXAM
>
> Where the pipeline lives, how it reaches accounts, what gates a release.

MODULE 43 · DOMAIN 5 - OPERATIONAL EXCELLENCE AND AUTOMATION

# DevSecOps: Pipeline Security and AI Evaluation

Scan code, dependencies and images, sign what you build, verify signatures before it runs, and gate AI releases on measured quality.

DOMAIN 5 of 5 EXAM WEIGHT 20% MODULE 43 of 52

admin@sthithapragna.com

Every stage **measures** something and can stop the release: vulnerabilities, provenance, or **model quality**.

# Security checks along the pipeline

| STAGE | CHECK | SERVICE |
|---|---|---|
| Pull request | SAST, SCA, IaC | Inspector code security |
| Build | SBOM and CVE scan | Inspector SBOM generator, ScanSbom API |
| Registry | Continuous image scanning | ECR enhanced scanning |
| Publish | Sign the artefact | AWS Signer, ECR managed signing |
| Run | Verify signature | Admission controller, Lambda code signing |

ON THE EXAM

Inspector code security scans GitHub and GitLab repositories, GA June 2025.

# ECR basic or enhanced scanning?

BASIC SCANNING

## Operating system packages

- On push or on demand
- OS packages only
- No rescans as new CVEs appear
- No extra charge

ENHANCED SCANNING

## Amazon Inspector

- Continuous rescanning
- OS and language packages
- New CVEs found in old images
- Findings in Inspector and Security Hub

THE TIEBREAKER

Language libraries, or a CVE published after the push: enhanced scanning.

# Sign and verify

01

## Signing profile

AWS Signer holds keys and certificates

02

## Sign on push

ECR managed signing rule

03

## Verify at admission

Notation with Kyverno or Ratify on EKS

04

## Lambda

Code signing config, enforce mode

ON THE EXAM

Scanning says an artefact is safe; signing says it came from your pipeline.

# Amazon Bedrock Evaluations

| EVALUATION | MEASURES |
|---|---|
| Programmatic | Exact match, F1, BERT score |
| LLM as a judge | Correctness, completeness, harmfulness |
| Human | Your team or an AWS-managed team |
| RAG, retrieve only | Context relevance and coverage |
| RAG, retrieve and generate | Faithfulness, correctness |
| Bring your own responses | Models hosted anywhere |

ON THE EXAM

Compare jobs side by side to decide whether a candidate beats the current model.

# AI evaluation as a pipeline gate

01
### Change
New model, prompt or knowledge base

02
### Evaluate
Same test set, same metrics

03
### Compare
Candidate against baseline

04
### Promote or stop
Threshold decides

ON THE EXAM

Treat a prompt or model change like code: test it against a fixed set before release.

# Reading the scenario

| WHEN THE QUESTION SAYS | IT IS TESTING |
|---|---|
| New CVE in an old image, language libraries | ECR enhanced scanning |
| Fail the build before the image is pushed | Inspector SBOM scan in CodeBuild |
| Findings on developers' pull requests | Inspector code security |
| Only run images built by our pipeline | Signing plus admission verification |
| Is the new model or prompt as good? | Bedrock Evaluations against baseline |
| Model hosted outside Bedrock | Bring your own inference responses |

ON THE EXAM

Scan for safety, sign for provenance, evaluate for quality.

> Fenwick Health stores 400 container images in Amazon ECR, mostly Python and Java services. Basic scanning runs on push.
>
> Security discovered that a critical library vulnerability published last month was never reported for images pushed earlier.

**What should the solutions architect change?**

A Rescan every image manually each week

B Enable Amazon GuardDuty Runtime Monitoring

C Turn on ECR enhanced scanning with continuous scanning

D Rebuild all images every night

◆ PAUSE AND DECIDE

## What should the solutions architect change?

A Manual weekly rescans

*Basic scanning still misses language libraries.*

B GuardDuty Runtime

*Detects threats at runtime, not package CVEs.*

C Enhanced, continuous

Covers language packages and rescans as CVEs appear.

D Nightly rebuilds

*Costly, and still does not report findings.*

THE SIGNAL

Language libraries and newly published CVEs: ECR enhanced scanning.

> Fenwick Health wants images with critical vulnerabilities stopped in the CodeBuild stage, before they ever reach ECR.
>
> The check must use the same vulnerability data that Inspector uses for running workloads.

**What should the solutions architect implement?**

A. In CodeBuild, generate an SBOM with the Inspector SBOM generator, scan it with the Inspector ScanSbom API, and fail on critical findings

B. Rely on ECR enhanced scanning after push

C. Enable Amazon Macie on the artefact bucket

D. A Security Hub CSPM control

◆ PAUSE AND DECIDE

## What should the solutions architect implement?

**A** SBOM scan in CodeBuild

Checks before push, with Inspector's data, and fails the build.

**B** Enhanced scanning

*Runs after the image is in ECR.*

**C** Macie

*Finds sensitive data, not CVEs.*

**D** Security Hub CSPM

*Checks configuration, not image contents.*

THE SIGNAL

Stop it before the registry, with Inspector's data: SBOM scan in the build.

> Fenwick Health developers use GitHub. Security wants code flaws, vulnerable dependencies and Terraform misconfigurations reported on each repository, so developers see them before merging.
>
> Security also wants an organisation-wide view of the findings.

**Which service should the solutions architect use?**

A AWS Config with conformance packs

B Amazon GuardDuty

C ECR enhanced scanning

D Amazon Inspector code security, integrated with GitHub

◆ PAUSE AND DECIDE

## Which service should the solutions architect use?

A **Config**
*Evaluates deployed resources, not source code.*

B **GuardDuty**
*Threat detection, not code analysis.*

C **ECR scanning**
*Images only, after build.*

D **Inspector code security**
SAST, SCA and IaC scans in GitHub, central findings.

THE SIGNAL

Code, dependencies and IaC, in the repository: Inspector code security.

> Fenwick Health's EKS clusters must run only container images built and pushed by its own pipeline. An engineer recently deployed an image pulled straight from a public registry.
>
> Security wants a cryptographic guarantee, with signing keys managed by AWS.

**What should the solutions architect implement?**

A ECR tag immutability

B ECR managed signing with an AWS Signer profile, and an admission controller on EKS that verifies signatures with Notation

C ECR enhanced scanning

D An IAM policy limiting who can push to ECR

◆ PAUSE AND DECIDE

## What should the solutions architect implement?

A Tag immutability
*Stops tags being overwritten, not foreign images.*

B Sign and verify
Unsigned images are refused at admission.

C Enhanced scanning
*Finds CVEs, not provenance.*

D Push permissions
*Images from other registries bypass ECR entirely.*

THE SIGNAL

Only our images may run, cryptographically: sign on push, verify at admission.

> Fenwick Health runs a clinical guidance assistant on a Bedrock knowledge base. Teams change prompts, models and documents every few weeks, and one change last quarter increased unsupported answers.
>
> Every change must now be proven no worse than production before it is released.

**What should the solutions architect add to the pipeline?**

A. A Bedrock guardrail with contextual grounding

B. CloudWatch latency alarms

C. A human review of five answers per release

D. A Bedrock RAG evaluation job on a fixed test set, comparing faithfulness and correctness against the production baseline

◆ PAUSE AND DECIDE

## What should the solutions architect add to the pipeline?

A Guardrail

*Filters at runtime; does not compare releases.*

B Latency alarms

*Speed, not answer quality.*

C Five answers

*Too small to detect a regression.*

D RAG evaluation gate

Scores each change against the baseline before release.

THE SIGNAL

Prove a change is no worse before release: evaluation job against the baseline.

> Fenwick Health also runs a fine-tuned open-weight model on SageMaker AI endpoints. The team wants to score it with the same LLM-as-a-judge metrics used for its Bedrock models.
>
> Moving the model to Bedrock is not planned.

**How should the solutions architect evaluate it?**

A. Run Bedrock Evaluations with bring-your-own inference responses from the SageMaker model in the prompt dataset

B. Import the model into Bedrock first

C. Write a custom judge application on EC2

D. Use human evaluation only

◆ PAUSE AND DECIDE

## How should the solutions architect evaluate it?

**A** Bring your own responses
Same judge and metrics, model stays where it is.

**B** Import to Bedrock
*A migration the team has ruled out.*

**C** Custom judge
*Rebuilds a managed feature, and metrics differ.*

**D** Human only
*Not the same metrics, and slower.*

THE SIGNAL

Evaluate a model hosted anywhere with Bedrock metrics: bring your own inference responses.

# What to carry out of this module

- **Inspector code security** for repositories; **SBOM scan** in the build.
- **ECR enhanced scanning**: language packages, continuous rescans.
- **Sign and verify**: ECR managed signing, admission checks, Lambda code signing.
- **Bedrock Evaluations** as a release gate against a baseline.
- **Bring your own responses** for models hosted elsewhere.

> ON THE EXAM
>
> Scan for safety, sign for provenance, evaluate for quality.

MODULE 44 · DOMAIN 5 - OPERATIONAL EXCELLENCE AND AUTOMATION

# Deployment Strategies and Rollback

Expose a release to as few users as possible until it proves itself, and make going back faster than going forward.

DOMAIN 5 of 5 EXAM WEIGHT 20% MODULE 44 of 52

admin@sthithapragna.com

Every strategy trades **blast radius** and **rollback speed** against cost and time to release.

# The strategies

| STRATEGY | BLAST RADIUS | ROLLBACK | EXTRA COST |
|---|---|---|---|
| All at once | Everyone | Redeploy old | None |
| Rolling | Grows by batch | Roll back batches | None or one batch |
| Blue/green | Everyone at switch | Switch back, instant | Double capacity |
| Canary | Small slice first | Shift slice back | Small |
| Linear | Equal steps | Shift back | Small |

ON THE EXAM

Smallest exposure: canary. Fastest return: blue/green. Cheapest: rolling.

# Strategy by compute

| COMPUTE | FEATURE | STRATEGIES |
|---|---|---|
| Lambda | Alias weights with CodeDeploy | Canary, linear, all at once |
| ECS | Built-in deployment controller | Rolling, blue/green, canary, linear |
| EC2 Auto Scaling | Instance refresh | Rolling with checkpoints |
| EC2 | CodeDeploy | In-place or blue/green |
| API Gateway | Canary release on a stage | Canary |

ON THE EXAM

ECS gained built-in blue/green in July 2025 and canary and linear in October 2025.

# ECS: built-in or CodeDeploy?

BUILT-IN ECS DEPLOYMENTS

## Default for new services

- Blue/green, canary, linear
- Service Connect, multiple target groups
- Bake time before old is retired
- Alarm and hook rollback

CODEDEPLOY FOR ECS

## Still supported

- Existing pipelines built on it
- Releases coordinated with CodeDeploy
- Established governance
- No Service Connect

THE TIEBREAKER

New ECS service, or Service Connect: built-in. Existing CodeDeploy process: keep it.

# Automatic rollback triggers

| WHERE | TRIGGER |
| --- | --- |
| CodeDeploy | CloudWatch alarms, failed hooks |
| ECS built-in | Alarms, lifecycle hooks, bake time |
| ECS rolling | Deployment circuit breaker |
| Instance refresh | Alarms, failed health checks |
| CloudFormation | Rollback triggers with monitoring time |

ON THE EXAM

A strategy without an automatic trigger still depends on someone noticing.

# Database changes: expand and contract

01
## Expand
Add new columns or tables only

02
## Deploy app
Works with old and new schema

03
## Migrate
Backfill and switch reads

04
## Contract
Remove old columns later

ON THE EXAM

Rollback only works if the old version can still use the database.

# Reading the scenario

| WHEN THE QUESTION SAYS | IT IS TESTING |
|---|---|
| Small percentage first, revert on errors | Canary with alarm rollback |
| Switch back instantly, test full stack first | Blue/green |
| Tasks keep failing, deployment hangs | ECS deployment circuit breaker |
| New AMI across an Auto Scaling group | Instance refresh, checkpoints |
| Rollback broke on a schema change | Expand and contract |
| ECS with Service Connect | Built-in ECS deployments |

ON THE EXAM

Match the risk to the strategy, then the compute to the feature.

> Larkspur Payments runs card authorisation in a Lambda function. A new version should take 10% of traffic for 10 minutes, then the rest.
>
> If the error alarm fires during that time, traffic must return to the old version automatically.

**What should the solutions architect implement?**

A. Publish the new version and point callers at $LATEST

B. CodeDeploy with a Canary10Percent10Minutes configuration on the function alias, with the error alarm attached

C. Route 53 weighted records for two functions

D. A rolling deployment of the function

◆ PAUSE AND DECIDE

## What should the solutions architect implement?

A $LATEST
*All traffic at once, no rollback.*

B CodeDeploy canary on alias
10% for 10 minutes, alarm rolls back.

C Route 53 weights
*DNS caching, and no automatic rollback.*

D Rolling
*Lambda has no instances to roll through.*

THE SIGNAL

Lambda, small slice first, automatic revert: CodeDeploy canary on the alias.

> Larkspur Payments is launching a new ECS service on Fargate that talks to other services through ECS Service Connect.
>
> It wants canary releases, a bake time before the old revision is removed, and rollback on alarms, with as few extra services as possible.

**What should the solutions architect use?**

A CodeDeploy blue/green for ECS

B Rolling updates with minimum healthy percent of 50

C The ECS built-in deployment controller with a canary strategy, bake time and CloudWatch alarms

D Two ECS services behind Route 53 weighted records

◆ PAUSE AND DECIDE

## What should the solutions architect use?

A CodeDeploy

*Does not support Service Connect, and adds a service.*

B Rolling

*No traffic slice, no bake time.*

C ECS built-in canary

Canary, bake time, alarm rollback, Service Connect.

D Route 53 split

*Custom, imprecise, no automatic rollback.*

THE SIGNAL

New ECS service with Service Connect: the built-in deployment controller.

> Larkspur Payments uses ECS rolling updates for an internal service. A release with a bad image caused new tasks to fail health checks again and again.
>
> The deployment kept retrying for three hours before anyone noticed and rolled back by hand.

## What should the solutions architect enable?

A The ECS deployment circuit breaker with rollback enabled

B A longer health check grace period

C Blue/green deployments with twice the capacity

D A larger minimum healthy percent

◆ PAUSE AND DECIDE

## What should the solutions architect enable?

A **Circuit breaker**
Stops a failing rollout and returns to the last good revision.

B **Longer grace**
*Delays detection further.*

C **Blue/green**
*A bigger change than the problem needs.*

D **Minimum healthy**
*Protects capacity, does not stop retries.*

THE SIGNAL

ECS tasks keep failing during a rolling update: deployment circuit breaker.

> Larkspur Payments runs 200 EC2 instances in an Auto Scaling group. A new AMI must replace them gradually, pausing at 20% for validation.
>
> If the latency alarm fires during the rollout, the group must return to the previous launch template automatically.

**What should the solutions architect use?**

A Terminate instances in batches by hand

B Create a second Auto Scaling group and switch DNS

C CodeDeploy in-place deployment

D Instance refresh with a checkpoint at 20%, alarms, and auto rollback enabled

◆ PAUSE AND DECIDE

## What should the solutions architect use?

A **Manual batches**
*No checkpoint logic, no rollback.*

B **Second group**
*Blue/green; not gradual, and more to build.*

C **CodeDeploy in place**
*Deploys application code, not a new AMI.*

D **Instance refresh**
Gradual, pauses at checkpoints, rolls back on alarm.

THE SIGNAL

New AMI across an Auto Scaling group, gradual, with rollback: instance refresh.

> Larkspur Payments used blue/green for a release that renamed a database column. When an error forced a switch back, the old version failed because the column it expected no longer existed.
>
> Future releases must keep the switch back working.

## What should the solutions architect change?

A Restore a database snapshot during each rollback

B Use expand and contract: add new columns first, keep old ones until no rollback is needed

C Deploy all at once at night

D Give blue and green separate databases

◆ PAUSE AND DECIDE

## What should the solutions architect change?

A Snapshot restore

*Loses transactions written since the snapshot.*

B Expand and contract

Both versions work with the schema during the release.

C All at once

*Makes rollback harder, not easier.*

D Separate databases

*Data diverges; payments split across two stores.*

THE SIGNAL

Rollback broken by a schema change: expand and contract.

> Larkspur Payments' settlement service runs on EC2 behind an Application Load Balancer and is released twice a year. Each release must be tested end to end in production conditions before any customer traffic reaches it.
>
> If a problem appears, the return must be immediate. Doubling capacity for a day is acceptable.

**Which strategy should the solutions architect choose?**

A Canary, 5% of traffic for an hour

B Rolling, one instance at a time

C Blue/green with CodeDeploy, testing the green environment before shifting traffic

D All at once during a maintenance window

◆ PAUSE AND DECIDE

## Which strategy should the solutions architect choose?

A **Canary**
*Customers reach the new version before full testing.*

B **Rolling**
*Mixed versions, slow rollback.*

C **Blue/green**
Test green fully, switch, switch back instantly.

D **All at once**
*No pre-traffic test, no fast return.*

THE SIGNAL

Test before any customer traffic, instant return, double capacity allowed: blue/green.

# What to carry out of this module

- **Canary** for smallest exposure; **blue/green** for fastest return.
- **Lambda**: CodeDeploy on aliases. **ASG**: instance refresh.
- **ECS built-in** blue/green, canary and linear for new services.
- **Automatic triggers**: alarms, hooks, circuit breaker.
- **Expand and contract** keeps rollback possible.

> ON THE EXAM
>
> Match the risk to the strategy, then the compute to the feature.

MODULE 45 · DOMAIN 5 - OPERATIONAL EXCELLENCE AND AUTOMATION

# Observability Foundations

Metrics, logs and traces from every workload and every account, gathered with open standards and kept for as long as you need at the lowest cost.

DOMAIN 5 of 5 EXAM WEIGHT 20% MODULE 45 of 52

admin@sthithapragna.com

Instrument once with **OpenTelemetry**, view every account from **one place**, and keep each signal in the cheapest store that meets its query needs.

# Three signals

| SIGNAL | ANSWERS | AWS SERVICE |
|---|---|---|
| Metrics | How much, how fast, is it healthy? | CloudWatch metrics |
| Logs | What exactly happened? | CloudWatch Logs |
| Traces | Where did the time go across services? | X-Ray, Transaction Search |

ON THE EXAM

Embedded metric format turns structured log lines into metrics without API calls.

# X-Ray SDK or OpenTelemetry?

X-RAY SDKS AND DAEMON

## Maintenance mode

- Maintenance since 25 Feb 2026
- End of support 25 Feb 2027
- Security fixes only
- Migrate existing code

ADOT AND OPENTELEMETRY

## The supported path

- Vendor-neutral instrumentation
- Traces, metrics and logs
- Sends to X-Ray and CloudWatch
- Auto-instrumentation available

THE TIEBREAKER

New instrumentation: OpenTelemetry through ADOT, not the X-Ray SDK.

# Container Insights

| PLATFORM | HOW IT IS ENABLED | WHAT IT ADDS |
|---|---|---|
| EKS | CloudWatch Observability add-on | Pod, container and control plane metrics |
| ECS | Cluster setting, enhanced observability | Task and container metrics |
| Both | Curated dashboards | Drill down from cluster to container |

ON THE EXAM

Per-container CPU, memory and network with little setup: Container Insights.

# Seeing every account

CROSS-ACCOUNT OBSERVABILITY

## View in place

- Monitoring account linked to sources
- Metrics, logs and traces
- No data copied
- Set up across an organisation

LOG SUBSCRIPTIONS

## Copy and stream

- Subscription filter to a destination
- Kinesis, Firehose or Lambda
- Account-level filters cover every group
- Feeds a SIEM or archive

THE TIEBREAKER

Look across accounts: cross-account observability. Move the data somewhere: subscriptions.

# Keeping logs at the right cost

| STORE | QUERY SPEED | SUITS |
|---|---|---|
| CloudWatch Logs Standard | Seconds, full features | Active troubleshooting |
| CloudWatch Logs Infrequent Access | Seconds, fewer features | Occasional queries |
| S3 Standard-IA, Glacier Instant | Milliseconds, Athena | Monthly analysis |
| S3 Glacier Flexible Retrieval | Minutes to hours | Rare audits |
| S3 Glacier Deep Archive | Within 12 hours | Years of retention |

ON THE EXAM

Retention in years, query within a day: Firehose to S3, lifecycle to Deep Archive.

# Reading the scenario

| WHEN THE QUESTION SAYS | IT IS TESTING |
|---|---|
| New tracing, vendor-neutral | ADOT and OpenTelemetry |
| One view of all accounts, no copying | Cross-account observability |
| Stream logs to a security account | Subscription filters |
| Per-pod or per-task metrics | Container Insights |
| Keep for seven years, rarely read | S3 lifecycle to Glacier |
| Metrics from Lambda without API calls | Embedded metric format |

ON THE EXAM

How it is collected, where it is viewed, where it is kept.

> Corvane Retail is adding distributed tracing to 40 services on ECS and Lambda. The lead developer proposes the X-Ray SDK and daemon, which an older project used.
>
> The company wants instrumentation it will not need to replace, and may later send traces to a second tool.

**What should the solutions architect recommend?**

A The X-Ray SDK and daemon, as proposed

B VPC Flow Logs with Athena

C CloudTrail data events

D OpenTelemetry instrumentation through ADOT, sending traces to X-Ray and CloudWatch

◆ PAUSE AND DECIDE

## What should the solutions architect recommend?

A X-Ray SDK

*In maintenance mode; end of support February 2027.*

B Flow Logs

*Network records, not request traces.*

C CloudTrail

*API audit, not application traces.*

D ADOT

Supported, vendor-neutral, exports to several tools.

THE SIGNAL

New tracing that will last and stay portable: OpenTelemetry through ADOT.

> Corvane Retail has 60 workload accounts. During incidents, operators switch roles between accounts to read dashboards, logs and traces.
>
> The operations team wants one place to search and correlate all three signals across accounts, without copying the data.

**What should the solutions architect implement?**

A. CloudWatch cross-account observability, with a central monitoring account linked to every workload account

B. Subscription filters sending all logs to a central account

C. A dashboard in each account

D. Amazon OpenSearch Service with every log copied in

◆ PAUSE AND DECIDE

## What should the solutions architect implement?

A **Cross-account observability**
Metrics, logs and traces viewed in place.

B **Subscriptions**
*Copies logs only; no metrics or traces.*

C **Per-account dashboards**
*Still switching accounts.*

D **OpenSearch**
*Copies data and adds a cluster to run.*

THE SIGNAL

All signals, all accounts, one view, no copying: cross-account observability.

> Corvane Retail's security team runs a SIEM in a dedicated security account. It needs every application log group in 60 accounts streamed to it in near real time.
>
> New log groups must be included automatically.

**What should the solutions architect configure?**

A. Cross-account observability linking every account

B. Account-level subscription filters in each account, sending to a cross-account destination backed by Kinesis Data Streams in the security account

C. A daily export of log groups to S3

D. CloudTrail organisation trail

◆ PAUSE AND DECIDE

## What should the solutions architect configure?

A Cross-account observability

*Views data; does not deliver it to a SIEM.*

B Account-level subscriptions

Streams every group, new ones included.

C Daily export

*Not near real time.*

D CloudTrail

*API events, not application logs.*

THE SIGNAL

Deliver logs to another account's tool, continuously: subscription filters.

> Corvane Retail's EKS clusters show healthy node metrics, but users report slow checkouts. Engineers cannot see which pods are short of memory or being throttled.
>
> They want pod and container metrics with ready-made dashboards, with as little setup as possible.

## What should the solutions architect do?

A Publish custom metrics from each application with PutMetricData

B Enable detailed monitoring on the worker nodes

C Install the CloudWatch Observability add-on to enable Container Insights with enhanced observability

D Turn on VPC Flow Logs

◆ PAUSE AND DECIDE

## What should the solutions architect do?

A Custom metrics

*Code changes in every service; no dashboards.*

B Detailed monitoring

*More frequent node metrics, still no pod view.*

C Container Insights

Pod and container metrics with dashboards, one add-on.

D Flow Logs

*Network records, not resource use.*

THE SIGNAL

Pod or container resource metrics, little setup: Container Insights.

> Corvane Retail must keep payment application logs for seven years. After 90 days they are read only for audits, about once a year, and auditors accept results within a day.
>
> The company wants the lowest storage cost.

**What should the solutions architect design?**

A. Stream logs through Firehose to S3, with a lifecycle rule moving objects to S3 Glacier Deep Archive after 90 days

B. Set CloudWatch Logs retention to seven years

C. Use the CloudWatch Logs Infrequent Access class for seven years

D. Store logs in S3 Glacier Instant Retrieval

◆ PAUSE AND DECIDE

## What should the solutions architect design?

**A** S3 to Deep Archive

Lowest cost; retrieval within 12 hours meets the day.

**B** CloudWatch Standard

*Most expensive way to store cold logs.*

**C** Logs Infrequent Access

*Cheaper ingestion, still far above Deep Archive storage.*

**D** Glacier Instant

*Pays for millisecond access nobody needs.*

THE SIGNAL

Years of retention, read within a day: S3 lifecycle to Glacier Deep Archive.

> Corvane Retail's checkout Lambda function needs custom metrics for basket value and payment provider, broken down by several dimensions.
>
> Calling the CloudWatch API on every invocation added latency and throttling errors.

**What should the solutions architect recommend?**

A Batch PutMetricData calls in a background thread

B X-Ray annotations

C Write the values to DynamoDB and graph them later

D Write the metrics as structured log lines in CloudWatch embedded metric format

◆ PAUSE AND DECIDE

## What should the solutions architect recommend?

A Background batching

*Lambda may freeze before the thread sends.*

B X-Ray annotations

*Index traces; they are not metrics.*

C DynamoDB

*Builds a metrics system by hand.*

D Embedded metric format

Logs written asynchronously become metrics.

THE SIGNAL

Custom metrics from Lambda without API calls: embedded metric format.

# What to carry out of this module

- **ADOT and OpenTelemetry** for new instrumentation; X-Ray SDK ends Feb 2027.
- **Cross-account observability** views; **subscriptions** copy.
- **Container Insights** for pod and task metrics.
- **Firehose to S3**, lifecycle to Glacier, for years of logs.
- **Embedded metric format** for metrics without API calls.

> ON THE EXAM
>
> How it is collected, where it is viewed, where it is kept.

MODULE 46 · DOMAIN 5 - OPERATIONAL EXCELLENCE AND AUTOMATION

# User Experience Monitoring and SLOs

Measure what users actually experience, set objectives for it, alert on how fast the error budget is burning, and start the fix automatically.

DOMAIN 5 of 5 EXAM WEIGHT 20% MODULE 46 of 52

admin@sthithapragna.com

Measure the user's experience, judge it against an objective, and alert on the budget burning, not on every blip.

# Watching from the user's side

| TOOL | MEASURES | BEST AT |
| --- | --- | --- |
| CloudWatch Synthetics | Scripted canaries on a schedule | Finding breakage before users do |
| CloudWatch RUM | Real browser and mobile sessions | Actual load times and errors by geography |
| Application Signals | Service operations and dependencies | Latency, faults and SLOs per service |
| Internet Monitor | Internet paths to your application | Provider and location problems |

ON THE EXAM

Synthetics works with no users; RUM needs them.

# Synthetics or RUM?

SYNTHETICS CANARIES

## Simulated users

- Runs every few minutes, any hour
- Scripted journeys, screenshots
- Catches breakage at 3 a.m.
- Same path every time

REAL USER MONITORING

## Actual users

- Every real session
- Browsers, devices, countries
- Web vitals and JavaScript errors
- Silent when nobody visits

THE TIEBREAKER

Know before users notice, at quiet times: Synthetics. What real users see, by place and device: RUM.

# SLO building blocks

| TERM | MEANING |
| --- | --- |
| SLI | The measure: availability or latency |
| Attainment goal | For example 99.9% over 28 days |
| Error budget | The failure allowed by the goal |
| Burn rate | How fast the budget is being spent |
| Period-based | Each minute healthy or unhealthy |
| Request-based | Good requests over total requests |

ON THE EXAM

Burn rate above 1 means the goal will be missed if nothing changes.

# Burn-rate alerting

01
### Long window
For example 1 hour, high burn

02
### Short window
One twelfth: 5 minutes

03
### Composite alarm
Both in alarm together

04
### Page
Only while it is still happening

ON THE EXAM

Pair a long and a short window so pages fire for real, ongoing budget loss.

# From alarm to action

| ALARM ACTION | RESULT |
| --- | --- |
| SNS topic | Notify people or systems |
| Systems Manager OpsItem | Track and review in OpsCenter |
| EventBridge rule | Start an SSM Automation runbook |
| Auto Scaling or EC2 action | Scale, stop, reboot or recover |
| Lambda function | Run custom remediation |

ON THE EXAM

Known fix for a known alarm: run it automatically with SSM Automation.

# Reading the scenario

| WHEN THE QUESTION SAYS | IT IS TESTING |
|---|---|
| Broken at night, found by customers | Synthetics canary |
| Slow for some users in some countries | CloudWatch RUM |
| Alert on objective, not every spike | SLO with burn-rate alarms |
| Maintenance counts against the SLO | Exclusion windows |
| Low traffic, one failure spoils a minute | Request-based SLI |
| Known fix, run it automatically | Alarm to SSM Automation |

ON THE EXAM

Measure the user, judge against the objective, act automatically.

> Ashgrove Travel's booking flow broke at 03:00 after a dependency change. Traffic is light at night, and customers reported it at 08:00.
>
> The team wants the full booking journey checked every five minutes, around the clock, with an alarm on failure.

**What should the solutions architect implement?**

A CloudWatch RUM on the booking pages

B A CloudWatch Synthetics canary that scripts the booking journey, with an alarm on its success metric

C A Route 53 health check on the home page

D A metric filter on application error logs

◆ PAUSE AND DECIDE

# What should the solutions architect implement?

A RUM

*Needs real users; there were almost none.*

B Synthetics canary

Runs the journey every five minutes, users or not.

C Health check

*Home page may load while booking fails.*

D Log metric filter

*Only sees errors the app logs, and needs traffic.*

THE SIGNAL

Catch breakage when nobody is using the site: a Synthetics canary.

> Ashgrove Travel's canaries in eu-west-1 show fast page loads, but customers in Brazil and India complain that the site is slow on mobile.
>
> The team wants actual page-load times and JavaScript errors, broken down by country, browser and device.

**What should the solutions architect add?**

A More canaries in eu-west-1

B X-Ray tracing on the back end

C CloudWatch RUM, with its web client added to the site

D Application Load Balancer access logs

◆ PAUSE AND DECIDE

## What should the solutions architect add?

A More canaries

*Same Region, same browser; not real users.*

B X-Ray

*Back-end timing; misses the browser.*

C RUM

Real sessions by country, browser and device.

D ALB logs

*Server timing; no page rendering or JS errors.*

THE SIGNAL

**What real users see, by place and device: RUM.**

> Ashgrove Travel promises 99.9% availability for its search API over a rolling 28 days. A static alarm on any 5xx minute pages the on-call engineer several times a night for brief spikes.
>
> The team wants pages only when the promise is genuinely at risk.

**What should the solutions architect implement?**

A. An Application Signals SLO with burn-rate alarms on a long and a short window, joined in a composite alarm

B. Raise the static threshold until the pages stop

C. Anomaly detection on the 5xx count

D. A dashboard reviewed each morning

◆ PAUSE AND DECIDE

## What should the solutions architect implement?

**A** SLO burn-rate alarms

Pages when the budget is genuinely burning.

**B** Higher threshold

*Arbitrary; may hide real outages.*

**C** Anomaly detection

*Unusual is not the same as at risk.*

**D** Dashboard

*No alerting at all.*

THE SIGNAL

Alert when the promise is at risk, not on every spike: SLO burn-rate alarms.

> Ashgrove Travel takes the search API down for planned maintenance every Sunday from 02:00 to 02:30, with customers notified in advance.
>
> Those 30 minutes consume the SLO error budget every week, and the agreement with customers excludes them.

**What should the solutions architect do?**

A Lower the attainment goal

B Delete and recreate the SLO after each window

C Disable the SLO alarms by hand on Sundays

D Add a recurring exclusion window to the SLO for the maintenance period

◆ PAUSE AND DECIDE

## What should the solutions architect do?

A Lower goal

*Misstates the promise every other day.*

B Recreate

*Loses history; absurd effort.*

C Manual disable

*Budget still consumed; relies on memory.*

D Recurring exclusion window

Maintenance excluded from measurement.

THE SIGNAL

Planned maintenance outside the agreement: SLO exclusion windows.

> Ashgrove Travel's partner API receives about 20 requests per minute overnight. With a period-based availability SLO, one failed request marks a whole minute unhealthy.
>
> Overnight attainment looks far worse than the share of requests that actually failed.

## What should the solutions architect change?

A Use a 5-minute period

B Switch to a latency SLI

C Use a request-based SLI that counts good requests against total requests

D Exclude the night from the SLO

◆ PAUSE AND DECIDE

## What should the solutions architect change?

A Longer period

*One failure now spoils five minutes.*

B Latency SLI

*Measures something else.*

C Request-based

Attainment reflects the real failure ratio.

D Exclude nights

*Hides real failures from the objective.*

THE SIGNAL

Low or uneven traffic, period health misleading: request-based SLI.

> Ashgrove Travel's EC2 batch servers regularly fill their temporary volume. An engineer is paged, logs in, runs the same cleanup commands, and closes the alert.
>
> The team wants the cleanup to run automatically, with a record of each occurrence for review.

**What should the solutions architect implement?**

A. An SNS email to the whole team

B. A disk-usage alarm that creates a Systems Manager OpsItem, and an EventBridge rule on the alarm that starts an SSM Automation runbook to clean up

C. Replace the instances every night

D. Double the volume size

◆ PAUSE AND DECIDE

## What should the solutions architect implement?

A Team email

*Still manual, and noisier.*

B OpsItem plus Automation

Fix runs itself; each occurrence recorded.

C Nightly replacement

*Disrupts batch jobs; ignores the trigger.*

D Bigger volume

*Delays the same problem.*

THE SIGNAL

Known fix, run automatically, with a record: alarm to SSM Automation and OpsItem.

# What to carry out of this module

- **Synthetics** before users notice; **RUM** for what real users see.
- **SLOs** in Application Signals: SLI, goal, error budget.
- **Burn-rate alarms**, long and short window, composite.
- **Exclusion windows**; **request-based** for low traffic.
- **Alarm to SSM Automation** for known fixes.

> ON THE EXAM
>
> Measure the user, judge against the objective, act automatically.

MODULE 47 · DOMAIN 5 - OPERATIONAL EXCELLENCE AND AUTOMATION

# AI/ML Observability and Model Drift

A model can be up, fast and wrong. Watch its inputs, its outputs, its fairness and its cost, and trace every step an agent takes.

DOMAIN 5 of 5 EXAM WEIGHT 20% MODULE 47 of 52

admin@sthithapragna.com

A model can be **available, fast and wrong**. Its quality has to be measured, because no error code will report it.

# SageMaker Model Monitor

| MONITOR | DETECTS | NEEDS |
|---|---|---|
| Data quality | Inputs drifting from training data | Baseline, data capture |
| Model quality | Accuracy, precision falling | Ground truth labels |
| Bias drift | Predictions becoming unfair | SageMaker Clarify config |
| Feature attribution drift | Different features driving results | SageMaker Clarify baseline |

ON THE EXAM

Inputs only: data quality. Correctness: model quality, which needs labels.

# How a drift monitor works

01
### Baseline
Statistics from training data

02
### Capture
Endpoint records requests and responses

03
### Schedule
Compare capture with baseline

04
### Alarm
CloudWatch, then retrain pipeline

ON THE EXAM

No baseline, no drift: the comparison needs a reference.

# Observing Amazon Bedrock

| SIGNAL | SOURCE |
| --- | --- |
| Invocations, latency, throttles | CloudWatch runtime metrics |
| Input and output tokens | CloudWatch metrics, per model |
| Full prompts and responses | Model invocation logging, off by default |
| Cost per application | Application inference profiles with tags |
| Guardrail interventions | Guardrail metrics and traces |

ON THE EXAM

Token metrics show how much; invocation logs show which prompts.

# Tracing agents

| NEED | FEATURE |
| --- | --- |
| Every step of an agent run | CloudWatch generative AI observability |
| Model calls, tools, memory, gateway | AgentCore observability spans |
| Strands, LangChain, LangGraph | OpenTelemetry instrumentation |
| Tokens, latency, errors per agent | Curated dashboards |

> ON THE EXAM
>
> Why did the agent do that? End-to-end trace of the run, not just the model call.

# Drift in predictive models and in LLM apps

PREDICTIVE MODELS

## Model Monitor

- Tabular inputs and labels
- Statistical baseline
- Ground truth for accuracy
- Retrain on drift

LLM APPLICATIONS

## Evaluation on live samples

- Free-text inputs and answers
- Judge model scores
- Sample from invocation logs
- Fix prompt, model or knowledge base

THE TIEBREAKER

LLM answers getting worse with no labels: score sampled production responses with an evaluation job.

# Reading the scenario

| WHEN THE QUESTION SAYS | IT IS TESTING |
|---|---|
| Inputs no longer look like training data | Data quality monitor |
| Accuracy falling, labels arrive later | Model quality monitor |
| Predictions becoming unfair to a group | Bias drift with Clarify |
| Which application drives token spend | Invocation logs, inference profiles |
| Why did the agent take that path? | Generative AI observability traces |
| LLM answers worse, no labels | Evaluation on sampled traffic |

ON THE EXAM

Inputs, correctness, fairness, cost, and the agent's path.

> Pellham Bank's fraud model runs on a SageMaker AI endpoint. New merchant categories launched, and transaction features now look quite different from the training data, but nothing alerted.
>
> The team wants an alert when production inputs drift from the training data.

**What should the solutions architect implement?**

A. A Model Monitor data quality schedule, using a baseline from the training data and endpoint data capture, with a CloudWatch alarm

B. A CloudWatch alarm on endpoint latency

C. Retrain the model every week regardless

D. A Clarify bias report at deployment

◆ PAUSE AND DECIDE

## What should the solutions architect implement?

**A** Data quality monitor
Compares live inputs with the training baseline.

**B** Latency alarm
*Drifted inputs are served just as fast.*

**C** Weekly retraining
*Costly, blind, and still no alert.*

**D** Bias report once
*Fairness, at one moment, not input drift.*

THE SIGNAL

Production inputs drifting from training data: data quality monitor.

> Pellham Bank also needs to know whether the fraud model's precision and recall are falling. Investigators confirm whether a transaction was fraud about two weeks after it happens.
>
> The input distribution is already monitored.

**What should the solutions architect add?**

A A second data quality monitor

B An A/B test against the previous model

C Alarms on invocation errors

D A Model Monitor model quality schedule that merges the investigators' labels with captured predictions

◆ PAUSE AND DECIDE

## What should the solutions architect add?

A Data quality again

*Inputs only; says nothing about correctness.*

B A/B test

*Compares models, does not monitor one.*

C Error alarms

*Wrong predictions are not errors.*

D Model quality monitor

Labels plus predictions give precision and recall.

THE SIGNAL

Is the model still correct, with labels arriving later: model quality monitor.

> Pellham Bank's credit model passed a fairness review before launch. The regulator now requires ongoing evidence that approval rates do not drift against applicants over 60.
>
> Results must be recorded on a schedule.

**What should the solutions architect implement?**

A. A data quality monitor on the age feature

B. Remove age from the model inputs

C. A Model Monitor bias drift schedule using SageMaker Clarify, with age as the facet

D. A quarterly manual review

◆ PAUSE AND DECIDE

## What should the solutions architect implement?

A Data quality on age

*Watches the age distribution, not outcomes.*

B Remove age

*Proxies can still carry bias; no evidence produced.*

C Bias drift monitor

Scheduled Clarify metrics for the age group.

D Manual review

*Infrequent, not continuous.*

THE SIGNAL

Ongoing evidence that outcomes stay fair to a group: bias drift monitor.

> Pellham Bank runs four applications on the same Bedrock model. Spend on the model doubled last month, and finance wants to know which application caused it and which prompts are largest.
>
> Only aggregate CloudWatch token metrics are available today.

**What should the solutions architect do?**

A Read CloudTrail management events

B Give each application its own tagged application inference profile, and enable model invocation logging to analyse prompt sizes

C Enable X-Ray tracing on the model

D Divide the bill evenly between the applications

◆ PAUSE AND DECIDE

## What should the solutions architect do?

A CloudTrail

*No token counts or prompt contents.*

B Profiles and invocation logs

Cost per application; prompts per request.

C X-Ray

*Timing, not token attribution.*

D Even split

*Guesswork.*

THE SIGNAL

Which application and which prompts drive token spend: inference profiles and invocation logs.

> Pellham Bank's customer service agent, built with Strands Agents on Bedrock AgentCore, sometimes calls the wrong tool and takes 40 seconds to answer.
>
> Engineers need to see each step of a run: model calls, tool calls, memory reads, with timings.

**What should the solutions architect use?**

A Model invocation logs alone

B CloudTrail data events

C An Application Signals availability SLO

D CloudWatch generative AI observability, with the agent instrumented through OpenTelemetry

◆ PAUSE AND DECIDE

## What should the solutions architect use?

A Invocation logs

*Model calls only; no tools, memory or timeline.*

B CloudTrail

*API audit, not a run trace.*

C SLO

*Tells you it is slow, not why.*

D Generative AI observability

End-to-end trace of every step, with timings.

THE SIGNAL

Every step of an agent run, with timings: generative AI observability traces.

> Pellham Bank's policy assistant answers staff questions from a knowledge base that changes weekly. Staff say answers have become vaguer over three months. There are no labels for production questions.
>
> The team wants continuing measurement of answer quality in production.

**What should the solutions architect implement?**

A. Sample responses from invocation logs each day and score them with a Bedrock LLM-as-a-judge evaluation, publishing scores to CloudWatch with an alarm

B. A Model Monitor data quality schedule

C. A stricter Bedrock guardrail

D. An alarm on output token count

◆ PAUSE AND DECIDE

## What should the solutions architect implement?

**A** Judge on live samples

Measures quality without labels, over time.

**B** Model Monitor

*Built for structured inputs and SageMaker endpoints.*

**C** Stricter guardrail

*Blocks content; does not measure quality.*

**D** Token alarm

*Length is not quality.*

THE SIGNAL

Generative answers drifting, no labels: evaluate sampled production responses.

# What to carry out of this module

- **Model Monitor**: data quality, model quality, bias, attribution.
- **Baseline, capture, schedule, alarm**, then retrain.
- **Bedrock**: token metrics, invocation logs, inference profiles.
- **Generative AI observability** traces every agent step.
- **LLM drift**: judge-scored samples from production.

> ON THE EXAM
>
> Inputs, correctness, fairness, cost, and the agent's path.

MODULE 48 · DOMAIN 5 - OPERATIONAL EXCELLENCE AND AUTOMATION

# Operational Automation and Resilience Patterns

Let events start the fix, let the code survive its dependencies, let capacity arrive before the load, and let unhealthy parts replace themselves.

DOMAIN 5 of 5 EXAM WEIGHT 20% MODULE 48 of 52

admin@sthithapragna.com

Design so that the system **contains** a failure and **repairs** itself, and a person only decides what the automation cannot.

# Resilience patterns in code

| PATTERN | PREVENTS | ON AWS |
|---|---|---|
| Timeout | Waiting forever on a slow call | SDK and client settings |
| Retry, backoff, jitter | Retry storms in step | AWS SDK retry modes |
| Circuit breaker | Hammering a failing dependency | Library or Step Functions logic |
| Bulkhead | One workload starving another | Reserved concurrency, separate pools |
| Rate limit | Overload from one caller | API Gateway usage plans, WAF rate rules |
| Idempotency | Duplicate effects from retries | Idempotency keys, Powertools |

ON THE EXAM

Retries without backoff, jitter and idempotency make an outage worse.

# Scaling policies

| POLICY | HOW IT DECIDES | BEST FOR |
|---|---|---|
| Target tracking | Hold a metric at a target | Most workloads, the default |
| Step scaling | Act by alarm breach size | Custom, tiered responses |
| Scheduled | Change capacity at set times | Known one-off events |
| Predictive | Forecast from history, launch early | Daily or weekly cycles, slow start |

ON THE EXAM

Regular cycle, slow warm-up: add predictive scaling alongside target tracking.

# Self-healing

| COMPUTE | MECHANISM |
|---|---|
| EC2 Auto Scaling | ELB health checks replace unresponsive instances |
| EC2 single instance | Automatic recovery on hardware failure |
| ECS | Unhealthy tasks stopped and replaced |
| Lambda, asynchronous | Retries, then on-failure destination or DLQ |
| Lambda, SQS source | Failed messages to a dead-letter queue |

ON THE EXAM

EC2 status checks pass while the application hangs: use ELB health checks.

# Event-driven operations

01
### Event
Alarm, health event, Config change

02
### EventBridge
Rule matches, or Scheduler fires

03
### Runbook
SSM Automation with approvals

04
### Record
OpsItem, notification, audit

ON THE EXAM

Incident Manager and Change Manager closed to new customers on 7 Nov 2025.

# Reading the scenario

| WHEN THE QUESTION SAYS | IT IS TESTING |
|---|---|
| Slow dependency, failure cascades | Circuit breaker and timeouts |
| Retries arrive in waves | Exponential backoff with jitter |
| One workload starves another | Bulkhead, reserved concurrency |
| Daily peak, scaling too late | Predictive scaling |
| App hangs, instance not replaced | ELB health check type |
| Quota limits hit across accounts | Service Quotas automatic management |

ON THE EXAM

Contain, repair, scale ahead, automate the fix.

> Hollins Grocers' checkout service calls a third-party payment provider. When the provider slowed to 30-second responses, checkout threads filled up waiting, and the whole site stopped responding.
>
> The team wants a provider problem to degrade checkout, not take down the site.

**What should the solutions architect recommend?**

A Increase the client timeout to 60 seconds

B Short timeouts and a circuit breaker that stops calling the provider when it fails, returning a fallback such as queueing the payment

C Retry each failed call five times immediately

D Move checkout to larger instances

◆ PAUSE AND DECIDE

## What should the solutions architect recommend?

A Longer timeout

*Threads wait even longer.*

B Timeouts and circuit breaker

Fails fast, stops calling, degrades gracefully.

C Immediate retries

*Multiplies load on a struggling provider.*

D Larger instances

*More threads to fill; same outcome.*

THE SIGNAL

Slow dependency spreading to the whole system: timeouts and a circuit breaker.

> After a brief DynamoDB throttling event, Hollins Grocers' 2,000 order workers all retried exactly one second later, causing a second, larger spike, then a third.
>
> Some orders were also recorded twice.

## What should the solutions architect change?

A Remove retries entirely

B Retry every 100 milliseconds instead

C Use exponential backoff with jitter for retries, and make order writes idempotent with a client token

D Request a higher table throughput only

◆ PAUSE AND DECIDE

## What should the solutions architect change?

A No retries

*Turns brief throttles into failed orders.*

B Faster fixed retries

*Waves arrive sooner, still in step.*

C Backoff, jitter, idempotency

Spreads retries; duplicates have no effect.

D More throughput only

*Helps capacity; duplicates and waves remain.*

THE SIGNAL

Retries arriving in waves, plus duplicates: backoff with jitter, and idempotency.

> Hollins Grocers runs checkout and a nightly catalogue import as Lambda functions in the same account. Last night the import scaled to the account's concurrency limit, and checkout requests were throttled.
>
> Checkout must always have capacity, whatever the import does.

**What should the solutions architect configure?**

A Provisioned concurrency on the import function

B Move checkout to EC2

C Raise the account concurrency limit only

D Reserved concurrency for checkout, and a maximum concurrency on the import's SQS event source

◆ PAUSE AND DECIDE

## What should the solutions architect configure?

A Provisioned on import

*Pre-warms the wrong function; no limit.*

B Move to EC2

*Large change for an isolation problem.*

C Higher limit only

*The import can still grow into it.*

D Reserved and capped

Checkout keeps its share; import is bounded.

THE SIGNAL

One workload starving another: a bulkhead, with reserved and capped concurrency.

> Hollins Grocers' web tier in an Auto Scaling group sees traffic triple every weekday between 08:30 and 09:00. Instances need eight minutes to warm their caches.
>
> Target tracking reacts, but customers see slow pages for the first ten minutes every morning.

**What should the solutions architect add?**

A. Predictive scaling, alongside the existing target tracking policy

B. Step scaling with larger steps

C. A lower target tracking threshold

D. Double the minimum capacity all day

◆ PAUSE AND DECIDE

## What should the solutions architect add?

A **Predictive scaling**
Launches capacity before the daily peak.

B **Bigger steps**
*Still reacts after load arrives.*

C **Lower threshold**
*Earlier reaction, still too late for warm-up.*

D **Double minimum**
*Pays for peak capacity all day.*

THE SIGNAL

Regular daily peak plus slow warm-up: predictive scaling.

> Hollins Grocers' application on EC2 sometimes deadlocks. The instance stays up and passes EC2 status checks, but stops answering requests. The Application Load Balancer marks it unhealthy, but the Auto Scaling group never replaces it.
>
> The team wants such instances replaced automatically.

**What should the solutions architect change?**

A Enable EC2 automatic recovery

B A CloudWatch alarm that reboots the instance on high CPU

C Set the Auto Scaling group health check type to ELB, with a suitable grace period

D Use a larger instance type

◆ PAUSE AND DECIDE

## What should the solutions architect change?

A Auto recovery

*Acts on hardware and system failures only.*

B Reboot on CPU

*A deadlock may not raise CPU.*

C ELB health checks

The group then replaces instances the ALB finds unhealthy.

D Larger instance

*Deadlocks are not about size.*

THE SIGNAL

Load balancer sees it unhealthy, group does not replace it: ELB health check type.

> Hollins Grocers has 200 accounts. Launches keep failing when a team hits a service quota, such as Elastic IP addresses or Lambda concurrency, and a quota request is raised by hand.
>
> The platform team wants warnings as usage nears a quota, and quotas adjusted automatically based on usage.

**What should the solutions architect use?**

A. A weekly review of Trusted Advisor service limit checks

B. Service Quotas automatic quota management, with notifications

C. A Lambda function that requests the maximum for every quota

D. Ask teams to raise requests earlier

◆ PAUSE AND DECIDE

## What should the solutions architect use?

A Weekly review

*Manual and infrequent.*

B Automatic quota management

Alerts near limits, adjusts by usage, no charge.

C Request maximum

*Unjustified requests; removes useful guard rails.*

D Earlier requests

*Still manual.*

THE SIGNAL

Warn near quotas and adjust them by usage: Service Quotas automatic management.

# What to carry out of this module

- **Timeouts, circuit breakers, bulkheads** contain failures.
- **Backoff with jitter** plus **idempotency** make retries safe.
- **Predictive scaling** for regular peaks and slow warm-up.
- **ELB health checks** replace hung instances.
- **EventBridge to SSM Automation**; quotas managed automatically.

> ON THE EXAM
>
> Contain, repair, scale ahead, automate the fix.

MODULE 49 · EXAM STRATEGY - ALL DOMAINS

# Confusion Pairs

Thirty pairs, six per domain, each divided by one property. Learn the divider, not two definitions.

DOMAIN Cross-cutting  EXAM WEIGHT All five  MODULE 49 of 52

admin@sthithapragna.com

For each pair, one property decides. **Learn the divider**, and the definitions stop mattering.

# Domain 1: architecture

| PAIR | THE PROPERTY THAT DIVIDES THEM |
|---|---|
| FIFO queue vs Kinesis | One worker pool vs several readers or replay |
| Step Functions Standard vs Express | Waits and callbacks vs millions of short runs |
| Service Connect vs VPC Lattice | ECS only vs mixed compute, VPCs, IAM auth |
| Bedrock Agents vs AgentCore | Built in Bedrock vs your framework, model or MCP |
| RAG vs customised model | Changing facts and citations vs behaviour |
| Lake Formation vs Clean Rooms | Partner sees records vs only permitted results |

ON THE EXAM

AI pairs are new to C03, and the RAG divider is the one most often missed.

# Domain 2: security

| PAIR | THE PROPERTY THAT DIVIDES THEM |
| --- | --- |
| SCP vs RCP | Follows the identity vs follows the resource |
| User pool vs identity pool | Who you are vs AWS credentials |
| Client VPN vs Verified Access | Network access vs per-app with device posture |
| ML-KEM vs ML-DSA | Keeps data secret vs proves origin |
| Grounding vs Automated Reasoning | Supported by a source vs checked against rules |
| Residency vs sovereignty | Regions and policy vs operating model |

ON THE EXAM

Neither an SCP nor an RCP grants anything, and neither affects the management account.

# Domain 3: cost

| PAIR | THE PROPERTY THAT DIVIDES THEM |
|---|---|
| Savings Plan vs capacity reservation | Discount vs guaranteed launch |
| Budgets vs Cost Anomaly Detection | Known limit vs surprise |
| Showback vs chargeback | Visibility vs a bill teams must accept |
| Prompt routing vs distillation | Mixed difficulty vs one task at huge volume |
| Longer TTLs vs Origin Shield | Repeat requests vs misses from many locations |
| Lambda vs Managed Instances | Spiky vs steady, very high volume |

ON THE EXAM

A Savings Plan never guarantees capacity. For a launch event, reserve, then cover it with a plan.

# Domain 4: resilience and migration

| PAIR | THE PROPERTY THAT DIVIDES THEM |
| --- | --- |
| Pilot light vs warm standby | Core off vs running, scaled down |
| Route 53 failover vs Global Accelerator | DNS TTLs vs fixed IPs, no caching |
| Agent vs agentless replication | Software allowed in the guest or not |
| Rehost to EC2 vs relocate to EVS | Change operations vs keep VMware as is |
| Replatform vs refactor | Less to run vs new capabilities |
| Mainframe refactor vs reimagine | Change the language vs change the design |

ON THE EXAM

Clients that allow-list IPs or ignore DNS TTLs rule out DNS failover.

# Domain 5: operations

| PAIR | THE PROPERTY THAT DIVIDES THEM |
| --- | --- |
| CloudFormation Hook vs Config rule | At deployment vs any resource, afterwards |
| Template drift vs policy drift | Drift-aware change set vs Config remediation |
| Canary vs blue/green | Smallest exposure vs fastest return |
| Synthetics vs RUM | Before users notice vs what real users see |
| Cross-account observability vs subscriptions | View in place vs copy out |
| Data quality vs model quality monitor | Inputs only vs correctness, needs labels |

ON THE EXAM

Hooks never see console or CLI changes. Anything created by hand needs Config.

# How to use these under exam pressure

- **Name the pair** the question is testing before reading the options.
- **Find the word that resolves it**: never, guarantee, automatically, existing, a number.
- **Two plausible options usually means one pair.** The other two fill the page.
- If both members still seem right, you have the wrong pair. Read the requirement again.

> ON THE EXAM
>
> Composite questions combine two pairs. Each one eliminates two options.

> An insurer has a claims agent built with LangGraph that holds conversations lasting up to an hour. It wants to run the agent on managed AWS infrastructure without rewriting it.
>
> The agent must answer from policy documents that change weekly, and cite the clause it used.

**Which combination should the solutions architect choose?**

A. Fine-tune a model on the documents each week, and rebuild the agent in Bedrock Agents

B. A Bedrock knowledge base, and rebuild the agent in Bedrock Agents

C. A Bedrock knowledge base for retrieval, with the existing agent hosted on AgentCore Runtime

D. Fine-tune a model each week, with the existing agent hosted on AgentCore Runtime

◆ PAUSE AND DECIDE

## Which combination should the solutions architect choose?

A Fine-tune, Bedrock Agents

*Both halves wrong: no citations, and a rewrite.*

B Knowledge base, Bedrock Agents

*Right on RAG, but rewrites the agent.*

C Knowledge base, AgentCore

RAG gives citations; AgentCore runs LangGraph, long sessions.

D Fine-tune, AgentCore

*Right on hosting; weekly facts and citations need RAG.*

THE SIGNAL

Two pairs: RAG versus customisation, and Bedrock Agents versus AgentCore.

> A payments processor needs recovery in a second Region within 10 minutes. The recovery Region must be running and able to accept traffic immediately, then scale up.
>
> Card networks connect to fixed IP addresses on their allow-lists, and some of their systems ignore DNS TTLs.

**Which design should the solutions architect choose?**

A. Warm standby in the second Region, with Global Accelerator in front of both Regions

B. Pilot light in the second Region, with Global Accelerator

C. Warm standby, with Route 53 failover records

D. Pilot light, with Route 53 failover records

◆ PAUSE AND DECIDE

## Which design should the solutions architect choose?

A. Warm standby, Global Accelerator
Running copy; fixed IPs, no DNS caching.

B. Pilot light, Global Accelerator
*Core is off; cannot take traffic at once.*

C. Warm standby, Route 53
*New IPs and cached DNS break the card networks.*

D. Pilot light, Route 53
*Both halves fail.*

THE SIGNAL

Two pairs: pilot light versus warm standby, and DNS failover versus anycast.

> A retailer runs 12 teams on one shared EKS cluster with GPU nodes. Finance will start billing each team for its share, so teams must accept the allocation as fair.
>
> Finance also wants to hear about unusual spikes in any team's spend, without setting a threshold for each team.

**What should the solutions architect recommend?**

A. Tag each node group by team, and set AWS Budgets per team

B. A showback dashboard of node costs, and Cost Anomaly Detection

C. Split cost allocation data for EKS, and AWS Budgets per team

D. Split cost allocation data for EKS, and Cost Anomaly Detection monitors by team cost category

◆ PAUSE AND DECIDE

## What should the solutions architect recommend?

A Node tags, Budgets

*Shared nodes cannot be tagged per team; thresholds needed.*

B Showback, anomaly

*Showback is not a bill teams accept.*

C Split cost, Budgets

*Fair allocation, but Budgets need thresholds.*

D Split cost, anomaly detection

Measured usage, and alerts with no thresholds.

THE SIGNAL

Two pairs: showback versus chargeback, and Budgets versus Cost Anomaly Detection.

> A travel company is releasing a new booking API. It wants the new version exposed to as few real customers as possible at first, reverting automatically if errors rise.
>
> It also wants to know within minutes if the overnight booking journey breaks, when almost nobody is online.

**Which combination should the solutions architect choose?**

A Blue/green deployment, with CloudWatch RUM

B Canary deployment with alarm rollback, with a CloudWatch Synthetics canary on the booking journey

C Blue/green deployment, with a Synthetics canary

D Canary deployment with alarm rollback, with CloudWatch RUM

◆ PAUSE AND DECIDE

## Which combination should the solutions architect choose?

A Blue/green, RUM

*Everyone moves at the switch; RUM is silent at night.*

B Canary, Synthetics

Small slice first; checks the journey with no users.

C Blue/green, Synthetics

*Right monitor, but no small first exposure.*

D Canary, RUM

*Right strategy, but RUM needs real users.*

THE SIGNAL

Two pairs: canary versus blue/green, and Synthetics versus RUM.

> A device maker must sign firmware so that devices can verify its origin, and the signatures must resist future quantum attacks.
>
> Unreleased firmware sits in S3. No principal outside the organisation may ever read it, even if a developer misconfigures a bucket policy.

**Which combination should the solutions architect choose?**

A. An ML-KEM key in AWS KMS, and a resource control policy limiting access to the organisation

B. An ML-DSA key in AWS KMS for signing, and a resource control policy limiting access to the organisation

C. An ML-DSA key in AWS KMS, and a service control policy on developer accounts

D. An ML-KEM key in AWS KMS, and a service control policy on developer accounts

◆ PAUSE AND DECIDE

## Which combination should the solutions architect choose?

A ML-KEM, RCP

*ML-KEM establishes secrets; it does not sign.*

B ML-DSA, RCP

Quantum-resistant signatures; the RCP caps the bucket.

C ML-DSA, SCP

*An SCP limits your identities, not outsiders.*

D ML-KEM, SCP

*Both halves fail.*

THE SIGNAL

Two pairs: ML-KEM versus ML-DSA, and SCP versus RCP.

> A retailer and an advertiser want to measure how many of the retailer's customers saw a campaign. Neither may see the other's customer records.
>
> Separately, the retailer's own analysts may only query certain columns of the customer tables in its data lake.

**What should the solutions architect use for each need?**

A. Lake Formation for both needs

B. AWS Clean Rooms for both needs

C. Share the S3 bucket with the advertiser, and IAM policies for analysts

D. AWS Clean Rooms with the advertiser, and Lake Formation column permissions for analysts

◆ PAUSE AND DECIDE

## What should the solutions architect use for each need?

A Lake Formation for both

*Sharing would expose records to the advertiser.*

B Clean Rooms for both

*Internal analysts need governed access, not a collaboration.*

C Bucket share, IAM

*Exposes raw data; IAM cannot filter columns.*

D Clean Rooms and Lake Formation

Results only for the partner; columns for analysts.

THE SIGNAL

One pair, used twice: partner results only, internal fine-grained access.

# What to carry out of this module

- **Name the pair before reading the options.** Most questions are one of about thirty.
- **Learn the divider**, not two definitions.
- **Composite questions resolve independently.** Two pairs leave one answer.
- If both members still seem right, re-read the requirement, not the options.

> ON THE EXAM
>
> Most missed in C03: RAG versus customisation, ML-KEM versus ML-DSA, SCP versus RCP, Hooks versus Config.

MODULE 50 · EXAM STRATEGY - ALL DOMAINS

# What Changed: C02 to C03

Five domains instead of four, a lower passing score, AI in every domain, four scope reversals, and a long list of services that left.

DOMAIN Cross-cutting  EXAM WEIGHT All five  MODULE 50 of 52

admin@sthithapragna.com

C03 is not a refresh of C02. It is organised along a **different axis**, and some correct C02 answers are now **wrong**.

# Exam mechanics

| ITEM | C02 | C03 |
|---|---|---|
| Questions and time | 75 in 180 minutes | 75 in 180 minutes |
| Scored questions | 65, plus 10 unscored | 65, plus 10 unscored |
| Passing score | 750 | 720 |
| Domains | 4 | 5 |
| Guide structure | Knowledge and skills | Numbered skills only |

ON THE EXAM

The 30-point drop in the passing score is real: the 100 to 1000 scale is unchanged.

# Where C02's domains went

| C02 DOMAIN | WEIGHT | MOSTLY BECAME |
|---|---|---|
| Organizational Complexity | 26% | Security, networking, cost visibility |
| New Solutions | 29% | Architecture, plus IaC to operations |
| Continuous Improvement | 25% | Operations, plus posture and reliability |
| Migration and Modernization | 20% | Shares 15% with resilience |

ON THE EXAM

Migration's share roughly halves. Security rises to 25% and operations to 20%.

# New subject areas

| AREA | WHERE IT APPEARS |
| --- | --- |
| AI and ML: Bedrock, SageMaker AI | 12 skills, all five domains |
| Data lakes, Iceberg, Clean Rooms | Task 1.5 |
| Multi-tenant isolation | Skill 1.1.13 |
| Post-quantum: ML-DSA, ML-KEM | Skill 2.2.4 |
| IPv6 and dual-stack | Task 1.4 |
| Responsible AI controls | Task 2.5 |

ON THE EXAM

AI is architected, not built: training and fine-tuning are out of scope.

# Scope reversals

| SERVICE | C02 | C03 |
|---|---|---|
| Amazon VPC Lattice | Out of scope | Skill 1.1.7 |
| AWS Fault Injection Service | Out of scope | Skills 4.3.2, 4.3.5 |
| AWS Resilience Hub | Out of scope | Skills 4.2.3, 4.2.5 |
| Application Recovery Controller | Out of scope | Skill 4.2.4 |

ON THE EXAM

Material that says these are out of scope was right for C02 and is wrong for C03.

# Services that left the in-scope list

| AREA | GONE FROM C03 |
| --- | --- |
| Migration | Migration Hub, Application Discovery Service, Migration Evaluator, Snow Family |
| Security | Macie, Detective, Audit Manager, Firewall Manager, Service Catalog |
| Compute and delivery | Batch, App Runner, Wavelength, Image Builder, SAM, Amplify |
| Cost | Trusted Advisor, Billing Conductor |

> ON THE EXAM
>
> Absent from the list is weaker than explicitly out of scope, but do not choose them as answers.

# Old answers, new answers

| REQUIREMENT | C02-ERA ANSWER | C03 ANSWER |
|---|---|---|
| Ship petabytes physically | Snowball Edge | Data Transfer Terminal |
| Discover and assess servers | Migration Hub, ADS | AWS Transform |
| Rehost servers | Application Migration Service | AWS Transform MGN |
| Chaos testing | Custom scripts | Fault Injection Service |
| Service mesh on EKS | App Mesh | VPC Lattice |
| Quantum-safe key exchange | Not examined | KMS ML-KEM |

ON THE EXAM

If a remembered answer names a closed or renamed service, find its successor.

> A retailer wants to prove its checkout service survives losing an Availability Zone. The test must be repeatable, run in production, and stop automatically if customer errors rise.
>
> A C02-era runbook suggests a script that terminates instances at random.

**What should the solutions architect recommend?**

A. An AWS Fault Injection Service experiment from the AZ availability scenario, with CloudWatch alarm stop conditions

B. The random termination script, run weekly

C. An AWS Resilience Hub assessment only

D. Manually change network ACLs to block one Availability Zone

◆ PAUSE AND DECIDE



admin@sthithapragna.com

## What should the solutions architect recommend?

**A** FIS experiment
Repeatable AZ scenario, stops on alarms.

**B** Random script
*Not an AZ loss, no stop condition.*

**C** Assessment only
*Estimates resilience; does not test it.*

**D** Manual ACL change
*Not repeatable, no automatic stop.*

THE SIGNAL

C02 called FIS out of scope. C03 names it: controlled fault injection with stop conditions.

> A film studio new to AWS must move 400 TB from a site with a 100 Mbps uplink within three weeks. Staff can drive storage media to a nearby city.
>
> A colleague's C02 notes say to order Snowball Edge devices.

**What should the solutions architect recommend?**

A Order Snowball Edge devices

B DataSync over the existing uplink

C Take the media to an AWS Data Transfer Terminal and upload over its high-throughput connection

D Order a 10 Gbps Direct Connect connection

◆ PAUSE AND DECIDE



admin@sthithapragna.com

## What should the solutions architect recommend?

A Snowball Edge

*No longer available to new customers.*

B DataSync

*100 Mbps moves about 22 TB in three weeks.*

C Data Transfer Terminal

AWS's stated physical-transfer replacement.

D Direct Connect

*Weeks to provision; the site still has one uplink.*

THE SIGNAL

New customer, physical transfer: Data Transfer Terminal, not Snowball.

> A manufacturer new to AWS has 800 VMware virtual machines. It needs dependency maps, right-sized recommendations and a wave plan before migrating.
>
> A C02 study guide recommends AWS Migration Hub with Application Discovery Service agents.

**What should the solutions architect recommend?**

A Application Discovery Service agents on every VM

B AWS Transform discovery and assessment

C Migration Evaluator

D Migration Hub Strategy Recommendations

◆ PAUSE AND DECIDE



admin@sthithapragna.com

## What should the solutions architect recommend?

A Discovery Service
*Closed to new customers since Nov 2025.*

B AWS Transform
Discovery, assessment and wave planning, in scope.

C Migration Evaluator
*Off the C03 in-scope list.*

D Strategy Recommendations
*Part of Migration Hub, closed to new customers.*

THE SIGNAL

Discovery and assessment for a new customer: AWS Transform.


admin@sthithapragna.com

> A bank's services run on EKS, ECS and Lambda across 40 VPCs in several accounts. Each call between services must be authorised per request with IAM, with no overlapping-CIDR workarounds.
>
> Its EKS services used AWS App Mesh until last year.

**What should the solutions architect recommend?**

A Amazon VPC Lattice service networks with IAM auth policies

B Re-create the App Mesh configuration

C Transit Gateway with security groups

D A PrivateLink endpoint for every pair of services

◆ PAUSE AND DECIDE



admin@sthithapragna.com

## What should the solutions architect recommend?

**A** VPC Lattice
Mixed compute, cross-VPC, IAM per request.

**B** App Mesh
*Discontinued on 30 September 2026.*

**C** Transit Gateway
*Network reachability, no per-request IAM; CIDRs clash.*

**D** PrivateLink per pair
*Hundreds of endpoints to manage.*

THE SIGNAL

Out of scope in C02, central in C03: VPC Lattice.


admin@sthithapragna.com

> A healthcare group with 50 accounts wants threats detected in every account, and all findings, including vulnerability findings, gathered in one place and prioritised by risk.
>
> A C02 module suggested Amazon Detective and Amazon Macie for this.

**What should the solutions architect design?**

A Amazon Detective in every account

B Amazon Macie for threat detection

C A self-built SIEM on EC2

D GuardDuty and Inspector with delegated administration, aggregated and correlated in AWS Security Hub

◆ PAUSE AND DECIDE

## What should the solutions architect design?

A Detective

*Investigation, not detection; off the in-scope list.*

B Macie

*Finds sensitive data, not threats; off the list.*

C Self-built SIEM

*Heavy operations for a managed capability.*

D GuardDuty, Inspector, Security Hub

Detect, scan, correlate and prioritise centrally.

THE SIGNAL

Detection and aggregation are in scope; forensic investigation is not.

> A government contractor exchanges encrypted data with a partner. Policy now requires that the key exchange resist future quantum attacks, using a NIST standard algorithm.
>
> The private key must stay in a FIPS 140-3 Level 3 HSM, with the least custom cryptography.

## What should the solutions architect use?

A An RSA-4096 key in AWS KMS

B An ECC key agreement in AWS KMS

C An ML-KEM key in AWS KMS, sharing the public key and using Encapsulate and Decapsulate

D An ML-DSA key in AWS KMS

◆ PAUSE AND DECIDE



admin@sthithapragna.com

## What should the solutions architect use?

A RSA-4096

*Not quantum-resistant at any size.*

B ECC agreement

*Not quantum-resistant.*

C ML-KEM in KMS

FIPS 203 key exchange, private key in KMS HSMs.

D ML-DSA

*Signatures, not key exchange.*

THE SIGNAL

Brand new to C03: ML-KEM in KMS, announced one day before the guide was published.



admin@sthithapragna.com

# What to carry out of this module

- **Five domains by concern**; passing score **720**.
- **AI in every domain**: architect it; training is out of scope.
- **Reversals**: Lattice, FIS, Resilience Hub, ARC are in.
- **Gone**: Migration Hub era tools, Snow Family, Macie, Detective.
- A remembered C02 answer naming a departed service is now a distractor.

> ON THE EXAM
>
> Carry the networking, storage and identity knowledge. Re-check everything else.

MODULE 51 · EXAM STRATEGY - ALL DOMAINS

# The Stale Catalogue

Services that closed, ended or were renamed, numbers that moved, and one closure that was reversed. Check the date on every study source.

DOMAIN Cross-cutting  EXAM WEIGHT All five  MODULE 51 of 52

admin@sthithapragna.com

An answer that was right two years ago can now name a service you cannot buy, or a limit that has since changed.

# How AWS retires a service

- **Maintenance:** closed to new customers, no new features; existing customers continue.
- **Sunset:** a published end date, when operations and support stop.
- **Shutdown:** removed entirely, no longer available in any form.
- Check the **AWS Product Lifecycle page** and each service's availability-change page.

> ON THE EXAM
>
> Closed to new customers is the most common state, and the most commonly missed.

# Ended or ending

| SERVICE | STATUS | USE INSTEAD |
|---|---|---|
| AWS App Mesh | Discontinued 30 Sep 2026 | Service Connect, VPC Lattice |
| Amazon Inspector Classic | Support ended 20 May 2026 | Amazon Inspector |
| X-Ray SDKs and daemon | End of support 25 Feb 2027 | OpenTelemetry, ADOT |
| Snowball Edge | Support ends 31 Dec 2026 | DataSync, Data Transfer Terminal |

> ON THE EXAM
>
> The X-Ray service continues. Only its SDKs and daemon are ending.

# Closed to new customers

| SERVICE | CLOSED | USE INSTEAD |
|---|---|---|
| Migration Hub, Discovery Service | 7 Nov 2025 | AWS Transform |
| Migration Hub Refactor Spaces | 7 Nov 2025 | AWS Transform |
| Incident Manager, Change Manager | 7 Nov 2025 | Partner tools |
| CloudTrail Lake | 31 May 2026 | Trails to S3, CloudWatch |
| Timestream for LiveAnalytics | 20 Jun 2025 | Timestream for InfluxDB |
| Simple AD | 30 Jul 2026 | Managed Microsoft AD |

ON THE EXAM

Also closed: Snow Family devices, FSx File Gateway, Mainframe Modernization managed runtime.

# Renamed

| OLD NAME | CURRENT NAME |
| --- | --- |
| AWS Application Migration Service | AWS Transform MGN |
| AWS Security Hub (original) | AWS Security Hub CSPM |
| Route 53 Resolver | Route 53 VPC Resolver |
| Amazon SageMaker | Amazon SageMaker AI |
| Control Tower controls library | Control Catalog |

ON THE EXAM

A rename changes nothing technical. Do not let an unfamiliar name push you off a right answer.

# Numbers that moved

| FACT | OLD | CURRENT |
|---|---|---|
| SAP passing score | 750 | 720 |
| SQS maximum message | 256 KB | 1 MiB |
| EBS gp3 maximum | 16,000 IOPS, 16 TiB | 80,000 IOPS, 64 TiB |
| ACM default validity | 395 days | 198 days |
| SCP policy language | Limited | Full IAM language |

ON THE EXAM

A raised limit removes a workaround. Old material keeps the workaround as the answer.

# One closure reversed

| SERVICE | HISTORY |
| --- | --- |
| AWS CodeCommit | Closed to new customers July 2024 |
| | Back to full GA, November 2025 |
| Scope reversals | Lattice, FIS, Resilience Hub, ARC now examinable |

ON THE EXAM

Staleness runs both ways: a source can wrongly call something closed.

# Triaging your own material

- **Check the date.** Anything before October 2026 predates the C03 guide.
- **Search for departed names**: Snowball, Migration Hub, App Mesh, Inspector Classic.
- **Re-check limits** it quotes, especially SQS, gp3 and certificates.
- If it calls Lattice, FIS or Resilience Hub out of scope, it was written for C02.

> ON THE EXAM
>
> One test catches most stale sources: does it mention ML-KEM in KMS?

> An energy start-up opening its first AWS account needs a managed time-series database for meter readings, queried with a familiar open-source interface.
>
> A design document written in 2024 specifies Timestream for LiveAnalytics.

**What should the solutions architect recommend?**

A Amazon Timestream for LiveAnalytics, as specified

B Amazon Timestream for InfluxDB

C DynamoDB with a custom time-bucketing scheme

D Amazon Keyspaces

◆ PAUSE AND DECIDE

## What should the solutions architect recommend?

A LiveAnalytics
*Closed to new customers since June 2025.*

B Timestream for InfluxDB
Managed, open-source interface, open to new accounts.

C DynamoDB scheme
*Builds a time-series engine by hand.*

D Keyspaces
*Wide-column, not a time-series engine.*

THE SIGNAL

First AWS account plus a closed service: pick the named successor.

> A bank's audit team, new to CloudTrail Lake, wants to run SQL over seven years of API activity from all 80 accounts in its organisation.
>
> The architecture must use services open to new customers.

**What should the solutions architect design?**

A. A CloudTrail Lake event data store for the organisation

B. Amazon Detective

C. CloudTrail event history in each account

D. An organisation trail delivering to S3 in the log archive account, queried with Athena

◆ PAUSE AND DECIDE

## What should the solutions architect design?

A CloudTrail Lake
*Closed to new customers since 31 May 2026.*

B Detective
*Investigation graphs, not SQL; off the list.*

C Event history
*90 days, one account at a time.*

**D Org trail, S3, Athena**
Central, long retention, SQL, open to all.

THE SIGNAL

Organisation-wide SQL over API history for a new customer: org trail to S3 with Athena.

> An order service sends messages of up to 600 KB to a worker fleet through Amazon SQS. A design from 2023 stores each payload in S3 and sends a pointer, using the SQS Extended Client Library.
>
> The team wants the simplest design that works today.

**What should the solutions architect recommend?**

A. Send the messages directly in SQS, which now accepts up to 1 MiB

B. Keep the Extended Client Library with S3 pointers

C. Move to Kinesis Data Streams

D. Compress every payload below 256 KB

◆ PAUSE AND DECIDE

## What should the solutions architect recommend?

A **Direct in SQS**
1 MiB limit since August 2025; no S3 step.

B **Extended client**
*Works, but a workaround for an old limit.*

C **Kinesis**
*Changes the delivery model for no reason.*

D **Compression**
*Extra code to meet a limit that has gone.*

THE SIGNAL

A raised limit retires the workaround: SQS messages up to 1 MiB.

> A reporting database on EC2 needs 40,000 IOPS, 1,000 MiB/s throughput and 20 TiB on one volume. Typical latency is acceptable, and Multi-Attach is not needed.
>
> Cost matters, and a 2023 design guide says anything above 16,000 IOPS needs io2.

**Which volume should the solutions architect choose?**

A. io2 Block Express

B. io1

C. One gp3 volume with 40,000 IOPS and 1,000 MiB/s provisioned

D. Three gp3 volumes striped with RAID 0

◆ PAUSE AND DECIDE

## Which volume should the solutions architect choose?

A io2 Block Express

*Pays for latency and durability not required.*

B io1

*Older and costlier per IOPS.*

C One gp3

Now up to 80,000 IOPS, 2,000 MiB/s, 64 TiB.

D Striped gp3

*A workaround for limits that were raised.*

THE SIGNAL

IOPS alone no longer forces io2: gp3 reaches 80,000 IOPS since September 2025.

> A design studio opening its first AWS account needs a small managed directory so that 30 Windows and Linux instances can join a domain. There is no on-premises directory.
>
> An older reference architecture recommends Simple AD as the cheapest option.

**What should the solutions architect recommend?**

A Simple AD, as recommended

B AD Connector

C Active Directory on self-managed EC2 instances

D AWS Managed Microsoft AD, Standard Edition

◆ PAUSE AND DECIDE

## What should the solutions architect recommend?

A Simple AD

*Closed to new customers since July 2026.*

B AD Connector

*Needs an existing directory to connect to.*

C Self-managed AD

*Not managed; patching and backups are yours.*

D Managed Microsoft AD

Managed, small edition, open to new accounts.

THE SIGNAL

New account, small managed directory: Managed Microsoft AD, not Simple AD.

> A logistics company wants continuous vulnerability scanning of EC2 instances and container images across 120 accounts.
>
> Its security runbook describes Inspector assessment templates and an Inspector agent installed on each instance.

**What should the solutions architect recommend?**

A. Follow the runbook with Inspector Classic assessment templates

B. Amazon Inspector enabled organisation-wide through a delegated administrator, with agentless or SSM-based EC2 scanning and ECR scanning

C. Amazon GuardDuty

D. AWS Config managed rules

◆ PAUSE AND DECIDE

## What should the solutions architect recommend?

A Inspector Classic

*Support ended 20 May 2026.*

B Amazon Inspector

Continuous, org-wide, EC2 and images.

C GuardDuty

*Threat detection, not vulnerability scanning.*

D Config rules

*Configuration, not software vulnerabilities.*

THE SIGNAL

Assessment templates and a dedicated agent describe Inspector Classic, which has ended.

# What to carry out of this module

- **Closed to new customers** is the commonest change. Watch for new accounts.
- **Renames** change nothing technical: Transform MGN, Security Hub CSPM.
- **Raised limits** retire workarounds: SQS 1 MiB, gp3 80,000 IOPS.
- **Reversals** exist: CodeCommit is open again.
- A runbook or notes from before October 2026 need checking.

> ON THE EXAM
>
> Every date in this module was verified in November 2026. Check again if you study later.

MODULE 52 · EXAM STRATEGY - ALL DOMAINS

# Exam Mechanics and Strategy

Seventy-five questions, three hours, five domains and a passing score of 720. How the exam is scored, how to spend the time, and how to read a long stem.

DOMAIN Cross-cutting  EXAM WEIGHT All five  MODULE 52 of 52

admin@sthithapragna.com

# The format, precisely

- **75 questions in 180 minutes.** 65 are scored; 10 are unscored and not identified.
- **Multiple choice:** one correct answer. **Multiple response:** two or more correct out of five or more.
- **Multiple response needs every correct option.** There is no partial credit.
- **Unanswered scores as incorrect**, and guessing carries no penalty.

> ON THE EXAM
>
> About one question in seven does not count, and you cannot tell which. Treat every one as real.

# How it is scored

- **Scaled from 100 to 1,000, with 720 to pass.** C02 needed 750.
- **Compensatory:** you pass on the total, not domain by domain.
- A weak domain can be carried by strong ones, but not a weak heavy one.
- **720 is not 72%.** Scaling adjusts for form difficulty, so aim well clear.

> ON THE EXAM
>
> The section table on your score report is diagnostic. Only the total decides the result.

# Where the questions come from

| DOMAIN | WEIGHT | ABOUT, OF 65 SCORED |
|---|---|---|
| 1 Architecture built for the cloud | 25% | 16 |
| 2 Security, compliance, governance | 25% | 16 |
| 3 Cost-optimized architecture | 15% | 10 |
| 4 Resilience, migration, continuity | 15% | 10 |
| 5 Operational excellence, automation | 20% | 13 |

ON THE EXAM

Half the scored questions come from Domains 1 and 2. Prioritise revision by weight times weakness.

# The time budget

- **2.4 minutes per question** on average; some take forty seconds, some five minutes.
- **Checkpoints:** question 25 by minute 60, question 50 by minute 120.
- **The common failure** is six minutes on one question, then rushing the last twenty.
- **Flag and move at three minutes.** Come back with fresh eyes.

> ON THE EXAM
>
> Two checkpoints catch drift early. You cannot feel elapsed time reliably under pressure.

# Reading a long stem

- **Read the final question first**, then the scenario.
- **Find the constraint sentence**: cost, downtime, deadline, who may change what.
- **Note the superlative:** MOST cost-effective, LEAST operational overhead.
- **Planted details eliminate options.** New to AWS, existing framework, no labels: none is background.

> ON THE EXAM
>
> Most stems contain one sentence that removes two options. Find it before weighing all four.

# C03 clues worth knowing

- **New account or new to AWS** tests closed-to-new-customers services.
- **Changing facts, citations** point to RAG, not customisation.
- **Created by hand, any tool** point past Hooks to SCPs or Config.
- **Never, guarantee** demand preventive controls, not detective ones.
- Training or fine-tuning as the answer to a knowledge problem is usually a distractor.

> ON THE EXAM
>
> Training and fine-tuning models are listed as out of scope for the candidate.

# The day itself

- **Breaks are unscheduled and the clock keeps running.** Decide in advance.
- Online proctoring needs a quiet room and a clear desk; a test centre needs ID.
- **Retakes** require a 14-day wait, so leave room before any deadline.
- Fatigue is the real adversary at three hours. Sleep beats a final evening of revision.

> ON THE EXAM
>
> Check the AWS certification page before booking. These details were recorded in November 2026.

> At the 100-minute mark you have completed 38 questions, and six are flagged. The scenarios are long but not conceptually hard.
>
> There are 80 minutes and 37 questions left.

## What should you do?

A Speed up to about two minutes per remaining question, and leave the six flagged questions until the end

B Go back and resolve the six flagged questions now

C Keep the current pace and accept leaving some unanswered

D Skip ahead and answer only the easiest remaining questions

◆ PAUSE AND DECIDE

## What should you do?

**A** Speed up, defer flags

37 in about 74 minutes leaves time for the flags.

**B** Flags now

*Spends scarce time before every question is seen.*

**C** Same pace

*Blank answers score zero.*

**D** Easiest only

*Leaves points on the table.*

THE SIGNAL

Behind the checkpoint: speed up, see every question, return to flags last.

> A question says Select TWO. You are confident about one option and cannot decide between two others. You have spent two and a half minutes.
>
> Multiple response needs every correct option for credit.

## What should you do?

A. Select only the option you are sure of

B. Spend another three minutes working it out

C. Select your confident option plus the more likely of the other two, flag it, and move on

D. Leave it blank and return at the end

◆ PAUSE AND DECIDE

## What should you do?

A One selection

*Certain to score zero.*

B Three more minutes

*Breaks the time budget for a coin flip.*

C Best guess, flag, move

A fair chance now, and a second look later.

D Blank

*Zero if time runs out.*

THE SIGNAL

**No partial credit: always select the full number asked for.**

> Two options remain. One adds a CloudFormation Guard Hook; the other adds an AWS Config rule with automatic remediation. You have re-read both options twice.
>
> You have not re-read the scenario.

## What should you do?

A Choose the Hook, since preventing is better than fixing

B Choose the Config rule, since it covers more

C Guess and move on immediately

D Re-read the requirement for how resources are created, such as the console or the CLI, and when the check must happen

◆ PAUSE AND DECIDE

## What should you do?

A Always the Hook

*Misses anything made outside CloudFormation.*

B Always Config

*Fails a before-provisioning requirement.*

C Guess

*The deciding words are already on screen.*

D Re-read the requirement

The pair is settled by how and when.

THE SIGNAL

Stuck between a pair: the divider is in the requirement, not in the options.

> With three minutes left, four flagged questions are unanswered. All are long, and reading one properly would take most of the time.
>
> There is no penalty for guessing.

## What should you do?

A Answer all four with quick best guesses, then reconsider one if time remains

B Read one carefully and leave three blank

C Read two quickly and answer only those

D Leave them blank, since wrong answers count against you

◆ PAUSE AND DECIDE

## What should you do?

A **Guess all four first**
Each guess has a chance; blanks have none.

B **One careful answer**
*Three certain zeros.*

C **Two quick answers**
*Two certain zeros.*

D **Leave blank**
*Wrong answers are not penalised.*

THE SIGNAL

**Final minutes: fill every blank first, then improve answers.**

> A practice exam returns these domain scores: Domain 1 72%, Domain 2 58%, Domain 3 60%, Domain 4 75%, Domain 5 70%.
>
> The real exam is in ten days.

**Where should most of the remaining revision go?**

A Spread evenly across all five domains

B Domain 3, since it is close to the weakest

C Domain 2, since it is the weakest and carries 25% of the exam

D More full practice exams until the score rises

◆ PAUSE AND DECIDE

## Where should most of the remaining revision go?

A Even spread

*Wastes time on strong domains.*

B Domain 3

*Similar gap, but only 15% of questions.*

C Domain 2

Largest gap times largest weight.

D More practice exams

*Measures the gap without closing it.*

THE SIGNAL

Revise by weight times weakness: Domain 2 here, Domain 3 second.

> An architect earned the SAP-C02 certification in March 2025. It is now November 2026, and C02 is no longer offered.
>
> She asks whether her certification has lapsed and what she must do to keep it.

**What is the correct advice?**

A. It lapsed when C02 retired; she must sit C03 immediately

B. It stays valid until its three-year expiry; she recertifies by passing the current version, C03, before then

C. It converts automatically to a C03 certification

D. She must sit C02 again before it expires

◆ PAUSE AND DECIDE

## What is the correct advice?

A Lapsed

*Retiring an exam does not cancel certifications.*

B Valid, recertify on C03

Three years from passing; recertify on the current exam.

C Converts

*No automatic conversion.*

D Sit C02 again

*C02 is no longer offered.*

THE SIGNAL

The credential is Solutions Architect Professional. The exam version only changes how you earn it.

# What to carry out of this module

- **Never leave a question blank**, and always select the full number asked for.
- **Checkpoints:** question 25 by minute 60, question 50 by minute 120.
- **Question first, then stem**; find the constraint and the superlative.
- **Revise by weight times weakness**; 720 passes on the total.
- Thank you for taking the course, and good luck.

> ON THE EXAM
>
> Practice exams follow: five domain papers and a full 75-question mock.

MODULE 53 · DOMAIN 1 - ARCHITECTURE BUILT FOR THE CLOUD

# Practice Exam: Domain 1

Fifteen original questions on architecture built for the cloud. Pause, decide, then watch.

DOMAIN 1 of 5 EXAM WEIGHT 25% SET 1 of 6

admin@sthithapragna.com

# How to use this set

- **Allow 2.4 minutes per question**: 36 minutes for the set.
- **Write your answer down** before you unpause.
- **Mark the ones you guessed**, even when the guess was right.
- The last slide maps every question to the module that teaches it.

> ON THE EXAM
>
> A correct guess is a gap you have not closed yet. Count it as a miss.

An online retailer publishes order events. Three teams consume them independently: fraud scoring, analytics and fulfilment.

After a bug, the analytics team must be able to reprocess the previous seven days of events without affecting the other teams.

## Which service should carry the events?

A Amazon Kinesis Data Streams with retention extended to seven days

B An SQS FIFO queue shared by all three teams

C An SNS topic with an SQS queue per team

D EventBridge with a rule per team

◆ PAUSE AND DECIDE

# Which service should carry the events?

**A** Kinesis, 7-day retention

Independent readers, each able to replay history.

**B** Shared FIFO queue

*One worker pool; messages leave once consumed.*

**C** SNS fan-out to SQS

*Fan-out works, but deleted messages cannot be replayed.*

**D** EventBridge rules

*Routes events; no seven-day replay per consumer.*

THE SIGNAL

Several independent readers plus replay: a stream. Module 01.

> A lender's loan workflow calls a credit bureau, then waits for an underwriter to approve. Approval can take up to five days, and the step must escalate if nobody responds in 48 hours.
>
> The team wants the least custom code.

**What should the solutions architect use?**

A. A Lambda function that polls a DynamoDB table for the approval

B. Step Functions Express workflow with a Wait state

C. Step Functions Standard workflow with a task token, a timeout and a Catch that escalates

D. An SQS delay queue that re-checks every 15 minutes

◆ PAUSE AND DECIDE

## What should the solutions architect use?

A Polling Lambda
*Custom polling code and state.*

B Express workflow
*Express runs last at most five minutes; no callbacks.*

C Standard, task token
Waits days for a callback; timeout drives escalation.

D SQS delay queue
*Custom re-check loop.*

THE SIGNAL

Waiting days for a person: Standard with a task token. Module 02.

A media company runs EKS with 14 managed node groups, one per instance type. Pods wait several minutes for capacity during spikes, and nodes are often half empty.

The platform team wants faster scale-out and better packing, with as little node management as possible.

## What should the solutions architect recommend?

A Add more node groups with larger instance types

B EKS Auto Mode, which manages Karpenter-based provisioning for the cluster

C Increase the Cluster Autoscaler scan interval

D Move all workloads to Fargate profiles

◆ PAUSE AND DECIDE

## What should the solutions architect recommend?

A More node groups

*More sprawl, same slow scale-out.*

B EKS Auto Mode

Fast, right-sized nodes; AWS manages provisioning.

C Tune Cluster Autoscaler

*Tuning does not fix group-based bin-packing.*

D All Fargate

*Removes nodes but loses DaemonSets, GPUs, some features.*

THE SIGNAL

Slow scale-out, poor packing, node group sprawl: Karpenter, or Auto Mode to have it managed. Module 03.

A payments API runs behind an Application Load Balancer that uses path-based routing. A bank partner will only connect to two fixed IP addresses on its firewall allow-list.

The ALB's routing rules must stay as they are.

**What should the solutions architect add?**

A Replace the ALB with a Network Load Balancer

B Elastic IP addresses attached to the ALB

C A CloudFront distribution in front of the ALB

D AWS Global Accelerator with the ALB as its endpoint

◆ PAUSE AND DECIDE

## What should the solutions architect add?

A Replace with NLB

*Loses the ALB's path-based routing.*

B Elastic IPs on ALB

*An ALB cannot take Elastic IP addresses.*

C CloudFront

*CloudFront IP addresses change.*

D Global Accelerator

Two static anycast IPs, ALB unchanged.

THE SIGNAL

Fixed IPs, keep the ALB: Global Accelerator in front of it. Module 04.

A SaaS provider stores every tenant's documents in one S3 bucket under tenant prefixes. A large tenant requires the ability to revoke the provider's access to its data at any time, immediately.

Other tenants have no such requirement.

**What should the solutions architect design for that tenant?**

A. A separate prefix with a stricter bucket policy

B. SSE-S3 encryption with versioning

C. Encrypt that tenant's objects with a KMS key owned by the tenant's account, which the tenant can disable

D. A separate IAM role for the tenant's data

◆ PAUSE AND DECIDE

## What should the solutions architect design for that tenant?

A Stricter prefix policy

*The provider controls the policy, so can change it.*

B SSE-S3

*AWS-managed key; the tenant controls nothing.*

C Tenant-owned KMS key

Tenant disables the key; data becomes unreadable.

D Separate IAM role

*The provider controls the role.*

THE SIGNAL

A tenant who must be able to revoke access needs a key it controls. Module 05.

A European insurer uses Amazon Bedrock in eu-central-1. Peak traffic now exceeds the Region's on-demand throughput for its model.

Regulation requires that prompts and responses are processed only within the EU.

**What should the solutions architect configure?**

A. A geographic cross-Region inference profile for the EU

B. A global cross-Region inference profile

C. Call the model in us-east-1 when eu-central-1 throttles

D. Purchase Provisioned Throughput in us-west-2

◆ PAUSE AND DECIDE

## What should the solutions architect configure?

A EU geographic profile
Spreads load across EU Regions only.

B Global profile
*May route outside the EU.*

C Fail over to us-east-1
*Processes data in the US.*

D Provisioned in us-west-2
*Processes data in the US.*

THE SIGNAL

Residency plus more throughput: a geographic cross-Region inference profile. Module 06.

A publisher wants retrieval-augmented generation over 60 million archived articles. Queries are rare, a few hundred a day, and a second of latency is acceptable.

Storage cost for the vectors must be as low as possible, with a managed Bedrock knowledge base.

## Which vector store should the knowledge base use?

A Amazon OpenSearch Serverless

B Aurora PostgreSQL with pgvector

C Amazon Neptune Analytics

D Amazon S3 Vectors

◆ PAUSE AND DECIDE

# Which vector store should the knowledge base use?

A OpenSearch Serverless

*Fast and busy-friendly; costly for cold scale.*

B Aurora pgvector

*A database to size and run for rare queries.*

C Neptune Analytics

*Graph analytics, not the cost-optimised choice.*

D S3 Vectors

Lowest-cost store for large, rarely queried vectors.

THE SIGNAL

Huge and rarely queried: S3 Vectors. Busy and interactive: OpenSearch. Module 07.

A manufacturer must connect its data centre to AWS within one week for a migration pilot. Within three months it will need a steady 5 Gbps with predictable latency.

Connectivity must survive the failure of either path.

**What should the solutions architect plan?**

A Order Direct Connect now and wait for it before starting the pilot

B Site-to-Site VPN now; add Direct Connect later and keep the VPN as backup

C Two Site-to-Site VPN connections as the permanent design

D A single 10 Gbps Direct Connect connection with no backup

◆ PAUSE AND DECIDE

## What should the solutions architect plan?

A Wait for Direct Connect
*Misses the one-week deadline.*

B VPN now, DX later, VPN backup
Fast start, then steady throughput with resilience.

C VPN permanently
*No predictable latency; VPN tunnels cap throughput.*

D Single DX
*One path; fails the resilience requirement.*

THE SIGNAL

Needed this week: VPN. Sustained and predictable: Direct Connect. Most answers use both. Module 08.

> Applications in a corporate data centre must resolve names in a Route 53 private hosted zone associated with a shared-services VPC. The data centre is connected by Direct Connect.
>
> On-premises DNS servers run Windows Server.

**What should the solutions architect configure?**

A. A Route 53 VPC Resolver inbound endpoint, with on-premises conditional forwarders pointing to it

B. A Route 53 VPC Resolver outbound endpoint with a forwarding rule

C. Make the hosted zone public

D. Copy the records into on-premises DNS each night

◆ PAUSE AND DECIDE

## What should the solutions architect configure?

**A** Inbound endpoint
On premises asks; inbound receives the queries.

**B** Outbound endpoint
*For AWS resolving on-premises names.*

**C** Public zone
*Exposes internal names.*

**D** Nightly copy
*Stale records, manual work.*

THE SIGNAL

Who needs the answer decides the endpoint: on premises asking means inbound. Module 09.

A logistics group operates in 12 AWS Regions. Every Region needs the same three network segments, production, development and shared services, with production isolated from development.

The network team wants one policy document to define the global network, not separate route tables per Region.

**What should the solutions architect use?**

A. A Transit Gateway in each Region with peering and per-Region route tables

B. VPC peering between every pair of VPCs

C. AWS Cloud WAN with a core network policy defining the segments

D. A single Transit Gateway in one Region

◆ PAUSE AND DECIDE

## What should the solutions architect use?

A TGW per Region, peered
*Works, but segments managed per Region by hand.*

B Full-mesh peering
*Unmanageable at this scale.*

C Cloud WAN
One policy defines segments in every Region.

D One Transit Gateway
*Transit Gateway is regional.*

THE SIGNAL

Many Regions, same segments, one policy: Cloud WAN. Module 10.

A bank must inspect all traffic between VPCs and to the internet using a specific third-party firewall product. It already owns licences for that product.

The design must scale the appliances horizontally and keep flows symmetric.

**What should the solutions architect use?**

A AWS Network Firewall in a central inspection VPC

B Security groups and network ACLs only

C AWS WAF on every load balancer

D A Gateway Load Balancer in front of the third-party appliances in an inspection VPC

◆ PAUSE AND DECIDE

## What should the solutions architect use?

A Network Firewall

*Managed, but not the named third-party product.*

B SGs and NACLs

*Not deep inspection.*

C AWS WAF

*Web requests only, not all traffic.*

D Gateway Load Balancer

Scales third-party appliances, keeps flows symmetric.

THE SIGNAL

A named third-party firewall or existing licences: Gateway Load Balancer. Module 11.

A trading platform writes account balances in two Regions. If a Region fails, no committed write may be lost, and a read in either Region must return the latest balance.

The team already uses DynamoDB.

**What should the solutions architect configure?**

A DynamoDB global tables with eventual consistency

B DynamoDB global tables with multi-Region strong consistency

C A single-Region table with cross-Region backups

D DynamoDB Streams replicating to a second table by Lambda

◆ PAUSE AND DECIDE

## What should the solutions architect configure?

A Global tables, eventual

*Recent writes can be lost; reads can be stale.*

B Global tables, MRSC

RPO zero, latest read anywhere.

C Backups

*RPO of the backup interval.*

D Streams and Lambda

*Asynchronous, custom, lossy.*

THE SIGNAL

RPO zero and read-your-latest-write in any Region: MRSC. Chosen at creation. Module 12.

A retailer's data lake holds customer orders as Parquet files in S3. Under GDPR, it must delete individual customers' rows within days of a request, and nightly jobs upsert changed orders.

The data team does not want to run compaction or snapshot clean-up jobs.

**What should the solutions architect recommend?**

A Rewrite whole Parquet partitions for every deletion

B Move the lake into Amazon Redshift

C Store the tables as Apache Iceberg in Amazon S3 Tables

D Self-managed Apache Iceberg tables with scheduled maintenance jobs

◆ PAUSE AND DECIDE

## What should the solutions architect recommend?

A Rewrite partitions

*Slow, error-prone, conflicts with writers.*

B Move to Redshift

*A large change for a table-format problem.*

C Iceberg in S3 Tables

Row-level deletes and upserts, maintenance managed.

D Self-managed Iceberg

*Works, but runs the maintenance they want to avoid.*

THE SIGNAL

Row-level deletes or upserts on the lake: Iceberg. Without running maintenance: S3 Tables. Module 13.

A healthcare company's services run on EC2, ECS and Lambda across 25 VPCs in eight accounts. Some VPCs have overlapping CIDR ranges.

Each service-to-service call must be authorised with IAM, and teams want to avoid managing routing between VPCs.

**What should the solutions architect recommend?**

A Amazon VPC Lattice service networks shared with AWS RAM, with IAM auth policies

B Transit Gateway with re-addressed VPCs

C ECS Service Connect across all services

D A PrivateLink endpoint service for every service

◆ PAUSE AND DECIDE

## What should the solutions architect recommend?

**A** VPC Lattice
Mixed compute, overlapping CIDRs, IAM per request.

**B** Transit Gateway
*Re-addressing work, no per-request IAM.*

**C** Service Connect
*ECS only.*

**D** PrivateLink per service
*Hundreds of endpoints, no shared auth model.*

THE SIGNAL

Mixed compute, crossing VPCs, or per-request IAM authorisation: VPC Lattice. Module 04.

> A subscription service processes renewals with Lambda functions reading from an SQS FIFO queue with content-based deduplication. Occasionally a function charges a card and then times out, and the message is processed again.
>
> Some customers have been charged twice.

**What should the solutions architect change?**

A Increase the deduplication interval

B Make the charge idempotent by recording a renewal ID with a conditional write before charging, and checking it on retry

C Switch to a standard SQS queue

D Set the maximum receive count to one

◆ PAUSE AND DECIDE

## What should the solutions architect change?

A Longer dedup window

*The deduplication interval is fixed, and it stops duplicate sends only.*

B Idempotent consumer

A retry finds the record and skips the charge.

C Standard queue

*Adds duplicates rather than removing them.*

D Max receives one

*Sends failures to the dead-letter queue, losing renewals.*

THE SIGNAL

Broker deduplication stops duplicate sends. Only an idempotent consumer stops duplicate effects. Module 01.

# Where to revisit

| IF YOU MISSED | REWATCH |
|---|---|
| Q1, Q15 | Module 01: Event-driven architecture |
| Q2 | Module 02: Stateless design and durable workflows |
| Q3 | Module 03: Containers and orchestration |
| Q4, Q14 | Module 04: Service mesh and ingress |
| Q5 | Module 05: Edge and multi-tenant isolation |
| Q6, Q7 | Modules 06-07: Bedrock, RAG and inference |
| Q8, Q9 | Modules 08-09: Hybrid connectivity and DNS |
| Q10, Q11 | Modules 10-11: Multi-VPC and network security |
| Q12, Q13 | Modules 12-13: Databases and data lakes |

ON THE EXAM

12 or more out of 15 is on track for this domain. Below 9, rewatch before the next set.

MODULE 54 · DOMAIN 2 - SECURITY, COMPLIANCE, AND GOVERNANCE

# Practice Exam: Domain 2

Fifteen original questions on security, compliance and governance.
Pause, decide, then watch.

DOMAIN 2 of 5  EXAM WEIGHT 25%  SET 2 of 6

admin@sthithapragna.com

# How to use this set

- **Allow 2.4 minutes per question**: 36 minutes for the set.
- **Write your answer down** before you unpause.
- **Watch for absolutes**: never, guarantee, any principal.
- The last slide maps every question to the module that teaches it.

> ON THE EXAM
>
> Security distractors are usually right about the control and wrong about who it applies to.

> A company with 200 AWS accounts uses Microsoft Entra ID for its workforce. Staff must sign in once and reach any account they are entitled to.
>
> Joiners and leavers must appear in AWS automatically, without scripts.

**What should the solutions architect implement?**

A. A SAML identity provider in each of the 200 accounts

B. IAM Identity Center with Entra ID as the external identity provider and SCIM provisioning

C. IAM users synchronised nightly from Entra ID

D. Amazon Cognito user pools federated with Entra ID

◆ PAUSE AND DECIDE

## What should the solutions architect implement?

A SAML per account
*200 providers to maintain; no provisioning.*

B Identity Center with SCIM
One sign-in, permission sets, automatic provisioning.

C Synced IAM users
*Long-term credentials and a script.*

D Cognito
*For application users, not workforce access to AWS.*

THE SIGNAL

Many accounts, workforce sign-in, automatic joiners and leavers: Identity Center with SCIM. Module 14.

A government agency is joining EC2 Windows instances to its on-premises Active Directory. Its security policy states that no directory data, including password hashes, may be stored in AWS.

Users must sign in with their existing domain credentials.

**What should the solutions architect use?**

A AWS Managed Microsoft AD with a trust to on-premises

B A read-only domain controller on EC2

C Simple AD

D AD Connector

◆ PAUSE AND DECIDE

## What should the solutions architect use?

A Managed AD with trust

*Stores a directory in AWS.*

B RODC on EC2

*Caches directory data in AWS.*

C Simple AD

*A separate directory in AWS; closed to new customers.*

D AD Connector

A proxy: stores nothing, authenticates on premises.

THE SIGNAL

No directory data may live in AWS: AD Connector. Module 14.

A fitness app lets signed-in users upload workout videos from their phones directly to S3. Each user writes to a prefix named after their own user ID.

Users sign up with email or with Google.

## What should the solutions architect use?

A. A Cognito user pool for sign-in, and a Cognito identity pool granting temporary credentials scoped to each user's prefix

B. An IAM user per app user

C. A Cognito user pool only, with the app calling S3 using the pool's tokens

D. Embed an access key in the mobile app

◆ PAUSE AND DECIDE

## What should the solutions architect use?

**A** User pool plus identity pool

Sign-in, then scoped AWS credentials per user.

**B** IAM user each

*Does not scale; long-term keys.*

**C** User pool only

*User pool tokens cannot sign S3 requests.*

**D** Embedded key

*Shared secret in every phone.*

THE SIGNAL

Users calling AWS services directly, such as S3: add an identity pool. Module 15.

> An insurer has six microservices, each with its own copy of the rules deciding which brokers may view or amend which policies. The copies have drifted, and auditors cannot read them.
>
> The company wants one place to define and evaluate these rules.

**What should the solutions architect recommend?**

A IAM policies for each broker

B A shared library of authorisation code

C Amazon Verified Permissions, with the rules written as Cedar policies

D API Gateway resource policies

◆ PAUSE AND DECIDE

## What should the solutions architect recommend?

A IAM per broker

*IAM governs AWS APIs, not application records.*

B Shared library

*Still code, still unreadable, redeployed everywhere.*

C Verified Permissions

Central, readable policies evaluated by every service.

D API resource policies

*Coarse; cannot express per-record rules.*

THE SIGNAL

The same rules duplicated across services, or auditors needing to read them: Verified Permissions. Module 15.

A third-party monitoring vendor needs read-only access to a company's AWS account. The vendor serves thousands of customers from its own AWS account.

The company wants to stop another of the vendor's customers from tricking the vendor into using the company's role.

## What should the trust policy include?

A. A condition requiring an ExternalId value unique to this company

B. A condition on aws:SourceArn

C. MFA required for the vendor

D. A permissions boundary on the role

◆ PAUSE AND DECIDE

## What should the trust policy include?

**A** ExternalId

Prevents the confused deputy for a vendor role.

**B** SourceArn

*For AWS service principals, not a vendor account.*

**C** Require MFA

*The vendor's automation cannot do MFA.*

**D** Permissions boundary

*Limits permissions; does not stop misuse of the role.*

THE SIGNAL

A vendor assuming your role: ExternalId. AWS service principals: SourceArn and SourceAccount. Module 16.

A platform team lets developers create IAM roles for their Lambda functions. A developer recently created a role with administrator access and used it.

Developers must keep creating roles, but no role they create may exceed a defined set of permissions.

**What should the solutions architect implement?**

A Remove iam:CreateRole from developers

B Allow role creation only when a specific permissions boundary is attached, and deny removing it

C An AWS Config rule that flags administrator roles

D A service control policy denying AdministratorAccess

◆ PAUSE AND DECIDE

## What should the solutions architect implement?

A Remove CreateRole

*Stops the work the team needs.*

B Required permissions boundary

Every created role is capped by the boundary.

C Config rule

*Detects after the fact.*

D SCP on one policy

*Blocks one policy; custom policies still escalate.*

THE SIGNAL

Let teams create their own roles, but require a boundary on every role they create. Module 16.

A retailer's contractors need access to three internal web applications in a VPC. They must not get a VPN or network-level access.

Access must depend on the user's identity and on the posture of their device.

**What should the solutions architect use?**

A AWS Client VPN with security groups

B Make the applications public behind AWS WAF

C AWS Verified Access with identity and device trust providers

D A bastion host

◆ PAUSE AND DECIDE

## What should the solutions architect use?

A Client VPN

*Network access, which is ruled out.*

B Public with WAF

*Exposes the applications to the internet.*

C Verified Access

Per-application, identity and device checks, no VPN.

D Bastion host

*Network access and a host to run.*

THE SIGNAL

Per-application access with device posture and no VPN: Verified Access. Module 17.

A bank's regulator requires that encryption keys for its data reside in single-tenant HSMs under the bank's exclusive control.

The bank still wants S3, EBS and RDS to encrypt data natively, with no application changes.

**What should the solutions architect implement?**

A AWS KMS with the default key store

B Client-side encryption in every application using CloudHSM

C SSE-S3 with versioning

D An AWS KMS custom key store backed by an AWS CloudHSM cluster

◆ PAUSE AND DECIDE

## What should the solutions architect implement?

A Default KMS key store

*Multi-tenant HSMs.*

B Client-side with CloudHSM

*Meets the HSM rule but changes every application.*

C SSE-S3

*AWS-owned keys.*

D KMS custom key store

Keys in your CloudHSM; services use KMS as normal.

THE SIGNAL

Dedicated HSM plus native AWS service encryption: a custom key store. Module 18.

A medical device maker signs firmware updates. The devices will be in service for 20 years, and regulators expect signatures to stay trustworthy against future quantum computers.

The private key must never leave AWS-managed hardware.

**What should the solutions architect use?**

A An RSA-4096 signing key in AWS KMS

B An ML-DSA signing key in AWS KMS

C An ML-KEM key in AWS KMS

D An ECC P-384 signing key in AWS KMS

◆ PAUSE AND DECIDE

## What should the solutions architect use?

A RSA-4096
*Not quantum-resistant.*

B ML-DSA
Post-quantum signatures, key held in KMS.

C ML-KEM
*Key establishment, not signatures.*

D ECC P-384
*Not quantum-resistant.*

THE SIGNAL

Proving origin or integrity: ML-DSA. Keeping data secret: ML-KEM. Module 19.


admin@sthithapragna.com

> No principal outside a company's organisation may ever access its S3 buckets or KMS keys, in any account. This must hold even if a developer writes a permissive bucket or key policy.
>
> Partners inside the organisation must keep access.

**What should the solutions architect implement?**

A. A resource control policy denying access unless aws:PrincipalOrgID matches the organisation

B. A service control policy on every OU

C. An AWS Config rule with automatic remediation

D. IAM Access Analyzer external access findings

◆ PAUSE AND DECIDE

## What should the solutions architect implement?

**A** RCP on PrincipalOrgID

Caps the resources, whatever their policies say.

**B** SCP on every OU

*Governs your identities, not outsiders.*

**C** Config remediation

*Fixes after exposure.*

**D** Access Analyzer

*Reports exposure; does not prevent it.*

THE SIGNAL

Outsiders reaching your resources: an RCP. Your own identities: an SCP. Module 20.

A financial group must keep CloudTrail logs from 80 accounts and every Region for seven years. Nobody, including administrators in the log archive account, may delete or alter them during that time.

Control Tower is deployed.

**What should the solutions architect implement?**

A. A trail in each account writing to its own bucket

B. CloudWatch Logs with seven-year retention in each account

C. An organisation trail to a bucket with S3 Object Lock in governance mode

D. An organisation trail to the log archive bucket with S3 Object Lock in compliance mode and a seven-year retention

◆ PAUSE AND DECIDE

## What should the solutions architect implement?

A Trail per account

*Local administrators can delete their logs.*

B CloudWatch retention

*Administrators can delete log groups.*

C Object Lock governance

*Privileged users can override governance mode.*

D Object Lock compliance

Nobody can delete or shorten retention.

THE SIGNAL

Nobody, including administrators: compliance mode, not governance. Module 21.

A company patches EC2 instances in its Auto Scaling groups every month with Patch Manager. After each scale-out, new instances launch unpatched, and scanners flag them.

The company wants every instance compliant from the moment it launches.

**What should the solutions architect change?**

A Run Patch Manager every hour

B Disable scale-out between patch windows

C Build a patched AMI on a schedule, update the launch template, and roll it out with instance refresh

D Patch new instances with a user data script

◆ PAUSE AND DECIDE

## What should the solutions architect change?

A Hourly patching
*New instances still launch unpatched.*

B Freeze scaling
*Sacrifices availability.*

C Patched AMI, instance refresh
Instances launch already patched.

D User data patching
*Slow boots; a window before patching completes.*

THE SIGNAL

Auto Scaling groups and containers: rebuild the image. Long-lived servers: patch in place. Module 22.

A hospital group's auditor asks for AWS's SOC 2 report and for the hospital's signed Business Associate Addendum with AWS.

The compliance team wants to provide both without opening a support case.

**Where should the team get them?**

A AWS Artifact

B AWS Audit Manager

C AWS Security Hub CSPM

D AWS Config conformance packs

◆ PAUSE AND DECIDE

## Where should the team get them?

**A** AWS Artifact
AWS's reports and agreements, on demand.

**B** Audit Manager
*Collects evidence of your controls; off the in-scope list.*

**C** Security Hub CSPM
*Your posture against standards.*

**D** Conformance packs
*Your configuration compliance.*

THE SIGNAL

AWS's own certifications or a BAA: AWS Artifact. Proof of your controls: your own data. Module 23.


admin@sthithapragna.com

> An HR assistant built on Amazon Bedrock answers questions about leave entitlement. Answers must be checked against the written leave policy, and any answer that breaks a policy rule must be flagged.
>
> HR wants an explanation of which rule was broken.

**What should the solutions architect configure?**

A. A guardrail content filter for misconduct

B. Contextual grounding checks only

C. A larger model

D. Automated Reasoning checks in Amazon Bedrock Guardrails, built from the policy document

◆ PAUSE AND DECIDE


admin@sthithapragna.com

## What should the solutions architect configure?

A Content filter

*Harmful content, not policy logic.*

B Contextual grounding

*Checks support by sources; gives no rule-level explanation.*

C Larger model

*No verification at all.*

D Automated Reasoning checks

Verifies against the rules, explains what failed.

THE SIGNAL

Verifiable against written rules, with an explanation of which rule failed: Automated Reasoning. Module 24.

> A customer service agent on Amazon Bedrock can issue refunds. Refunds above 500 dollars must be approved by a supervisor, who may respond hours later.
>
> If no supervisor responds within four hours, the request must escalate to a manager.

**What should the solutions architect implement?**

A Ask the customer to confirm the refund in the chat

B A guardrail that blocks refunds above 500 dollars

C A Step Functions Standard workflow that pauses on a task token for the supervisor, with a timeout that escalates

D Log large refunds for a weekly review

◆ PAUSE AND DECIDE

## What should the solutions architect implement?

A Customer confirms
*The customer is not the approver.*

B Guardrail block
*Blocks rather than routes for approval.*

C Step Functions task token
Waits hours for a separate reviewer, then escalates.

D Weekly review
*Approval after the money has gone.*

THE SIGNAL

A separate reviewer, possibly hours later, with escalation: Step Functions with a task token. Module 24.

# Where to revisit

| IF YOU MISSED | REWATCH |
|---|---|
| Q1, Q2 | Module 14: Identity and federation |
| Q3, Q4 | Module 15: Application authentication |
| Q5, Q6 | Module 16: Least privilege |
| Q7 | Module 17: Data perimeters and zero trust |
| Q8, Q9 | Modules 18-19: Encryption and post-quantum |
| Q10 | Module 20: Organisation guardrails |
| Q11, Q12 | Modules 21-22: Logging and patching |
| Q13 | Module 23: Residency and evidence |
| Q14, Q15 | Module 24: Responsible AI |

ON THE EXAM

12 or more out of 15 is on track. Domain 2 is 25% of the exam, so gaps here cost the most.

MODULE 55 · DOMAIN 3 - COST-OPTIMIZED ARCHITECTURE DESIGN

# Practice Exam: Domain 3

Fifteen original questions on cost-optimised architecture. Pause, decide, then watch.

DOMAIN 3 of 5  EXAM WEIGHT 15%  SET 3 of 6

admin@sthithapragna.com

# How to use this set

- **Allow 2.4 minutes per question**: 36 minutes for the set.
- **Write your answer down** before you unpause.
- **The cheapest option must still meet every requirement.**
- The last slide maps every question to the module that teaches it.

> ON THE EXAM
>
> A cost answer that breaks a requirement is wrong, however cheap it is.

A ticketing company runs 60 instances all year. For a three-day sale it needs 200 more instances of one type in one Availability Zone, and launches must not fail.

It wants the lowest cost for the year-round fleet.

**What should the solutions architect recommend?**

A. A Compute Savings Plan sized for 260 instances

B. Spot Instances for the sale

C. Reserved Instances for 260 instances

D. An On-Demand Capacity Reservation for the sale, and a Savings Plan covering the year-round 60

◆ PAUSE AND DECIDE

## What should the solutions architect recommend?

A Savings Plan for 260
*No capacity guarantee; pays for 200 idle all year.*

B Spot for the sale
*Can be interrupted or unavailable.*

C RIs for 260
*Commits a year for a three-day need.*

D Reservation plus Savings Plan
Guaranteed launches; discount on the steady base.

THE SIGNAL

A Savings Plan never guarantees capacity. Reserve for the event, commit for the baseline. Module 25.

A company runs EC2 instances across several families, plus Fargate tasks and Lambda functions. Over the next three years it expects to change instance families and possibly move workloads to another Region.

Spend is steady at about 40 dollars an hour.

## Which commitment gives the most flexibility?

A EC2 Instance Savings Plans

B Compute Savings Plans

C Standard Reserved Instances

D Convertible Reserved Instances

◆ PAUSE AND DECIDE

## Which commitment gives the most flexibility?

A EC2 Instance SP

*Locked to a family in a Region.*

B Compute Savings Plans

Any family, size, Region, plus Fargate and Lambda.

C Standard RIs

*Fixed attributes; EC2 only.*

D Convertible RIs

*Exchangeable, but EC2 only.*

THE SIGNAL

Changing families, Regions, or using Fargate and Lambda: Compute Savings Plans. Module 25.

A company spends steadily on Amazon RDS for PostgreSQL and Aurora MySQL. Next year it plans to move some databases between engines and instance families.

It wants a commitment discount that survives those moves.

**What should the solutions architect recommend?**

A Database Savings Plans

B RDS Reserved Instances for each current instance

C Compute Savings Plans

D Aurora Serverless for everything

◆ PAUSE AND DECIDE

## What should the solutions architect recommend?

**A** Database Savings Plans
Applies across engines and instance families.

**B** RDS Reserved Instances
*Tied to engine, family and Region.*

**C** Compute Savings Plans
*Do not apply to database services.*

**D** Move to serverless
*Not a commitment discount; may cost more.*

THE SIGNAL

Database spend that will change engines or families: Database Savings Plans. Module 25.

A research group runs nightly genome analysis jobs that checkpoint every few minutes and can restart. Jobs can run on many instance types.

The group wants the lowest compute cost with few interruptions.

**What should the solutions architect recommend?**

A On-Demand Instances of one type

B Reserved Instances for the nightly peak

C Spot Instances across many instance types, with the price-capacity-optimized allocation strategy

D Spot Instances of a single instance type

◆ PAUSE AND DECIDE

## What should the solutions architect recommend?

A On-Demand
*Pays full price for interruptible work.*

B Reserved
*Pays all day for a nightly job.*

C Diversified Spot
Deepest discount; diversity reduces interruptions.

D Single-type Spot
*One pool: more interruptions.*

THE SIGNAL

Fault-tolerant, flexible work: Spot, diversified across instance types. Module 26.

> A payments company's Lambda functions run at a steady, very high volume, all day, every day. Its finance team already holds Savings Plans and wants EC2-style pricing for this compute.
>
> The team wants to keep the Lambda programming model.

**What should the solutions architect recommend?**

A Rewrite the functions as containers on EC2

B Lambda Managed Instances for these functions

C Provisioned concurrency on every function

D Increase memory to shorten duration

◆ PAUSE AND DECIDE

## What should the solutions architect recommend?

A Rewrite for EC2
*Gives up the Lambda model.*

B Lambda Managed Instances
Lambda model on EC2 capacity and pricing.

C Provisioned concurrency
*Reduces cold starts; still Lambda pricing.*

D More memory
*May help a little; not the pricing change.*

THE SIGNAL

Steady, very high-volume functions that want EC2 pricing and commitments: Lambda Managed Instances. Module 26.

A legal research assistant on Amazon Bedrock sends a 40-page practice guide as context with every question. The guide changes monthly, and users ask thousands of questions a day.

Input token costs are the largest line on the bill.

**What should the solutions architect do first?**

A Switch to a larger model

B Fine-tune a model on the guide

C Use batch inference for every question

D Enable prompt caching for the repeated guide

◆ PAUSE AND DECIDE

## What should the solutions architect do first?

A Larger model

*Costs more per token.*

B Fine-tune

*Training is out of scope and the guide changes.*

C Batch inference

*Users need answers now.*

D Prompt caching

Cached prefix tokens are billed at a lower rate.

THE SIGNAL

The same long prefix in every request: prompt caching. Module 27.

A support chatbot on Amazon Bedrock gets a mix of trivial questions and complex troubleshooting. All requests currently go to the most capable model in a family.

The team wants lower cost without training anything or losing quality on hard questions.

**What should the solutions architect use?**

A Intelligent prompt routing across models in the family

B Model distillation

C Send everything to the smallest model

D Provisioned Throughput for the large model

◆ PAUSE AND DECIDE

## What should the solutions architect use?

**A** Prompt routing
Routes each request to the model that suits it.

**B** Distillation
*Requires a training job; suits one narrow task.*

**C** Smallest model
*Hard questions lose quality.*

**D** Provisioned Throughput
*Steady capacity, not a cheaper mix.*

THE SIGNAL

Mixed difficulty, no training: routing. One narrow task at huge volume: distillation. Module 27.

> Applications in private subnets read and write 300 TB a month to S3 in the same Region. The bill shows large NAT gateway data processing charges.
>
> Security wants traffic to stay on the AWS network.

**What should the solutions architect do?**

A Move the applications to public subnets

B Add a second NAT gateway

C Add an S3 gateway endpoint to the private subnets' route tables

D Use S3 Transfer Acceleration

◆ PAUSE AND DECIDE

## What should the solutions architect do?

A Public subnets
*Weakens security.*

B Second NAT gateway
*Doubles the cost.*

C S3 gateway endpoint
No processing charge; stays on AWS.

D Transfer Acceleration
*For long-distance uploads; adds cost.*

THE SIGNAL

S3 traffic through NAT gateways: a gateway endpoint, which has no charge. Module 28.

A streaming service delivers video worldwide through CloudFront with long TTLs already set. The origin is still overloaded by cache misses arriving from many edge locations at once when new episodes launch.

The team wants to reduce origin load and cost.

**What should the solutions architect enable?**

A Shorter TTLs

B A second origin in another Region

C Lambda@Edge to rewrite cache keys

D CloudFront Origin Shield in the Region closest to the origin

◆ PAUSE AND DECIDE

## What should the solutions architect enable?

A Shorter TTLs

*More misses, not fewer.*

B Second origin

*Doubles origin cost.*

C Lambda@Edge

*Helps only if cache keys are fragmented.*

D Origin Shield

Collapses misses from all locations into one layer.

THE SIGNAL

Caching already tuned, origin still flooded by misses from many locations: Origin Shield. Module 28.

A company replicates an entire 2 PB bucket to a second Region for disaster recovery. Half the data is temporary processing output under the tmp/ prefix, deleted within a week.

Replication and storage costs in the second Region are higher than expected.

**What should the solutions architect change?**

A Switch to Same-Region Replication

B Scope the replication rule to exclude temporary data, for example by prefix or tag

C Replicate with S3 Batch Operations once a month

D Turn off versioning in the destination

◆ PAUSE AND DECIDE

## What should the solutions architect change?

A Same-Region Replication
*No longer protects against a Regional failure.*

B Filtered replication rule
Stops paying to replicate data nobody needs.

C Monthly batch copy
*Loses continuous protection.*

D No versioning
*Replication requires versioning on both buckets.*

THE SIGNAL

Replicate only what recovery needs: filter rules by prefix or tag. Module 29.

> Finance activated a team cost allocation tag today. The tag has existed on resources for a year, but cost reports only show it from today.
>
> Finance needs the previous months broken down by team for a budget review.

**What should the solutions architect do?**

A Request a cost allocation tag backfill for the previous months

B Re-tag every resource

C Wait twelve months for history to build

D Export Cost Explorer data and edit it by hand

◆ PAUSE AND DECIDE

## What should the solutions architect do?

**A** Tag backfill

Applies the tag to up to 12 months of past data.

**B** Re-tag

*Tags already exist; reports still miss history.*

**C** Wait a year

*Too late for the review.*

**D** Edit by hand

*Error-prone and unauditable.*

THE SIGNAL

A tag existed but was activated late: backfill cost allocation tags. Module 29.

A company's AWS spend varies by team and by month. Last quarter, a misconfigured job tripled one team's data transfer costs for two weeks before anyone noticed.

Finance wants to hear about unusual spend quickly, without setting thresholds for every team and service.

**What should the solutions architect configure?**

A AWS Budgets with a fixed threshold per team

B A monthly cost report emailed to each team

C CloudWatch billing alarms per service

D AWS Cost Anomaly Detection monitors with alert subscriptions

◆ PAUSE AND DECIDE

## What should the solutions architect configure?

A Budgets per team

*Needs a threshold for each, and spend varies.*

B Monthly report

*Weeks too late.*

C Billing alarms

*Fixed thresholds again.*

D Cost Anomaly Detection

Learns normal patterns and alerts on unusual spend.

THE SIGNAL

A known limit: Budgets. A surprise nobody set a threshold for: Cost Anomaly Detection. Module 30.

> Twelve teams share one EKS cluster with GPU and CPU node groups. Finance will charge each team for its share of the cluster.
>
> Teams must accept the allocation as fair.

**What should the solutions architect implement?**

A Split the bill evenly across the teams

B Tag each node group by team

C Enable split cost allocation data for EKS, allocating node costs by each pod's resource requests and use

D Give each team its own cluster

◆ PAUSE AND DECIDE

## What should the solutions architect implement?

A **Even split**
*Not fair; teams will dispute it.*

B **Tag node groups**
*Nodes are shared, so tags cannot divide them.*

C **Split cost allocation data**
Measured per-pod allocation, including GPUs.

D **Cluster per team**
*Costly duplication to solve a reporting problem.*

THE SIGNAL

Chargeback needs measured allocation. Shared clusters: split cost allocation data. Module 30.

A media archive holds 400 TB in S3 Standard. Some objects are read daily, most are never read, and access patterns change unpredictably when old stories trend.

Retrieval must stay instant, with no retrieval fees.

**Which storage class should the solutions architect choose?**

A S3 Glacier Deep Archive

B S3 Intelligent-Tiering

C S3 Standard-IA for everything

D S3 One Zone-IA

◆ PAUSE AND DECIDE

## Which storage class should the solutions architect choose?

A Deep Archive
*Hours to retrieve.*

B Intelligent-Tiering
Moves objects by access, no retrieval fees.

C Standard-IA
*Retrieval fees on popular objects.*

D One Zone-IA
*Less durable, still retrieval fees.*

THE SIGNAL

Unknown or changing access, instant retrieval, no retrieval fees: Intelligent-Tiering. Module 31.

> A platform team ingests 20 TB a month of verbose debug logs into CloudWatch Logs. They are queried with Logs Insights perhaps twice a month during incidents.
>
> The team does not need metric filters or subscription filters on these logs.

**What should the solutions architect change?**

A Use the CloudWatch Logs Infrequent Access log class for these log groups

B Delete the logs after one day

C Send the logs to an EC2-hosted Elasticsearch cluster

D Reduce the retention period to seven days

◆ PAUSE AND DECIDE

## What should the solutions architect change?

**A** Infrequent Access class

Lower ingestion price, Logs Insights still works.

**B** Delete after a day

*Loses incident data.*

**C** Self-hosted cluster

*Adds servers to run.*

**D** Shorter retention

*Ingestion, not storage, is the main cost.*

THE SIGNAL

Rarely queried logs without filters: the Infrequent Access log class. Module 31.

# Where to revisit

| IF YOU MISSED | REWATCH |
|---|---|
| Q1, Q2, Q3 | Module 25: Pricing models and commitments |
| Q4, Q5 | Module 26: Compute cost |
| Q6, Q7 | Module 27: AI cost |
| Q8, Q9 | Module 28: Delivery and data transfer |
| Q10, Q11 | Module 29: Tagging and replication cost |
| Q12, Q13 | Module 30: Visibility and chargeback |
| Q14, Q15 | Module 31: Storage, database and observability cost |

ON THE EXAM

12 or more out of 15 is on track. Domain 3 is 15%, but cost clues appear in every domain.

MODULE 56 · DOMAIN 4 - RESILIENCE, MIGRATION AND CONTINUITY

# Practice Exam: Domain 4

Fifteen original questions on resilience, migration and business continuity. Pause, decide, then watch.

DOMAIN 4 of 5 EXAM WEIGHT 15% SET 4 of 6

admin@sthithapragna.com

# How to use this set

- **Allow 2.4 minutes per question**: 36 minutes for the set.
- **Write your answer down** before you unpause.
- **Do the arithmetic**: RTO, RPO, terabytes and bandwidth.
- Watch for services closed to new customers, such as Migration Hub.

> ON THE EXAM
>
> Numbers decide resilience and migration questions. Check them before weighing the options.

A defence supplier is planning a migration from a site with no internet access. No software agents may be installed on its servers.

It needs server inventory, utilisation and dependency data to plan waves.

**What should the solutions architect recommend?**

A. Install Application Discovery Service agents on each server

B. Use AWS Migration Hub network visualisation

C. Deploy the AWS Transform discovery appliance on premises, then upload its exported data

D. Interview application owners and build a spreadsheet

◆ PAUSE AND DECIDE

## What should the solutions architect recommend?

A Discovery agents
*Agents are prohibited; service closed to new customers.*

B Migration Hub
*Closed to new customers.*

C Discovery appliance, export
Agentless, works offline, data uploaded later.

D Interviews
*No utilisation or dependency data.*

THE SIGNAL

No agents allowed, air-gapped site: deploy the discovery appliance on premises and upload its export. Module 32.

> During wave planning, a dependency map shows that an order application and a pricing service make thousands of synchronous calls per transaction to each other.
>
> The network link to AWS adds 15 milliseconds of latency.

**How should the solutions architect plan the migration?**

A Move both in the same wave

B Move the order application first, then pricing a month later

C Move pricing first to test the network

D Rewrite both before migrating

◆ PAUSE AND DECIDE

## How should the solutions architect plan the migration?

**A** Same wave
Chatty dependencies stay on the same side.

**B** Order first
*Thousands of calls cross the link each transaction.*

**C** Pricing first
*Same latency problem, reversed.*

**D** Rewrite first
*Not needed to migrate.*

THE SIGNAL

Tightly coupled, chatty dependencies migrate together. Module 32.

A hospital is rehosting 400 VMware virtual machines to EC2. Its change board forbids installing any new software inside the guest operating systems.

Replication must be continuous so that cutover takes minutes.

**What should the solutions architect use?**

A AWS Transform MGN with the replication agent on each VM

B VM Import/Export of nightly snapshots

C Rebuild each server from scratch on EC2

D AWS Transform MGN with agentless replication through the vCenter appliance

◆ PAUSE AND DECIDE

## What should the solutions architect use?

A MGN with agents
*Installs software in every guest.*

B VM Import/Export
*Not continuous; long cutovers.*

C Rebuild
*Months of work, not a rehost.*

D MGN agentless
Continuous replication with nothing in the guests.

THE SIGNAL

No software allowed inside VMware guests: agentless replication through the vCenter appliance. Module 33.

> A retailer must leave its data centre within eight weeks because the lease ends. It runs 900 VMs on VMware Cloud Foundation and holds VCF licences.
>
> Operations staff must keep their existing VMware tools and processes for now.

**What should the solutions architect recommend?**

A Rehost all 900 VMs to EC2 with AWS Transform MGN

B Relocate to Amazon Elastic VMware Service

C Refactor the applications to containers

D Replatform onto Amazon RDS and Fargate

◆ PAUSE AND DECIDE

## What should the solutions architect recommend?

A Rehost to EC2

*Changes operations, too much in eight weeks.*

B Relocate to EVS

Same VMware stack and tools, own licences, fast.

C Refactor

*Far too long.*

D Replatform

*Far too long, and changes operations.*

THE SIGNAL

Exit fast, change nothing in operations, keep the VCF licences: relocate to Amazon EVS. Module 33.

> A company is moving a 6 TB Oracle database to Aurora PostgreSQL. It uses PL/SQL stored procedures heavily.
>
> Downtime at cutover must be under 15 minutes.

**What should the solutions architect do?**

A. Export with Data Pump and import into Aurora

B. Use AWS DMS full load only during a weekend outage

C. Use Aurora zero-ETL integration

D. Convert the schema and code with DMS Schema Conversion, then use DMS full load plus ongoing replication and cut over

◆ PAUSE AND DECIDE

## What should the solutions architect do?

A Data Pump

*Oracle-only tooling; long outage.*

B Full load only

*Hours of downtime for 6 TB.*

C Zero-ETL

*Feeds analytics, not a migration.*

D Schema Conversion, full load plus CDC

Converts code, then keeps data in sync until cutover.

THE SIGNAL

Changing engine adds a conversion step before any data moves. Module 34.


admin@sthithapragna.com

> A research institute must copy 500 TB from on-premises NFS servers to S3 within two weeks. It has an unused 10 Gbps Direct Connect connection.
>
> Transfers must be verified and must not saturate the link during working hours.

**What should the solutions architect use?**

A Order Snowball Edge devices

B A Python script using the S3 API

C AWS DataSync over Direct Connect, with a bandwidth limit schedule and verification

D S3 File Gateway

◆ PAUSE AND DECIDE

## What should the solutions architect use?

A Snowball Edge

*Closed to new customers, and slower here.*

B Custom script

*No verification or throttling built in.*

C DataSync

Fits in about six days at line rate; throttles and verifies.

D File Gateway

*For ongoing file access, not a bulk copy.*

THE SIGNAL

Bulk online transfer with verification and scheduling: DataSync. Module 34.

A company runs MySQL on self-managed EC2 instances. The DBA team spends days each month on patching, backups and failover testing.

The application team cannot change more than connection strings.

**Which migration strategy should the solutions architect recommend?**

A Refactor the application to DynamoDB

B Replatform to Amazon Aurora MySQL

C Rehost onto larger EC2 instances

D Retire the database

◆ PAUSE AND DECIDE

## Which migration strategy should the solutions architect recommend?

A Refactor to DynamoDB
*Major code changes.*

B Replatform to Aurora
Managed patching, backups, failover; same engine.

C Rehost bigger
*Same operational work.*

D Retire
*The data is needed.*

THE SIGNAL

Reduce operations with little code change: replatform. New capabilities: refactor. Module 35.

> A bank's core system runs as 4 million lines of COBOL on a mainframe. It wants to keep the business logic exactly as it behaves today, but run it as Java on AWS.
>
> The bank wants to automate as much of the conversion as possible.

**What should the solutions architect recommend?**

A AWS Transform for mainframe, using its refactor path to convert COBOL to Java

B Rewrite the system from scratch as microservices

C Rehost the mainframe on EC2 with an emulator

D The Mainframe Modernization managed runtime environment

◆ PAUSE AND DECIDE

## What should the solutions architect recommend?

**A** Transform, refactor to Java
Automated conversion, same logic, new language.

**B** Rewrite
*Changes the design; years of work.*

**C** Emulator rehost
*Keeps COBOL.*

**D** Managed runtime
*Closed to new customers.*

THE SIGNAL

Keep how it works, change the language: refactor. Keep what it decides, change how: reimagine. Module 36.

A logistics firm wants disaster recovery for 300 servers in another Region. It needs an RPO of seconds and an RTO under 30 minutes.

While idle, the recovery site must cost as little as possible.

**What should the solutions architect use?**

A. Daily AWS Backup copies to the second Region

B. A full active-active deployment

C. AWS Elastic Disaster Recovery, replicating to a low-cost staging area

D. Warm standby with every server running at half size

◆ PAUSE AND DECIDE

## What should the solutions architect use?

A Daily backups
*RPO of a day.*

B Active-active
*Most expensive option.*

C Elastic Disaster Recovery
Continuous replication, cheap staging, launch on failover.

D Warm standby
*Pays for 300 running servers.*

THE SIGNAL

Seconds of RPO, minutes of RTO, minimal idle cost, many servers: Elastic Disaster Recovery. Module 37.

A payments platform fails over between Regions by promoting an Aurora global database, scaling up ECS services and shifting Route 53 records. Today an engineer follows a 40-step document.

The company wants one orchestrated, approved plan that runs from the recovery Region, with progress visible to executives.

**What should the solutions architect implement?**

A. A Lambda function that runs the steps

B. Route 53 health checks with failover records

C. AWS Fault Injection Service

D. An Amazon Application Recovery Controller Region switch plan

◆ PAUSE AND DECIDE

## What should the solutions architect implement?

A Lambda function
*Custom, untested orchestration.*

B Route 53 failover
*Shifts DNS only.*

C FIS
*Tests failures; does not run recovery.*

D ARC Region switch
Orchestrates database, scaling and traffic steps.

THE SIGNAL

Many recovery steps across services, one approved plan: ARC Region switch. Module 37.

A streaming company wants to prove its service survives losing a dependency, such as a database failover, during business hours in production.

Experiments must stop automatically if customer-facing errors exceed a threshold.

**What should the solutions architect use?**

A. A script that reboots random instances

B. AWS Fault Injection Service experiments with CloudWatch alarm stop conditions

C. AWS Resilience Hub assessments

D. A tabletop exercise

◆ PAUSE AND DECIDE

## What should the solutions architect use?

A Random reboots
*No targeting, no stop condition.*

B FIS with stop conditions
Controlled faults, automatic stop on alarms.

C Resilience Hub
*Assesses; does not inject faults.*

D Tabletop
*Does not test real behaviour.*

THE SIGNAL

Inject faults in production safely: FIS with stop conditions. Module 38.

A bank must show that each of its 40 applications can meet its stated RTO and RPO. It must also catch changes that weaken resilience before they reach production.

It wants recommendations, not only a pass or fail.

**What should the solutions architect use?**

A AWS Resilience Hub, with resiliency policies per application and assessments run from the deployment pipeline

B AWS Fault Injection Service only

C A yearly disaster recovery test

D AWS Config conformance packs

◆ PAUSE AND DECIDE

## What should the solutions architect use?

**A** Resilience Hub in the pipeline
Assesses against RTO and RPO, with recommendations.

**B** FIS only
*Tests behaviour, not targets.*

**C** Yearly test
*Too infrequent to catch changes.*

**D** Conformance packs
*Configuration rules, not recovery objectives.*

THE SIGNAL

Measure against RTO and RPO targets, continuously, with recommendations: Resilience Hub. Module 38.

> After a ransomware attack at a peer firm, a company wants backups that can be restored even if attackers gain administrator access to its production accounts.
>
> Recovery must not depend on any credentials in those accounts.

**What should the solutions architect implement?**

A S3 versioning on all buckets

B Daily snapshots in the same account

C An AWS Backup logically air-gapped vault, shared to a recovery account, with multi-party approval for access

D Copy backups to a second Region in the same account

◆ PAUSE AND DECIDE

## What should the solutions architect implement?

A Versioning
*Administrators can delete versions.*

B Same-account snapshots
*Deletable by the attacker.*

C Logically air-gapped vault
Locked, separately owned, recoverable with approval.

D Second Region, same account
*Same credentials reach both Regions.*

THE SIGNAL

Recover even if the account is compromised: a logically air-gapped vault. Module 39.

A retailer runs all 60 microservices on one large EKS cluster. A failed control plane add-on upgrade made every service unavailable for two hours.

The company wants to limit the impact of future cluster problems.

**What should the solutions architect recommend?**

A Add more nodes to the cluster

B Split workloads across several clusters as separate failure domains, and upgrade them one at a time

C Stop upgrading the cluster

D Move the cluster to a larger instance type

◆ PAUSE AND DECIDE

## What should the solutions architect recommend?

A More nodes

*The cluster is still one failure domain.*

B Several clusters

A cluster failure affects only its share.

C No upgrades

*Unsupported versions and security risk.*

D Larger instances

*Same single failure domain.*

THE SIGNAL

A cluster is itself a failure domain. Upgrades and misconfiguration can take a whole cluster down. Module 39.

> A stock exchange's member firms connect to its order API in two Regions. The firms allow-list specific IP addresses, and some of their systems cache DNS for hours.
>
> Regional failover must take effect within a minute.

**What should the solutions architect use?**

A Route 53 failover records with a 60-second TTL

B Route 53 latency-based records

C CloudFront in front of both Regions

D AWS Global Accelerator with endpoint groups in both Regions

◆ PAUSE AND DECIDE

## What should the solutions architect use?

A Route 53 failover

*Cached DNS ignores the TTL; IPs change.*

B Latency records

*Same DNS caching problem.*

C CloudFront

*Dynamic APIs; IP addresses change.*

D Global Accelerator

Static IPs; shifts traffic without DNS changes.

THE SIGNAL

Clients that allow-list IPs or ignore DNS TTLs: Global Accelerator. Module 37.

# Where to revisit

| IF YOU MISSED | REWATCH |
|---|---|
| Q1, Q2 | Module 32: Discovery and wave planning |
| Q3, Q4 | Module 33: Rehost with Transform MGN and EVS |
| Q5, Q6 | Module 34: Data migration |
| Q7 | Module 35: Replatform and refactor |
| Q8 | Module 36: Mainframe and legacy |
| Q9, Q10, Q15 | Module 37: Disaster recovery design |
| Q11, Q12 | Module 38: DR testing and chaos engineering |
| Q13, Q14 | Module 39: Resilience and backup |

ON THE EXAM

12 or more out of 15 is on track. If arithmetic caught you out, rework the numbers before moving on.

MODULE 57 · DOMAIN 5 - OPERATIONAL EXCELLENCE AND AUTOMATION

# Practice Exam: Domain 5

Fifteen original questions on operational excellence and automation. Pause, decide, then watch.

DOMAIN 5 of 5 EXAM WEIGHT 20% SET 5 of 6

admin@sthithapragna.com

# How to use this set

- **Allow 2.4 minutes per question**: 36 minutes for the set.
- **Write your answer down** before you unpause.
- **Ask when the control acts**: before, during or after.
- Custom glue that recreates a built-in feature is usually a distractor.

> ON THE EXAM
>
> Timing words decide most operations questions: before deployment, before users notice, before the load.

A platform team must deploy a standard set of IAM roles and Config rules to every account in two OUs. Accounts are added to these OUs every week.

New accounts must receive the stack automatically, with no manual steps.

**What should the solutions architect use?**

A CloudFormation StackSets with self-managed permissions, updated weekly

B CloudFormation StackSets with service-managed permissions and automatic deployment to the OUs

C A Lambda function that deploys stacks when accounts are created

D A separate CloudFormation stack deployed by hand in each account

◆ PAUSE AND DECIDE

## What should the solutions architect use?

A StackSets, self-managed
*Needs roles in each account and manual targeting.*

B StackSets, service-managed
Deploys to new OU accounts automatically.

C Custom Lambda
*Custom glue for a built-in feature.*

D Manual stacks
*Manual steps every week.*

THE SIGNAL

Every account in an OU, including new ones, with no manual steps: service-managed with auto-deployment. Module 40.

> An engineer changed an ingress rule on a security group in the console. The security group belongs to a CloudFormation stack, and the template is correct.
>
> The team wants to restore the stack's resources to match the template, previewing the changes first.

**What should the solutions architect do?**

A Run drift detection, then create a drift-aware change set that reverts the drift, review it, and execute it

B Delete and recreate the stack

C Edit the security group back by hand

D Add an AWS Config rule

◆ PAUSE AND DECIDE

## What should the solutions architect do?

**A** Drift-aware change set
Previews and restores template values.

**B** Recreate stack
*Outage and needless risk.*

**C** Manual fix
*Error-prone; no preview or record.*

**D** Config rule
*Detects; does not restore the template.*

THE SIGNAL

A stack resource changed in the console: drift-aware change set. Module 40.

> A company's rule says every S3 bucket must block public access. Some teams deploy with CloudFormation, others with Terraform using the AWS Cloud Control provider.
>
> Non-compliant buckets must be rejected before they are created.

**What should the solutions architect implement?**

A A CDK aspect in a shared library

B A weekly report from AWS Config

C Amazon Macie

D A CloudFormation Guard Hook in fail mode, activated in every account

◆ PAUSE AND DECIDE

## What should the solutions architect implement?

A CDK aspect
*Only covers CDK apps.*

B Weekly Config report
*After creation, and slow.*

C Macie
*Finds sensitive data; off the in-scope list.*

D Guard Hook, fail mode
Rejects before provisioning, for both tools.

THE SIGNAL

Block before provisioning, CloudFormation and Cloud Control users alike: a Guard Hook. Module 41.

> An audit found EBS volumes without encryption in 30 accounts. Most were created years ago through the console and the CLI.
>
> Security wants all such volumes found across accounts, and wants future violations reported and remediated automatically.

**What should the solutions architect implement?**

A. A stricter CloudFormation Hook

B. A drift-aware change set on every stack

C. AWS Config rules deployed organisation-wide, with automatic remediation through Systems Manager Automation runbooks

D. A CDK aspect

◆ PAUSE AND DECIDE

## What should the solutions architect implement?

A Stricter Hook

*Never sees console or CLI changes.*

B Drift-aware change sets

*Only for stack resources.*

C Config with remediation

Finds every resource, however created, and remediates.

D CDK aspect

*Only for CDK apps.*

THE SIGNAL

Created by hand, found and fixed: Config rules with remediation. Module 41.

> A pipeline in a tooling account deploys CloudFormation stacks to a production account. The artefact bucket uses SSE-KMS with the AWS managed key.
>
> The production deploy action fails with access denied when reading the artefact.

**What should the solutions architect change?**

A. Encrypt artefacts with a customer managed KMS key whose key policy, and the bucket policy, allow the production deployment role

B. Disable encryption on the artefact bucket

C. Add the production account to the AWS managed key's policy

D. Run a separate pipeline inside the production account

◆ PAUSE AND DECIDE

## What should the solutions architect change?

**A** Customer managed key
Its policy can allow another account.

**B** No encryption
*Weakens security needlessly.*

**C** Edit the AWS managed key
*AWS managed key policies cannot be edited.*

**D** Pipeline per account
*Abandons build once, promote.*

THE SIGNAL

Cross-account artefacts: a customer managed KMS key shared through its key policy. Module 42.

A team keeps eight services in one GitHub repository, each in its own folder with its own V2 pipeline. Every commit starts all eight pipelines.

Each pipeline should start only when files in its own folder change.

**What should the solutions architect configure?**

A. A Lambda function that inspects commits and starts pipelines

B. Separate repositories for each service

C. Trigger filters on each pipeline with a file path include pattern for its folder

D. Polling on a five-minute schedule

◆ PAUSE AND DECIDE

## What should the solutions architect configure?

A Lambda dispatcher
*Custom code for a built-in feature.*

B Split repositories
*Major workflow change.*

C File path trigger filters
Native per-folder triggering.

D Polling
*Still triggers on any change.*

THE SIGNAL

Monorepo, start only the affected pipeline: trigger file path filters. Module 42.

> A company wants container images with critical vulnerabilities stopped in CodeBuild, before they are ever pushed to Amazon ECR.
>
> The check must use Amazon Inspector's vulnerability data.

**What should the solutions architect add to the build?**

A Rely on ECR enhanced scanning after push

B Generate an SBOM with the Inspector SBOM generator, scan it with the Inspector ScanSbom API, and fail on critical findings

C Enable GuardDuty Runtime Monitoring

D Add an AWS Config rule

◆ PAUSE AND DECIDE

## What should the solutions architect add to the build?

A Enhanced scanning
*Runs after the image is in ECR.*

B SBOM scan in CodeBuild
Before push, with Inspector's data.

C GuardDuty Runtime
*Detects runtime threats, not CVEs.*

D Config rule
*Checks configuration, not images.*

THE SIGNAL

Stop it before the registry, with Inspector's data: an SBOM scan in the build. Module 43.

A bank's EKS clusters must run only images built by its own pipeline. Last month, a pod ran an image pulled directly from a public registry.

Security wants a cryptographic guarantee, with signing keys managed by AWS.

**What should the solutions architect implement?**

A ECR tag immutability

B IAM policies limiting who can push to ECR

C ECR enhanced scanning

D ECR managed signing with an AWS Signer profile, and an admission controller that verifies signatures

◆ PAUSE AND DECIDE

## What should the solutions architect implement?

A Tag immutability
*Does not stop foreign images.*

B Push permissions
*Public images bypass ECR.*

C Enhanced scanning
*Finds CVEs, not provenance.*

D Sign and verify
Unsigned images refused at admission.

THE SIGNAL

Only our images may run, cryptographically: sign on push, verify at admission. Module 43.

A trading firm deploys a pricing Lambda function. A new version must take 10 percent of traffic for 10 minutes, then all of it.

If the error alarm fires during that time, traffic must return to the previous version automatically.

**What should the solutions architect use?**

A. CodeDeploy with a canary 10 percent, 10 minute configuration on the function alias, with the alarm attached

B. Route 53 weighted records for two function URLs

C. Publish the new version and update callers

D. An API Gateway stage variable switched by hand

◆ PAUSE AND DECIDE

## What should the solutions architect use?

**A** CodeDeploy canary on alias
Shifts alias weight, rolls back on alarm.

**B** Route 53 weights
*DNS caching; no automatic rollback.*

**C** Update callers
*All traffic at once.*

**D** Manual stage switch
*Manual, no rollback.*

THE SIGNAL

Lambda, small slice first, automatic revert: CodeDeploy canary on the alias. Module 44.

A logistics company uses ECS rolling updates. A release with a bad configuration caused new tasks to fail health checks repeatedly.

The deployment kept retrying for hours until someone noticed and rolled back by hand.

**What should the solutions architect enable?**

A. A longer health check grace period

B. Blue/green deployments with double capacity

C. A higher minimum healthy percent

D. The ECS deployment circuit breaker with rollback enabled

◆ PAUSE AND DECIDE

## What should the solutions architect enable?

A Longer grace period
*Delays detection.*

B Blue/green
*Larger change than needed.*

C Higher minimum healthy
*Protects capacity, not retries.*

D Circuit breaker
Stops failing rollouts and rolls back.

THE SIGNAL

ECS tasks keep failing during a rolling update: the deployment circuit breaker. Module 44.

A retailer is adding distributed tracing to 50 services on ECS and Lambda. A developer proposes the X-Ray SDK and daemon from an older project.

The company wants instrumentation it will not have to replace, and may send traces to a second tool later.

**What should the solutions architect recommend?**

A The X-Ray SDK and daemon

B VPC Flow Logs

C OpenTelemetry instrumentation through the AWS Distro for OpenTelemetry

D CloudTrail data events

◆ PAUSE AND DECIDE

## What should the solutions architect recommend?

A X-Ray SDK
*Maintenance mode; end of support February 2027.*

B Flow Logs
*Network records, not traces.*

C ADOT and OpenTelemetry
Supported, vendor-neutral, exports to X-Ray.

D CloudTrail
*API audit, not request traces.*

THE SIGNAL

New instrumentation: OpenTelemetry through ADOT, not the X-Ray SDK. Module 45.

> A travel site's synthetic canaries in eu-west-1 report fast page loads. Customers in Australia and Brazil complain that pages are slow on mobile.
>
> The team wants actual load times and JavaScript errors by country, browser and device.

**What should the solutions architect add?**

A More canaries in eu-west-1

B CloudWatch RUM, with its web client added to the site

C X-Ray tracing on the back end

D Application Load Balancer access logs

◆ PAUSE AND DECIDE

## What should the solutions architect add?

A More canaries
*Same Region; not real users.*

B CloudWatch RUM
Real sessions by country, browser and device.

C X-Ray
*Back-end timing only.*

D ALB logs
*Server timing; no browser data.*

THE SIGNAL

What real users see, by place and device: RUM. Before users notice, at quiet times: Synthetics. Module 46.

A partner API gets about 20 requests per minute overnight. Its availability SLO is period-based, so a single failed request marks a whole minute unhealthy.

Overnight attainment looks far worse than the true share of failed requests.

## What should the solutions architect change?

A Use a five-minute period

B Exclude overnight hours from the SLO

C Switch to a latency SLI

D Use a request-based SLI, counting good requests against total requests

◆ PAUSE AND DECIDE

## What should the solutions architect change?

A Longer period

*One failure now spoils five minutes.*

B Exclude nights

*Hides real failures.*

C Latency SLI

*Measures something else.*

D Request-based SLI

Attainment matches the real failure ratio.

THE SIGNAL

Low or uneven traffic, period health misleading: a request-based SLI. Module 46.

> Five applications share the same Bedrock model in one account. The model's cost has doubled, and finance wants to know which application caused it and which prompts are largest.
>
> Only aggregate token metrics are available today.

**What should the solutions architect do?**

A. Give each application a tagged application inference profile, and enable model invocation logging

B. Read CloudTrail management events

C. Enable X-Ray tracing on the model

D. Divide the bill evenly

◆ PAUSE AND DECIDE

## What should the solutions architect do?

A Inference profiles and invocation logs
Cost per application; prompts per request.

B CloudTrail
*No token counts.*

C X-Ray
*Timing, not token attribution.*

D Even split
*Guesswork.*

THE SIGNAL

Which application and which prompts drive spend: inference profiles and invocation logs. Module 47.

> An application on EC2 behind an Application Load Balancer sometimes deadlocks. The instance passes EC2 status checks but stops answering, and the load balancer marks it unhealthy.
>
> The Auto Scaling group never replaces it.

**What should the solutions architect change?**

A Enable EC2 automatic recovery

B Reboot instances on high CPU with a CloudWatch alarm

C Set the Auto Scaling group health check type to ELB, with a suitable grace period

D Use a larger instance type

◆ PAUSE AND DECIDE

## What should the solutions architect change?

A Auto recovery

*Hardware and system failures only.*

B Reboot on CPU

*A deadlock may not raise CPU.*

C ELB health checks

Group replaces what the ALB finds unhealthy.

D Larger instance

*Deadlocks are not about size.*

THE SIGNAL

Load balancer sees it unhealthy, group does not replace it: ELB health check type. Module 48.

# Where to revisit

| IF YOU MISSED | REWATCH |
|---|---|
| Q1, Q2 | Module 40: Infrastructure as code |
| Q3, Q4 | Module 41: Policy as code and drift |
| Q5, Q6 | Module 42: CI/CD pipeline design |
| Q7, Q8 | Module 43: DevSecOps and AI evaluation |
| Q9, Q10 | Module 44: Deployment strategies |
| Q11 | Module 45: Observability foundations |
| Q12, Q13 | Module 46: User experience and SLOs |
| Q14 | Module 47: AI observability |
| Q15 | Module 48: Automation and resilience |

ON THE EXAM

12 or more out of 15 is on track. Next, the full 75-question mock in three parts.

MODULE 58 · EXAM STRATEGY - ALL DOMAINS

# Full Mock, Part One

Part one of a 75-question mock, weighted across the five domains like the real exam.

PART 1 of 3 QUESTIONS 1-25 SET 6 of 6

admin@sthithapragna.com

# Sitting the mock

- **Allow 60 minutes per part**, 180 for all three, as on the day.
- **Checkpoint**: question 8 by minute 20, question 17 by minute 40.
- **Answer every question** before checking any walkthrough.
- For a true rehearsal, sit all three parts in one session.

> ON THE EXAM
>
> Score each part with the table at its end, then total all 75 after part three.

> An insurer's claim services publish events to a custom EventBridge bus in eu-west-1. If that Region becomes unavailable, producers must keep publishing with no manual action.
>
> Consumers run in eu-west-1 and eu-central-1.

**What should the solutions architect implement?**

A. A rule forwarding every event to a bus in eu-central-1

B. An SQS queue in front of the bus

C. An EventBridge global endpoint with a secondary bus in eu-central-1 and event replication

D. Producers that retry against eu-central-1 on failure

◆ PAUSE AND DECIDE

## What should the solutions architect implement?

A Forwarding rule
*Fails with the primary Region.*

B SQS buffer
*Still single-Region.*

C Global endpoint
Fails over publishing automatically.

D Client retry logic
*Custom failover logic in every producer.*

THE SIGNAL

Producers must keep publishing when a Region fails: a global endpoint, not a rule. Module 01.

A retailer's web tier on EC2 Spot Instances stores shopping carts in server memory and uses sticky sessions. Customers lose carts whenever instances are reclaimed or scaled in.

Traffic is in a single Region.

**What should the solutions architect change?**

A Store sessions in Amazon ElastiCache or DynamoDB and make the web tier stateless

B Increase the sticky session duration

C Move to On-Demand Instances

D Disable scale-in

◆ PAUSE AND DECIDE

## What should the solutions architect change?

**A** External session store

Any instance can serve any request.

**B** Longer stickiness

*Sessions still die with the instance.*

**C** On-Demand

*Still loses carts on scale-in.*

**D** No scale-in

*Wastes money; failures still lose carts.*

THE SIGNAL

Stickiness hides statefulness; it does not remove it. Externalise the state. Module 02.

A visual search service on Amazon ECS needs GPU instances of a specific family. The team does not want to patch or manage container hosts.

Fargate does not offer the GPUs required.

**What should the solutions architect use?**

A ECS on self-managed EC2 Auto Scaling groups

B Amazon ECS Managed Instances

C AWS Batch

D Amazon EKS with self-managed node groups

◆ PAUSE AND DECIDE

## What should the solutions architect use?

A Self-managed EC2
*The team patches the hosts.*

B ECS Managed Instances
Chosen instance types, AWS manages the hosts.

C AWS Batch
*Batch jobs; off the in-scope list.*

D EKS self-managed
*Host management and Kubernetes.*

THE SIGNAL

Needs a GPU or a particular family, and nobody wants to patch hosts: ECS Managed Instances. Module 03.

A data provider sells API access in three tiers, each with its own request quota per client key. It also needs AWS WAF protection and response caching.

Clients authenticate with API keys.

**Which API option should the solutions architect choose?**

A API Gateway HTTP API

B An Application Load Balancer with Lambda targets

C A Network Load Balancer

D API Gateway REST API with usage plans and API keys

◆ PAUSE AND DECIDE

## Which API option should the solutions architect choose?

A HTTP API

*No usage plans or caching.*

B ALB and Lambda

*No per-key quotas.*

C NLB

*No API management at all.*

D REST API, usage plans

Per-key quotas, WAF and caching.

THE SIGNAL

Per-client quotas, WAF, caching or a private endpoint rule out HTTP APIs. Module 04.

A news site wants to add a security header and redirect old URLs on every viewer request through CloudFront. The logic is a few lines and needs no network calls.

It runs on millions of requests an hour, and cost matters.

**What should the solutions architect use?**

A CloudFront Functions on the viewer request

B Lambda@Edge on the origin request

C A Lambda function behind the origin

D AWS WAF rules

◆ PAUSE AND DECIDE

## What should the solutions architect use?

**A** CloudFront Functions
Lightweight, cheapest, sub-millisecond.

**B** Lambda@Edge
*More capable, costlier, not needed.*

**C** Origin Lambda
*Every request hits the origin.*

**D** WAF rules
*Filters requests; cannot redirect URLs this way.*

THE SIGNAL

Default to CloudFront Functions. Move to Lambda@Edge only when a named capability forces it. Module 05.

> An insurer has trained its own fraud model with an in-house framework. It must serve real-time predictions with under 100 milliseconds of latency.
>
> Amazon Bedrock does not offer this model.

**Where should the solutions architect host it?**

A Amazon Bedrock on-demand inference

B Bedrock Knowledge Bases

C A SageMaker AI real-time endpoint

D AWS Lambda calling a Bedrock agent

◆ PAUSE AND DECIDE

## Where should the solutions architect host it?

A Bedrock on-demand
*Serves Bedrock's models, not this one.*

B Knowledge Bases
*Retrieval, not model hosting.*

C SageMaker AI endpoint
Hosts your own model with low latency.

D Bedrock agent
*Wrong service for a custom model.*

THE SIGNAL

A model the company built itself, or one Bedrock does not offer: a SageMaker AI endpoint. Module 07.

A retailer has 600 branches that use public DNS resolvers. Security wants central filtering of malicious domains for every branch, plus resolution of private AWS names, without installing appliances at each site.

Branches connect over the internet.

**What should the solutions architect recommend?**

A. A VPC Resolver inbound endpoint reached by VPN from every branch

B. Route 53 Global Resolver with its domain filtering

C. A DNS appliance at each branch

D. Public hosted zones for every private name

◆ PAUSE AND DECIDE

## What should the solutions architect recommend?

A Inbound endpoint via VPN

*600 VPNs to run.*

B Global Resolver

Internet-reachable resolver with central filtering.

C Appliance per site

*600 appliances.*

D Public zones

*Exposes private names.*

THE SIGNAL

Hundreds of branches, central DNS filtering, no appliance per site: Global Resolver. Module 09.

> Pods in an EKS cluster need IAM permissions. Some pods run on Fargate, and the rest on EC2 nodes.
>
> The team wants one mechanism that works for every pod.

**Which mechanism should the solutions architect choose?**

A EKS Pod Identity

B Node instance profiles

C Access keys in Kubernetes secrets

D IAM roles for service accounts

◆ PAUSE AND DECIDE

## Which mechanism should the solutions architect choose?

A Pod Identity
*Not supported on Fargate pods.*

B Instance profiles
*Every pod on a node gets the same rights.*

C Access keys
*Long-term credentials.*

D IRSA
Works on both Fargate and EC2 pods.

THE SIGNAL

Pod Identity whenever supported. Fargate pods, Windows nodes and EKS Anywhere still need IRSA. Module 15.

A data team in account A runs a job that copies objects from its own bucket into a bucket in account B. Each copy is a single operation.

Assuming a role in account B makes the job lose access to account A's bucket.

**What should the solutions architect do?**

A Assume the role in account B, then assume back

B Keep the job's account A role, and add a bucket policy in account B granting that role write access

C Copy objects through a local download

D Make account B's bucket public for writes

◆ PAUSE AND DECIDE

## What should the solutions architect do?

A Chain roles
*One call cannot hold both sets of permissions.*

B Resource policy in B
One identity, access to both buckets.

C Download and upload
*Slow and costly.*

D Public bucket
*Unsafe.*

THE SIGNAL

Moving data between your resource and theirs in one call needs a resource policy, because a role swaps permissions. Module 16.

A manufacturer's on-premises servers call AWS APIs using long-term access keys stored in configuration files. Each server already has an X.509 certificate from the company's certificate authority.

Security wants the access keys removed.

**What should the solutions architect implement?**

A. IAM Roles Anywhere, trusting the company CA, with profiles mapping to IAM roles

B. Rotate the access keys monthly

C. Systems Manager hybrid activations only

D. IAM Identity Center users for each server

◆ PAUSE AND DECIDE

## What should the solutions architect implement?

A **Roles Anywhere**
Temporary credentials from existing certificates.

B **Monthly rotation**
*Still long-term keys.*

C **Hybrid activations**
*For managing servers, not app credentials.*

D **Identity Center**
*For people, not workloads.*

THE SIGNAL

Match the mechanism to what the workload already has: a certificate means Roles Anywhere. Module 17.

A European public-sector body requires that its cloud is operated only by EU-resident staff, with infrastructure and metadata independent of other AWS Regions.

Data residency alone is not sufficient.

**What should the solutions architect recommend?**

A Any EU Region with an SCP limiting Regions

B An EU Region with customer managed KMS keys

C The AWS European Sovereign Cloud

D AWS Outposts in the body's data centre

◆ PAUSE AND DECIDE

## What should the solutions architect recommend?

A EU Region and SCP

*Residency only.*

B EU Region and CMKs

*Residency and key control only.*

C European Sovereign Cloud

Operated in the EU by EU residents, independent.

D Outposts

*Still managed from a parent Region.*

THE SIGNAL

Residency is solved with Regions and policy. Sovereignty may need a different operating model. Module 23.

A company must collect CloudTrail, VPC Flow Logs and security findings from 120 accounts into one store. Analysts query a year of data, and partner tools expect the OCSF schema.

The team wants the least custom pipeline work.

**What should the solutions architect use?**

A Custom Firehose streams and Glue jobs

B CloudTrail Lake

C CloudWatch Logs in each account

D Amazon Security Lake with a delegated administrator

◆ PAUSE AND DECIDE

## What should the solutions architect use?

A **Custom pipeline**
*Builds what Security Lake provides.*

B **CloudTrail Lake**
*Closed to new customers; CloudTrail only.*

C **Per-account logs**
*Not central, no OCSF.*

D **Security Lake**
Central, OCSF-normalised, organisation-wide.

THE SIGNAL

Organisation-wide security data in OCSF with least effort: Security Lake. Module 21.

A bank's customer assistant on Amazon Bedrock sometimes repeats customers' card numbers and phone numbers in its responses.

Card numbers must be blocked, and phone numbers masked.

**What should the solutions architect configure?**

A. A denied topic for payments

B. A Bedrock guardrail with sensitive information filters, blocking card numbers and masking phone numbers

C. A larger model

D. Contextual grounding checks

◆ PAUSE AND DECIDE

## What should the solutions architect configure?

A Denied topic

*Blocks whole conversations about payments.*

B Sensitive information filters

Per-entity block or mask actions.

C Larger model

*No guarantee.*

D Grounding checks

*Checks support by sources, not PII.*

THE SIGNAL

Personal data in prompts or responses: sensitive information filters, block or mask. Module 24.

A company runs the same EC2 instance family in one Region all year, at a steady 80 dollars an hour. It has no plans to change family or Region for three years.

It wants the largest commitment discount.

**What should the solutions architect recommend?**

A EC2 Instance Savings Plans

B Compute Savings Plans

C Spot Instances

D On-Demand Capacity Reservations

◆ PAUSE AND DECIDE

## What should the solutions architect recommend?

A **EC2 Instance SP**
Largest Savings Plan discount for a fixed family and Region.

B **Compute SP**
*More flexible, smaller discount.*

C **Spot**
*Interruptible.*

D **Capacity reservations**
*Capacity, not a discount.*

THE SIGNAL

Fixed family and Region, maximum discount: EC2 Instance Savings Plans. Module 25.

A publisher summarises two million archived articles with Amazon Bedrock each night. Results are needed by the next morning.

The team wants the lowest inference cost.

**What should the solutions architect use?**

A On-demand inference with more parallel calls

B Provisioned Throughput

C A larger model

D Bedrock batch inference

◆ PAUSE AND DECIDE

## What should the solutions architect use?

A Parallel on-demand
*Full on-demand price.*

B Provisioned Throughput
*Pays for reserved capacity.*

C Larger model
*Costs more per token.*

D Batch inference
Lower price for asynchronous jobs.

THE SIGNAL

Large, non-urgent jobs: batch inference at a lower price than on-demand. Module 27.

A DynamoDB table serves steady, predictable traffic of about 2,000 writes per second all day. It currently uses on-demand capacity.

Traffic has not varied by more than 10 percent in a year.

**How should the solutions architect reduce cost?**

A Keep on-demand and add DAX

B Move to the Standard-Infrequent Access table class

C Switch to provisioned capacity with auto scaling, and buy reserved capacity

D Add global secondary indexes

◆ PAUSE AND DECIDE

## How should the solutions architect reduce cost?

A On-demand plus DAX

*Caches reads; writes dominate.*

B Standard-IA class

*Saves on storage, not throughput.*

C Provisioned plus reserved

Cheapest for steady, predictable load.

D More indexes

*Adds cost.*

THE SIGNAL

Steady, predictable traffic: provisioned capacity, plus reserved capacity. Module 31.

> An application writes 5 TB of logs a month to S3. They are never read after 30 days, must be kept for a year for audit, and retrieval within 12 hours is acceptable.
>
> The company wants the lowest storage cost.

**What should the solutions architect configure?**

A S3 Standard for a year

B A lifecycle rule moving objects to S3 Glacier Deep Archive after 30 days and expiring them after a year

C S3 Intelligent-Tiering

D S3 One Zone-IA

◆ PAUSE AND DECIDE

## What should the solutions architect configure?

A Standard
*Most expensive.*

B Lifecycle to Deep Archive
Cheapest, retrieval within 12 hours.

C Intelligent-Tiering
*Monitoring fees for data with a known pattern.*

D One Zone-IA
*Costlier than Deep Archive.*

THE SIGNAL

Known access pattern, retrieval within a day: lifecycle rules to Deep Archive. Module 31.

> A company is moving a 3 TB MySQL database from on premises to Aurora MySQL. Downtime must be under ten minutes.
>
> There is a 1 Gbps Direct Connect link.

**What should the solutions architect do?**

A AWS DMS full load plus ongoing replication, then cut over

B DMS Schema Conversion first, then a full load

C mysqldump during a weekend outage

D AWS Transform MGN for the database server

◆ PAUSE AND DECIDE

## What should the solutions architect do?

**A** DMS full load plus CDC

Same engine; sync, then a brief cutover.

**B** Schema Conversion first

*No conversion needed for the same engine.*

**C** mysqldump

*Hours of downtime.*

**D** Rehost the server

*Moves a server, not to Aurora.*

THE SIGNAL

Same engine means no conversion step. Full load plus change data capture keeps downtime short. Module 34.

> A company has 70 ASP.NET Framework applications on Windows servers. It wants to run them on Linux to cut licence costs.
>
> It wants as much of the code porting automated as possible.

**What should the solutions architect recommend?**

A Rehost them to Windows on EC2

B Rewrite them in Java

C Run them on Windows containers on ECS

D AWS Transform for .NET to port them to cross-platform .NET on Linux

◆ PAUSE AND DECIDE

## What should the solutions architect recommend?

A Rehost to Windows
*Keeps the Windows licences.*

B Rewrite in Java
*Manual and slow.*

C Windows containers
*Still Windows licences.*

D AWS Transform for .NET
Automated porting to Linux.

THE SIGNAL

Windows .NET Framework to Linux, automated: AWS Transform for .NET. Module 35.

> A company needs disaster recovery for an order system with an RPO of five minutes and an RTO of two hours. Cost while idle must be low.
>
> The infrastructure is defined in CloudFormation.

**Which DR strategy should the solutions architect choose?**

A. Backup and restore with daily snapshots

B. Pilot light: replicate the database continuously, keep core services minimal, and deploy the rest from templates on failover

C. Warm standby at full size

D. Multi-site active-active

◆ PAUSE AND DECIDE

## Which DR strategy should the solutions architect choose?

A Daily backups
*RPO of a day.*

B Pilot light
Minutes of RPO, hours of RTO, low idle cost.

C Full warm standby
*Costs far more than needed.*

D Active-active
*Most expensive option.*

THE SIGNAL

Match the strategy to the numbers: RPO minutes, RTO hours, low idle cost means pilot light. Module 37.

> A group with 90 accounts must back up every production EBS volume and RDS database daily, keeping copies for 35 days. This must include resources created in future.
>
> Teams must not be able to opt out.

**What should the solutions architect implement?**

A. A Lambda function that snapshots tagged resources

B. A backup plan created by each team

C. AWS Organizations backup policies applying an AWS Backup plan to resources by tag

D. Daily EBS snapshots with Data Lifecycle Manager in each account

◆ PAUSE AND DECIDE

## What should the solutions architect implement?

A Custom Lambda
*Custom code to maintain.*

B Team-owned plans
*Teams can opt out.*

C Organisation backup policies
Central, enforced, covers new resources.

D DLM per account
*EBS only; managed per account.*

THE SIGNAL

Enforced backups across an organisation: backup policies in AWS Organizations. Module 39.

> A platform team wants encryption, versioning and a cost-centre tag applied automatically to every S3 bucket in any CDK app. This must happen before synthesis.
>
> Teams should not need to write this themselves.

**What should the solutions architect provide?**

A. A CDK aspect in a shared library

B. A Config rule with remediation

C. An SCP

D. A code review checklist

◆ PAUSE AND DECIDE

## What should the solutions architect provide?

**A** CDK aspect

Applies settings to every construct before synthesis.

**B** Config rule

*Acts after deployment.*

**C** SCP

*Denies; does not set properties.*

**D** Checklist

*Manual.*

THE SIGNAL

Fix or flag every construct in CDK apps before synthesis: an aspect. Module 41.

> A team builds a container image separately in its test, staging and production accounts. A production fault came from a dependency version that differed from what staging tested.
>
> Production must run exactly what passed staging.

**What should the solutions architect recommend?**

A Run the tests again in production

B Pin more dependency versions

C Build in production only

D Build the image once in a tooling account and promote the same image digest to every account

◆ PAUSE AND DECIDE

## What should the solutions architect recommend?

A Retest in production

*Tests a different build.*

B Pin versions

*Narrows the gap; still rebuilds.*

C Build in production

*Untested build ships.*

D Build once, promote

Tested artefact is the shipped artefact.

THE SIGNAL

Production must run exactly what was tested: build once and promote the artefact. Module 42.

> A team's pipeline uses queued execution mode. During busy days, dozens of commits queue up and each deploys in turn, delaying the latest fix by hours.
>
> Only the newest commit needs to reach production.

**What should the solutions architect change?**

A Switch to parallel execution mode

B Switch to superseded execution mode

C Add more stages

D Add a manual approval to skip old runs

◆ PAUSE AND DECIDE

## What should the solutions architect change?

A Parallel

*Runs them all at once; no stage rollback.*

B Superseded

Newer runs replace waiting ones.

C More stages

*Slower.*

D Manual approval

*Manual work for a built-in behaviour.*

THE SIGNAL

Rapid commits, deploy only the latest: superseded execution mode. Module 42.

> A Lambda function must publish custom metrics for order value and payment provider with several dimensions. Calling the CloudWatch API on each invocation added latency.
>
> The team wants no synchronous metric calls.

**What should the solutions architect recommend?**

A Batch PutMetricData calls in a background thread

B X-Ray annotations

C CloudWatch embedded metric format in structured log lines

D Write metrics to DynamoDB

◆ PAUSE AND DECIDE

## What should the solutions architect recommend?

A Background thread

*Lambda may freeze before the thread sends.*

B X-Ray annotations

*Index traces; not metrics.*

C Embedded metric format

Metrics extracted from logs asynchronously.

D DynamoDB

*A metrics system built by hand.*

THE SIGNAL

Custom metrics from Lambda without API calls: embedded metric format. Module 45.

# Part one: score and next steps

| RESULT ON THESE 25 | WHAT TO DO |
|---|---|
| 20 or more | On track. Continue to part two |
| 16 to 19 | Passing range but thin. Review misses first |
| 12 to 15 | Rewatch the modules named in your misses |
| Below 12 | Return to the domain papers for weak domains |
| Guessed but correct | Count as a miss when deciding |
| Over 60 minutes | Practise pacing with the checkpoints |

ON THE EXAM

Scaled scoring means a raw count cannot be converted to 720. Treat these bands as a guide, and aim well clear.

MODULE 59 · EXAM STRATEGY - ALL DOMAINS

# Full Mock, Part Two

Part two of the 75-question mock. Same weighting, same pace: 60 minutes for 25 questions.

PART 2 of 3 QUESTIONS 26-50 SET 6 of 6

admin@sthithapragna.com

# Part two checkpoints

- **Question 33 by minute 20** of this part.
- **Question 42 by minute 40.**
- **Flag and move at three minutes**; come back at the end.
- Mid-exam fatigue shows as re-reading. Read the question first, then the stem.

> ON THE EXAM
>
> On the real exam, minute 120 should find you near question 50.

A bank processes account events where each customer's events must be handled strictly in order. Events for different customers can be processed in parallel by one pool of workers.

Throughput is about 2,000 events per second.

**What should the solutions architect use?**

A. An SQS FIFO queue with high throughput mode, using the customer ID as the message group ID

B. A standard SQS queue

C. An SNS standard topic

D. One SQS FIFO queue per customer

◆ PAUSE AND DECIDE

## What should the solutions architect use?

A FIFO, group per customer
Order per customer, parallel across customers.

B Standard queue
*No ordering.*

C SNS standard
*No ordering, no buffering.*

D Queue per customer
*Millions of queues to manage.*

THE SIGNAL

One worker pool, order within a key: FIFO with a message group per key. Module 01.

A multiplayer game sends player position updates over UDP to servers on EC2. It needs very low latency and must preserve client source IP addresses.

Servers run in an Auto Scaling group.

**Which load balancer should the solutions architect choose?**

A Application Load Balancer

B Network Load Balancer

C Gateway Load Balancer

D API Gateway WebSocket API

◆ PAUSE AND DECIDE

## Which load balancer should the solutions architect choose?

A ALB
*HTTP and HTTPS only.*

B NLB
UDP, low latency, preserves source IP.

C GWLB
*For inline appliances.*

D WebSocket API
*TCP-based, adds latency.*

THE SIGNAL

Non-HTTP protocols, fixed IPs or PrivateLink all mean NLB. Module 04.

> Forty legacy applications in separate VPCs talk to each other over many TCP and UDP protocols. Some open ports dynamically. They need full IP reachability.
>
> The VPC CIDR ranges do not overlap.

**What should the solutions architect use to connect them?**

A Amazon VPC Lattice

B PrivateLink endpoint services

C AWS Transit Gateway with route tables

D ECS Service Connect

◆ PAUSE AND DECIDE

## What should the solutions architect use to connect them?

A VPC Lattice

*Service-level, not full IP reachability.*

B PrivateLink

*One service, one direction, per endpoint.*

C Transit Gateway

Routes IP traffic between many VPCs.

D Service Connect

*ECS only.*

THE SIGNAL

Network reachability is Transit Gateway. Service-to-service access with identity is Lattice. Module 04.

A company is adding IPv6 to its VPCs. Instances in private subnets need outbound IPv6 access to internet services, but must not be reachable from the internet.

The team wants the lowest cost.

**What should the solutions architect add?**

A A NAT gateway

B An internet gateway with a route for ::/0

C A NAT instance

D An egress-only internet gateway

◆ PAUSE AND DECIDE

## What should the solutions architect add?

A NAT gateway
*Charges per GB; not needed for IPv6 to IPv6.*

B Internet gateway
*Allows inbound connections.*

C NAT instance
*Servers to run.*

D Egress-only gateway
Outbound only, no processing charge.

THE SIGNAL

Private IPv6 traffic to IPv6 destinations: the egress-only gateway, which costs nothing to process. Module 10.

> A reservations database needs 12 read replicas for reporting, failover in well under a minute, and read access from a second Region with low lag.
>
> The application uses MySQL.

**Which database should the solutions architect choose?**

A. RDS for MySQL Multi-AZ with read replicas

B. Aurora MySQL with an Aurora global database

C. MySQL on EC2 with replication

D. DynamoDB global tables

◆ PAUSE AND DECIDE

## Which database should the solutions architect choose?

A RDS MySQL
*Slower failover; replicas lag more.*

B Aurora global database
Up to 15 replicas, fast failover, cross-Region reads.

C Self-managed MySQL
*Operations burden.*

D DynamoDB
*Different data model.*

THE SIGNAL

Many readers, fast failover or cross-Region reads point to Aurora. Module 12.

A gaming leaderboard reads the same DynamoDB items thousands of times per second. The team needs microsecond read latency.

Developers want the smallest possible code change.

**What should the solutions architect add?**

A DynamoDB Accelerator (DAX)

B ElastiCache with cache-aside logic

C DynamoDB global tables

D More read capacity

◆ PAUSE AND DECIDE

## What should the solutions architect add?

A **DAX**
DynamoDB-compatible API, microsecond reads.

B **ElastiCache**
*New caching code to write.*

C **Global tables**
*Replication, not latency.*

D **More capacity**
*Still single-digit milliseconds.*

THE SIGNAL

DynamoDB with minimal code change means DAX. Any other source, or computed results, means ElastiCache. Module 12.

> A role in account A can be assumed by an analytics role in account B. The analytics role can list objects in account A's bucket, but every GetObject fails with access denied.
>
> The objects are encrypted with a customer managed KMS key in account A.

**What is the MOST likely cause?**

A The trust policy is wrong

B The bucket policy denies listing

C The KMS key policy does not allow the role to decrypt

D S3 Block Public Access is enabled

◆ PAUSE AND DECIDE

## What is the MOST likely cause?

A Trust policy
*Assumption works, so trust is fine.*

B Bucket policy
*Listing works.*

C KMS key policy
Data access needs the key too.

D Block Public Access
*Not public access.*

THE SIGNAL

Can list but cannot read encrypted objects: the key policy is the forgotten grant. Module 18.

An application connects to Aurora PostgreSQL with a password stored in a configuration file. Auditors require the credential to rotate every 30 days with no application outage.

The team wants the least custom code.

**What should the solutions architect implement?**

A. A Lambda function that changes the password and edits the file

B. Systems Manager Parameter Store with a reminder

C. IAM database authentication with tokens cached for a month

D. AWS Secrets Manager with managed rotation, and the application reading the secret at runtime

◆ PAUSE AND DECIDE

## What should the solutions architect implement?

A Custom Lambda
*Custom rotation code.*

B Parameter Store
*No rotation.*

C IAM auth tokens
*Tokens last 15 minutes; caching breaks.*

D Secrets Manager rotation
Managed rotation, no outage.

THE SIGNAL

Database credentials rotated automatically: Secrets Manager managed rotation. Module 18.

> A company's internal microservices must authenticate each other with mutual TLS. It needs to issue thousands of private certificates, rotate them often, and control its own certificate hierarchy.
>
> Certificates must not be publicly trusted.

**What should the solutions architect use?**

A Public certificates from AWS Certificate Manager

B AWS Private CA

C Self-signed certificates on each service

D IAM server certificates

◆ PAUSE AND DECIDE

## What should the solutions architect use?

A Public ACM certificates
*Publicly trusted; wrong for internal mTLS.*

B AWS Private CA
Private hierarchy, issued and rotated at scale.

C Self-signed
*No common trust or rotation.*

D IAM certificates
*Legacy, not for this.*

THE SIGNAL

Private certificates for internal mTLS at scale: AWS Private CA. Module 18.

> Security finds an attack coming from a specific address range against instances in one subnet. The range must be blocked immediately at the subnet boundary.
>
> Security groups currently allow HTTPS from anywhere.

**What should the solutions architect do?**

A Add deny rules for the range to the subnet's network ACL

B Add a deny rule to the security group

C Remove the internet gateway

D Enable GuardDuty

◆ PAUSE AND DECIDE

## What should the solutions architect do?

**A** Network ACL deny

NACLs support explicit deny by address.

**B** Security group deny

*Security groups have no deny rules.*

**C** Remove IGW

*Takes down all traffic.*

**D** GuardDuty

*Detects; does not block.*

THE SIGNAL

Block a specific address range now: a network ACL deny. Allow by role or tier: security groups. Module 11.

A company must restrict outbound internet traffic from 30 VPCs to an approved list of domains, such as package repositories. It wants a managed service with the least operational overhead.

No third-party product is required.

**What should the solutions architect deploy?**

A Squid proxies on EC2

B Security groups with domain names

C AWS Network Firewall in a central egress VPC, with stateful domain list rules

D A Gateway Load Balancer with third-party firewalls

◆ PAUSE AND DECIDE

## What should the solutions architect deploy?

A Squid proxies

*Servers to patch and scale.*

B Security groups

*Security groups cannot filter by domain.*

C Network Firewall

Managed domain allow-listing.

D GWLB appliances

*Third-party appliances add work.*

THE SIGNAL

Least operational overhead and no named product: AWS Network Firewall. Module 11.

> Contractors need SSH and RDP access to a few dozen EC2 instances in private subnets. The company wants no VPN and no bastion hosts.
>
> Access must depend on user identity and device posture, and every session must be logged.

**What should the solutions architect use?**

A. A bastion host with key pairs

B. AWS Client VPN

C. Public IP addresses with restricted security groups

D. AWS Verified Access with TCP endpoints

◆ PAUSE AND DECIDE

## What should the solutions architect use?

A Bastion

*Ruled out.*

B Client VPN

*Ruled out.*

C Public IPs

*Exposes instances.*

D Verified Access TCP

Identity and posture checks for SSH and RDP.

THE SIGNAL

Per-application access with device posture and no VPN, including non-HTTP: Verified Access. Module 17.

> A bank's customer chatbot on Amazon Bedrock must never give investment advice or recommend specific securities, even when asked directly.
>
> Other banking questions must still be answered.

**What should the solutions architect configure?**

A. A content filter set to high for all categories

B. A guardrail denied topic describing investment advice

C. A word filter listing ticker symbols

D. A system prompt asking the model to refuse

◆ PAUSE AND DECIDE

## What should the solutions architect configure?

A Content filters
*Harmful categories, not a business topic.*

B Denied topic
Blocks the topic, allows the rest.

C Word filter
*Easily bypassed; incomplete.*

D System prompt
*Not enforced.*

THE SIGNAL

A business topic the assistant must never discuss: a denied topic. Module 24.

A company with 300 accounts suspects many EC2 instances, EBS volumes and Lambda functions are oversized. It wants rightsizing recommendations based on actual utilisation, across the organisation.

It wants the least effort.

**What should the solutions architect use?**

A. A script reading CloudWatch metrics in each account

B. AWS Trusted Advisor

C. AWS Compute Optimizer with organisation-wide opt-in

D. Cost Explorer filtered by service

◆ PAUSE AND DECIDE

## What should the solutions architect use?

A Custom script

*Builds a recommender by hand.*

B Trusted Advisor

*Off the in-scope list; fewer resource types.*

C Compute Optimizer

Utilisation-based recommendations, org-wide.

D Cost Explorer

*Shows spend, not sizing.*

THE SIGNAL

Rightsizing from real utilisation across an organisation: Compute Optimizer. Module 26.

A DynamoDB table holds eight years of order history. Storage is now 80 percent of the table's cost, and old items are rarely read.

The table must remain online and queryable.

**What should the solutions architect do?**

A Switch to on-demand capacity

B Add DAX

C Export to S3 and delete the table

D Change the table class to DynamoDB Standard-Infrequent Access

◆ PAUSE AND DECIDE

## What should the solutions architect do?

A On-demand
*Throughput pricing, not storage.*

B DAX
*Adds cost.*

C Export and delete
*No longer online.*

D Standard-IA class
Lower storage price, same API.

THE SIGNAL

Storage-dominated DynamoDB tables: the Standard-Infrequent Access table class. Module 31.

A software company lets customers worldwide download 50 TB of installers a month directly from an S3 bucket. Data transfer out is its largest AWS cost.

Downloads are mostly the same few files.

**What should the solutions architect do?**

A Put a CloudFront distribution in front of the bucket

B Enable S3 Transfer Acceleration

C Replicate the bucket to every Region

D Move the files to EFS

◆ PAUSE AND DECIDE

## What should the solutions architect do?

**A** CloudFront
Caches popular files; lower delivery cost.

**B** Transfer Acceleration
*Adds a charge.*

**C** Replicate everywhere
*Multiplies storage and still pays transfer.*

**D** EFS
*Not for public downloads.*

THE SIGNAL

Popular objects downloaded worldwide: serve them through CloudFront. Module 28.

A marketplace classifies 50 million product listings a day into categories with a large Bedrock model. Quality is good, but cost is too high.

The task is narrow and the same every day.

**What should the solutions architect recommend?**

A Intelligent prompt routing

B Model distillation, training a smaller model on the larger model's outputs for this task

C Provisioned Throughput for the large model

D Shorter prompts only

◆ PAUSE AND DECIDE

## What should the solutions architect recommend?

A Prompt routing
*Suits mixed difficulty.*

B Distillation
Small, cheap model at near-teacher quality.

C Provisioned Throughput
*Capacity, not a cheaper model.*

D Shorter prompts
*Modest savings.*

THE SIGNAL

Mixed difficulty, no training: routing. One narrow task at huge volume: distillation. Module 27.

> An airline wants to modernise its mainframe crew-scheduling system. It wants to keep the business rules but redesign the batch jobs into event-driven services on AWS.
>
> A line-by-line conversion to Java is not wanted.

**Which approach should the solutions architect recommend?**

A Refactor COBOL to Java with AWS Transform

B Rehost on an emulator

C Replatform onto a managed runtime

D Reimagine with AWS Transform, extracting business rules and redesigning the architecture

◆ PAUSE AND DECIDE

## Which approach should the solutions architect recommend?

A **Refactor**
*Line-by-line conversion, ruled out.*

B **Rehost**
*Keeps COBOL and batch.*

C **Replatform**
*Keeps the design; runtime closed to new customers.*

D **Reimagine**
Keeps the rules, changes the design.

THE SIGNAL

Keep what it decides, change how it works: reimagine. Module 36.

A company uses AWS Elastic Disaster Recovery for 200 servers. Auditors require a recovery test every quarter.

The test must not affect production or interrupt replication.

**What should the solutions architect do?**

A Fail over production to AWS each quarter

B Stop replication, test, then restart it

C Launch drill instances in Elastic Disaster Recovery into an isolated test VPC

D Restore from AWS Backup instead

◆ PAUSE AND DECIDE

## What should the solutions architect do?

A Real failover
*Risks production.*

B Pause replication
*Creates an RPO gap.*

C DRS drill
Tests recovery while replication continues.

D AWS Backup restore
*Tests a different mechanism.*

THE SIGNAL

Test DR without touching production: a drill in an isolated network. Module 38.

> A company backs up 2,000 resources with AWS Backup. Auditors want regular evidence that backups can actually be restored, not just that they exist.
>
> The team wants this automated.

**What should the solutions architect configure?**

A. An AWS Backup restore testing plan that restores sampled recovery points on a schedule and validates them

B. A manual restore once a year

C. More frequent backups

D. Backup vault lock

◆ PAUSE AND DECIDE

## What should the solutions architect configure?

A **Restore testing**
Automated, scheduled restore evidence.

B **Yearly manual restore**
*Infrequent and manual.*

C **More backups**
*More backups, still untested.*

D **Vault lock**
*Protects, does not test.*

THE SIGNAL

Prove backups restore, automatically: AWS Backup restore testing. Module 39.

A security team has written 30 new CloudFormation Guard Hook rules. Nobody knows how many existing stacks would fail them.

The team must enforce the rules without suddenly breaking delivery pipelines.

## How should the rules be rolled out?

A Activate all rules in fail mode at once

B Ask teams to test locally

C Apply the rules to new accounts only

D Activate the Hooks in warn mode, review invocation results, fix findings, then switch to fail mode

◆ PAUSE AND DECIDE

## How should the rules be rolled out?

A Fail mode at once
*Breaks many pipelines.*

B Local testing
*Voluntary, no central view.*

C New accounts only
*Leaves existing risk.*

D Warn, then fail
Measures impact, then enforces.

THE SIGNAL

New enforcement rules: warn mode first, results reviewed, then fail. Module 41.

A new ECS service on Fargate communicates with other services through ECS Service Connect. The team wants canary releases, a bake time before the old revision is removed, and alarm-based rollback.

It wants as few additional services as possible.

**What should the solutions architect use?**

A CodeDeploy blue/green for ECS

B The ECS built-in deployment controller with a canary strategy

C Rolling updates with the circuit breaker

D Two services behind Route 53 weighted records

◆ PAUSE AND DECIDE

## What should the solutions architect use?

A CodeDeploy

*No Service Connect support; extra service.*

B ECS built-in canary

Canary, bake time, rollback, Service Connect.

C Rolling

*No traffic slice or bake time.*

D Route 53 weights

*Custom and imprecise.*

THE SIGNAL

New ECS service, or Service Connect: the built-in deployment controller. Module 44.

> Operators for 70 accounts switch roles between accounts during incidents to read metrics, logs and traces.
>
> They want one place to search all three signals across accounts, without copying data.

**What should the solutions architect implement?**

A Subscription filters to a central account

B Dashboards in each account

C CloudWatch cross-account observability with a monitoring account

D OpenSearch with all logs copied in

◆ PAUSE AND DECIDE

## What should the solutions architect implement?

A Subscriptions
*Copies logs only.*

B Per-account dashboards
*Still switching roles.*

C Cross-account observability
All signals, viewed in place.

D OpenSearch
*Copies data; a cluster to run.*

THE SIGNAL

Look across accounts: cross-account observability. Move the data somewhere: subscriptions. Module 45.

> A lender's credit model on a SageMaker AI endpoint passed a fairness review at launch. A regulator now requires scheduled evidence that approval outcomes are not drifting against applicants over 60.
>
> Results must be recorded automatically.

**What should the solutions architect implement?**

A. A Model Monitor bias drift schedule using SageMaker Clarify

B. A data quality monitor on the age feature

C. Remove the age feature

D. A yearly manual review

◆ PAUSE AND DECIDE

## What should the solutions architect implement?

A Bias drift monitor
Scheduled bias metrics for the group.

B Data quality on age
*Watches inputs, not outcomes.*

C Remove age
*Proxies can still carry bias; no evidence.*

D Yearly review
*Infrequent and manual.*

THE SIGNAL

Ongoing evidence that outcomes stay fair to a group: a bias drift monitor. Module 47.

> Checkout and a nightly data import run as Lambda functions in the same account. Last night the import scaled to the account concurrency limit, and checkout requests were throttled.
>
> Checkout must always have capacity.

**What should the solutions architect configure?**

A Provisioned concurrency on the import

B Reserved concurrency for checkout, and a maximum concurrency on the import's event source

C A higher account limit only

D Move checkout to another Region

◆ PAUSE AND DECIDE

## What should the solutions architect configure?

A Provisioned on import

*Wrong function; no cap.*

B Reserved and capped

Checkout keeps a share; import is bounded.

C Higher limit only

*Import can grow into it.*

D Another Region

*A large change for isolation.*

THE SIGNAL

One workload starving another: a bulkhead with reserved and capped concurrency. Module 48.

# Part two: score and next steps

| RESULT ON THESE 25 | WHAT TO DO |
|---|---|
| 20 or more | On track. Continue to part three |
| 16 to 19 | Passing range but thin. Review misses first |
| 12 to 15 | Rewatch the modules named in your misses |
| Below 12 | Return to the domain papers for weak domains |
| Worse than part one | Likely fatigue: practise full sittings |
| Over 60 minutes | Practise pacing with the checkpoints |

ON THE EXAM

Compare with part one. A drop in the middle of a long sitting is common, and practice fixes it.

MODULE 60 · EXAM STRATEGY - ALL DOMAINS

# Full Mock, Part Three

Questions 51 to 75 of the mock. Finish the sitting, then total all 75.

PART 3 of 3 QUESTIONS 51-75 SET 6 of 6

admin@sthithapragna.com

# Part three checkpoints

- **Question 58 by minute 20** of this part.
- **Question 67 by minute 40.**
- **Leave five minutes** to answer anything flagged or blank.
- Never leave a question blank. Unanswered scores as incorrect.

> ON THE EXAM
>
> In the last minutes, fill every blank first, then improve answers.

> A trading firm runs dozens of applications built on Apache Kafka client libraries, with Kafka Connect pipelines, on self-managed brokers. It wants to stop managing brokers.
>
> Application code must not change.

**What should the solutions architect recommend?**

A Amazon Kinesis Data Streams

B Amazon SQS FIFO queues

C Amazon MSK

D Amazon EventBridge

◆ PAUSE AND DECIDE

## What should the solutions architect recommend?

A Kinesis

*Different API; code changes.*

B SQS FIFO

*Different API and model.*

C Amazon MSK

Managed Kafka; same clients and Connect.

D EventBridge

*Different API.*

THE SIGNAL

Kafka already in use means MSK. Starting fresh with the least to run means Kinesis. Module 13.

A retailer's 400 analysts run the same sales dashboards all day against a 30 TB dataset in S3. Athena queries are slow at peak and costs are rising with each scan.

Dashboards need consistent sub-second to few-second response.

**What should the solutions architect recommend?**

A More Athena workgroups

B Amazon EMR on demand for each query

C Store the data as CSV for faster scans

D Amazon Redshift, loading or querying the curated data, with dashboards pointed at it

◆ PAUSE AND DECIDE

## What should the solutions architect recommend?

A More workgroups
*Same per-scan engine.*

B EMR per query
*Cluster start-up per query.*

C CSV files
*Slower and costlier than columnar.*

D Amazon Redshift
Built for heavy, concurrent BI.

THE SIGNAL

All-day dashboards for hundreds of users outgrow Athena. Occasional exploration does not need Redshift. Module 13.

A SaaS platform serves 40 enterprise tenants. Some tenants require MFA for every user, others forbid it, and two require different password policies.

All tenants use Amazon Cognito for sign-in.

**How should the solutions architect structure Cognito?**

A. A user pool per tenant, or per policy group

B. One shared user pool with a tenant attribute

C. One identity pool for all tenants

D. Separate AWS accounts per tenant with IAM users

◆ PAUSE AND DECIDE

## How should the solutions architect structure Cognito?

A **Pool per tenant**
MFA and password policy are set per pool.

B **One shared pool**
*Pool-level settings cannot vary by tenant.*

C **Identity pool**
*Grants AWS credentials; not sign-in policy.*

D **IAM users**
*Wrong tool for app users.*

THE SIGNAL

Settings that live at pool level, such as MFA, cannot vary by attribute. Different rules mean different pools. Module 05.

> A team builds an agent with an open-source framework that assembles its own prompts. It needs relevant passages from a Bedrock knowledge base, but its framework will call the model itself.
>
> The team wants to keep full control of prompting.

**Which knowledge base API should the agent call?**

A RetrieveAndGenerate

B InvokeModel directly with the whole document set

C Retrieve

D CreateKnowledgeBase

◆ PAUSE AND DECIDE

## Which knowledge base API should the agent call?

A RetrieveAndGenerate
*Generates the answer itself.*

B Whole documents
*Exceeds context; costly.*

C Retrieve
Returns passages; the framework prompts.

D CreateKnowledgeBase
*Creates a knowledge base; not a query.*

THE SIGNAL

Least code with citations: RetrieveAndGenerate. Custom prompting or an agent framework: Retrieve. Module 07.

A fashion retailer serves product images, CSS and JavaScript to customers worldwide. Most files change weekly and are requested millions of times a day.

It wants lower latency and lower origin load.

**What should the solutions architect use?**

A AWS Global Accelerator

B Amazon CloudFront

C Route 53 latency-based routing to regional copies

D A larger origin fleet

◆ PAUSE AND DECIDE

## What should the solutions architect use?

A Global Accelerator
*No caching; every request reaches the origin.*

B CloudFront
Caches content at the edge.

C Latency routing
*Multiple origins to maintain; no caching.*

D Bigger origin
*Same latency, more cost.*

THE SIGNAL

Cacheable web content means CloudFront. Static IPs, UDP or DNS-free failover mean Global Accelerator. Module 11.

A car manufacturer's assembly-line systems need AWS services and APIs on premises. Production data must not leave the factory, and latency must be in single-digit milliseconds.

The factory has reliable connectivity to its AWS Region.

**What should the solutions architect recommend?**

A An AWS Local Zone near the factory

B AWS Wavelength

C Run everything in the nearest Region

D AWS Outposts racks in the factory

◆ PAUSE AND DECIDE

## What should the solutions architect recommend?

A Local Zone
*AWS-owned site; data leaves the factory.*

B Wavelength
*For 5G networks; off the in-scope list.*

C Nearest Region
*Data leaves; higher latency.*

D Outposts
AWS infrastructure on premises.

THE SIGNAL

On premises is a requirement for Outposts. Low latency to a city alone is a Local Zone. Module 09.

> A company must prevent anyone in member accounts from using AWS Regions other than eu-west-1 and eu-central-1. Global services such as IAM and CloudFront must keep working.
>
> A break-glass role must be exempt.

**What should the solutions architect implement?**

A IAM policies in every account

B AWS Config rules for each Region

C An SCP denying actions where aws:RequestedRegion is not one of the two, excluding global services and the break-glass role

D Disabling the other Regions in the management account

◆ PAUSE AND DECIDE

## What should the solutions architect implement?

A IAM per account
*Administrators can change them.*

B Config rules
*Detects; does not prevent.*

C Region-restriction SCP
Org-wide, preventive, with exemptions.

D Disable Regions
*Default Regions cannot be disabled.*

THE SIGNAL

Deny everywhere, for every identity in member accounts: an SCP with careful exemptions. Module 20.

> A company with 150 accounts wants to find IAM roles nobody has used in 90 days. It also wants permissions within active roles that are never exercised.
>
> It wants findings centrally, with the least custom work.

**What should the solutions architect use?**

A IAM Access Analyzer unused access analysis for the organisation

B A script reading CloudTrail for every role

C IAM credential reports per account

D GuardDuty

◆ PAUSE AND DECIDE

## What should the solutions architect use?

A **Unused access analyzer**
Unused roles and permissions, org-wide.

B **CloudTrail script**
*Custom and costly.*

C **Credential reports**
*Users only, per account.*

D **GuardDuty**
*Threat detection.*

THE SIGNAL

Find unused roles and permissions across an organisation: Access Analyzer unused access. Module 16.

A payment processor's application performs its own cryptographic operations through the PKCS 11 interface, including key derivation functions that KMS does not offer.

Keys must be held in single-tenant, FIPS-validated HSMs.

**What should the solutions architect use?**

A AWS KMS with the default key store

B A KMS custom key store

C AWS Secrets Manager

D AWS CloudHSM, used directly by the application

◆ PAUSE AND DECIDE

## What should the solutions architect use?

A KMS default

*Multi-tenant; no PKCS 11.*

B KMS custom key store

*Only KMS operations are available.*

C Secrets Manager

*Stores secrets; no crypto operations.*

D CloudHSM directly

Single-tenant HSM with PKCS 11.

THE SIGNAL

Dedicated HSM plus native AWS service encryption: custom key store. Your own crypto operations: CloudHSM directly. Module 18.

> A company's sensitive S3 buckets must only be accessed from its own VPCs through S3 VPC endpoints. Access from the internet must fail, even with valid credentials.
>
> Some AWS services act on the buckets on the company's behalf.

**What should the solutions architect implement?**

A Security groups on the bucket

B A bucket policy denying requests not coming through the company's VPC endpoints, with an exception for AWS service principals

C S3 Block Public Access only

D IAM policies requiring MFA

◆ PAUSE AND DECIDE

## What should the solutions architect implement?

A Security groups

*Buckets have no security groups.*

B Endpoint-restricted bucket policy

A network perimeter on the bucket.

C Block Public Access

*Stops public access, not stolen credentials.*

D MFA

*Does not restrict the network path.*

THE SIGNAL

Only from our networks, even with valid credentials: a network perimeter on the resource. Module 17.

A travel agent built on Bedrock AgentCore books flights through an airline's API on behalf of signed-in customers. The airline uses OAuth, and each customer must consent.

Tokens must be stored securely and never handled by the agent's code directly.

**What should the solutions architect use?**

A Store each customer's tokens in a DynamoDB table

B A shared API key in Secrets Manager

C Amazon Bedrock AgentCore Identity for user-delegated OAuth access

D IAM roles for each customer

◆ PAUSE AND DECIDE

## What should the solutions architect use?

A DynamoDB tokens
*Builds a token vault by hand.*

B Shared API key
*Not on behalf of each customer.*

C AgentCore Identity
Consent flows and a managed token vault.

D Role per customer
*IAM does not speak the airline's OAuth.*

THE SIGNAL

Agents acting for users against third-party OAuth APIs: AgentCore Identity. Module 06.

A RAG assistant over company manuals sometimes gives confident answers that the retrieved passages do not support.

The team wants such answers detected and blocked at runtime.

**What should the solutions architect configure?**

A. A higher temperature

B. More documents in the knowledge base

C. A denied topic

D. Contextual grounding checks in Amazon Bedrock Guardrails

◆ PAUSE AND DECIDE

## What should the solutions architect configure?

A Higher temperature

*Increases variation.*

B More documents

*Does not stop unsupported claims.*

C Denied topic

*Blocks subjects, not unsupported answers.*

D Contextual grounding

Blocks answers not supported by the sources.

THE SIGNAL

Answers not supported by retrieved sources: contextual grounding checks. Module 24.

> An internal document classifier on a SageMaker AI real-time endpoint receives a few hundred requests a day, in bursts. It sits idle most of the time.
>
> A few seconds of extra latency on the first request after idle is acceptable.

**How should the solutions architect cut cost?**

A Use SageMaker Serverless Inference

B Move to a larger instance

C Buy a SageMaker Savings Plan for the endpoint

D Add more instances behind the endpoint

◆ PAUSE AND DECIDE

## How should the solutions architect cut cost?

A **Serverless Inference**
Pays per use; scales to zero when idle.

B **Larger instance**
*More idle cost.*

C **Savings Plan**
*Discounts an instance that sits idle.*

D **More instances**
*More idle cost.*

THE SIGNAL

Idle most of the time, cold starts acceptable: serverless inference. Module 26.

A company runs stateless web services on EKS with fixed node groups of On-Demand instances. Utilisation averages 35 percent.

Services tolerate pods being rescheduled.

**What should the solutions architect recommend?**

A Larger node groups

B Reserved Instances for the current nodes

C Karpenter with consolidation enabled, using Spot capacity for these services

D Vertical scaling of each pod

◆ PAUSE AND DECIDE

## What should the solutions architect recommend?

A Larger groups
*More idle capacity.*

B Reserved Instances
*Discounts waste.*

C Karpenter, consolidation, Spot
Packs pods, removes idle nodes, cheaper capacity.

D Bigger pods
*Does not fix idle nodes.*

THE SIGNAL

Poor packing and tolerant pods: Karpenter consolidation with Spot. Modules 03 and 26.

A central networking account runs Transit Gateway, NAT gateways and inspection firewalls used by 50 workload accounts. Its cost appears entirely in one account.

Finance wants that cost shared among the workload accounts' cost centres in proportion to their usage.

**What should the solutions architect configure?**

A Tag the networking resources with every cost centre

B Move networking into every account

C AWS Budgets per account

D AWS Cost Categories with split charge rules allocating the shared networking cost

◆ PAUSE AND DECIDE

## What should the solutions architect configure?

A Tag with every cost centre

*A resource has one value per tag key.*

B Duplicate networking

*Multiplies cost.*

C Budgets

*Tracks spend; allocates nothing.*

D Cost categories, split charges

Splits shared costs proportionally.

THE SIGNAL

Shared costs allocated to cost centres: cost categories with split charge rules. Module 30.

A portfolio assessment finds an expense-tracking application used by 40 people, which needs a major upgrade. A SaaS product covers its features.

The application has no unique integrations.

**Which migration strategy fits this application?**

A Rehost it to EC2

B Repurchase: move to the SaaS product and retire the application

C Refactor it to serverless

D Retain it on premises

◆ PAUSE AND DECIDE

## Which migration strategy fits this application?

A Rehost

*Carries the upgrade problem to AWS.*

B Repurchase

Replaces it with an existing product.

C Refactor

*Effort for a commodity function.*

D Retain

*Leaves the upgrade problem.*

THE SIGNAL

A commodity function a SaaS product already covers: repurchase. Module 32.

> An order database on RDS for PostgreSQL must survive the loss of an Availability Zone with automatic failover and no data loss.
>
> Reporting load is light.

**What should the solutions architect configure?**

A. A read replica in another Availability Zone

B. Daily snapshots

C. A Multi-AZ deployment

D. A cross-Region read replica

◆ PAUSE AND DECIDE

## What should the solutions architect configure?

A Read replica
*Asynchronous; manual promotion.*

B Snapshots
*Data loss; slow restore.*

C Multi-AZ
Synchronous standby, automatic failover.

D Cross-Region replica
*Asynchronous; manual promotion.*

THE SIGNAL

High availability with automatic failover: Multi-AZ. Read scaling: replicas. Module 12.

A company rotates its primary Region between us-east-1 and us-west-2 twice a year for operational testing. Its database is an Aurora global database.

The planned rotation must lose no committed data.

**What should the solutions architect use?**

A Aurora global database switchover

B Aurora global database failover with data loss allowed

C Restore a snapshot in the other Region

D Re-create the cluster with AWS DMS

◆ PAUSE AND DECIDE

## What should the solutions architect use?

**A** Switchover
Planned, synchronised change; no data loss.

**B** Failover
*For outages; may lose recent writes.*

**C** Snapshot restore
*Data loss and long downtime.*

**D** DMS rebuild
*Slow and needless.*

THE SIGNAL

Planned Region change with no data loss: global database switchover. Outage: failover. Module 37.

A company's AWS Backup plan protects EBS volumes and RDS databases in eu-west-1. Its DR policy requires recovery points in eu-central-1 as well.

It wants this without scripts.

**What should the solutions architect configure?**

A. A Lambda function copying snapshots each night

B. S3 Cross-Region Replication

C. Data Lifecycle Manager in each Region

D. A copy rule in the backup plan to a vault in eu-central-1

◆ PAUSE AND DECIDE

## What should the solutions architect configure?

A Custom Lambda
*Custom code.*

B S3 CRR
*Not for EBS or RDS backups.*

C DLM
*EBS only; no cross-Region copy for RDS.*

D Backup copy rule
Built-in cross-Region copies.

THE SIGNAL

Recovery points in another Region, no scripts: a cross-Region copy rule in AWS Backup. Module 39.

> Launches across 200 accounts keep failing when teams reach service quotas. Requests to raise quotas are made by hand after the failure.
>
> The platform team wants warnings as usage approaches quotas, and automatic adjustments where possible.

**What should the solutions architect use?**

A. A weekly Trusted Advisor review

B. Service Quotas automatic quota management, with notifications

C. A Lambda function requesting the maximum for every quota

D. Ask teams to request quotas earlier

◆ PAUSE AND DECIDE

## What should the solutions architect use?

A Trusted Advisor
*Manual and infrequent.*

B Automatic quota management
Alerts near limits; adjusts by usage.

C Request maximums
*Removes useful guard rails.*

D Earlier requests
*Still manual.*

THE SIGNAL

Warn near quotas and adjust them by usage: Service Quotas automatic management. Module 48.

> When a CloudWatch alarm reports a full temporary volume on batch servers, an engineer logs in and runs the same cleanup commands every time.
>
> The team wants the fix automated, with each occurrence recorded.

**What should the solutions architect implement?**

A An SNS email to the team

B Replace the instances every night

C An EventBridge rule on the alarm state change that starts an SSM Automation runbook, and an OpsItem for each occurrence

D A larger volume

◆ PAUSE AND DECIDE

## What should the solutions architect implement?

A Email

*Still manual.*

B Nightly replacement

*Disruptive; ignores the signal.*

C EventBridge to Automation

Fix runs itself, and each event is recorded.

D Larger volume

*Delays the problem.*

THE SIGNAL

Known fix, run automatically, with a record: alarm to SSM Automation and an OpsItem. Module 46.

> An API's SLO is 99.9 percent availability over a rolling 28 days. Planned maintenance every Sunday for 30 minutes, announced to customers, consumes the error budget.
>
> The customer agreement excludes planned maintenance.

**What should the solutions architect do?**

A Lower the attainment goal

B Disable SLO alarms on Sundays by hand

C Delete and recreate the SLO each week

D Add a recurring exclusion window for the maintenance period

◆ PAUSE AND DECIDE

## What should the solutions architect do?

A Lower goal
*Weakens the promise all week.*

B Manual disable
*Budget still consumed.*

C Recreate
*Loses history.*

D Exclusion window
Maintenance excluded from measurement.

THE SIGNAL

Planned maintenance outside the agreement: SLO exclusion windows. Module 46.

A policy assistant on Bedrock answers staff questions from a knowledge base that changes weekly. Staff report vaguer answers over recent months, and there are no labels for production questions.

The team wants an ongoing measure of answer quality.

**What should the solutions architect implement?**

A Score daily samples of production responses from invocation logs with a Bedrock LLM-as-a-judge evaluation, publishing scores to CloudWatch

B A Model Monitor data quality schedule

C An alarm on output token count

D A stricter guardrail

◆ PAUSE AND DECIDE

## What should the solutions architect implement?

**A** Judge-scored samples
Measures quality over time without labels.

**B** Model Monitor
*For structured inputs on SageMaker endpoints.*

**C** Token alarm
*Length is not quality.*

**D** Stricter guardrail
*Blocks content; does not measure.*

THE SIGNAL

Generative answers drifting, no labels: evaluate sampled production responses. Module 47.

A web tier of 300 EC2 instances in an Auto Scaling group needs a new AMI. Instances must be replaced gradually, pausing at 10 percent and 50 percent for checks.

If the latency alarm fires, the group must return to the previous launch template automatically.

**What should the solutions architect use?**

A. Instance refresh with checkpoints at 10 and 50 percent, alarms, and auto rollback

B. Terminate instances in batches by hand

C. CodeDeploy in-place deployment

D. A new Auto Scaling group and a DNS switch

◆ PAUSE AND DECIDE

## What should the solutions architect use?

**A** Instance refresh
Gradual, checkpoints, automatic rollback.

**B** Manual batches
*Manual, no rollback.*

**C** CodeDeploy in place
*Deploys code, not AMIs.*

**D** New group, DNS
*Not gradual; more to build.*

THE SIGNAL

New AMI across an Auto Scaling group, gradual, with rollback: instance refresh. Module 44.

> After a brief throttling event, 3,000 workers retried writes at exactly the same moment, causing two further spikes. Some orders were recorded twice.
>
> The team wants both problems fixed.

**What should the solutions architect recommend?**

A Remove retries

B Exponential backoff with jitter, plus idempotent writes using a client token

C Retry every 100 milliseconds

D Raise capacity only

◆ PAUSE AND DECIDE

## What should the solutions architect recommend?

A No retries

*Brief throttles become failures.*

B Backoff, jitter, idempotency

Spreads retries; duplicates have no effect.

C Faster fixed retries

*Waves arrive sooner.*

D More capacity only

*Waves and duplicates remain.*

THE SIGNAL

Retries arriving in waves, plus duplicates: backoff with jitter, and idempotency. Module 48.

# Your total on all 75

| TOTAL CORRECT | WHAT IT SUGGESTS |
|---|---|
| 60 or more | Well prepared. Book the exam |
| 52 to 59 | Likely passing. Close gaps in your weakest domain |
| 45 to 51 | Borderline. Rewatch weak domains, then retake |
| Below 45 | Return to the teaching modules first |
| Guessed but correct | Count as misses |
| Over 180 minutes | Practise full sittings with checkpoints |

ON THE EXAM

These bands are a guide, not a conversion to 720. Aim well clear before booking.